

В.Т. Еременко
М.Ю. Рытов
П.Н. Рязанцев
М.Н. Орешина

**УПРАВЛЕНИЕ ИНФОРМАЦИОННОЙ
БЕЗОПАСНОСТЬЮ**



МИНИСТЕРСТВО ОБРАЗОВАНИЯ И НАУКИ РОССИЙСКОЙ ФЕДЕРАЦИИ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ БЮДЖЕТНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ - УЧЕБНО-НАУЧНО-
ПРОИЗВОДСТВЕННЫЙ КОМПЛЕКС»

В.Т. Еременко, М.Ю. Рытов, П.Н. Рязанцев,
М.Н. Орешина

**УПРАВЛЕНИЕ ИНФОРМАЦИОННОЙ
БЕЗОПАСНОСТЬЮ**

Рекомендовано ФГБОУ ВПО «Госуниверситет - УНПК»
для использования в учебном процессе в качестве учебного пособия
для высшего профессионального образования

Орел 2015

УДК 621.391
ББК 32.973.2-018.2я73
Е70

Рецензенты:

доктор технических наук,
профессор кафедры «Информационные системы»
Федерального государственного бюджетного образовательного
учреждения высшего профессионального образования
«Государственный университет - учебно-научно-
производственный комплекс»
В.И. Раков,

кандидат технических наук,
доцент кафедры «Системы информационной безопасности»
Федерального государственного бюджетного образовательного
учреждения высшего профессионального образования
«Брянский государственный технический университет»
О.М. Голембиовская

Еременко, В.Т.

Е70 Управление информационной безопасностью: учебное пособие для высшего профессионального образования / В.Т. Еременко, М.Ю. Рытов, П.Н. Рязанцев, М.Н. Орешина. – Орел: ФГБОУ ВПО «Госуниверситет - УНПК», 2015. – 265 с.

ISBN 978-5-93932-873-9

В учебном пособии изложены различные аспекты управления информационной безопасностью, описана нормативная база стандартов в области информационной безопасности; предложена методика разработки и реализации политики информационной безопасности в различных сферах человеческой деятельности.

Предназначено бакалаврам, обучающимся по направлению подготовки 090900.62 «Информационная безопасность», при изучении дисциплины Б.3.А.7 «Управление информационной безопасностью» и смежных с ней.

Может быть полезно всем, изучающим криптографические методы самостоятельно.

УДК 621.391
ББК 32.973.2-018.2я73

ISBN 978-5-93932-873-9 © ФГБОУ ВПО «Госуниверситет - УНПК», 2015

СОДЕРЖАНИЕ

Принятые сокращения	5
Введение	6
1. Базовая терминология.....	9
1.1. Система	9
1.2. Системный подход	11
1.3. Процесс	12
1.4. Процессный подход.....	15
1.5. Управление.....	16
1.6. Циклическая модель улучшения процессов	23
1.7. Системный подход к управлению организацией	25
1.8. Процессный подход к управлению организацией	27
Вопросы для самоконтроля	31
2. Стандартизация систем и процессов управления информационной безопасностью	32
2.1. Серия стандартов ISO/IEC 27000 «Информационные технологии. Методы обеспечения безопасности».....	33
2.2. Стандарты на отдельные процессы управления информационной безопасностью и оценка безопасности информационных технологий.....	70
2.3. Отраслевые стандарты в области управления информационной безопасностью, стандарты банковской системы Российской Федерации	80
Вопросы для самоконтроля	87
3. Политика информационной безопасности	90
3.1. Понятия политики обеспечения ИБ и политики ИБ организации	90
3.2. Причины выработки политики ИБ	98
3.3. Основные требования и принципы, учитываемые при разработке и внедрении политики ИБ	104
3.4. Содержание политики ИБ.....	109
3.5. Содержание корпоративной политики ИБ	111
3.6. Содержание частных политик ИБ	117
3.7. Жизненный цикл политики ИБ	120
3.8. Ответственность за исполнение политики ИБ	133
Вопросы для самоконтроля	138
4 Система управления информационной безопасностью	140
4.1. Необходимость управления обеспечением ИБ организации	140

4.2. Деятельность по обеспечению ИБ организации как процесс	141
4.3. Определение управления ИБ организации	147
4.4. Управление ИБ информационно-телекоммуникационных технологий организации.....	153
4.5. Система управления ИБ организации	157
4.6. Процессный подход в рамках управления ИБ	176
4.7. Работа с процессами СУИБ организации	193
4.8. Стратегии построения и внедрения СУИБ	207
Вопросы для самоконтроля	213
Литература	216
Приложение А. Примеры частных политик информационной безопасности	224

ПРИНЯТЫЕ СОКРАЩЕНИЯ

АБС – автоматизированная банковская система.
АС – автоматизированная система.
АО – аппаратное обеспечение.
БД – база данных.
БС – банковская система.
ВЧС – виртуальная частная сеть.
ГИТТ – готовность информационных и телекоммуникационных технологий.
ДМЗ – демилитаризованная зона.
ИБ – информационная безопасность.
ИС – информационная система.
ИСО – Международная организация по стандартизации.
ИТТ – информационные и телекоммуникационные технологии.
ИТ – информационные технологии.
МЭ – межсетевой экран.
МЭК – Международная электротехническая комиссия.
НСД – несанкционированный доступ.
ОИБ – обеспечение информационной безопасности.
ОНБ – обеспечения непрерывности бизнеса.
ОС – операционная система.
ПО – программное обеспечение.
ПолИБ – политика информационной безопасности.
РС – рекомендации в области стандартизации.
РФ – Российская Федерация.
САЗ – система анализа защищенности.
СЗИ – средства защиты информации.
СИБ – система информационной безопасности.
СМИ – средства массовой информации.
СМИБ – система менеджмента информационной безопасности.
СОВ – система обнаружения вторжений.
СОИБ – система обеспечения информационной безопасности.
СТО – стандарт отраслевой.
СУБД – система управления базой данных.
СУИБ – система управления информационной безопасностью.
ТК – телекоммуникационные компании.
ТКЭ – технико-криминалистическая экспертиза.
УД – удаленный доступ.
УНБ – управление непрерывностью бизнеса.
ЭЦП – электронная цифровая подпись.

ВВЕДЕНИЕ

В настоящее время информация представляет собой один из самых главных бизнес-активов любой организации, имеющий ценность для организации, находящийся в ее распоряжении, обеспечивающий добавочную стоимость и вследствие этого нуждающийся в защите. Вовремя не устраненные и известные злоумышленникам уязвимости в обеспечении информационной безопасности (ИБ) информационных активов могут привести к катастрофическим финансовым потерям и нанести непоправимый ущерб бизнес-процессам. Поэтому вопрос разработки эффективной и адекватной потребностям бизнеса системы управления информационной безопасностью (СУИБ) и ее квалифицированного внедрения и использования сегодня актуален как никогда прежде. Это вопрос из серии «быть или не быть» для любого бизнеса.

Осуществление бизнес-операций в информационной среде с применением информационных и телекоммуникационных технологий (ИТТ) современной организации выходит далеко за рамки мэйнфреймов, жестко соединенных проводами с терминалами, размещенными в защищенных центрах обработки данных с четко определенными физическими и логическими периметрами. В процессе эволюции усложнились программные и аппаратные средства. Различные операции теперь выполняют серверы, рабочие станции, ноутбуки, персональные компьютеры, сотовые телефоны, камеры, часы и прочие устройства, с которых сотрудники организации, подрядчики, поставщики и бизнес-партнеры могут осуществлять их в любое время.

Практически прямой доступ к ресурсам компьютерной системы получает значительное число пользователей различных категорий и с разными правами доступа. Эти пользователи подключаются к корпоративным сетям (интрасетям) через Интернет, выделенные линии, коммутируемые соединения и радиоволны. Большие объемы данных могут обрабатываться в их карманах или передаваться с помощью служб мгновенных сообщений, электронной почты и средств мобильной связи. Обработка информационных потоков требует высоких темпов и абсолютной точности. Сбор и хранение крупных информационных баз на электронных носителях, объединение в общий информационный массив данных с различными методами доступа, увеличение стоимости ресурсов компьютерных систем, большая зависимость организации от конфиденциальности, целостности, дос-

тупности и других значимых свойств всех ее информационных активов – это только часть видимых проблем, требующих обязательного решения вопросов управления ИБ.

В последние годы многие российские организации осознали необходимость эффективного управления своей информационной безопасностью, что приобретает все большее значение по мере их роста и продвижения на новые рынки товаров и услуг. Клиентам важно знать, что соблюдается конфиденциальность их персональных данных. Инвесторам необходима уверенность в том, что бизнес и информационные активы организации защищены. Бизнес-партнеры ожидают, что организация будет функционировать без сбоев, которые могут быть вызваны ошибками в работе информационных систем (ИС) на всех стадиях их жизненного цикла, умышленными или неумышленными действиями персонала, вредоносным программным обеспечением (ПО) и другими факторами.

В начале 80-х годов XX в. защита информации могла быть эффективно обеспечена при помощи специально разработанных организационных мер и программно-аппаратных средств шифрования. С изобретением локальных и глобальных сетей, каналов спутниковой связи вопрос об ИБ встал острее. Выборочная и бессистемная реализация защитных мер не может обеспечить требуемый организации уровень ИБ. Чтобы надежно защитить свою информацию, необходимо интегрировать решение вопросов ИБ в единый для всей организации процесс управления ИБ организации, связанный с собственно обеспечением информационной безопасности (ОИБ) и снижением выявленных рисков ИБ для ее бизнеса.

Любая информация, которая может повлиять на ИБ, качество, график, стоимость и окружение, должна быть объектом такого процесса управления. Любые действия, совершаемые в рамках выполнения какой-либо деятельности, должны быть вовлечены в процесс управления ИБ.

Управление ИБ не может рассматриваться только с технической и технологической точек зрения, хотя ответ на вопрос, является ли ИБ по существу информационной технологией (ИТ) или ИТ – это всего лишь одна из областей, в которой ИБ играет существенную роль, также очень важен. Управление ИБ – это комплексный, непрерывно выполняемый процесс, обязательно имеющий правовую, организационную, документальную и другие составляющие.

В современных условиях достаточно много сделано в направлении ОИБ, но мало предложено по управлению теми защитными мерами, которые внедрены в организации. Зачастую организации не осознают, какие активы являются более критичными, какие риски ИБ связаны с этими активами, какие защитные меры необходимо запланировать и почему. Все эти проблемы можно решить при эффективном управлении ИБ в организации за счет построения СУИБ.

Разработка централизованной СУИБ на уровне организации зависит от внутренних и внешних факторов, которые часто конфликтуют. Что хорошо для одной организации, категорически не подходит для других. Поэтому им требуются различные комбинации структур, процессов и механизмов, которые обеспечивают защищенное состояние существующей у них информационной инфраструктуры и совершенствуют ее наилучшим образом в каждом регионе и конечной точке, проводя в жизнь принятую организацией политику. Все это доказывает необходимость внимательного изучения вопросов управления ИБ.

В данном учебном пособии подробно рассмотрены основополагающие аспекты, связанные со сложным процессом управления ИБ, состоящим из многих направлений деятельности и охватывающим всю организацию независимо от ее масштаба и области деятельности, а также планированием, реализацией, проверкой и совершенствованием осуществляющей это процесс СУИБ.

1. БАЗОВАЯ ТЕРМИНОЛОГИЯ

1.1. Система

Система (от греч. *systema* – целое, составное из частей) – это совокупность взаимосвязанных и взаимодействующих элементов (рис. 1.1) [1, 2].

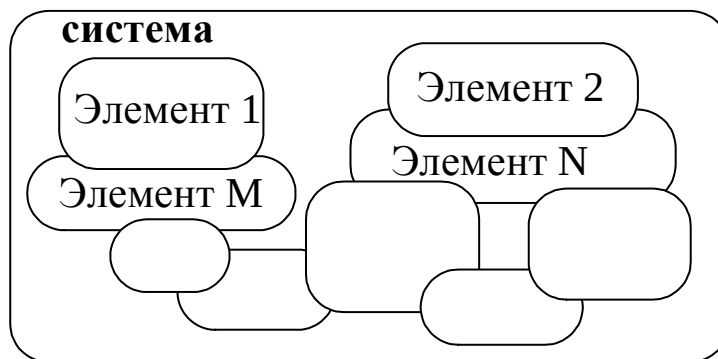


Рис. 1.1. Иллюстрация понятия «система»

Более детально система – это состоящее из двух или более элементов множество, которое удовлетворяет следующим трем условиям [3]:

1. Поведение каждого элемента воздействует на поведение целого (например, организм человека). Каждая его часть: сердце, легкие, желудок и т. д., – воздействует на функционирование организма в целом.

2. Поведение элементов и их воздействие на целое взаимозависимы. Данное условие означает, что поведение каждого элемента и его воздействие на целое зависит от того, как ведет себя по крайней мере еще один другой элемент. Ни один элемент не имеет самостоятельного воздействия на систему в целом.

3. Какие бы подгруппы элементов ни образовались, каждый элемент воздействует на поведение целого, и ни один из них не воздействует на них самостоятельно. Иными словами, элементы системы соединены таким образом, что образование ими независимых подгрупп невозможно.

Таким образом, систему можно определить как множество (совокупность) элементов (объектов) любой природы, взаимодействующих между собой для достижения общей цели, обладающее системным

свойством/свойствами (этого свойства не имеет ни один из элементов и ни одно из подмножеств элементов при любом способе членения).

Свойствами системы являются [4]:

- целостность – первичность целого по отношению к элементам;
- неаддитивность – принципиальная несводимость свойств системы к сумме свойств составляющих ее элементов;
- синергетичность – однонаправленность (или целенаправленность) действий совокупности элементов системы, усиливающая эффективность функционирования системы;
- эмерджентность – наличие новых свойств и качеств у множества элементов системы, которых не было до их объединения в систему; элемент системы обладает свойствами, которые он теряет в случае отделения от системы;
- мультипликативность – эффекты функционирования элементов в системе обладают свойством умножения, а не сложения;
- взаимодействие и взаимозависимость системы и внешней среды;
- структурность – возможны декомпозиция системы на части и установление связей между ними;
- иерархичность – каждая часть системы может рассматриваться как система (подсистема) более широкой глобальной системы;
- непрерывность функционирования;
- целенаправленность – система всегда рассматривается относительно некоторой цели / некоторых целей;
- адаптивность – система стремится к состоянию устойчивого равновесия, которое предполагает адаптацию параметров системы к изменяющимся параметрам внешней среды;
- альтернативность путей функционирования и развития – в зависимости от конкретных параметров, возникающих при функционировании системы, могут существовать несколько альтернативных путей достижения конкретной цели;
- наследственность – передача преобладающих (наиболее сильных) признаков на определённых этапах развития (эволюции) системы от ее старой версии к новой;
- приоритет интересов системы более глобального уровня перед интересами ее частей или подсистем.

Любая система имеет внутреннее и внешнее описание. К внутреннему описанию системы относятся ее внутреннее состояние и внутренний механизм преобразования входных данных в выходные. Это описание дает информацию о поведении системы, о соответствии

или несоответствии внутренней структуры системы заданным целям, подсистемам (элементам) и ее ресурсам. Внешнее описание включает внешние проявления системы и содержит информацию о взаимоотношениях с другими системами, с целями и ресурсами других систем [4].

1.2. Системный подход

Системный подход – это методологическое направление исследования объекта как системы с разных сторон, комплексно, в совокупности отношений и связей между его элементами, в отличие от ранее применявшихся (физических, структурных и т. д.) [1].

Системный подход ориентирован на раскрытие целостности объекта, на выявление многообразных типов связей и отношений, имеющих место как внутри исследуемого объекта, так и в его взаимоотношениях с внешней средой, и сведение их в единую теоретическую картину. Его основная задача состоит в разработке методов исследования и конструирования сложных развивающихся объектов систем разных типов и классов, опираясь на изучение объективных закономерностей развития систем.

Установлением структурных связей между элементами исследуемой системы, которая опирается на комплекс общенаучных, экспериментальных, естественнонаучных, статистических, математических методов, занимается системный анализ. Он представляет собой совокупность методов и средств исследования и построения сложных объектов за счет обоснования решений при создании и управлении техническими, экономическими и социальными системами. Системный анализ используется как один из важнейших методов в системном подходе, как эффективное средство решения сложных, обычно недостаточно четко сформулированных проблем, к которым относятся и проблемы управления различными объектами. Системный анализ позволяет уточнить проблемы и структурировать их в серию решаемых с помощью различных методов задач, найти критерии их решения, детализировать цели.

При системном подходе в рамках моделирования систем необходимо, прежде всего, четко определить цель моделирования системы. Важно помнить, что невозможно полностью смоделировать реально функционирующую систему, а нужно создать модель (систему-мо-

дель) под поставленную проблему при решении конкретной задачи. В конечном счете моделирование должно адекватно отражать реальные процессы поведения исследуемых систем. Одна из целей моделирования – её познавательная направленность. Реализации этой цели способствует правильный отбор в создаваемую модель элементов системы, структуры и связей между ними, критерия оценки адекватности модели. При таком подходе упрощается классификация реальных систем и их моделей.

Основными целями при системном подходе являются следующие:

- повышение синергетичности;
- снижение эмерджентности;
- обеспечение положительной мультипликативности в организации;
- обеспечение устойчивости функционирования организации;
- обеспечение адаптивности работы организации;
- обеспечение совместимости работы различных подсистем организации;
- обеспечение эффективной работы обратных связей в организации как внутри подсистем, так и между подсистемами.

В целом системный подход предполагает следующие этапы решения проблемы:

- изучение предметной области (качественный анализ);
- выявление и формулирование проблемы;
- математическая (количественная) постановка проблемы;
- натурное и/или математическое моделирование исследуемых объектов и процессов.

1.3. Процесс

Процесс (от лат. *processus* – продвижение) – это:

- 1) последовательная смена явлений, состояний в развитии чего-нибудь [Большой толковый словарь русского языка (издание РАН)];
- 2) цепь логически связанных, повторяющихся действий, в результате которых используются ресурсы организации с целью достижения определенных измеримых результатов для удовлетворения внутренних или внешних потребителей [5];
- 3) статистическая обработка результатов моделирования;
- 4) поиск и оценка альтернативных решений;

5) формулирование выводов и предложений по решению проблемы.

Иными словами, процесс – это совокупность взаимосвязанных или взаимодействующих видов деятельности, преобразующая входы в выходы и требующая для этого определенных ресурсов и управляющих воздействий (управления) (рис. 1.2). Входами к процессу обычно являются выходы других процессов [5].

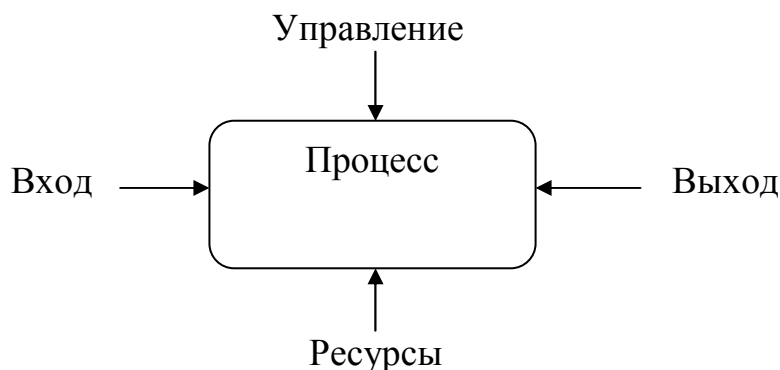


Рис. 1.2. Обобщенная иллюстрация понятия «процесс»

Входами могут быть специфические требования, включая ресурсы – подмножество активов организации, используемых или потребляемых в процессе выполнения некоторой деятельности. На выходе получают в той или иной степени удовлетворенные требования и сам непосредственный результат процесса.

Входы и выходы процесса могут быть осязаемыми (оборудование, материалы, продукция, информация на различных носителях и т. и.) и неосязаемыми (специфицированные требования, услуги и т. п.).

Любой процесс имеет заинтересованные стороны: потребителя, внутреннего или внешнего, и действует в соответствии с установленными целями.

Процессы организации можно разделить на несколько групп [4]:

1. Основные (процессы жизненного цикла), обеспечивающие намеченный результат деятельности организации. Назначение процесса – создание ключевых продуктов деятельности организации; результат – конечный продукт и/или полуфабрикат для его изготовления для промежуточных процессов.

2. Вспомогательные, предназначенные для обеспечения нормального функционирования основных и других процессов необходимыми ресурсами; они обеспечивают работу главных (сервисное обслуживание оборудования, обеспечение энергоресурсами и производственной средой, обеспечение работы офиса, информационное обеспечение, обеспечение финансовой поддержки, управление окружающей средой, PR-деятельность и связь с общественностью и т. д.). Назначение процесса – обеспечение деятельности основных процессов; результат – ресурсы и сервисы для базовых процессов. ОИБ относится к вспомогательной деятельности.

3. Процессы управления (менеджмента), относящиеся к стратегическому планированию, постановке целей и установлению политик, обеспечению коммуникаций и т. п. Назначение процесса – управление деятельностью организации; результат – деятельность всей организации. По своей природе управленческие задачи являются информационными.

4. Процессы измерения, анализа и совершенствования. Назначение процесса – входные данные для процессов усовершенствования всей деятельности организации; результат – совершенствование всей деятельности организации.

Продуктивность процесса отражает способность достижения желаемых результатов. Эффективность процесса определяется достигнутыми результатами в сравнении с использованными ресурсами и может оцениваться посредством внутренних и внешних процессов контроля (проверки).

Опираясь на определение процесса, все действия внутри организации можно рассматривать либо как процесс (бизнес-процесс), либо как его часть. Зачастую, когда говорится об организациях, используется понятие бизнес-процесса, что вызвано сложившимися традициями и является разумным с учетом того, что понятие «процесс» используется в других областях знания (математика, физика и т. д.) совсем в ином контексте. Об использовании этих понятий при выполнении конкретных проектов приходится договариваться.

Бизнес-процесс можно определить как множество из одного или нескольких упорядоченных во времени, логически связанных и завершенных видов деятельности, в совокупности поддерживающих деятельность организации и реализующих ее политику, направленную на достижение поставленных целей. Бизнес-процесс осуществ-

ляется обычно в рамках заранее определенной организационной структуры, которая описывает функциональные роли участников этой структуры и отношения между ними.

1.4. Процессный подход

Процессный подход – это систематическая идентификация и менеджмент применяемых организацией бизнес-процессов и особенно взаимодействия таких процессов [5].

В основе этого подхода – взгляд на организацию как на совокупность ключевых бизнес-процессов, а не функциональных подразделений. Главное внимание при таком подходе уделяется межфункциональным процессам, которые объединяют отдельные функции в общие потоки и в целом направлены на достижение конечного результата бизнеса, а не отдельного подразделения. Таким образом, основное преимущество процессного подхода заключается в управлении и контроле взаимодействия между различными процессами и связующими звеньями в контексте функциональной иерархии (организационно-штатной структуры) организации.

В ГОСТ Р ИСО 9000-2001 «Системы менеджмента качества. Основные положения и словарь» [5] содержится ряд требований к реализации процессного подхода, главными из которых являются следующие:

- определение процессов, необходимых для реализации в организации;
- выявление входов и выходов каждого процесса для установления последовательности и взаимодействия процессов;
- планирование и обеспечение ресурсами (включая информацию), необходимыми для осуществления процессов и управления ими;
- установление необходимой степени документированной торговой марки и документирование процессов;
- планирование процессов;
- наличие критериев и методов оценки осуществления и управления процессами;
- осуществление мониторинга, оценки и анализа процессов;
- проведение корректирующих и предупреждающих (превентивных) действий по результатам анализа процессов, включая совершенствование процессов, осуществляемых в организации;

- определение методов и осуществление управления процессами, результаты которых нельзя проверить посредством последовательного мониторинга и измерения.

1.5. Управление

Управление – древний вид человеческой деятельности, появившийся с возникновением совместной активности людей и регулирующий их отношения в этом процессе. Управление представляет собой осознанную, целенаправленную деятельность человека, с помощью которой он упорядочивает и подчиняет своим интересам элементы внешней среды общества, живой и неживой природы, техники [6].

В соответствии с ранее введенным определением процесса любая деятельность может рассматриваться как процесс, что справедливо и по отношению к управлению. Это – процесс, состоящий из серии непрерывных взаимосвязанных действий (управленческих функций), каждое из которых само по себе является процессом, важным для успеха организации. Каждая управленческая функция тоже представляет собой процесс, потому что также состоит из серии взаимосвязанных действий. Управление суммирует все эти управленческие функции, состав которых впервые был предложен Анри Файолем: «Управлять – это значит предвидеть, организовывать, распоряжаться, координировать и контролировать» [7]. Некоторыми примерами управленческих процессов являются процессы коммуникационные и принятия управленческих решений, производственные (технологические) и процессы закупок.

С позиции системного подхода управление представляет собой осуществление совокупности непрерывных взаимосвязанных воздействий на объект (управляемую систему), выбранных из множества возможных воздействий на основании информации о поведении объекта и состоянии внешней среды для достижения заданной цели. Управление есть функция системы, направленная либо на сохранение ее основного качества (совокупности свойств, утеря которых приводит к разрушению системы), либо на выполнение некоторой программы, обеспечивающей устойчивость функционирования и достижение определенной цели.

Управление предполагает измерение выходных параметров системы, сравнение результатов измерения с некоторыми заданными эталонами и последующее воздействие на вход системы (регулирование, корректировка входа) с целью установления необходимого режима работы.

Системой управления называют систему, в которой реализуются функции управления. Она объединяет управляющую систему и систему связи.

Главные вопросы, стоящие перед системой управления: чем (объект управления) и как управлять.

Основной элемент управляющей системы – *субъект управления*. Это лицо, группа лиц или специально созданный орган, являющийся носителем управленческого воздействия на объект (управляемую систему), осуществляющий деятельность, направленную на сохранение качественной специфики, обеспечение его нормального функционирования и успешное движение к заданной цели.

Объект управления — это система (организация, коллектив и т. п.), на которую направлены все виды управленческого воздействия с целью ее совершенствования, повышения качества функций и задач, успешного достижения запланированной цели (целей). Их соединяет система связи.

Управление всегда связано с решением проблем, возникших в процессе функционирования объекта управления. Субъект управления, применяя системный подход, выявляет всю совокупность условий, причин и факторов, приведших к возникновению проблем, и определяет возможные пути и средства их разрешения. Субъект управления реализует задачи целеполагания, стабилизации, выполнения программы, слежения или оптимизации и тем самым обеспечивает либо удержание выходных характеристик системы при изменениях внешней среды в требуемых пределах, либо выполнение системой действий по изменению значений ее характеристик или характеристик внешней среды. Объект управления является исполнительным инструментом, реализующим основную функцию системы.

Метод управления – это совокупность сознательно и последовательно применяемых способов и приемов воздействия субъекта управления на объект управления посредством своей деятельности для достижения поставленной цели. В зависимости от функций методы управления подразделяются на три основные группы: управление функциональными подсистемами, выполнение функций управления и принятие управленческих решений.

Программное управление – это выполнение последовательности действий (операций) в строгом соответствии с предписанной программой (правилами, распоряжениями, законами и т. п.). Не предполагается знание объектом управления цели управления, цели функционирования (существования) объекта управления, пути к цели и промежуточных этапов продвижения к намеченной цели, состояния объекта управления в каждой точке пути.

Управление по отклонениям от намеченного пути с обратной связью предполагает знание объектом управления своего состояния в каждый момент времени и пути следования к намеченной цели, но конечная цель пути объекту управления неизвестна – строгое следование намеченному пути приведет к ней. Объект управления определяет свое действительное положение на пути к цели по соответствию его реальных контролируемых параметров запланированным. При отклонении текущих параметров от требуемых в данный момент включается программа коррекции пути, что позволяет компенсировать некоторые ошибки при запуске программы, а также учесть и компенсировать небольшие случайные внешние возмущения.

Терминальное управление предусматривает знание объектом управления конечной цели его функционирования и наличие у него достаточных ресурсов для достижения поставленной цели. Такой метод управления предоставляет системе управления широкую свободу в выборе путей достижения желаемого результата процесса (при соблюдении необходимых ограничений), позволяет достигнуть оптимального (квазиоптимального) результата функционирования системы в условиях случайных возмущений и предъявляет более высокие требования к возможностям системы управления (прежде всего, к интеллектуальным ресурсам).

Часто применяют *два основных типа управления: иерархический и органический*. Первый тип больше ассоциируется с армейской структурой управления с жесткой вертикальной системой управления и постоянно закрепленными обязанностями каждого элемента системы. Второй тип отличается высокой адаптивностью к условиям работы с большими горизонтальными связями управления, при которых обязанности участников процесса могут достаточно часто меняться.

Организационно в системе управления выделяются следующие основные элементы: уровни (ступени), звенья, горизонтальные и вертикальные связи.

Теория управления как наука о принципах и методах управления различными системами, процессами и объектами применяет научные методы анализа с целью выработки определенных методов и рекомендаций для практики управления. К теории управления существует три основных подхода: системный, процессный и ситуационный. Системный и процессный подходы являются общими подходами. Ситуационный подход применяет различные приемы и концепции к конкретным ситуациям функционирования организации для достижения ею своих целей. При этом учитываются ситуационные различия как между организациями, так и внутри самих организаций, определяются значимые переменные ситуации и их влияние на эффективность деятельности организации.

Можно выделить некоторые отличительные черты всех современных систем управления:

- принятие решений на основе установленных фактов объективной информации, полученной в результате измерения параметров управляемых процессов, а не на основе предшествующего опыта, интуиции или руководящих указаний;

- проактивное управление параметрами процесса (с прогнозированием развития ситуации и упреждающим регулированием этих параметров) с целью недопущения нежелательного результата процесса, а не реактивное с принятием мер по устранению последствий неадекватного процесса;

- терминальное управление – планирование цели процесса и реализация управления по отклонениям от цели, а не программное (реализация установленных извне требований к содержанию процессов, не связанных с определенной целью каждого процесса);

- непрерывное совершенствование процессов и системы управления процессами, поскольку постоянное улучшение процесса неизбежно приведет и к постоянному улучшению его результата.

Для полноты раскрытия термина «управление» необходимо отметить, что в английском языке имеется несколько слов, которые переводятся на русский как «управление»:

- *control* – исторически первый из применяемых в информационных технологиях (ИТ) терминов, отражающий самые простейшие операции в области управления, в большей степени с точки зрения технического аспекта деятельности;

- *management* – термин, который первоначально употреблялся в отношении управления человеческими ресурсами; в настоящее вре-

мя встречается в сочетании с множеством понятий из области ИТ и имеет смысл организации и регулирования какой-либо деятельности, т. е. ее администрирования;

- *governance* – термин, который стал активно использоваться применительно к ИТ только в последнем десятилетии; под ним обычно понимается руководство по организации и контролю за какой-либо деятельностью. Переводится на русский как «власть, руководство, управление».

Организация IT Governance Institute (ITGI, <http://www.itgi.org>) определяет руководство ИТ как структуру взаимоотношений и процессов в организации по управлению и контролю для достижения ею поставленных целей посредством увеличения ее стоимости в процессе снижения рисков и повышения дохода от использования ИТ и связанных с ними процессов. Просто управление ИТ ориентировано на ИТ-сервисы и продукты и управление ИТ-операциями. Руководство ИТ значительно шире и концентрируется на том, что ИТ должны делать для удовлетворения нынешних и будущих потребностей бизнеса и клиентов организации.

В основе такого руководства лежит концепция, согласно которой управление организацией должно быть хорошо организованной деятельностью, осуществляемой специалистами, осознающими полную ответственность и подотчетность своих действий. Руководство является формальным средством исполнения своих обязанностей представителями исполнительной власти в государственных, коммерческих, образовательных и иных организациях. Руководство обусловлено необходимостью управления рисками и защитой самой организации и по своей сути связано с двумя функциями: производством продукции и снижением рисков.

В организации должна быть создана система руководства, применяемая ко всем видам деятельности и процессам: планированию, проектированию, закупкам, разработке, внедрению и мониторингу. Система руководства включает в себя управление окружающей средой и различными областями деятельности и строится на определенных принципах: понятные ожидания (понятные показатели, четкие политики и стандарты, сильные связи, ясная стратегия); понятное выполнение операций с установленной ответственностью (компетентные организационные структуры, четко определенные роли и обязанности, упорядоченные процессы и процедуры, эффективное использование технологий, ответственное управление активами; проактив-

ное управление изменениями; своевременное и точное обнаружение); независимый анализ и постоянное совершенствование.

Руководство осуществляется в следующих условиях и обстоятельствах:

- федеральные и государственные законы, директивы и руководящие указания;
- промышленное регулирование практики управления;
- миссия и стратегия организации;
- допустимые для организации риски;
- этика, культура и ценности организации;
- расположение организации и подход к управлению – централизованный или децентрализованный;
- политики, стандарты, процессы и процедуры, принятые в организации;
- роли и ответственность в организации;
- планы и отчетность организации;
- проверка организации на различные виды соответствия.

Возможные области руководства таковы: стратегическое планирование и регулирование – прогноз и возможности, необходимые для поставки продуктов организации; поставка продукции – создание прибыли во время и в рамках бюджета; управление рисками ИБ – непрерывный процесс, начинающийся с идентификации рисков ИБ (угроз ИБ и уязвимостей) и оценки их воздействия на активы, снижение рисков ИБ посредством контрмер и формальное принятие руководством остаточных рисков ИБ; управление ресурсами – правильное использование возможностей (люди, оборудование, АО, ПО и т. д.) для удовлетворения потребностей организации; измерение производительности обеспечивает обратную связь с потребностями организации, чтобы она оставалась дееспособной или вовремя принимались корректирующие меры.

В начале XX века начала развиваться наука управления, которую стали называть менеджмент (от англ. *management* < *manage* – управлять, руководить).

В современной литературе имеются разные определения менеджмента, раскрывающие это понятие с различных точек зрения:

- способ (манера) обращения с людьми, власть и искусство управления, особого рода административные навыки, орган управления (Оксфордский словарь английского языка);

- совокупность принципов, форм, методов, приемов и средств управления производством и производственным персоналом с использованием достижений науки управления;

- искусство управления интеллектуальными, финансовыми, материальными ресурсами [2];

- эффективное и результативное достижение целей организации посредством планирования, организации, лидерства (руководства) и контроля над организационными ресурсами [3];

- скоординированная деятельность по руководству и управлению организацией [5] (поэтому иногда делают вывод, что понятие менеджмента шире, чем просто управление).

В других источниках менеджмент определяется:

- как особый вид профессионально осуществляемой (осуществляемой профессионалами, профессиональными управляющими) деятельности, направленной на достижение определенных целей путем рационального использования материальных и трудовых ресурсов с применением определенных научных подходов, принципов, функций и методов;

- объединение управленческой деятельности с кадровой политикой;

- состояние всей управленческой инфраструктуры в различных масштабах;

- процесс оптимизации человеческих, материальных и финансовых ресурсов для достижения организационных целей;

- теория и практика научного и хозяйственного управления организацией в условиях рынка;

- система научных знаний, составляющих теоретическую базу практического опыта в области управления и имеющих междисциплинарный характер;

- совокупность лиц, идентифицируемых с менеджерами, а также с органами или аппаратом управления и т. п.

Менеджмент включает основные функции управления (прогнозирование, целеполагание, планирование, организация деятельности, мотивирование персонала, лидерство, контроль, учет и анализ, корректировка деятельности и т. д.) и определяет эффективное достижение целей организации при оптимальном использовании ресурсов. Ограниченность ресурсов при выполнении функций управления требует их эффективного распределения и использования с учетом взаимозависимости и взаимосвязанности этих функций. Менеджмент

применяет и реализует специальные технологии и инструменты управления: организацию и организационные отношения (формальные и неформальные), организационную культуру, мотивирование, стимулирование и др. Таким образом, менеджмент является наиболее эффективным способом управления.

Часто слова «менеджмент» и «управление» используются как синонимы, хотя их научная трактовка, что видно из приведенных выше объяснений, совпадает не полностью.

1.6. Циклическая модель улучшения процессов

Для структурирования всех процессов управления и для обеспечения учета всех значимых элементов процессного подхода применяется циклическая модель, или цикл, PDCA (от англ. PlanDoCheckAct – планируй, выполняй, проверяй, действуй), предложенная и развитая двумя американскими учеными и специалистами в теории управления качеством (рис. 1.3).

Действуй (усвой изменения или отбрось их, или повтори ещё раз при других условиях)

Планируй изменения или испытания, направленные на улучшение

Проверяй, оценивай, изучай результат

Попробуй осуществить

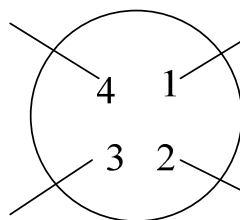


Рис. 1.3. Цикл PDCA

В. Шухарт впервые описал цикл PDCA в 1939 г. в своей книге «Статистические методы с точки зрения управления качеством». В. Деминг пропагандировал использование цикла PDCA в качестве основного способа достижения непрерывного улучшения процессов, и поэтому в современном мире эта формула больше известна как «цикл Деминга». Он также ввел модификацию цикла PDCA – цикл PDSA (от англ. *study* – изучай):

- «Планируй» (*Plan*) – определение целей и задач, а также способов достижения целей. На данном этапе обеспечивается единое направление деятельности организации к достижению ее целей за счет установления процессов, необходимых для получения результатов в соответствии с существующими требованиями в обозначенный отрезок времени. Для этого определяются и описываются текущее и желаемое состояния процессов за счет выявленных несоответствий и причин их появления. Планирование не является отдельным разовым событием, если организация стремится функционировать как можно дольше. Поэтому она пересматривает свои цели, если полное достижение первоначальных практически завершено или их выполнение невозможно в силу ряда причин.

Вторая причина, по которой планирование должно осуществляться непрерывно, – это постоянная неопределенность будущего. Изменения в окружающей среде, ошибки в суждениях и другие факторы приводят к тому, что события разворачиваются не так, как это предвидело руководство при выработке первоначальных планов. Поэтому, чтобы планы согласовывались с реальностью, их необходимо регулярно пересматривать. В процессе планирования нужно консультироваться с владельцами процессов, которые обладают самими полными знаниями о них.

- «Осуществляй» (*Do*) – реализация процесса: обучение и подготовка кадров, выполнение работ. На данном этапе в первую очередь происходит создание некоторой структуры, которая должна выполнять намеченные планы и тем самым достигать цели организации. Внедряются процессы, осуществляется выполнение запланированных мероприятий. Здесь следует помнить о том, что стандарты всегда несовершенны, поэтому необходимо полагаться на опыт и знания квалифицированных работников. На всех этапах прохождения цикла Деминга возникает проблема нехватки квалифицированных и подготовленных работников. Поэтому необходимо внедрять программы обучения и целенаправленной подготовки кадров.

- «Проверяй» (*Check*) – проверка результатов выполнения работ, проведенных на предыдущем этапе. Данный этап говорит о том, что необходимо проводить мониторинг процессов и измерять их по отношению к политикам, целям и требованиям к продукции за определенный период и сообщать о полученных результатах в сравнении с ожидаемыми. Контроль и оценка обеспечивают организации дости-

жение своих целей. Если все идет в соответствии с поставленными задачами и согласно требованиям стандартов, то, соответственно, никакой корректировки не требуется. Однако если обнаружено отклонение, то вмешательство руководства для установления причин неэффективной работы процессов и планирования мер по улучшению становится необходимым.

- *«Действуй, или воздействуй» (Act)* – осуществление соответствующих управляющих воздействий по постоянному усовершенствованию (улучшению) показателей процессов. На данном этапе на основе результатов, полученных ранее, предпринимаются действия по коррекции отклонений от первоначальных планов и постоянному улучшению функционирования процессов. Если вносимые изменения не решают поставленную задачу, цикл следует повторить. Тогда одно из возможных действий – пересмотр целей для того, чтобы они стали более реалистичными и соответствовали ситуации.

Применение цикла PDCA в самых различных областях позволяет эффективно управлять деятельностью на системной основе [7]. Данный цикл может быть применен внутри каждого процесса организации, как высокого уровня, так и к простым производственным процессам, а также по отношению к системе процессов в целом. Он тесно связан с планированием, внедрением, управлением и постоянным улучшением как бизнес-процессов организации, так и других процессов системы управления. Управление следует организовывать на основе комплексов мероприятий, которые доказали свою эффективность.

1.7. Системный подход к управлению организацией

Системный подход применительно к управлению рассматривает управленческую деятельность как систему, т. е. как совокупность элементов, взаимодействующих между собой в пространстве и времени, функционирование которых направлено на достижение общей цели.

Системный подход к управлению организацией – это выявление, понимание и административное управление системой взаимосвязанных процессов с целью достижения заданной стратегической цели [1].

При таком подходе организация представляется в виде иерархической системы взаимосвязанных моделей, позволяющих изучать ее целостные свойства, структуру.

Системный подход к управлению организацией позволяет:

- определить систему путем выявления или разработки процессов, влияющих на достижение заданной стратегической цели;
- структурировать систему так, чтобы достичь заданной стратегической цели наиболее эффективным способом;
- обеспечить понимание взаимосвязей между процессами системы;
- обосновать зависимость организации от переменных факторов внешней и внутренней среды, оказывающих прямое и косвенное воздействие на ее функционирование;
- проводить непрерывное совершенствование системы посредством измерения и оценки;
- обеспечить лучшее понимание распределения ролей и ответственности при достижении общих стратегических целей, уменьшая тем самым межфункциональные барьеры и улучшая коллективную работу.

Системный подход к управлению позволяет выделить ряд его сущностных признаков:

1) Исходным моментом в организации управления и конечным результатом его осуществления является человек с его потребностями, мотивами, ценностями; при этом создаются организационные, экономические и социально-психологические условия заинтересованности человека в результатах труда, удовлетворении его потребностей, что управляет мотивацией людей.

2) Принципы и методы системного подхода позволяют управлять как внутренними процессами деятельности людей, так и процессами поведения организации во внешней социально-экономической среде.

3) Руководство организации характеризует профессионализм управления, выступающий как одно из главных требований к персоналу.

4) Для руководства характерна гибкая организация управления, способная быстро перестраиваться в соответствии с меняющимися условиями, факторами внешней и внутренней среды.

1.8. Процессный подход к управлению организацией

Процессный подход к управлению, или процессное управление, – подход к управлению, который рассматривает управление как непрерывную серию взаимосвязанных управленческих функций.

Процессное управление представляет собой планомерную деятельность по формированию целенаправленного поведения организации посредством выделения, описания и менеджмента системы взаимосвязанных и взаимодополняющих процессов организации и их ресурсного окружения. Руководство организацией возможно осуществлять, только управляя ее процессами (бизнес-процессами) [1]. Поэтому процессное управление – это инструмент корпоративного управления, обеспечивающий реализацию стратегии организации. Управление может быть эффективно лишь тогда, когда оно сознательно нацелено на управление процессами, являющимися сутью деятельности системы при наличии цели.

Система управления, основанная на процессном подходе, – это система, в которой основным объектом управления выступает бизнес-процесс. Применение процессного подхода требует описания, оптимизации и автоматизации бизнес-процессов.

При использовании процессного подхода структура управления организацией включает два уровня:

- управление в рамках каждого бизнес-процесса;
- управление группой бизнес-процессов на уровне всей организации.

Основой управления отдельным бизнес-процессом и группой бизнес-процессов являются показатели эффективности, среди которых можно выделить:

- затраты на его осуществление;
- расчет времени на его осуществление;
- показатели качества бизнеспроцесса.
- информационную безопасность.

Поскольку в настоящее время цифровая обработка информации является частью почти всех сфер жизни, нет различия между обработкой информации с использованием ИТ или коммуникационных технологий либо с использованием бумажных носителей. Поэтому считается, что термин «информационная безопасность» (а не «безопасность ИТ») более всеобъемлющ и более уместен. Однако словосочетание «безопасность ИТ» по-прежнему используется, но преимущественно в печатных изданиях, потому что оно короче.

В России в основном используются три термина: «безопасность информации», «защита информации» и «информационная безопасность».

Согласно Руководящему документу Гостехкомиссии России от 30 марта 1992 г. «Защита от несанкционированного доступа к информации. Термины и определения», безопасность информации – это состояние защищенности информации, обрабатываемой средствами вычислительной техники или автоматизированной системы, от внутренних или внешних угроз [8].

Согласно Рекомендациям по стандартизации Р 50.1.053-2005 «Информационные технологии. Основные термины и определения в области технической защиты информации» и ГОСТ Р 50922-2006 «Защита информации. Основные термины и определения», безопасность информации (данных) – это состояние защищенности информации, при котором обеспечивается ее (их) конфиденциальность, доступность и целостность [9, 10].

Согласно Р 50.1.053-2005, безопасность информации (при применении информационных технологий – это состояние защищенности ИТ, обеспечивающее безопасность информации, для обработки которой она применяется, и ИБ автоматизированной ИС, в которой она реализована.

В ГОСТ Р 50922-2006 под защитой информации понимается деятельность, направленная на предотвращение утечки защищаемой информации, несанкционированных и непреднамеренных воздействий на защищаемую информацию.

Словосочетание «информационная безопасность» в разных контекстах имеет разный смысл. Например, в Доктрине информационной безопасности Российской Федерации этот термин определяется как состояние защищенности национальных интересов в информационной сфере, определяемых совокупностью сбалансированных интересов личности, общества и государства. В Стандарте Банка России СТО БР ИББС1.0 ИБ организации БС РФ – это безопасность (состояние защищенности интересов (целей) организации БС РФ в условиях угроз), связанная с угрозами в информационной сфере. При этом защищенность достигается обеспечением совокупности свойств ИБ: доступности, целостности, конфиденциальности информационных активов, а информационная сфера представляет собой совокупность информации, информационной инфраструктуры, субъектов, осущест-

влияющих сбор, формирование, распространение, хранение и использование информации, а также системы регулирования возникающих при этом отношений [11].

Под ИБ часто также понимается следующее:

- защищенность информации и поддерживающей инфраструктуры от случайных или преднамеренных воздействий естественного или искусственного характера, чреватых нанесением ущерба владельцам или пользователям информации и поддерживающей инфраструктуры [12];

- механизм защиты, обеспечивающий конфиденциальность, целостность и доступность информации [13];

- свойство информации сохранять конфиденциальность, целостность и доступность [14].

Согласно ГОСТ Р 53113.1-2008 «Информационная технология. Защита информационных технологий и автоматизированных систем от угроз информационной безопасности, реализуемых с использованием скрытых каналов. Часть 1. Общие положения», информационная безопасность – это аспекты, связанные с определением, достижением и поддержанием конфиденциальности, целостности, доступности, неотказуемости, подотчетности, аутентичности и надежности информации, или средства ее обработки [15].

Кроме того, данное понятие в современных условиях должно включать в себя еще четыре свойства:

- аутентичность, или подлинность (свойство, гарантирующее правдивость, подлинность и т. п.), применяется к пользователям, процессам, системам, информации;

- учетность или подотчетность (однозначная прослеживаемость всех действий объектов, влияющих на ИБ);

- неотказуемость или неоспоримость (причастность к совершению операций с информацией);

- надежность (соответствие преднамеренному поведению и результатам).

Итак, информационную безопасность можно определить как состояние защищённости информации, которое достигается обеспечением совокупности для нее свойств доступности, целостности, конфиденциальности, аутентичности, подотчетности, неотказуемости и надежности.

Под ИБ организации понимается состояние защищенности интересов (целей) организации в условиях угроз ИБ (угроз доступности,

целостности, конфиденциальности, аутентичности, подотчетности, неотказуемости и надежности) в информационной сфере.

ИБ должна стать неотъемлемой частью производственной и деловой культуры организации. Для достижения целей ИБ организации перечисленные свойства информации поддерживаются комплексом мероприятий по управлению ИБ, осуществляемых на основе соответствующих нормативных актов и ПолИБ и организационных структур, за счет реализации установленных мер, методов, процедур и программно-аппаратных средств защиты информации (СЗИ), которыми необходимо постоянно управлять [13]. Итак, ИБ представляет, главным образом, проблему управления (хотя в условиях сильной зависимости от использования ИТ и техническая сторона не должна оставаться без внимания), а ОИБ – это процесс поддержания состояния защищенности активов организации, который должен осуществляться постоянно, и поэтому им необходимо управлять. Этапы этого процесса составляют основу комплексной СОИБ организации, поскольку ОИБ требует комплексного подхода, включающего организационную (подготовленный персонал и нормативные документы), техническую (СЗИ) и другие составляющие (рис. 1.4).

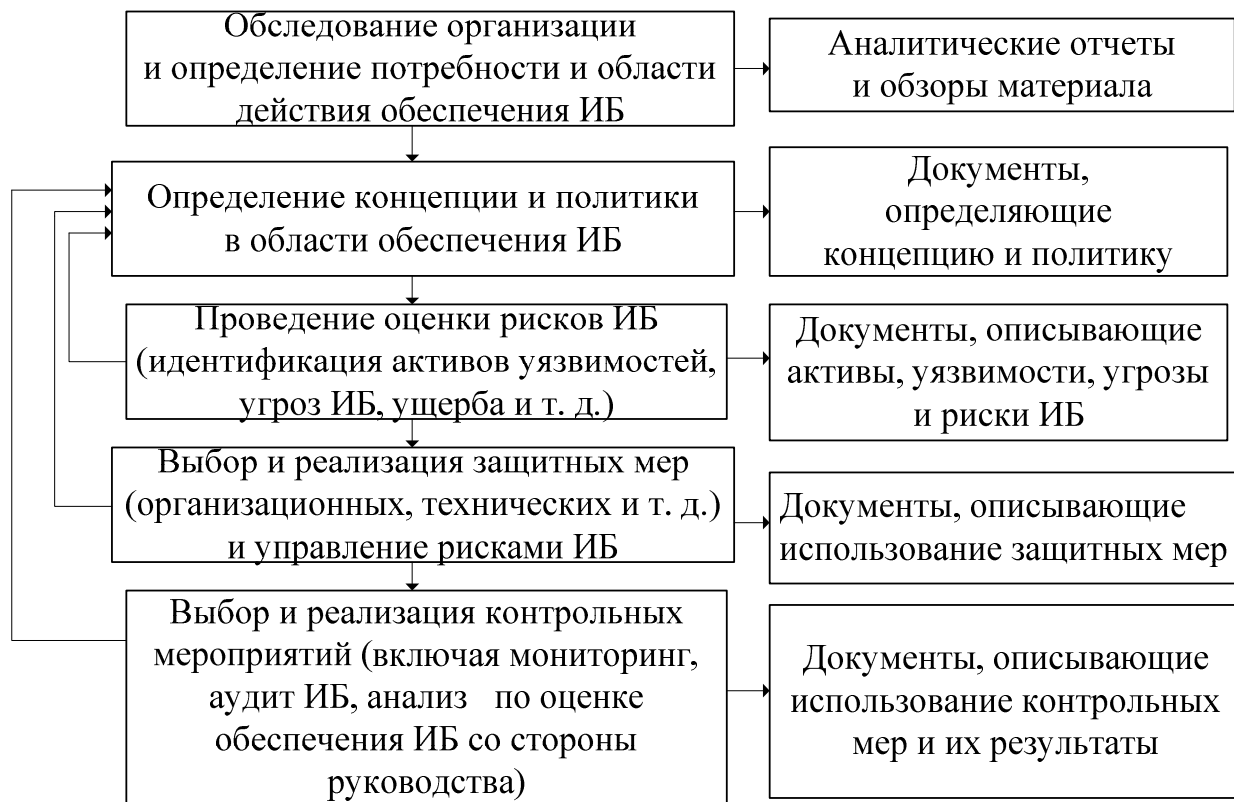


Рис. 1.4. Этапы процесса ОИБ организации

Вопросы для самоконтроля

1. Как определяется понятие системы?
2. Каковы основные свойства системы?
3. В чем заключается системный подход к исследованию объектов?
4. Каковы особенности рассмотрения системного подхода применительно к управлению?
5. Какие элементы процесса могут быть исключены из определения: входные данные процесса, выходные данные процесса, управляющее воздействие, ресурсы?
6. Какие виды деятельности в организации можно назвать процессом (или бизнес-процессом)?
7. Какую роль играют процессы в терминах системного подхода к организации?
8. Кто в организации может и должен определять цели бизнес-процессов?
9. Что понимается под ресурсами в рамках определения понятия процесса?
10. Что понимается под управляющим воздействием в рамках определения понятия процесса?
11. В чем заключается процессный подход?
12. Дайте определение понятия «управление» с позиций системного подхода.
13. Дайте определение понятия «менеджмент».
14. В чем различия понятий «управление» и «менеджмент»?
15. Каковы основные функции управления?
16. Что такое метод управления?
17. Дайте определение системы управления.
18. Что представляет собой система управления, основанная на процессном подходе?
19. Каковы особенности рассмотрения процессного подхода применительно к управлению?
20. К каким процессам организации может быть применена циклическая модель PDCA?
21. В чем состоят основные преимущества использования циклической модели PDCA?
22. Чем различаются термины «защита информации» и «информационная безопасность»?
23. Какие свойства ИБ в современных условиях должны приниматься во внимание и что понимается под каждым из свойств?

2. СТАНДАРТИЗАЦИЯ СИСТЕМ И ПРОЦЕССОВ УПРАВЛЕНИЯ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТЬЮ

Международная организация по стандартизации ISO (ИСО) и Международная электротехническая комиссия ИЕС (МЭК) формируют специализированную систему всемирной стандартизации. На текущий момент можно утверждать, что мировое сообщество проделало существенную работу в направлении стандартизации СУИБ и отдельных процессов управления ИБ и по-прежнему весьма активно продолжает эту работу. В соответствии с разработанными стандартами ОИБ в любой организации заключается в выполнении следующих действий:

- определение целей ОИБ;
- создание эффективной СУИБ;
- расчет совокупности детализированных не только качественных, но и количественных показателей для оценки соответствия уровня ИБ заявленным целям;
- применение инструментария ОИБ и оценки текущего состояния, использование методик (с системой критериев и защитных мер, или мер ОИБ) в процессе анализа и управления рисками, позволяющих объективно оценить текущее состояние дел в организации.

Основоположником подобной стандартизации стала серия стандартов ISO 9000, предъявляющих требования к системам менеджмента качества, соблюдение которых позволяет контролировать качество выпускаемой продукции или предоставляемых услуг. При разработке стандартов на СУИБ многое было взято за основу именно из стандартов серии ISO 9000, например, основной подход, процессный подход и использование циклической модели PDCA для непрерывного совершенствования как самой системы, так и отдельных ее процессов. Помимо этого отличительной особенностью стандартов ISO 9000, которая была перенята при стандартизации СУИБ, является то, что они устанавливают степень ответственности руководства компании за качество. Причем руководство предприятия отвечает как за разработку политики в области качества, так и за внедрение и поддержание в рабочем состоянии системы менеджмента качества. Очень большое количество процессов управления из систем менеджмента качества

с некоторыми изменениями присутствует и в СУИБ, например внутренние аудиты ИБ, корректирующие и предупреждающие действия и т. д.

2.1. Серия стандартов ISO/IEC 27000 «Информационные технологии. Методы обеспечения безопасности»

История развития серии стандартов 27000 началась в 1999 г., когда обновленная первая часть британского стандарта BS 7799:1995 (BS 7799:1999) была передана в ИСО и в 2000 г. впервые утверждена в качестве международного стандарта как ISO/IEC 17799:2000. Следующей его версией стал стандарт ISO/IEC 17799:2005.

В том же 1999 г. вышла в свет вторая часть стандарта BS 7799 – BS 7799:1999 «Information Security Management. Specification for ISMS» для СУИБ (Information Security Management System). В 2002 г. стандарт был усовершенствован, и выпущена его новая редакция BS 7799:2002. На ее основе в 2005 г. был разработан и принят стандарт ISO/IEC 27001:2005.

Дальнейшее развитие стандартов серии 27000 включает в себя появление стандартов, более подробно раскрывающих требования к отдельным процессам управления ИБ. Базируясь на единой структуре и методологии, заложенной в ISO/IEC 27001:2005, они представляют руководства по управлению ИБ для различных сфер деятельности, включая финансовый и страховой сектор, здравоохранение, телекоммуникации и т. д.

С 2012 г. существуют международные стандарты серии 27000 (табл. 2.1).

Что касается собственно российских стандартов по управлению ИБ, то сначала были приняты стандарт ГОСТ Р ИСО/МЭК 17799-2005, идентичный ISO/IEC 17799:2000 и актуализированный 01.01.2008, и стандарт ГОСТ Р ИСО/МЭК 27001-2006, идентичный ISO/IEC 27001:2005. В настоящее время российская стандартизация в области управления ИБ проходит некоторую промежуточную стадию своего формирования и является еще недостаточно зрелой, однако намечаются положительные тенденции в развитии данной области. После некоторого перерыва были приняты национальные стандарты, идентичные 27006, 27005, 27004 и 270331.

Таблица 2.1

Перечень международных стандартов серии 27000

Номер и год принятия	Название
1	2
27000:2009	СУИБ. Определения и основные принципы
27001:2005	СУИБ. Требования (на основе BS 7799-2:2005)
27002:2005	Практические правила управления ИБ (ранее ISO/IEC 17799:2005)
27003:2010	Руководство по внедрению СУИБ
27004:2009	Управление ИБ. Оценка СУИБ
27005:2011	Управление рисками ИБ (на основе BS 7799-3:2006)
27006:2007	Требования к органам, обеспечивающим аудит и сертификацию СУИБ
27007:2011	Руководство по аудиту СУИБ
27008:2011	Руководство по аудиту средств управления ИБ, реализованных в СУИБ
27010	Управление ИБ при коммуникации между секторами (в нескольких частях, представляющих руководство по совместному использованию информации о рисках ИБ, средствах управления, проблемах и/или инцидентах ИБ, выходящих за границы отдельных секторов экономики и государств, особенно в части, касающейся критичных инфраструктур)
27011:2008	Руководство по управлению ИБ для телекоммуникационных компаний на основе ISO/IEC 27002
27013	Руководство по интегрированному внедрению ISO 20000 и ISO 27001
27014	Базовая структура управления ИБ
27015	Руководство по внедрению СУИБ для финансовых сервисов (банков, страховых компаний, кредитных организаций и т. д.)
27031:2011	Руководство по готовности информационных и телекоммуникационных технологий для обеспечения непрерывности бизнеса (на основе BS 25699:2006/2007)
27032	Руководство по обеспечению кибербезопасности
27033-1:2009	Безопасность сетей. Часть 1. Общие положения и концепции
27033-2	Руководство по проектированию и внедрению системы обеспечения безопасности сетей
27033-3:2010	Базовые сетевые сценарии – угрозы, методы проектирования и средства управления

1	2
27033-4	Обеспечение безопасности межсетевых взаимодействий при помощи шлюзов безопасности – угрозы, методы проектирования и средства управления
27033-5	Обеспечение безопасности виртуальных частных сетей – угрозы, методы проектирования и средства управления
27033-6	Конвергенция в JP-сетях (определение угроз, методов проектирования и средств управления в IP-сетях с конвергенцией данных, голоса и видео)
27033-7	Руководство по обеспечению безопасности беспроводных сетей – риски, методы проектирования и средства управления
27034-1:2011	Безопасность приложений. Часть 1. Обзор и основные концепции в области обеспечения безопасности приложений
27034-2	Нормативная база организации
27034-3	Процесс управления безопасностью приложений
27034-4	Оценка безопасности приложений
27034-5	Протоколы и структура управляющей информации для обеспечения безопасности приложений (XML-схема)
27034-6	Руководство по обеспечению безопасности конкретных приложений
27035:2011	Управление инцидентами безопасности (заменит ISO/IEC TR 18044)
27036	Руководство по аутсорсингу безопасности
27037	Руководство по идентификации, сбору и/или получению и обеспечению сохранности свидетельств, представленных в электронной форме (на основе BS 10008:2008)
27799:2008	Управление ИБ в сфере здравоохранения

Взаимосвязь российских, международных и британских стандартов, посвященных СУИБ, отражена в табл. 2.2.

Также проблематикой СУИБ занимается и Федеральное агентство по ИБ немецкого правительства BSI (Bundesamt für Sicherheit in der Informationstechnik), которое является одним из признанных разработчиков решений в области ИБ, предоставляющим бесплатный доступ к своим документам через сайт BSI (www.bsi.bund.de). Методика JT-Grundschutz позволяет создать СУИБ, соответствующую требованиям ISO/IEC 27001, поскольку эта методика полностью совместима с подходами, использованными в стандарте 27001, и рекомендациями

стандарта ISO/IEC 27002. Но методика IT-Grundschutz описывает некоторые вопросы, затронутые в стандарте, более детально и поэтому представляет более дидактический подход для организаций, внедряющих у себя СУИБ.

Таблица 2.2

Взаимосвязь стандартов, посвященных СУИБ

Российский стандарт	Международный стандарт	Британский стандарт
ГОСТ Р ИСО/МЭК 17799-2005	ISO/IEC 27002:2005	BS 7799-1:2005
-	ISO/IEC 17799:2005	
ГОСТ Р ИСО/МЭК 27001-2006	ISO/IEC 27001:2005	BS 7799-2:2005
ГОСТ Р ИСО/МЭК 27006-2008	BS ISO/IEC 27006:2007	
ГОСТ Р ИСО/МЭК 27005-2010	ISO/IEC 27005:2011	BS 7799-3:2005
ГОСТ Р ИСО/МЭК 27004-2011	BS ISO/IEC 27004:2009	
ГОСТ Р ИСО/МЭК 27033-1-2011	BS ISO/IEC 27033-1:2009	

Агентство разработало и регулярно обновляет четыре стандарта в области ОИБ (рис. 2.1) [16, 19]:

- BSI-Standard 100-1 «Information Security Management Systems», который содержит общие требования к СУИБ;

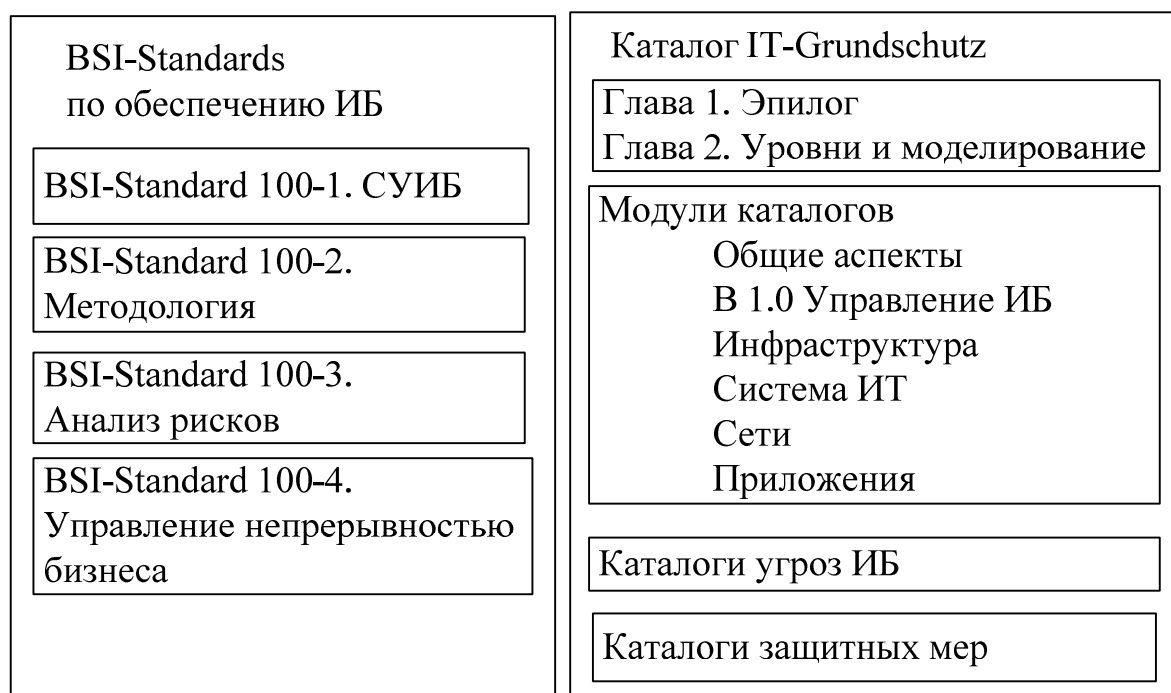


Рис. 2.1. Серия стандартов BSI

- BSI-Standard 100-2 «IT-Grundschatz Methodology», освещающий вопросы поэтапного построения СУИБ и ее дальнейшего использования на практике и содержащий подробные руководства по ОИБ применительно к различным аспектам функционирования ИС и различным областям ИТ. В стандарте выделяются функции СУИБ и организационная структура ОИБ, даются подробные практические рекомендации по разработке политики ИБ и выбору защитных мер, а также рассматриваются сопровождение и усовершенствование деятельности по ОИБ в повседневной практике организации;

- BSI-Standard 100-3 «Risk Analysis based on IT-Grundschatz», посвященный анализу рисков ИБ на основе методики IT-Grundschatz;

- BSI-Standard 100-4 «Business Continuity Management», рассматривающий вопросы управления непрерывностью бизнеса (УНБ).

Кроме того, BSI составило сборник IT-Grundschatz Catalogues (Каталог по безопасности ИТ), являющийся самым объемным (более 4 тыс. ст.) и детальным из существующих. Каталоги типовых информационных активов, связанных с ними угроз ИБ и защитных мер содержат конкретные практические рекомендации для оценки рисков ИБ, выбора и применения защитных мер, включая технические аспекты их использования.

ISO/IEC 27000:2009. СУИБ: определения и основные принципы. Международный стандарт ISO/IEC 27000:2009 «Information technology. Security techniques. Information security management systems. Overview and vocabulary» (Информационная технология. Методы и средства обеспечения безопасности. Обзор и определения) содержит термины и определения, которые используются во всех стандартах серии 27000 [20]. Главная цель ISO/IEC 27000:2009 — подробное описание основных принципов, концепций и определений для серии документов ISO/IEC 27000, регламентирующих все то, что связано с СУИБ.

В стандарте приведен обзор серии 27000 (рис. 2.2); представлено введение в СУИБ, являющееся предметом рассмотрения данной серии стандартов, определены требования к СУИБ и к их оценке соответствия, в том числе для тех, кто сертифицирует эти системы; описан цикл PDCA со всеми процессами и требованиями к ним, а также введены термины и определения, используемые в стандартах серии 27000.

В ISO/IEC 27000:2009 СУИБ определяется как часть общей системы управления, основанная на использовании методов оценки бизнес-рисков для разработки, внедрения, функционирования, мониторинга, анализа, сопровождения (поддержания) и совершенствования (улучшения) ИБ.

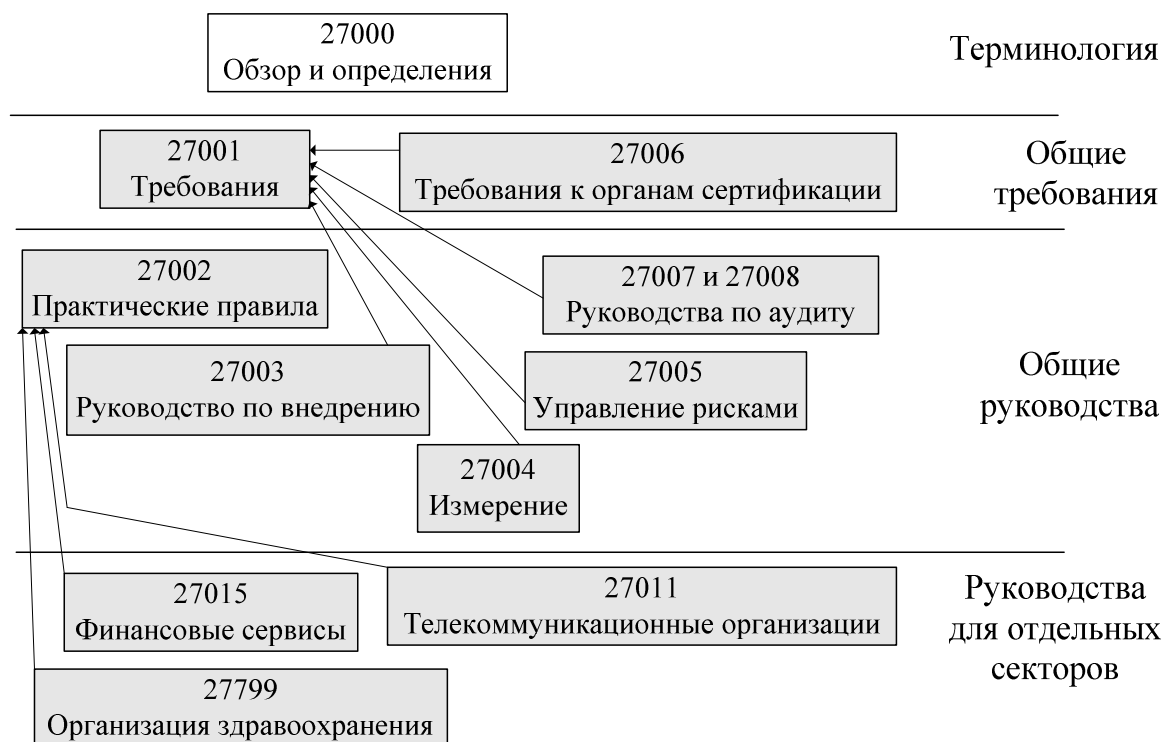


Рис. 2.2. Логическая взаимосвязь стандартов серии 27000

Далее уточняется, что СУИБ определяет модель защиты информационных активов организации для достижения ее бизнес-целей на основе оценки рисков и установления уровня приемлемых для организации рисков, отражающих эффективное устранение и управление рисками. При этом под ИБ понимается сохранение конфиденциальности, целостности и доступности информации, а под системой управления – совокупность политик, процедур, руководящих принципов и ресурсов, необходимых для достижения бизнес-целей организации. Эта система включает в себя организационную структуру, политики, деятельность по планированию, распределение ответственности, практическую деятельность, процедуры, процессы и ресурсы.

При разработке стандарта ISO/IEC 27000:2009 были учтены основные положения следующих документов: ISO/IEC Guide 2:1996 «Стандартизация и смежная деятельность. Основные определения»

и ISO/IEC Guide 73:2002 «Управление рисками. Определения. Рекомендации по использованию в стандартах», а также проведена унификация со стандартами COBIT и ITIL.

В России Ассоциацией ЕВРААС и ООО «НИИ СОКБ» осенью 2011 г. была подготовлена первая редакция проекта национального стандарта ГОСТ Р ИСО/МЭК 27000 201х.

ISO/IEC 27001:2005 и ГОСТ Р ИСО/МЭК 27001-2006. Требования к СУИБ. Международный стандарт ISO/IEC 27001:2005 «Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования» содержит модель создания, внедрения, эксплуатации, мониторинга, анализа, сопровождения и совершенствования СУИБ [21].

В России принят ГОСТ Р ИСО/МЭК 27001-2006 «Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования», идентичный 27001:2005 [14]. Основным объект рассмотрения стандарта в этом документе переведен как система менеджмента ИБ (СМИБ). Целью построения такой системы является выбор соответствующих мер управления ИБ, предназначенных для защиты информационных активов и гарантирующих доверие заинтересованных сторон.

ГОСТ Р ИСО/МЭК 27001-2006 определяет общую организацию СУИБ, требования к ней, разработку и управление СУИБ, требования к документации СУИБ, ответственность руководства в контексте управления ИБ (его обязанности и управление ресурсами), внутренний аудит (СУИБ, анализ СУИБ и направления усовершенствования СУИБ) и т. д. Применение этого стандарта позволит на основе процессного подхода управлять конфиденциальностью, целостностью и доступностью важного актива компании. Стандарт может с одинаковым успехом использоваться в компаниях разного размера (от индивидуальных предпринимателей до предприятий с численностью сотрудников в десятки тысяч человек), типа (коммерческих компаний, государственных и некоммерческих структур) и сферы деятельности.

ГОСТ Р ИСО/МЭК 27001-2006 может использоваться для защиты любых видов информации, включая финансовую, персональные данные, информацию по поставщикам и клиентам, другие данные компании и, что немаловажно, информацию, принадлежащую ее партнёрам/клиентам, всё, что является значимым информационным акти-

вом, и всё, что подвержено угрозам ИБ. Требования стандарта не накладывают каких-либо технических требований на ИТ-средства или СЗИ, стандарт не устанавливает ограничения на выбор программно-аппаратных средств и оставляет организации полную свободу выбора технических решений по защите информации. Таким образом, основную цель ГОСТ Р ИСО/МЭК 27001-2006 можно сформулировать как создание общей методологии разработки, внедрения и оценки эффективности СУИБ.

Решение о создании СУИБ является стратегическим решением организации. На проектирование и внедрение СУИБ оказывают влияние потребности и бизнес-цели компании, используемые бизнес-процессы, а также ее структура и размер, что, в свою очередь, ведет к выработке конкретных требований по обеспечению безопасности бизнеса в широком смысле его понимания. СУИБ объединяет людей, процессы и ИТ-системы, а также обеспечивает согласованную работу службы безопасности, ИТ-отдела и руководства компании.

При использовании СУИБ реализуется системный подход к управлению «чувствительной» для компании информацией с целью обеспечения её конфиденциальности, целостности и доступности. В связи с этим особую значимость приобретают следующие факторы:

- понимание требований по ОИБ организации и необходимости установления политики и целей ИБ;
- внедрение и использование мер для управления рисками ИБ наряду с общими бизнес-рисками организации;
- мониторинг и проверка производительности и эффективности СУИБ;
- непрерывное улучшение СУИБ, основанное на результатах объективных измерений.

Начиная с 2005 г. к августу 2011 г. более 7300 организаций во всем мире успешно прошли официальные процедуры сертификации СУИБ по требованиям ISO/IEC 27001:2005 и еще сотни тысяч организаций активно внедряют международные стандарты серии 27000 без прохождения официальных процедур сертификации (www.iso27001security.com). Сертифицируя СУИБ на соответствие стандарту ISO/IEC 27001:2005, организация демонстрирует своим партнерам применение проверенного международными компаниями методологического подхода к ОИБ, показывает прочность и стабильность своего положения, по-

вышает степень доверия инвестиционных и страховых компаний. Следование требованиям стандарта позволяет существенно повысить прозрачность и защищенность внутренних процессов. Несмотря на рекомендательный статус стандарта ISO/IEC 27001, правительства ряда стран поддерживают его на государственном уровне.

ISO/IEC 27002:2005 и ГОСТ Р ИСО/МЭК 17799-2005. Практические правила управления ИБ. Стандарт ISO/IEC 17799:2005 «Информационные технологии. Управление ИБ. Практические правила» включен в серию стандартов 27000, не претерпев существенных изменений и получив номер ISO/IEC 27002:2005. Международный стандарт менеджмента ИБ 27002:2005 «Информационная технология. Методы и средства обеспечения безопасности. Практические правила управления ИБ» [22] разработан на базе первой части британского стандарта 7799, который предназначен для управления ИБ организации вне зависимости от сферы ее деятельности.

В России стандарт ISO/IEC 17799 начал активно применяться в практике экспертами в области управления ИБ начиная с 20.01.2004 г., и в 2005 г. был принят ГОСТ Р ИСО/МЭК 17799-2005, идентичный 17799:2000, содержащий десять основных разделов (ПолИБ; организационные вопросы безопасности; классификация и управление активными процессами безопасности, связанные с персоналом; физическая защита от воздействий окружающей среды; управление передачей данных и операционной деятельностью; контроль доступа; разработка и облагораживание систем; управление непрерывностью бизнеса; соответствие требованиям). После введения в действие этот стандарт был актуализирован и переиздан в январе 2008 г. с учетом изменений, появившихся в редакции ISO/IEC 17799:2005.

ГОСТ Р ИСО/МЭК 17799-2005 является совокупностью практических правил по управлению ИБ и может быть использован в качестве критериев для оценки механизмов безопасности. В соответствии со стандартом при создании эффективной системы безопасности особое внимание следует уделить комплексному подходу к управлению ИБ. По этим причинам в качестве элементов управления рассматриваются не только технические, но и организационно-административные меры, направленные на обеспечение таких требований к информации, как: конфиденциальность, целостность, доступность, аутентичность.

В последней редакции стандарта 17799 определяются 139 средств управления ИБ, включающих по собственно управлению ИБ и контролю за этим управлением следующие направления управления ИБ:

- управление рисками ИБ (включая оценку, анализ и снижение рисков ИБ);

- ПолИБ (определяются требования к поддержке заданной ИБ; вводятся принципы и аксиомы, описываются некоторые новые стандарты, руководящие принципы и процедуры в области ОИБ);

- организация защиты (управление ИБ при взаимодействии с объектами, включая структуру, анализ и взаимосвязи);

- управление активами (обеспечение защиты активов организации, включая их инвентаризацию, классификацию и владельцев);

- безопасность персонала (снижение риска человеческих ошибок и преднамеренных нарушений, а также средства управления выполнением правил ПолИБ со стороны пользователей, их обучения пониманию, осведомленности в вопросах ИБ);

- физическая защита и защита от воздействия окружающей среды (предотвращение несанкционированного доступа (НСД), изменения, кражи и повреждения средств защиты и информации при физическом доступе; также рассматриваются системы вентиляции, пожаротушения, водоснабжения и электропитания);

- администрирование систем и коммуникаций (снижение риска возникновения системных сбоев, предотвращение повреждения сетевого оборудования, а также средства управления сохранением конфиденциальности, целостности, доступности и аутентичности при передаче информации, включая архивирование, резервное копирование, журналирование и оповещение, установку обновлений, мониторинг и конфигурирование);

- управление доступом (контроль доступа к информационным ресурсам и предоставляемым услугам, а также противодействие несанкционированной активности в части физического, сетевого доступа, доступа к системам, приложениям, функциям и данным);

- приобретение, развитие и сопровождение ИС (обеспечение выполнения функций защиты информации в операционных системах (ОС) и приложениях на всех стадиях их жизненного цикла, начиная с требований, проектирования, развития, приобретения, тестирования, внедрения и заканчивая сопровождением и поддержкой);

- управление инцидентами ИБ (включая планирование, идентификацию, собственно реагирование, управление и сохранение собранной информации, устранение последствий и извлечение уроков на будущее);

- управление непрерывностью бизнеса организации (обеспечение защиты критически важных бизнес-процессов от сбоев и нарушений на основе повышения их устойчивости и восстановления после сбоев и аварий);

- соответствие систем ИБ требованиям нормативных и руководящих документов (обеспечение соблюдения общепринятых и внутренних правил, норм, национальных и международных стандартов, законов, требований третьих лиц, аудиторов и т. д.).

ГОСТ Р ИСО/МЭК 17799-2005 не является техническим стандартом и не зависит от конкретных средств защиты или технологий. Он описывает концептуальные основы управления ИБ и является признанным набором лучших практик по ОИБ.

ISO/IEC 27003:2010. Руководство по внедрению СУИБ. Стандарт ISO/IEC 27003:2010 «Информационная технология. Методы и средства обеспечения безопасности. Руководство по внедрению систем менеджмента ИБ» [23] является общим руководством по практическому применению стандартов серии 27000 и базируется на ISO/IEC 27000 и 27001, которые полезны для всех организаций, независимо от их размера, типа, сферы деятельности, сложности и имеющих рисков ИБ.

Основная цель стандарта – обеспечение руководства по проектированию такой СУИБ, на основе которой риски ИБ для информационных активов поддерживаются в пределах приемлемых границ, с учетом реализации требований, предъявляемых к СУИБ в ISO/IEC 27001.

В России Ассоциацией ЕВРААС и ООО «НИИ СОКБ» осенью 2011 г. подготовлена первая редакция проекта национального стандарта ГОСТ Р ИСО/МЭК 27003 201х.

ISO/IEC 27003:2010 не рассматривает функционирование СУИБ, а описывает только стадии проектирования деятельности, которая начнет осуществляться после создания СУИБ. Основным результатом применения стандарта является разработанный окончательный план внедрения проекта СУИБ в организации.

Данный стандарт описывает процесс разработки спецификации и проектирования СУИБ с самого начала, включая:

- поддержку со стороны руководства организации;
- установление целей и приоритетов внедрения СУИБ, границ ее действия и политики использования;
- анализ требований по ОИБ и требований к процессам, поддерживаемым СУИБ, с идентификацией защищаемых активов и критериев оценки ИБ;
- оценку рисков ИБ и их снижение с определением требований к средствам управления и до момента внедрения плана проектирования СУИБ с учетом подготовки и планирования деятельности по ее фактической реализации и внедрению, в том числе:
 - стадии проектирования СУИБ;
 - проектирование организации ОИБ;
 - проектирование обеспечения защиты ИТ и физической безопасности;
 - учет некоторых других аспектов использования СУИБ;
 - разработку окончательного плана проектирования СУИБ.

В приложениях к стандарту представлены роли и обязанности сотрудников организации по ОИБ, информация по внутреннему аудиту ИБ, структура ПолИБ и процессы мониторинга и измерения успешности функционирования СУИБ.

ISO/IEC 27004:2009 и ГОСТ Р ИСО/МЭК 27004-2011. Оценка функционирования СУИБ. Стандарт ISO/IEC 27004:2009 «Информационная технология. Методы и средства обеспечения безопасности. Менеджмент ИБ. Измерение» [24] предназначен для помощи организациям в оценке результативности деятельности по управлению ИБ в рамках имеющихся у них СУИБ за счет представления единого руководства по применению механизмов получения оценки в результате измерений и введения показателей. На основе полученных показателей, их анализа и принятия соответствующих решений по устранению выявленных проблем организациям удастся повысить результативность функционирования их СУИБ. Эта информация крайне важна для обоснования всех решений, связанных с СУИБ, при внедрении СУИБ и необходимости внесения изменений в существующую СУИБ для ее дальнейшего совершенствования (улучшения).

С января 2012 г. в России введен в действие ГОСТ Р ИСО/МЭК 27004-2011 «Информационная технология. Методы и средства обес-

печения безопасности. Менеджмент информационной безопасности. Измерения» [25], идентичный ISO/IEC 27004:2009. В стандарте содержатся общее руководство и рекомендации по разработке и использованию измерений и мер измерений и их сбору для оценки эффективности и результативности внедренной в организации СУИБ, а также по мерам и средствам управления ИБ (и их группам), определенным в ISO/IEC 27001, включая политику, управление рисками ИБ, задачи средств управления, сами средства управления, процессы и процедуры, поддержку процесса их пересмотра, помощи в определении необходимости изменения или усовершенствования процессов или средств управления СУИБ.

ГОСТ Р ИСО/МЭК 27004-2011 содержит следующие разделы:

- обзор измерений, связанных с ИБ (цели, программа, факторы успеха, модель измерений);
- обязанности руководства;
- разработка измерений и мер измерений (процессов их сбора и показателей);
- процесс измерений;
- анализ данных и отчетность по результатам измерений;
- оценивание и совершенствование программы измерений в организации.

В приложениях к стандарту предложен шаблон (типовая форма) описания измерений и приведены некоторые рабочие примеры.

ГОСТ Р ИСО/МЭК 27004-2011 подразумевает, что начальной точкой для разработки измерений и мер измерений является правильное понимание организацией рисков ИБ, с которыми она сталкивается, и того, что деятельность в данном направлении осуществляется корректно (например, на основе ISO/IEC 27005), как того требует ISO/IEC 27001. Для проведения данных мероприятий необходима разработка программы измерений, связанных с ИБ. Полученные результаты позволят выявить прогресс (или отсутствие такового) в достижении целей ОИБ за некоторый период времени как одного из элементов процесса непрерывного совершенствования СУИБ организации.

Стандарт содержит достаточно детальное описание процессов измерения, использования операции агрегирования полученных мер измерений, математического вычисления производных (от двух и более основных) мер и последующего применения аналитических методов и методов принятия решений для выявления «индикаторов» со-

вершенствования СУИБ. Но, к сожалению, не указывается, какие именно основные и производные меры измерений и индикаторы могут на практике наилучшим образом повлиять на это совершенствование.

Само измерение определяется как процесс получения информации об эффективности СУИБ и элементах управления ИБ с использованием метода и функций измерения, аналитической модели и критериев принятия решений.

Механизмы, описанные в стандарте, применимы к различным организациям с разными СУИБ. Подход организации для выполнения требований к измерениям, определенных в ISO/IEC 27001, зависит от ряда существенных факторов, включая риски ИБ, величину организации, имеющиеся ресурсы и применимые правовые, нормативные и договорные требования, и важен для обеспечения того, чтобы для этой деятельности СУИБ не выделялись чрезмерные ресурсы в ущерб другой необходимой деятельности. В идеальном случае текущая деятельность, связанная с постоянными измерениями, должна быть интегрирована в обычную деятельность организации с привлечением минимальных дополнительных ресурсов.

Для организаций небольшого размера число мер измерений может быть невелико, и для них необходимо разработать одну программу измерений, в то время как для крупных организаций таких программ может быть создано несколько.

На основе ГОСТ Р ИСО/МЭК 27004-2011 организация сможет разработать для себя документацию, которая будет свидетельствовать, что в ней ведется контроль за ОИБ и производится его всесторонняя оценка.

ISO/IEC 27005:2011 и ГОСТ Р ИСО/МЭК 27005-2010. Управление рисками ИБ. Стандарт ISO/IEC 27005:2011 «Информационная технология. Методы и средства обеспечения безопасности. Управление рисками ИБ» [26] содержит общее руководство по управлению рисками ИБ, которое может быть использовано в различных типах организаций: коммерческих, некоммерческих, государственных. ISO/IEC 27005:2011 предназначен для организации адекватного бизнес-потребностям ОИБ на основе риск-ориентированного подхода. Для правильного применения этого стандарта необходимо знание концепций, моделей, процессов и терминологии, введенных в ISO/IEC 27001 и 27002.

В ISO/IEC 27005:2011 развиты основные идеи, ранее представленные в теперь уже недействующих стандартах ISO/IEC 133353:1998 [27] и 133351:2000 [28], посвященных управлению безопасностью информационных и телекоммуникационных технологий (ИТТ). Вторая редакция стандарта ISO/IEC 27005 гармонизирована с ISO/IEC 27000:2009 [20]. Также он опирается на следующие стандарты управления рисками, перечисленные в его библиографическом списке: ISO Guide 73:2009 (словарь из более чем 50 терминов в области управления рисками; на основе его более ранней редакции был создан ГОСТ Р 51897-2002 «Менеджмент риска. Термины и определения» [29]), ISO 16085, AS/NZS 4360 и NIST SP 80030. Кроме этого были предприняты определенные усилия по его адаптации в соответствии с принятыми в 2009 г. стандартами ISO 31000:2009 «Управление рисками. Принципы и руководящие указания» и ISO 31010:2009 «Управление рисками. Методики оценки рисков».

Считается, что ISO/IEC 27005:2011 был разработан на основе британского стандарта BS 77993:2006 «Системы менеджмента ИБ. Руководство по управлению рисками ИБ» [30], определяющего процессы оценки и управления рисками как составные элементы системы управления организации, при этом используя процессную модель PDCA. BS 77993:2006 носит концептуальный характер, что позволяет экспертам по ИБ реализовать любые методы, средства и технологии оценки, обработки и управления рисками ИБ. С другой стороны, стандарт не содержит рекомендаций по выбору какого-либо аппарата оценки риска ИБ, а также по разработке мер, средств и сервисов защиты, используемых для минимизации рисков ИБ. BS 77993:2006 допускает использование как количественных, так и качественных методов оценки рисков ИБ, но, к сожалению, в документе нет обоснования и рекомендаций по выбору математического и методического аппарата оценки рисков ИБ.

Стандарт BS 77993:2006 придерживается самого общего понятия риска ИБ, под которым понимают комбинацию вероятности события и его последствий (стоимости компрометируемого ресурса). Управление риском ИБ сформулировано как скоординированные непрерывные действия по управлению и контролю рисков в организации. Непрерывный процесс управления делится на четыре фазы: оценку рисков ИБ, включающую анализ и вычисление рисков; обработку риска ИБ (выбор и реализация мер и средств защиты); контроль рис-

ков ИБ путем мониторинга, тестирования, анализа механизмов безопасности и аудита ИБ системы; оптимизацию рисков ИБ путем модификации и обновления правил, мер и средств защиты.

Помимо определения основных факторов риска и подходов к его оценке и обработке, стандарт также описывает взаимосвязи между рисками ИБ и другими рисками организации, содержит требования и рекомендации по выбору методологии и инструментов для оценки рисков, определяет требования, предъявляемые к экспертам по оценке рисков, менеджерам, отвечающим за процессы управления рисками, владельцам активов и руководству организации, содержит соображения по выбору законодательных и нормативных требований безопасности, отмечает необходимость использования принципа осведомленности о процессах оценки, отработки, контроля и оптимизации рисков ИБ в организации и многое другое. На каждом этапе управления рисками ИБ предусмотрено информирование всех участников процесса управления ИБ, а также фиксирование событий СУИБ. В приложениях приведены примеры активов, угроз ИБ, уязвимостей, методов оценки рисков ИБ.

К основным документам по управлению рисками ИБ в BS 77993:2006 отнесены описание методологии оценки рисков ИБ, отчет об оценке рисков ИБ, план обработки рисков ИБ. Кроме того, в непрерывном цикле управления рисками ИБ задействовано множество рабочей документации: реестры активов и рисков, декларации применимости, списки проверок, протоколы процедур и тестов, журналы безопасности, аудиторские отчеты, планы коммуникаций, инструкции, регламенты и т. п.

С декабря 2011 г. в России введен в действие ГОСТ Р ИСО/МЭК 27005-2010 «Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности» [31], идентичный ISO/IEC 27005:2008 и заменяющий ГОСТ Р ИСО/МЭК ТО 133353-2007 «Методы менеджмента безопасности информационных технологий» и ГОСТ Р ИСО/МЭК ТО 133354-2007 «Выбор защитных мер».

В целом ГОСТ Р ИСО/МЭК 27005-2010 носит описательный характер и не содержит какой-либо конкретной методологии и даже не называет конкретные методы управления рисками ИБ, хотя и устанавливает структурированный, систематический и строгий метод анализа рисков ИБ посредством создания плана их обработки. Стандарт позволяет применяющей его организации самостоятельно учесть

различные аспекты СУИБ, идентифицировать уровни своих рисков, определить критерии для принятия риска, идентифицировать приемлемые риски и т. д. Организация сама должна выбрать из имеющихся свой подход к управлению рисками ИБ, зависящий, например, от целей использования СУИБ, области ее действия, содержания процесса управления рисками ИБ и сферы своей деятельности.

ГОСТ Р ИСО/МЭК 27005-2010 состоит из таких разделов, как:

- обзор процесса управления рисками ИБ как непрерывного процесса;
- установление контекста управления рисками ИБ;
- оценка рисков ИБ (общее описание оценки рисков ИБ, анализ рисков ИБ, включая идентификацию, оценивание значительности и вычисление рисков ИБ);
- обработка рисков ИБ (общее описание обработки рисков, снижение, сохранение, избежание и передача рисков);
- принятие рисков ИБ;
- коммуникация рисков ИБ;
- мониторинг и пересмотр рисков ИБ.

В приложениях к стандарту содержится ряд сведений информативного характера: определение целей и границ процесса управления рисками ИБ, определение и оценка активов и воздействия на них, примеры типичных угроз ИБ, уязвимости и методы их оценки, подходы к оценке рисков ИБ, ограничения для снижения рисков.

В стандарте риск ИБ определяется как потенциальная возможность того, что установленная угроза воспользуется уязвимостью актива или группы активов и тем самым нанесет ущерб организации. Измеряется риск ИБ как сочетание последствий, вытекающих из возникновения нежелательного события, и вероятности возникновения этих событий. Указывается, что процесс анализа рисков ИБ требует выполнения следующих действий: определения информационных активов, которые подвержены рискам, потенциальных угроз ИБ и их источников, потенциальных уязвимостей и потенциальных последствий при реализации рисков ИБ. Упоминаются как качественные, так и количественные методы оценки рисков ИБ, но ни одному из них не отдается предпочтение. Однако отмечается, что процесс оценки рисков ИБ сильно зависит от исходных данных и поэтому может быть итеративным, если полученные результаты будут признаны неудовлетворительными. Также наглядно представлен весь процесс управления рисками ИБ и более детально рассмотрены оценка и обработка рисков ИБ, остаточные риски ИБ.

ГОСТ Р ИСО/МЭК 27005-2010 предназначен для руководителей и сотрудников организации, занимающихся управлением рисками ИБ, и для сотрудников внешних организаций, задействованных в данной деятельности.

ISO/IEC 27006:2011 и ГОСТ Р ИСО/МЭК 27006-2008. Требования к органам, осуществляющим аудит и сертификацию СУИБ. Стандарт ISO/IEC 27006:2011 «Информационная технология. Методы и средства обеспечения безопасности. Требования к органам, осуществляющим аудит и сертификацию систем менеджмента ИБ» [32] является руководством по формализованному процессу сертификации или регистрации СУИБ организаций для органов, осуществляющих такую сертификацию. Этот стандарт включает и заменяет руководство по процессам сертификации аккредитованными для этого органами и в первую очередь предназначен для поддержки аккредитации органов сертификации, осуществляющих сертификацию СУИБ. Стандарт ISO 17026, упомянутый как нормативная ссылка в ISO/IEC 27006:2011, был недавно обновлен, поэтому потребуется пересмотр некоторых положений 27006, но такая работа пока не проведена.

ГОСТ Р ИСО/МЭК 27006-2008 «Информационная технология. Методы и средства обеспечения безопасности. Требования к органам, осуществляющим аудит и сертификацию систем менеджмента ИБ», идентичный более ранней редакции международного стандарта ISO/IEC 27006:2007, введен в действие в России с ноября 2009 г. [33].

Цель ГОСТ Р ИСО/МЭК 27006-2008 – установить общие требования к сертификации или регистрации СУИБ организаций, которым должны удовлетворять их СУИБ, чтобы быть признанными достаточными и надежными для выполнения заявленных функций по управлению ИБ, а также способствовать проведению аккредитации органов сертификации. Определяются требования и дается руководство по осуществлению аудита и сертификации СУИБ, дополняющие требования ISO/IEC 27001 и стандарта 170211 «Оценка соответствия. Требования к органам, проводящим аудит и сертификацию систем управления», давшего начало стандарту 27006. Вторая редакция ISO/IEC 17021:2011 устанавливает новые требования к аудиту систем управления, направленные на повышение ценности сертификации системы управления для государственных и частных организаций по всему миру, и к квалификации аудиторов, выполняющих сертификацию, а также способов организации их работы.

ГОСТ Р ИСО/МЭК 27006-2008 содержит следующие разделы:

- принципы;
- общие требования (правовые и договорные вопросы, управление объективностью, обязательства и финансирование);
- требования к структуре (организационная структура и руководство, комитет по охране объективности);
- требования к ресурсам (компетентность руководства и персонала, привлекаемый к сертификации персонал, привлечение внешних индивидуальных аудиторов и технических экспертов, учет кадров, аутсорсинг);
- требования к информации (общедоступная информация, сертификационные документы, каталог сертифицированных клиентов, ссылка на сертификацию и использование знаков, конфиденциальность, обмен информацией между органом сертификации и его клиентами);
- требования к процессу (общие требования, первоначальный аудит и сертификация, надзорная деятельность, повторная сертификация, специальные аудиты, приостановка, отмена или уменьшение области сертификации, апелляции, совместимость, учет заявителей и клиентов);
- требования системы управления к органам сертификации.

В приложениях информативного характера приведены анализ сложности сертифицируемых организаций и их областей деятельности, примеры компетенций аудиторов, продолжительность аудитов, руководство по анализу реализованных мер управления на основе ISO/IEC 27001:2005.

ISO/IEC 27007:2011 и ISO/IEC 27008:2011. Руководства по аудиту СУИБ и средств управления ИБ, реализованных в СУИБ. Стандарт ISO/IEC 27007:2011 «Информационная технология. Методы и средства обеспечения безопасности. Руководство по аудиту систем менеджмента ИБ» [34] содержит руководство для аккредитованных органов сертификации, внутренних аудиторов, внешних аудиторов/третьих лиц и других организаций, проводящих аудит СУИБ на соответствие требованиям стандарта ISO/IEC 27001 (например, аудит на совместимость с требованиями данного стандарта) или советы по аудиту или анализу имеющейся в организации СУИБ на ее соответствие стандарту ISO/IEC 27002 (например, проводящим аудит средств управления на их применимость к управлению рисками ИБ).

ISO/IEC 27007:2011 в значительной степени основывается на пересматриваемом в настоящее время стандарте ISO 19011:2002, содержащем руководящие указания по аудиту систем менеджмента качества и систем менеджмента окружающей среды, и стандарте ISO 170212 «Оценка соответствия. Требования к сертификационному аудиту систем управления, проводимому третьей стороной». В отличие от ISO 19011 в ISO/IEC 27007:2011 сформулированы специальные рекомендации для аудиторов в таких областях, как:

- подтверждение области /действия СУИБ;
- проверка того, что был использован соответствующий подход оценки рисков ИБ;
- исследование результатов оценки рисков ИБ;
- проверка того, что был осуществлен выбор таких средств управления, которые соответствуют принятому решению в области обработки рисков ИБ;
- сбор объективных доказательств реализации контрольных мероприятий;
- разработка путей аудита СУИБ;
- сопровождение сертификационного аудита СУИБ согласно ISO/IEC 27006:2011.

В ISO/IEC 27007:2011 рассматриваются такие вопросы, как принципы аудита, управление программой аудита (включая постановку задач, определение ответственности, необходимых ресурсов и процедур, реализацию, документы, мониторинг и анализ), деятельность в рамках проводимого аудита (начиная с инициализации процесса, проведения анализа представленных документов, подготовки к аудиту на месте и заканчивая подготовкой отчета по результатам аудита, завершению аудита и последующих действий), компетентность и оценка аудиторов.

Стандарт ISO/IEC 27008:2011 «Информационная технология. Методы и средства обеспечения безопасности. Руководство для аудиторов системы менеджмента ИБ» [35] дополняет ISO/IEC 27007:2011 в части аудита средств управления ИБ, используемых в рамках СУИБ. Такой аудит выявляет, насколько хорошо СУИБ справляется с выполнением функций по ОИБ в организации любого размера и типа: общественной и частной, государственной и некоммерческой и т. п. Основой рассматриваемого в стандарте аудита выбран риск-ориентированный подход к управлению ИБ.

В то время как ISO/IEC 27007:2011 ориентирован на аудит всей СУИБ в целом, как это описано в ISO/IEC 27001, стандарт ISO/IEC 27008:2011 фокусируется на проверке средств управления ИБ, используемых в рамках СУИБ, описанных в ISO/IEC 27002 и перечисленных в прил. А ISO/IEC 27001. Стандарт ISO/IEC 27008:2011 не предназначен для аудита систем управления в целом, поскольку он ориентирован на процесс управления рисками ИБ в рамках СУИБ, определенный в ISO/IEC 27001 и 27005, и средства управления ИБ, перечисленные в ISO/IEC 27002. Он представляет собой руководящие указания по анализу реализации и функционирования средств управления ИБ, включая техническую проверку их соответствия вышеперечисленным стандартам и установленным в организации стандартам ИБ.

Проведенный в соответствии ISO/IEC 27008:2011 аудит позволит удостовериться, что СУИБ существует не только на бумаге, но и представляет реальные свидетельства своего функционирования, поддающиеся проверке. Полученные результаты аудита могут быть использованы для усовершенствования СУИБ за счет оптимизации взаимодействия между отдельными процессами в рамках функционирования СУИБ и необходимым контролем уровня ИБ, обеспечиваемого этой СУИБ. В качестве примера таких мероприятий можно привести реализацию механизмов снижения вреда, причиненного сбоями в защите информации, за счет чего возможно появление ошибочных финансовых отчетов и некорректных документов, выпущенных организацией, а также негативное воздействие на нематериальные ценности, такие как репутация и имидж организации, частная жизнь, навыки и опыт людей.

ISO/IEC 27011:2008. Руководство по управлению ИБ для телекоммуникационных компаний на основе ISO/IEC 27002. Стандарт ISO/IEC 27011:2008 «Информационная технология. Методы и средства обеспечения безопасности. Руководство по менеджменту ИБ для телекоммуникационных компаний, основанное на ISO/IEC 27002» [36] разработан совместно Международным союзом электросвязи (сектором стандартизации электросвязи) ITUT и ИСО и опубликован как ISO/IEC 27011 и Рекомендации ITUT ХЛ051 (СУИБ. Требования к телекоммуникационным компаниям) [37]. Он основан на следующих документах: ITUT Recommendation X.800 (1991 г.) (Архитектура безопасности для взаимодействия открытых систем для CC1 прило-

жений), ITUT Recommendation X.805 (2003) (Архитектура безопасности для систем, обеспечивающих сквозные коммуникации), ISO 9001:2000 (Системы менеджмента качества. Требования), ISO 14001:1996 (Системы менеджмента окружающей среды. Спецификация с руководством по использованию), ISO/IEC 27001, ISO/IEC 27002, ISO/IEC Guide 73:2002 (Управление рисками. Словарь. Руководство по использованию в стандартах).

Основное назначение стандарта ISO/IEC 27011:2008 – определить руководящие принципы, обеспечивающие реализацию управления ИБ для телекоммуникационных компаний (ТК) и соблюдение ими базовых требований конфиденциальности, целостности, доступности и любых других соответствующих свойств ИБ. Целевая аудитория стандарта не ограничивается только ТК. Он рассчитан на всех тех, кто отвечает за ОИБ продавцов (вендоров), аудиторов, поставщиков телекоммуникационных терминалов, поставщиков (провайдеров) прикладного контента.

Конфиденциальность в ISO/IEC 27011:2008 определяется как то, что информация, с которой работает ТК, должна быть защищена от несанкционированного раскрытия. Это означает неразглашение информации о коммуникациях в терминах существования, содержания, источника, места назначения, даты и времени передачи информации. Очень важно, чтобы ТК обеспечивали соблюдение неразглашения информации о коммуникациях, обрабатываемой ими. Лица, привлеченные ТК, должны сохранять конфиденциальность любой информации обо всем, что, возможно, стало им известно во время выполнения ими своих трудовых обязанностей.

Целостность понимается как то, что инсталляция и использование телекоммуникационных средств должны контролироваться, обеспечивать подлинность, точность и полноту информации, переданной или полученной по проводам, радиоканалам или любыми другими методами.

Доступность означает, что при необходимости должен быть обеспечен только авторизированный доступ к информации, передаваемой с помощью телекоммуникаций, самим телекоммуникационным средствам и среде, используемой для функционирования средств связи, независимо от того, какими методами она передается или получается (по проводам, радиоканалам и т. п.). Расширяя доступность, в случае чрезвычайных ситуаций ТК должны предоставлять приоритет наиболее важным средствам связи и соблюдать требования соответствующих нормативных документов.

Для ТК сети, линии связи, хранимая, обрабатываемая и передаваемая информация являются важными активами. Для эффективного управления этими активами и успешного ведения бизнеса ТК необходимо управление ИБ независимо от способа связи (проводной, беспроводной или широковещательный). Архитектура и реализация СУИБ продиктованы потребностями бизнеса, требованиями по ОИБ, используемыми процедурами, а также размером и структурой ТК. Предполагается, что со временем эти характеристики и поддерживающие их системы изменяются. Поэтому реализация СУИБ будет масштабироваться в соответствии с изменяющимися потребностями организации.

Если управление и средства управления ИБ реализованы не должным образом, то риск нарушения конфиденциальности, целостности и доступности может возрасти.

Поскольку ТК предоставляют телекоммуникационные сервисы, используя средства связи и сервисы посредников совместно с другими организациями, то к передаваемой ими информации имеют доступ не только их сотрудники, но и другие пользователи вне этих организаций. Поэтому управление ИБ для ТК охватывает все области сетевой инфраструктуры, сервисные приложения и многое другое

Стандарт ISO/IEC 27011:2008 содержит такие основные разделы, как:

- обзор (структура рекомендаций, система управления ИБ в телекоммуникационной сфере);
- ПолИБ;
- организация ИБ (внутренняя организация, внешние стороны);
- управление активами (ответственность за активы, классификация информации);
- безопасность персонала (до приема на работу, работа, увольнение или смена работы);
- физическая и экологическая безопасность (защищаемые области, безопасность оборудования);
- управление средствами связи и их функционированием (процедуры функционирования и обязанности, управление сервисами доставки третьим лицам, планирование систем и их приемка, защита от вредоносного и мобильного кода, резервирование, управление безопасностью сетей, управление средой, обмен информацией, сервисы электронной коммерции, мониторинг);

- управление доступом (бизнес-требования к управлению доступом, управление доступом пользователей, обязанности пользователей, управление сетевым доступом, управление доступом к ОС, приложениям и информации, мобильные вычисления и дистанционная работа);

- приобретение, развитие и сопровождение ИС (требования по ОИБ для ИС, корректная обработка в приложениях, управление с использованием криптографии, защита файловых систем, безопасность процессов разработки и поддержки, устранение технических уязвимостей);

- управление инцидентами ИБ (подготовка отчетов о событиях ИБ и уязвимостях, процесс управления инцидентами ИБ и его усовершенствование);

- управление непрерывностью бизнеса (с учетом аспектов ИБ);

- соответствие стандартам ИБ.

ITUТ предложил расширить TSO/IEC 27011:2008 двумя новыми частями:

- руководящие принципы управления безопасностью для малых и средних ТК: руководство по реализации управления ИБ на основе рекомендаций X. 1051 (стандарта ISO/TEC 27011);

- руководящие принципы управления активами: руководство по хорошим практикам в области управления активами для ТК.

ISO/IEC 27013. Руководство по интегрированному внедрению стандартов ISO/IEC 20000 и 27001. Проект стандарта ISO/IEC 27013 «Информационная технология. Методы и средства обеспечения безопасности. Руководство по интегрированному внедрению стандартов ISO/IEC 200001 и ISO/IEC 27001» [38] совпадает с пересмотром стандарта ISO/IEC 200001, представляет собой руководство по системам интегрированного управления ИБ и ИТ-сервисам, как взаимодополняющим и поддерживающим друг друга системам управления. Этот стандарт поможет организациям осуществить реализацию систем интегрированного управления ИБ и ИТ-сервисами и обеспечить необходимое документальное сопровождение этого процесса в соответствии с основными положениями стандартов ISO/IEC 27001 и ISO/IEC 20000:2005 (Система менеджмента ИТ-сервисов).

Стандарт ISO/IEC 20000 посвящен управлению и обслуживанию ИТ-сервисов, учитывающим лучшие существующие практики, и со-

стоит из двух частей. Первая часть ISO/IEC 200001:2005 «Менеджмент ИТ-сервисов. Спецификация управления сервисом» содержит подробное описание требований к системе менеджмента ИТ-сервисов (на основе документов библиотеки ITIL (Information Technology Infrastructure Library) и устанавливает ответственность за инициирование, выполнение и поддержку таких систем в организациях [39].

В стандарте рассматриваются пять основных групп процессов:

- предоставления сервисов, включая управление уровнем сервисов, управление непрерывностью и доступностью, управление мощностями, отчётность по предоставлению сервисов, управление ИБ, распределение бюджета и учёт затрат);
- взаимодействия, включая управление взаимодействием с бизнесом и управление сервис-провайдерами (поставщиками сервисов);
- разрешения, включая управление проблемами и инцидентами;
- контроля, включая управление изменениями и конфигурациями;
- управления релизами (новыми версиями и откорректированными имеющимися решениями).

Вторая часть ISO/IEC 200002:2005 «Менеджмент ИТ сервисов. Практические правила управления сервисом» дает практические рекомендации по процессам, требования к которым сформулированы в ISO/IEC 200001, и является руководством для аудиторов и компаний, намеренных пройти сертификацию [40].

Стандарт ISO/IEC 27013 создаст основу для организации и приоритезации деятельности в таких направлениях, как:

- координация задач усовершенствования и управления для ИБ и сервисов;
- координация междисциплинарной деятельности, ведущей к внедрению интегрированного подхода (например, при управлении инцидентами);
- создание общей системы процессов и их документирования (включая политики, процедуры и многое другое);
- выработка единой терминологии и единых точек зрения;
- объединение преимуществ для бизнеса клиентов и сервис-провайдеров и извлечение дополнительной выгоды, появляющейся при интеграции двух систем управления ИБ и ИТ-сервисами;
- совместный аудит этих систем управления в одно время и сокращение затрат на его проведение.

ISO/IEC 27014. Инфраструктура руководства ИБ. Разрабатываемый в настоящее время проект стандарта ISO/IEC 27014 «Информационная технология. Методы и средства обеспечения безопасности. Инфраструктура руководства ИБ» станет руководством, помогающим организациям руководить их ИБ, определяющим для них базовую инфраструктуру эффективного управления ИБ и показывающим, как ее использовать для оценки, задания основных направлений деятельности и мониторинга функционирования СУИБ [41].

Такое руководство должно установить задачи, принципы и процессы в рамках инфраструктуры руководства ИБ и учесть следующие важные факторы:

- бизнес-стратегии, политики и задачи организации в отношении ИБ, рисков и средств управления ИБ;
- соответствие надлежащим государственным нормативным документам и законам в отношении обязательств в области ИБ;
- соблюдение соответствия контрактным и другим правовым обязательствам в отношении третьих лиц и самими третьими лицами в области ИБ;
- требования к аудиту и, возможно, сертификации с целью обеспечения гарантий (в смысле уверенности относительно владения ситуацией в области ИБ) для третьих лиц.

Ожидается, что стандарт рассмотрит следующие аспекты руководства:

- управление рисками, особенно управление рисками ИБ;
- средства управления применительно к СУИБ, являющейся основой для всех средств управления ИБ в организации;
- деятельность в области соблюдения соответствий и предоставления гарантий особенно для сертифицирующих, внутренних аудитов, составления отчетов по СУИБ для руководства организации и т. п.;
- взаимосвязь руководств ИБ, ИТ и всеми информационными активами организации;
- различия между «руководством» и «менеджментом»;
- подотчетность и ответственность за ОИБ, владение информационными активами внутри организации.

Данный стандарт будет учитывать потребности всех заинтересованных сторон: акционеров, регуляторов, аудиторов и руководства организаций, а также основные принципы, изложенные в стандарте ISO/IEC 38500:2008, посвященном руководству ИТ.

ISO/IEC 27015. Руководство по управлению ИБ для финансовых сервисов. Обсуждаемый в настоящее время проект стандарта ISO/IEC 27015 «Информационная технология. Методы и средства обеспечения безопасности. Руководство по управлению ИБ для финансовых сервисов» посвящен вопросам управления ИБ в сфере предоставления финансовых услуг и призван помочь внедрять СУИБ в этой сфере с учетом требования стандартов серии 27000. Хотя уже существуют стандарты по ИБ и обработке рисков, такие как ISO TR 13569:2005 (Финансовые сервисы. Руководство по ИБ), SOX, Basel II (теперь и III) и т. п., стандарт ISO/IEC 27015 будет точно соответствовать всем требованиям к СУИБ, изложенным в ISO/IEC 27001 и ISO/IEC 27002.

ISO/IEC 27015 направлен на поддержку специфической деятельности финансовых организаций, особенно заинтересованных в ОИБ, для которых таким образом будет создана международно признанная и одобренная основа для ведения бизнеса, отвечающая всем правовым требованиям и требованиям регуляторов. В стандарте будет представлено руководство, позволяющее выполнять как основные требования по управлению ИБ и реализации средств управления ИБ по поддержке конфиденциальности, целостности и доступности, так и другие значимые требования по ОИБ.

Стандарт ISO/IEC 27015 рассчитан на организации финансового и страхового сектора, их бизнес-партнеров и клиентов. Он использует риск-ориентированный подход к СУИБ и, следовательно, позволяет достичь определенной гибкости при разработке защиты информационных активов конкретной организации. При этом учитываются следующие факторы: бизнес-стратегия организации и текущие возможности данного сегмента рынка, характеристики различных географических регионов, специфические сервисы и производимая продукция организации, применимые правовые ограничения и ограничения регуляторов.

ISO/IEC 27015 не претендует на определение обязательных требований. Скорее, он будет служить руководством по обеспечению видимой наглядности деятельности по управлению ИБ в организации и доказательством бизнес-партнерам, клиентам и соответствующим регулирующим органам следования ею лучшим практикам в области управления и обеспечения ИБ.

ISO/IEC 27031:2011. Руководство по готовности информационных и телекоммуникационных технологий для обеспечения непрерывности бизнеса. Стандарт ISO/IEC 27031:2011 «Информационная технология. Методы и средства обеспечения безопасности. Руководство по готовности ИТТ к непрерывности бизнеса» содержит концепции и принципы, возлагаемые на ИТТ как на неотъемлемую часть критической инфраструктуры любой организации по обеспечению непрерывности ее бизнеса [42]. Этот стандарт официально заменяет британский стандарт BS 25777:2008 [43], который в свою очередь был разработан на базе существующих стандартов обеспечения непрерывности бизнеса (ОНБ) BS 25999 и дополняющей их открытой спецификации PAS 77:2006 «IT Service Continuity Management. Code of practice» (Управление непрерывностью ИТ-сервисов. Практические правила) [44], обобщающей лучшую мировую практику в области обеспечения непрерывности ИТ-сервисов, а именно принципов и методов управления последнему, но не представляющей собой пошаговую инструкцию по внедрению процессов управления непрерывностью ИТ-сервисов. Управление непрерывностью ИТТ обеспечивает необходимую жизнеспособность ИТТ и сервисов и возможность их восстановления до заранее определенного уровня в необходимые сроки, согласованные с руководством организации. Эффективное УНБ зависит от управления непрерывностью ИТТ, чтобы гарантировать, что организация всегда способна достичь своих целей, особенно в моменты аварий и бедствий.

Предшественник ISO/IEC 27031:2011 британский стандарт BS 25777:2008 раскрывает такие вопросы, как:

- управление программой управления непрерывности ИТТ;
- внедрение принципов управления непрерывностью ИТТ в культуру организации;
- документирование системы управления непрерывностью ИТТ;
- определение требований к непрерывности ИТТ;
- разработка и реализация стратегии обеспечения непрерывности ИТТ;
- разработка и тестирование планов обеспечения непрерывности ИТТ;
- проведение обучения и повышения осведомленности в области восстановления сервисов ИТТ (под ними понимается совокупность функциональных возможностей ИТТ, предоставляемая конечным

пользователям в качестве услуги; примеры сервисов ИТТ, передача сообщений, бизнес-приложения, сервисы файлов и печати, сетевые сервисы и т. п.);

- сопровождение, анализ и совершенствование системы управления непрерывностью ИТТ.

В ISO/IEC 27031:2011 предложена базовая основа (методы и процессы) для любого типа организаций, определены и описаны все аспекты (включая критерии, проектирование и реализацию), позволяющие улучшить готовность ИТТ (ГИТТ) в рамках СУИБ организации для обеспечения непрерывности ее бизнеса, а также последовательно и общепринятым способом измерить непрерывность, безопасность и готовность к преодолению аварий и бедствий.

Область действия настоящего стандарта – все события и инциденты (в том числе связанные с ИБ), которые могут воздействовать на инфраструктуру и системы ИТТ. Системы ИТТ включают аппаратные, программные и программно-аппаратные средства компьютеров, телекоммуникационное и сетевое оборудование и другие электронные системы обработки информации и взаимосвязанное оборудование. Стандарт расширяет практику обработки и управления инцидентами ИБ на область планирования готовности и соответствующих сервисов ИТТ.

Во многих современных организациях ИТТ превалируют над другими технологиями и являются основными компонентами поддержания критически важных бизнес-процессов и процессов управления. Планирование непрерывности бизнеса без надлежащей защиты, доступности и непрерывности функционирования ИТТ невозможно.

Готовность ИТТ должна снижать для организации негативное воздействие (масштаб, продолжительность и/или последствия) инцидентов ИБ и включает в себя:

- подготовку в организации ИТТ (инфраструктура, функционирование и приложения для ИТТ) и взаимосвязанных процессов и персонала к противодействию непредвиденным обстоятельствам, которые могут изменить риски и повлиять на непрерывность функционирования самих ИТТ и всего бизнеса организации;

- перераспределение и оптимизацию использования ресурсов между ОНБ, восстановлением после аварий/бедствий, реакцией на нештатные ситуации и инциденты, нарушающие безопасность ИТТ, и управленческой деятельностью.

Стандарт ISO/IEC 27031:2011 базируется на цикле PDCA, расширяя обычный процесс планирования непрерывности бизнеса за счет большего учета влияния на него ИТТ. Также используются такие методы оценки сценариев сбоев, как анализ отказов и их последствий FMEA (Failure Modes and Effects Analysis), при котором определяются запускающие события или события-триггеры, влекущие за собой серьезные инциденты.

Основная содержательная часть ISO/IEC 27031:2011 представлена такими разделами, как:

- роль готовности ИТТ для ОНБ при УНБ;
- планирование готовности ИТТ;
- внедрение и использование, мониторинг и анализ, улучшение.

Если организация при создании СУИБ ориентируется на ISO/IEC 27001 и/или использует открытую спецификацию ISO 22399:2007 для разработки системы УНБ (СУНБ), планирование готовности ИТТ также должно основываться на данных стандартах и проводиться в рамках создания СУИБ и СУНБ, что позволит избежать дублирования одинаковых процессов в одной организации.

Есть отдельный стандарт ISO/IEC 24762:2008 по восстановлению ИТТ после аварий, который вышел вне рамок серии стандартов 27000. Также ведется работа по другим стандартам, касающимся непрерывности бизнеса, включая стандарт ISO 22301 «Общественная безопасность. Системы управления обеспечением готовности и непрерывности. Требования».

ISO/IEC 27033. Управление безопасностью сетей. Необходимость в обеспечении безопасности сетей особенно важна в современном информационном пространстве, так как многие организации объединяют свои сети. Сетевые соединения могут находиться в границах самой организации, между разными организациями и иногда между организацией и сетями общего пользования. Поэтому бизнес организаций сильно зависит от всех видов связи: от классических автоматизированных систем информационного обслуживания до беспроводного и радиодоступа. Их потребности в сетях должны быть удовлетворены, при этом обеспечению безопасности сетей придается все большее значение. Стандарт ISO/IEC 27033 «Информационная технология. Методы и средства обеспечения безопасности. Безопасность в сетях» как раз и освещает вопросы обеспечения безопасности в сетях.

В настоящее время планируется в составе ISO/IEC 27033 объединить семь частей, первая и третья из которых уже опубликованы: ISO/IEC 270331:2009 «Общие положения и концепции» [45] и идентичный ему введенный в действие в России с 2012 г. ГОСТ Р ИСО/МЭК 270331-2011 «Информационная технология. Методы и средства обеспечения безопасности. Безопасность сетей. Часть 1. Обзор и концепции» [46]. В стандарте определяются и описываются концепции, связанные с управлением безопасностью сетей и обеспечивающие такое управление. Приводится обзор вопросов, относящихся к безопасности сетей, вводятся основные определения, дается руководство по идентификации и анализу рисков ИБ в сетях, определяются основные требования по безопасности сетей и средствам управления ИБ в сетях. Также описывается, как достичь хорошего качества архитектуры ОИБ с технической точки зрения.

Стандарт содержит большой список определений и сокращений в области безопасности сетей. Кратко описан процесс планирования и управления безопасностью сетей, и рассмотрены основы сетевого взаимодействия, после чего даны рекомендации по идентификации рисков ИБ для сетей, и выделены возможные области управления безопасностью сетей. В качестве необходимых защитных мер определены следующие: утверждение и следование ПолИБ для сетей, процедуры ОИБ и проверки ИБ, технические аспекты устранения уязвимостей, идентификация, аутентификация и авторизация, мониторинг и аудит безопасности, обнаружение и предотвращение вторжений, защита от вредоносного ПО, сервисы на основе криптографии, УНБ.

Перечислены основные виды сетевых архитектур, для которых необходимы руководящие указания по проектированию и реализации защиты в сетях (более подробно угрозы для этих архитектур рассмотрены в третьей части стандарта). Связанные с этими вопросами технологические аспекты таковы: локальные, глобальные, беспроводные, радио, широковещательные, виртуальные, голосовые сети, шлюзы безопасности, конвергенция IP, веб-хостинг, электронная почта Интернета, маршрутизируемый доступ к третьим организациям, центры обработки данных. Отдельное внимание уделено разработке и тестированию решений по ОИБ в сетях, их функционированию, мониторингу и анализу.

ISO/IEC 270332 «Руководство по проектированию и внедрению системы обеспечения безопасности сетей» определяет, как организация должна создавать архитектуру, проект и реализацию технической безопасности для сетей, которые будут обеспечивать эффективную, соответствующую бизнес-требованиям защиту, опирающуюся на базовые модели и понятную для всех сотрудников организации, вовлеченных в планирование, проектирование и внедрение архитектурных аспектов безопасности сетей.

ISO/IEC 270333:2010 «Базовые сетевые сценарии – угрозы, методы проектирования и средства управления» [47] устанавливает специфические риски, методики проектирования и вопросы управления, связанные с типичными сценариями использования сетей и понятные для всех сотрудников организации, вовлеченных в планирование, проектирование и внедрение архитектурных аспектов безопасности сетей. Риски рассматриваются в таких областях предоставления сервисов, как: доступ в Интернет, взаимодействие различных организаций между собой и с клиентами, коллективная работа, сегментация сетей, сетевое взаимодействие для работы из дома и небольшого офиса, мобильная связь, удаленные пользователи, аутсорсинг. В приложениях приводятся политика использования Интернета и каталог угроз ИБ.

ISO/IEC 270334 «Обеспечение безопасности межсетевых взаимодействий при помощи шлюзов безопасности, угрозы, методы проектирования и средства управления» определяет специфические риски, методики проектирования и средства управления для защиты информации, циркулирующей между сетями, соединенными шлюзами безопасности. Предназначен для всех сотрудников организации, вовлеченных в планирование, проектирование и внедрение шлюзов безопасности.

ISO/IEC 270335 «Обеспечение безопасности виртуальных частных сетей, угрозы, методы проектирования и средства управления» приводит специфические риски, методики проектирования и средства управления для защиты соединений, устанавливаемых посредством использования виртуальных частных сетей (ВЧС) (англ. Virtual Private Network, VPN). Предназначен для всех сотрудников организации, вовлеченных в планирование, проектирование и внедрение ВЧС.

ISO/IEC 270336 «Конвергенция в IP-сетях (Определение угроз, методов проектирования и средств управления в IP-сетях с конвергенцией данных, голоса и видео)» определяет специфические риски,

методики проектирования и средства управления для защиты конвергентных IP-сетей, например IP-сетей с конвергенцией данных, голоса и видео. Предназначен для всех сотрудников организации, вовлеченных в планирование, проектирование и внедрение таких сетей.

ISO/IEC 270337 «Руководство по обеспечению безопасности беспроводных сетей, риски, методы проектирования и средства управления» устанавливает специфические риски, методики проектирования и средства управления для защиты беспроводных и радиосетей. Предназначен для всех сотрудников организации, вовлеченных в планирование, проектирование и внедрение таких сетей.

Со временем, возможно, будут разработаны и другие дополнительные части стандарта.

Стандарт ISO/IEC 27033 и соответствующий ГОСТ Р ИСО/МЭК 27033 постепенно (по мере принятия новых частей) заменяют международный стандарт сетевой безопасности ISO/IEC 18028, расширяющий разделы 10.6 и 11.4 стандарта ISO/IEC 27002 и руководство по управлению безопасностью ИТ стандарта ISO/IEC 13335 за счет более детальной спецификации основных операций и механизмов реализации мер защиты сетей и средств управления ИБ в различных сетевых средах, а также установления тесной взаимосвязи между внедрением управления безопасностью ИТ и техническими аспектами безопасности сетей.

ISO/IEC 18028 состоит из пяти частей, опубликованных в 2005 – 2006 гг. и рассматривающих следующие вопросы: управление безопасностью сетей, архитектуру безопасности сетей, защиту сетевых взаимодействий при помощи шлюзов безопасности, защиту удаленного доступа, защиту сетевых взаимодействий при помощи ВЧС. Первая часть стандарта ISO/IEC 180281:2006 содержит руководство по созданию сетей и организации их взаимодействия с учетом аспектов безопасности и при удаленном доступе к сети. Руководство включает идентификацию и анализ факторов, связанных с сетевыми взаимодействиями, которые следует учитывать при определении требований к безопасности сетей, выделяет необходимые средства управления при подключении к сетям, включая проектирование и внедрение, которые подробно рассматриваются в остальных четырех частях стандарта.

ISO/IEC 27035:2011. Управление инцидентами ИБ. Никакие типовые ПолИБ или методы и средства ОИБ не могут гарантировать

полную защиту информации, информационных систем, сервисов или сетей. Средства управления ИБ еще несовершенны и независимо от их форм могут быть на практике невыполнимы вообще, недостаточны или полностью отсутствовать. Даже превентивные защитные меры не могут предусмотреть заранее все и поэтому не вполне надежны. После внедрения защитных мер с большой долей вероятности останутся уязвимости, которые могут сделать ОИБ неэффективным и, следовательно, способствовать реализации инцидентов ИБ, оказывающих прямое или косвенное негативное воздействие на бизнес организации. Кроме этого в динамически изменяющемся современном мире будут неизбежно выявляться новые, ранее неизвестные угрозы ИБ. Поэтому недостаточная подготовка организации к обработке таких инцидентов делает практическую реакцию на инциденты ИБ малоэффективной, и это увеличивает ущерб для ее бизнеса. Управление инцидентами ИБ успешно сочетает детективные и корректирующие защитные меры, минимизируя негативные последствия инцидентов, по возможности позволяет собрать доказательства для дальнейшего расследования и извлечь уроки, улучшив СУИБ, особенно за счет внедрения превентивных мер. Инциденты ИБ обычно основаны на использовании ранее невыявленных и/или неконтролируемых уязвимостей, поэтому установка обновлений к ИС, устранение слабых мест в различных процедурах и пр. – это действия и превентивные и корректирующие одновременно.

Стандарт ISO/IEC 27035:2011 «Информационная технология. Методы и средства обеспечения безопасности. Управление инцидентами ИБ» [48] содержит структурированный и планомерный подход:

- к обнаружению, составлению отчетов и оценке инцидентов ИБ;
- осуществлению ответной реакции и управлению инцидентами ИБ;
- обнаружению, оценке и устранению уязвимостей;
- постоянному улучшению управления ИБ и инцидентами ИБ.

После принятия в конце 2011 г. этот стандарт заменяет ISO/IEC TR 18044:2004 «Информационная технология. Методы и средства обеспечения безопасности. Менеджмент инцидентов ИБ» [49]. В России был принят идентичный ISO/IEC TR 18044:2004 ГОСТ Р ИСО/МЭК ТО 18044-2007 «Информационная технология. Методы и средства обеспечения безопасности. Менеджмент инцидентов информационной безопасности» [50], который определяет формальную модель процессов управления инцидентами ИБ и уста-

навливают рекомендации по менеджменту инцидентов ИБ для руководителей подразделения по ИБ, информационных систем, сервисов и сетей.

ISO/IEC 27035:2011 является достаточно емким и всесторонне рассматривает управление как уязвимостями, так и инцидентами ИБ. Приводятся шаблоны для подготовки отчетов по событиям, инцидентам ИБ и уязвимостям.

В стандарте после освещения основ управления инцидентами ИБ, его преимуществ и ключевых вопросов, некоторых примеров инцидентов ИБ и причин их возникновения процесс управления инцидентами ИБ рассматривается как включающий несколько подпроцессов:

- планирование и подготовку к обработке инцидентов ИБ, в том числе составление документов, поддерживающих управление инцидентами;
- обнаружение/идентификацию и подготовку отчета по инциденту ИБ;
- оценку инцидента и принятие решений по инциденту ИБ;
- ответную реакцию на инцидент ИБ;
- извлечение уроков из инцидента ИБ.

Даются рекомендации по необходимым ресурсам и процедурам.

В приложениях содержатся примерные формы отчетов о событиях и инцидентах ИБ и общие рекомендации для оценки негативных последствий инцидентов ИБ, включаемых в формы отчетов.

В ISO/IEC 27035:2011 и ГОСТ Р ИСО/МЭК ТО 18044-2007 описание процессов управления инцидентами ИБ, как и в стандарте ISO/IEC 27001, основано на использовании циклической модели PDCA. Поэтому в ходе разработки процесса управления инцидентами ИБ возможно связать требования ISO/IEC 27001 и представленную модель управления инцидентами ИБ, создать процесс, полностью удовлетворяющий требованиям ISO/IEC 27001. Целями следования этой модели является уверенность в том:

- что события и инциденты ИБ выявляются и обрабатываются эффективным образом, в особенности в части классификации событий ИБ;
- выявленные в организации инциденты ИБ учитываются и обрабатываются наиболее подходящим и эффективным для них образом;
- последствия инцидентов ИБ могут быть минимизированы в процессе реагирования на инциденты, возможно с привлечением процессов ОИБ;

- за счет анализа событий и инцидентов ИБ повышается вероятность предотвращения инцидентов в будущем, улучшаются механизмы и процессы ОИБ.

ISO/IEC 27037. Руководство по идентификации, сбору и/или получению и обеспечению сохранности свидетельств, представленных в электронной форме. Область знаний, посвященная сбору доказательств для последующего расследования компьютерного преступления, в англоязычной литературе называется компьютерной форензикой. В российских публикациях по данной теме используется термин «технико-криминалистическая экспертиза» (ТКЭ).

Наиболее критическими аспектами проведения ТКЭ являются сбор и сохранение доказательств, которые должны проводиться таким образом, чтобы обеспечить их целостность. Как и при сборе обычных физических доказательств, для определения первых и всех промежуточных звеньев совершения преступления решающее значение имеет забота о последовательном сохранении всех доказательств, представленных в электронной форме. Это гарантирует, что они собирались и защищались с помощью строго структурированных процессов, признаваемых судами. Не просто обеспечивая целостность, такие процессы должны еще гарантировать, что с доказательствами ничего плохого не может произойти и в будущем. Для этого требуется соблюдение или даже превышение базового уровня защиты доказательств.

Доказательства в электронной форме как информация, которая может быть представлена в суде, порождаются любым электронным хранилищем (базой) или средствами связи (мобильные телефоны, компьютеры, iPod'ы, консоли видеоигр и т. д.). По своей природе такая информация очень непрочна, поскольку может быть легко уничтожена или изменена в случае недолжного обращения по неосторожности или со злым умыслом.

Недавние международные инициативы, такие как «Конвенция о киберпреступности», продемонстрировали, что международное сообщество признает важность совершенствования и совместного использования лучших практик в области доказательств, представленных в электронной форме.

Проект стандарта ISO/IEC 27037 «Информационная технология. Методы и средства обеспечения безопасности. Руководство по идентификации, сбору и/или получению и обеспечению сохранности сви-

детельств, представленных в электронной форме» как раз представляет руководство по сбору и сохранению доказательств компьютерных преступлений, представленных в электронной форме. Ожидается, что его можно будет использовать при трансграничных преступлениях (когда жертва и атакующий находятся в различных государствах), когда собранные в одной стране доказательства должны быть признаны и приняты к рассмотрению в суде другой страны. В настоящее время юридические тонкости законов не позволяют добиться этого, поскольку в разных странах разработаны собственные руководства и процедуры сбора и сохранения доказательств в электронной форме. Кроме этого события, классифицируемые как преступление в одной стране, в другой таковыми не считаются.

Проект ISO/IEC 27037 разработан на основе британского стандарта BS 10008:2008 «Evidential weight and legal admissibility of electronic information. Specification» (Допустимость электронной информации в качестве доказательств и её доказательная сила. Спецификации) [51], соблюдение требований которого обеспечивает максимальную доказательную силу электронной информации, используемой в качестве свидетельства деловых транзакций. В стандарте сформулированы требования к планированию, внедрению, оперативному использованию, мониторингу и совершенствованию систем управления электронной информацией, применяемых организацией, и к процессам электронной передачи информации из одной компьютерной системы в другую в связи с задачей обеспечения целостности и аутентичности электронной информации.

Стандарт ISO/IEC 27037 будет содержать детальное руководство по идентификации, сбору и/или получению, пометке, хранению, транспортировке и сохранению доказательств в электронной форме, в частности с точки зрения обеспечения их целостности. Будет определен и описан гармонизированный для разных стран процесс распознавания и идентификации, документирования «места преступления», сбора и сохранения, упаковки и транспортировки доказательств. Будут рассмотрены доказательства, порождаемые различными источниками: источниками статических данных, транзитными данными (например, перемещающимися по сетям), источниками данных, передаваемых беспроводным образом (например, мобильными телефонами) и т. д.

Для более широкого применения стандарт не будет использовать специальную юридическую терминологию, а также анализировать доказательства в электронной форме, их конкретное наполнение, вес, релевантность и т. д.

2.2. Стандарты на отдельные процессы управления информационной безопасностью и оценка безопасности информационных технологий

ISO/IEC 13335. Методы и средства обеспечения безопасности информационных технологий. Стандарт ISO/IEC 13335 «Информационная технология. Методы и средства обеспечения безопасности. Менеджмент безопасности ИТТ», первоначально появившийся в статусе технического отчета, прежде чем стать полноценным стандартом ISO/IEC, объединил несколько руководящих документов по управлению безопасностью ИТ. Он состоит из четырех частей:

1. ISO/IEC 13335-1:2004 «Концепции и модели менеджмента безопасности информационных и телекоммуникационных технологий», объясняющий концепции и модели управления безопасностью ИТТ. Последняя переработанная версия ISO/IEC 13335-1:2004 содержит и вторую часть стандарта ISO/IEC 13335-2, которая после этого была отменена как самостоятельная часть стандарта 13335 [52].

2. ISO/IEC TR 13335-3:1998 «Методы менеджмента безопасности информационных технологий», устанавливающий методы управления ИБ ИТ, но в настоящее время эта часть стандарта отменена и заменена стандартом ISO/IEC 27005.

3. ISO/IEC TR 13335-4:2000 «Методы и средства менеджмента безопасности информационных технологий», который охватывал выбор защитных мер (в смысле технических средств управления ИБ. В настоящее время данная часть стандарта также отменена и заменена стандартом ISO/IEC 27005.

4. ISO/IEC TR 13335-5:2001 «Руководство по менеджменту безопасности ИТ-сети», который представляет собой руководство по управлению безопасностью сетей. В настоящее время и эта часть стандарта отменена и заменена стандартом ISO/IEC 180281, который, в свою очередь, стал частью стандарта ISO/IEC 27033 [53].

В России были приняты четыре следующих стандарта, идентичных соответствующим частям ISO/IEC 13335.

ГОСТ Р ИСО/МЭК 13335-1-2006 «Информационная технология. Методы и средства обеспечения безопасности. Концепция и модели менеджмента безопасности информационных и телекоммуникационных технологий» (идентичный ISO/IEC 13335-1:2004) [54] представляет собой руководство по управлению безопасностью ИТТ, устанавливает концепцию и модели, лежащие в основе базового понимания безопасности ИТТ, и раскрывает общие вопросы управления, которые важны для успешного планирования, реализации и поддержки безопасности ИТТ. Отмечается, что для создания эффективной программы безопасности ИТТ фундаментальными являются следующие высокоуровневые принципы безопасности:

- менеджмент риска: активы должны быть защищены путем принятия соответствующих мер, которые должны выбираться и применяться на основании соответствующей методологии управления рисками, устанавливающей допустимые риски и учитывающей существующие ограничения, исходя из активов организации, угроз, уязвимостей и различных воздействий угроз;
- обязательства организации в области ОИБ ИТТ и в управлении рисками ИБ, для формирования которых следует разъяснить преимущества от реализации защиты ИТТ;
- служебные обязанности и ответственность за ОИБ активов, которые должны быть определены и доведены до сведения персонала;
- цели, стратегии и политика, которые должны учитываться при управлении рисками, связанными с защитой ИТТ организации;
- управление жизненным циклом: управление ИБ ИТТ должно быть непрерывным в течение всего их жизненного цикла.

ГОСТ Р ИСО/МЭК ТО 13335-3-2007 «Информационная технология. Методы и средства обеспечения безопасности. Методы менеджмента безопасности информационных технологий» [55] (идентичный ISO/IEC TR 13335-3:1998) устанавливает методы управления ИБ ИТ, в основе которых лежат общие принципы, установленные ISO/IEC 13335-1. В стандарте приведены общий обзор способов управления, цели, стратегия и политика обеспечения безопасности ИТТ, описание вариантов стратегии анализа рисков и детальное описание комбинированного подхода анализа рисков, вопросы применения защитных мер и ознакомления с ними персонала и процесса их одобрения, описание работ по последующему наблюдению за системой, необходимых для обеспечения эффективного действия средств защиты. В настоящее

время заменен действующим ГОСТ Р ИСО/МЭК 27005-2010 «Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности» [31].

ГОСТ Р ИСО/МЭК ТО 13335-4-2007 «Информационная технология. Методы и средства обеспечения безопасности. Выбор защитных мер» [56] (идентичный TSO/IEC TR 133354:2000) является руководством по выбору защитных мер с учетом потребностей и проблем безопасности организации. В стандарте описан процесс выбора защитных мер в соответствии с риском системы безопасности и с учетом особенностей окружающей среды, а также устанавливаются способы достижения соответствующей защиты на основе базового уровня безопасности. Приведенный в стандарте подход к выбору защитных мер согласован с методами управления ИБ ИТ, приведенными в ISO/IEC TR 13335-3. В настоящее время заменен действующим ГОСТ Р ИСО/МЭК 27005-2010 «Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности» [31].

ГОСТ Р ИСО/МЭК ТО 13335-5-2006 «Информационная технология. Методы и средства обеспечения безопасности. Руководство по менеджменту безопасности сети» [57] (идентичный ISO/IEC TR 13335-5:2001) представляет собой руководство по управлению безопасностью сетей для персонала, ответственного за эту деятельность, и содержит основные положения по выявлению и анализу факторов, имеющих отношение к компонентам безопасности связи и учитываемых при установлении требований по безопасности сети и указании потенциальных средств управления. Отмечается, что для идентификации требований по ОИБ для сетей и соответствующих средств управления (их детальное проектирование и техническая реализация не рассматриваются) необходимо решить следующие задачи, каждой из которых посвящен отдельный раздел стандарта:

- анализ общих требований по ОИБ сетевых соединений, изложенных в ПолИБ организации;
- анализ сетевой структуры с сетевыми соединениями и ее применения как необходимой основы для выполнения последующих задач;
- идентификация типа (ов) рассматриваемых сетевых соединений;
- анализ характеристик предложенного объединения в сеть (используя при необходимости имеющуюся информацию о применении структуры сети) и связанные с этим доверительные отношения;

- определение видов рисков ИБ, если это возможно, с помощью анализа рисков и управления результатами проведенного анализа, включая оценки бизнес-операций и информацию, которую предполагается передавать через соединения, и любую другую информацию, потенциально доступную для несанкционированного получения через эти соединения;

- идентификация возможных средств управления, которые могут быть использованы, на основе анализа типа (ов) соединения и характеристик организации сети и связанных с этим доверительных отношений, а также видов установленных рисков ИБ;

- разработка документации и анализ вариантов структуры ОИБ;

- распределение задач по детальному выбору защитных мер, проектированию, реализации и их обслуживанию, используя идентифицированные возможные средства управления и согласованную структуру ОИБ.

ISO/IEC 15408 и ISO/IEC 18045:2008. Общие критерии и методология оценки безопасности информационных технологий. Состоящий из трех частей стандарт ISO/IEC 15408 «Общие критерии оценки безопасности ИТ» [58, 60], в создании которого участвовали США, Канада, Великобритания, Франция, Германия, Нидерланды, – один из наиболее распространенных международных стандартов в области ИБ, в котором подробно рассмотрены общие подходы, методы и функции обеспечения защиты информации программно-технического уровня в организациях. Его первая версия вышла в 1999 г., действующая в настоящее время – в 2008 – 2009 гг. (в зависимости от части).

Стандарт был создан для взаимного признания результатов оценки безопасности ИТ в мировом масштабе. Он позволяет сравнить результаты независимых оценок ИБ и допустимых рисков на основе множества общих требований к функциям безопасности средств и систем ИТ, а также гарантий, применяемых к ним в процессе тестирования.

Функции обеспечения безопасности ИТ (в стандарте выделено 11 классов: аудит, идентификация и аутентификация, криптографическая защита, конфиденциальность, передача данных, защита пользовательских данных, управление безопасностью, защита функций безопасности системы, использование ресурсов, доступ к системе, надежность средств) представлены в виде четырехуровневой иерар-

хической структуры: класс – семейство – компонент – элемент. Оценка безопасности ИТ базируется на моделях системы безопасности, состоящих из перечисленных функций.

В стандарте содержится ряд predetermined моделей (профилей защиты), описывающих стандартные модули системы безопасности, например системы управления базами данных (СУБД) или межсетевого экрана (МЭ). Для профиля защиты определяются следующие характеристики: область применения; уровень надежности; статус сертификации. Сертифицированный профиль представляет собой полное описание определенной части (или функции) системы безопасности. В нем содержится анализ внутренней и внешней среды объекта, требования к его функциональности и надежности, логическое обоснование его использования, возможности и ограничения развития объекта.

Также вводятся два основных вида требований безопасности: функциональные, предъявляемые к функциям безопасности и реализующим их механизмам, и требования доверия, предъявляемые к технологии и процессу разработки и эксплуатации. Требования безопасности объекта оценки определяются исходя из целей безопасности, которые, в свою очередь, основываются на анализе назначения объекта оценки и условий среды его использования (угрозы, предположения, политика безопасности).

Отличаясь значительной полнотой, универсализмом и большим потенциалом развития, стандарт ISO/IEC 15408 получил признание во многих странах мира, в том числе и в России. Стандарт ГОСТ Р ИСО/МЭК 15408 «Информационная технология. Методы и средства обеспечения безопасности. Критерии оценки безопасности информационных технологий» также состоит из трех частей:

- ГОСТ Р ИСО/МЭК 154081-2008 «Информационная технология. Методы и средства обеспечения безопасности. Введение и общая модель» (идентичный ISO/IEC 154081:2005) устанавливает общий подход к формированию требований к оценке безопасности, основные конструкции (профиль защиты, задание по безопасности) представления требований безопасности в интересах потребителей, разработчиков и оценщиков продуктов и систем ИТ [61].

- ГОСТ Р ИСО/МЭК 154082-2008 «Информационная технология. Методы и средства обеспечения безопасности. Функциональные требования безопасности» (идентичный ISO/IEC 154082:2005) содержит универсальный систематизированный каталог функциональных тре-

бований безопасности и предусматривает возможность их детализации и расширения по определенным правилам [62].

- ГОСТ Р ИСО/МЭК 154083-2008 «Информационная технология. Методы и средства обеспечения безопасности. Требования доверия к безопасности» (идентичный ISO/IEC 154083:2005) включает в себя систематизированный каталог требований доверия, определяющих меры, которые должны быть приняты на всех этапах жизненного цикла продукта или системы ИТ для обеспечения уверенности в том, что они удовлетворяют предъявленным к ним функциональным требованиям.

Здесь же содержатся оценочные уровни доверия, устанавливающие шкалу требований, которые позволяют с возрастающей степенью полноты и строгости оценить проектную, тестовую и эксплуатационную документацию, правильность реализации функций безопасности объекта оценки, уязвимости продукта или системы ИТ, стойкость механизмов защиты и сделать заключение об уровне доверия к безопасности объекта оценки [63].

Второй стандарт по данной тематике – это международный стандарт ISO/IEC 18045:2008 [64] и идентичный ему ГОСТ Р ИСО/МЭК 18045-2008 «Информационная технология. Методы и средства обеспечения безопасности. Методология оценки безопасности информационных технологий» [65]. Он представляет собой нормативный документ, применяемый совместно с ГОСТ Р ИСО/МЭК 15408. Последний описывает минимум действий, выполняемых оценщиком и органом сертификации, подтверждающим действия оценщика, при проведении оценки безопасности ИТ по ИСО/МЭК 15408 с использованием определенных в последнем критериев и свидетельств оценки. Стандарт также предназначен для заявителей оценки, разработчиков, авторов профилей защиты и заданий по безопасности и других сторон, заинтересованных в безопасности ИТ.

ISO 19011:2011 и ГОСТ Р ИСО 19011:2003. Рекомендации по аудиту систем менеджмента. Международные стандарты ISO серий 9000 (качество) и 14000 (экология, окружающая среда) придают особое значение аудитам в составе деятельности, относящейся к менеджменту, обеспечивающим проверку результативности внедрения политики организации в области менеджмента качества и/или окружающей среды (последние системы иногда называются система-

ми экологического менеджмента). Аудиты являются важной составляющей деятельности по оценке соответствия при сертификации/регистрации, оценке провайдеров, инспекционном контроле.

В конце 2011 г. вышла вторая редакция стандарта ISO 19011:2011 «Руководство по аудиту систем менеджмента» [66]. По сравнению с первой редакцией, опубликованной в 2002 г. и применявшейся только к стандартам ISO 9001 и ISO 14001, область применения ISO 19011:2011 расширилась и отразила современные точки зрения на проведение внешних и внутренних аудитов в соответствии с существующими многочисленными стандартами на системы менеджмента. Особое внимание уделено разработке, реализации и управлению программой аудита. При строгом соблюдении рекомендаций будут обеспечены все необходимые предпосылки для того, чтобы сделать аудит важнейшим инструментом достижения бизнес-целей организации.

В ISO 19011:2011 было добавлено понятие риска и в явной форме установлены требования к компетентности команды аудиторов и отдельных аудиторов. Также признана важность применения технологий при удаленном аудите, например, проведении удаленных интервью и просмотре документации. Другое важное улучшение – более четкое описание разницы между стандартами ISO 19011:2011 и ISO/IEC 17021:2011.

Идентичный первой редакции ISO 19011:2002 российский стандарт ГОСТ Р ИСО 19011-2003 «Руководящие указания по аудиту систем менеджмента качества и/или систем экологического менеджмента» [67] содержит указания по принципам аудита, управлению программами аудита, проведению аудита названных систем менеджмента, по управлению программами аудита, проведению внутреннего или внешнего аудита таких систем менеджмента, а также по компетентности и оценке аудиторов (экспертов). Он предназначен для потенциальных пользователей, включая аудиторов (экспертов); организаций, внедряющих системы менеджмента качества и/или окружающей среды; организаций, в которых необходимо провести аудит таких систем менеджмента согласно договорам организаций, участвующих в сертификации или в обучении аудиторов (экспертов), а также для использования при сертификации/регистрации систем менеджмента; аккредитации или стандартизации в области оценки соответствия.

В разделе стандарта по управлению программой аудитов рассматриваются следующие вопросы: определение цели и объема програм-

мы аудитов; ответственность, ресурсы и процедуры программы аудитов; внедрение программы аудитов (информирование заинтересованных сторон, координация и подготовка графика аудитов, квалификация аудиторов и выбор аудиторских групп, предоставление необходимых ресурсов, поддержание протоколов (регистрационных записей); мониторинг и анализ программы аудитов.

Для процесса проведения аудита в стандарте отдельно описываются следующие подпроцессы:

- инициализация аудита (назначение ведущего аудитора группы, определение целей, критериев и объема аудита, оценка осуществимости аудита, выбор аудиторской группы и установление начальных контактов);
- подготовка к аудиту (предварительный анализ документации, подготовка плана аудита и распределение обязанностей в группе, подготовка рабочих документов);
- проведение аудита на месте (вступительное совещание, общение в ходе аудита, сопровождающие и наблюдатели, сбор и проверка информации, выработка наблюдений аудита, подготовка заключений по результатам аудита, заключительное совещание);
- подготовка, утверждение и распространение отчета по аудиту;
- завершение аудита;
- проведение последующих действий.

При рассмотрении квалификации и оценки аудиторов выделяются следующие важные моменты: личные качества; знания и умения, включая способность применять их на практике; поддержание и повышение квалификации; оценка аудиторов.

В многочисленных приложениях к стандарту приведены формы и указания по их заполнению: график проведения аудитов, отчет об анализе программы аудита, опросный лист, отчет о несоответствии, паспорт аудитора, план аудита, отчет по аудиту, журнал регистрации отчетов о несоответствии, журнал регистрации планов аудита, журнал регистрации графиков аудитов.

При совместном внедрении систем менеджмента (качества и окружающей среды) пользователь стандарта сам решает вопрос о проведении отдельных аудитов или комплексного аудита.

Указания стандарта являются гибкими. Их использование может быть различным в зависимости от размера, вида деятельности, сложности проверяемых организаций, а также целей и области аудита.

В выделенных рамках представлены дополнительные указания или примеры по конкретным вопросам в виде практических рекомендаций.

Основное достоинство ГОСТ Р ИСО 19011-2003 – это возможность применения или распространения данных руководящих указаний на другие виды аудита, включая аудиты других систем менеджмента (например, как внутренний, так и внешний аудит СУИБ). Стандарт содержит общие указания, которые могут быть использованы для разработки собственных для какой-либо организации требований, связанных с аудитом.

BS 25999 и ГОСТ Р 53647. Управление непрерывностью бизнеса. ОНБ в случае глобального инцидента или локального сбоя является одним из основных требований к организации в рамках эксплуатации СУИБ.

Британские стандарты серии BS 25999 – первые, посвященные УНБ. Они были разработаны на основе передового опыта в данной области большой группой специалистов-практиков мирового класса, в которую вошли представители разных отраслей и государств.

В серию BS 25999 входят два стандарта:

- BS 259991:2006 «УНБ. Практические правила» [68], который определяет процесс, принципы и терминологию в области УНБ, закладывая основы для понимания, разработки и внедрения системы УНБ в организации и поддержания уверенности в ее надежности со стороны клиентов и партнеров. Этот стандарт в десяти разделах описывает всеобъемлющий набор средств управления и охватывает весь жизненный цикл процесса УНБ, начиная со стратегии ОНБ и заканчивая учетом данных вопросов в культуре организации.

- BS 259992:2007 «УНБ. Спецификация» [69].

В то время как BS 259991:2006 содержит общие рекомендации по УНБ, вторая часть устанавливает и детализирует конкретные требования к СУНБ, причем только те, соблюдение которых может быть объективно проверено. Используя эти требования, организации могут проводить оценку существующей СУНБ как самостоятельно, так и привлекая внешних консультантов. На основании именно второй части стандарта сертификационные органы выдают заключение о соответствии СУНБ требованиям стандарта BS 25999.

Среди национальных стандартов Великобритании также есть еще два, посвященных вопросам ОНБ:

- BIP 2142:2007 «Маршрутная карта менеджмента непрерывности бизнеса. Внедрение требований BS 25999».

- BIP 2151:2008 «Аудит планов в области непрерывности бизнеса».

В 2009 г. в России на основе британских стандартов вышли три документа:

- ГОСТ Р 53647.12009 «Менеджмент непрерывности бизнеса. Часть 1. Практическое руководство» [70] (идентичный BS 259991:2006).

- ГОСТ Р 53647.22009 «Менеджмент непрерывности бизнеса. Часть 2. Требования» [71] (идентичный BS 259992:2007).

- ГОСТ Р 53647.32010 «Менеджмент непрерывности бизнеса. Часть 3. Руководство по внедрению» [72] (разработан с учетом основных требований BIP 2142:2007).

В перечисленных стандартах под УНБ принято понимать целостный процесс управления, в ходе которого выявляются потенциальные угрозы и определяются возможные последствия в случае их осуществления для организации, а также создается основа обеспечения способности организации восстанавливаться и эффективно реагировать на инциденты.

Такой подход гарантирует соблюдение интересов основных частных сторон, сохранение репутации и дальнейшего функционирования организации в целом. УНБ включает управление восстановлением и продолжением деятельности в случае нарушения нормального хода бизнеса, а также управление общей программой УНБ посредством проведения обучения и повышения осведомленности персонала, а также анализа с целью поддержания плана (ов) ОНБ в актуальном состоянии.

Стандарты ГОСТ Р 53647, направленные на минимизацию рисков возникновения инцидентов и снижение потерь от сбоев в работе, дают четкие критерии и рекомендации по построению СУНБ и направлены на поддержание бесперебойной деятельности организации в самых сложных и неожиданных обстоятельствах. На базе изложенных требований можно построить процесс УНБ для целей обеспечения непрерывности ключевых бизнес-процессов в рамках области действия СУНБ.

Стандарты ГОСТ Р 53647 подходят для любой организации, независимо от размера и области деятельности. Они имеют особое значение для организаций, работающих в среде с высокой степенью риска,

например в области финансов, телекоммуникаций, транспорта и в государственном секторе. Здесь возможность обеспечения непрерывной деятельности имеет первостепенное значение, как для самой организации, так и для ее клиентов и заинтересованных сторон.

2.3. Отраслевые стандарты в области управления информационной безопасностью, стандарты банковской системы Российской Федерации

Для организаций банковской сферы задача ОИБ выступает одним из важных требований бизнеса, поскольку, являясь объектом пристального внимания злоумышленников, банки ежедневно сталкиваются с инцидентами ИБ. Развитие и укрепление банковской системы (БС) Российской Федерации, включающей в себя Банк России, кредитные организации, филиалы и представительства иностранных банков, а также обеспечение эффективного и бесперебойного функционирования платежной системы РФ являются целями деятельности Банка России. Важнейшее условие их реализации – обеспечение необходимого и достаточного уровня ИБ организаций БС РФ, включая их активы (в том числе информационные), который во многом определяется уровнем ИБ банковских технологических процессов: платежных, информационных и прочих, автоматизированных банковских систем (АБС), эксплуатирующихся организациями БС РФ, и т. д.

Негативные последствия сбоев в работе отдельных организаций могут привести к быстрому развитию системного кризиса всей платежной системы РФ, нанести ущерб интересам ее собственников и клиентов. Поэтому для организаций БС РФ угрозы ИБ информационных активов и их реализация в виде инцидентов ИБ представляют реальную опасность. Для противостояния таким угрозам и обеспечения эффективности мероприятий по ликвидации неблагоприятных последствий инцидентов ИБ (их влияния на операционные, кредитные и иные риски) в организациях БС РФ следует обеспечить достаточный уровень ИБ, который необходимо сохранить в течение длительного времени. По этим причинам ОИБ является для организаций БС РФ одним из основополагающих аспектов их деятельности [11].

Деятельность, относящаяся к ОИБ в организациях БС РФ, должна контролироваться за счет регулярного проведения оценки уровня и рисков ИБ, принятия мер, необходимых для управления этими рис-

ками. Для подобных целей был разработан комплекс документов, положенный в основу стандартизации обеспечения и управления ИБ для организаций БС РФ. Основные цели такой стандартизации [11]:

- повышение доверия к БС РФ;
- повышение стабильности функционирования организаций БС РФ и на этой основе стабильности функционирования БС РФ в целом;
- достижение адекватности мер по защите от реальных угроз ИБ,
- предотвращение и/или снижение ущерба от инцидентов ИБ.

Главные задачи стандартизации по ОИБ организаций БС РФ заключаются в следующем:

- установление для них единых требований по ОИБ;
- повышение эффективности мероприятий по обеспечению и поддержанию ИБ организаций.

Комплекс документов по обеспечению и управлению ИБ организаций БС РФ состоит из отраслевых стандартов (СТО) и рекомендаций в области стандартизации (РС) (рис. 2.3). Уже разработан ряд документов комплекса:

- Стандарт Банка России СТО БР ИББС-1.0 «Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Общие положения» [11]. Четвертая редакция введена в действие с 21 июня 2010 г.



Рис. 2.3. Комплекс документов по ОИБ для организаций БС РФ

- Стандарт Банка России СТО БР ИББС-1.1 «Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Аудит информационной безопасности» [73]. Первая редакция введена в действие с 1 мая 2007 г.

- Стандарт Банка России СТО БР ИББС-1.2 «Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Методика оценки соответствия информационной безопасности организаций БС РФ требованиям СТО БР ИББС-1.0» [74]. Третья редакция введена в действие с 21 июня 2010 г.

- Рекомендации в области стандартизации Банка России РС БР ИББС-2.0 «Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Методические рекомендации по документации в области обеспечения информационной безопасности в соответствии с требованиями СТО БР ИББС-1.0» [75]. Первая редакция введена в действие с 1 мая 2007 г.

- Рекомендации в области стандартизации Банка России РС БР ИББС-2.1 «Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Руководство по самооценке соответствия информационной безопасности организаций БС РФ требованиям СТО БР ИББС-1.0» [76]. Первая редакция введена в действие с 1 мая 2007 г.

- Рекомендации в области стандартизации Банка России РС БР ИББС-2.2 «Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Методика оценки рисков нарушения информационной безопасности» [77]. Первая редакция введена в действие с 1 января 2010 г.

- Рекомендации в области стандартизации Банка России РС БР ИББС-2.3 «Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Требования по обеспечению безопасности персональных данных в информационных системах персональных данных организаций БС РФ» [78]. Первая редакция введена в действие с 21 июня 2010 г.

- Рекомендации в области стандартизации Банка России РС БР ИББС-2.4 «Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Отраслевая частная модель угроз безопасности персональных данных при их обработке в информационных системах персональных данных организаций БС РФ» [79]. Первая редакция введена в действие с 21 июня 2010 г.

СТО БР ИББС-1.0. Общие положения в области обеспечения ИБ организаций банковской системы Российской Федерации. Стандарт СТО БР ИББС-1.0 «Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Общие положения» является базовым для развивающей и обеспечивающей его группы СТО и РС. С момента выхода в 2004 г. первой редакции стандарт претерпел ряд изменений и постоянно обновляется по результатам его применения. В настоящее время действует четвертая редакция стандарта.

В СТО БР ИББС-1.0-2010 СМИБ определяется как часть менеджмента организации БС РФ, предназначенная для создания, реализации, эксплуатации, мониторинга, анализа, поддержки и совершенствования системы обеспечения ИБ. СОИБ организации БС РФ – это совокупность ее СМИБ и системы ИБ (СИБ). Система информационной безопасности представляет собой совокупность защитных мер, защитных средств и процессов их эксплуатации, включая ресурсное и административное (организационное) обеспечение [11].

Процессы СМИБ сгруппированы в виде циклической модели ПРПС: «планирование – реализация – проверка – совершенствование».

В стандарте отмечается, что для успешного функционирования СМИБ в организации БС РФ следует выполнить требования по таким видам деятельности, как:

- организация и функционирование службы ИБ организации;
- определение/коррекция области действия СОИБ;
- выбор/коррекция подхода к оценке рисков нарушения ИБ и проведение оценки таких рисков;
- разработка планов обработки рисков нарушения ИБ и организация реализации этих планов;
- разработка/коррекция внутренних документов, регламентирующих деятельность в области ОИБ;
- принятие руководством организации решений о реализации и эксплуатации СОИБ;
- разработка и организация реализации программ по обучению и повышению осведомленности в области ИБ;
- организация обнаружения и реагирования на инциденты ИБ;
- организация ОИБ и его восстановления после прерываний;

- проверка и оценка ИБ организаций путем выполнения процессов, таких как: мониторинг и контроль защитных мер, проведение аудита и самооценки ИБ, анализ функционирования СОИБ (в том числе со стороны руководства организации);
- принятие решений по стратегическим и тактическим улучшениям СОИБ.

СТО БР ИББС-1.1. Аудит ИБ. СТО БР ИББС-1.1 «Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Аудит информационной безопасности» распространяется на организации БС РФ, а также на организации, проводящие аудит ИБ организации БС РФ, и устанавливает требования к проведению внешнего аудита ИБ организаций БС РФ [73].

Одним из условий реализации целей деятельности организаций БС РФ является обеспечение необходимого и достаточного уровня их ИБ. Уровень ИБ считается высоким, если процессы СОИБ проводятся осознанно на основе прогноза, мониторинга и анализа внутренней и внешней среды, развития и изменения целей бизнеса (деятельности) организации. Основным из видов проверки уровня ИБ служит аудит ИБ. Это – систематический, независимый и документированный процесс получения свидетельств аудита деятельности организации по ОИБ и определения степени выполнения в организации установленных критериев аудита ИБ, проводимый внешней по отношению к проверяемой независимой проверяющей организацией. Оценка соответствия ИБ критериям аудита ИБ проводится на основе документов по ОИБ и фактов, свидетельствующих о выполнении, частичном выполнении или невыполнении установленных требований по ОИБ.

К главным целям аудита ИБ как важнейшего процесса в непрерывном цикле процессов менеджмента ИБ организации относятся:

- повышение доверия к этим организациям;
- оценка соответствия ИБ организаций критериям аудита ИБ, установленным согласно требованиям СТО БР ИББС-1.0.

Данный стандарт провозглашает основные принципы проведения аудита ИБ организаций БС РФ, такие как независимость и полнота аудита ИБ, оценка на основе свидетельств аудита ИБ, достоверность свидетельств аудита ИБ, компетентность и этичность поведения. Однако данные принципы применимы при проведении аудита ИБ любых других организаций.

В СТО БР ИББС-1.1-2007 рассматривается целый ряд требований:

- к менеджменту программ аудита ИБ;
- взаимоотношениям представителей аудиторской организации с представителями проверяемой организации, включая их обязанности и ответственность;
- этапам проведения аудита ИБ организаций БС РФ: подготовке к проведению аудита ИБ; анализу документов; проведению аудита ИБ на месте; подготовке, утверждению и рассылке отчета по аудиту ИБ; завершению аудита ИБ.

В программу аудита ИБ входит деятельность, необходимая для планирования и организации определенного количества аудитов ИБ, их контроля, анализа и совершенствования, а также обеспечения их ресурсами, необходимыми для эффективного и результативного проведения аудитов ИБ в заданные сроки. Последовательность процессов менеджмента программы аудита ИБ (после распределения полномочий) соответствует циклической модели PDCA и включает в себя следующие процессы:

- разработку программы аудита ИБ;
- внедрение программы аудита ИБ и деятельность по проведению аудита ИБ;
- контроль и анализ программы аудита ИБ;
- совершенствование программы аудита ИБ.

Согласно стандарту, хорошей практикой проверки уровня ИБ и подготовки к аудиту ИБ организации БС РФ является самооценка ИБ, которая проводится на основе принятых в организации документов и методик.

Как было отмечено выше, СТО БР ИББС-1.1 устанавливает требования к проведению внешнего аудита ИБ организаций БС РФ. Однако почти все приведенные положения и требования стандарта могут быть применены в организациях, работающих в других отраслях, с минимальными изменениями.

СТО БР ИББС-1.2. Методика оценки соответствия ИБ организаций банковской системы Российской Федерации требованиям СТО БР ИББС-1.0. Стандартом СТО БР ИББС-1.0 с целью проверки уровня ИБ как самого Банка России, так и организаций БС РФ определено требование проведения регулярной внешней и внутренней оценки ИБ, а также самооценки ИБ. Стандарт СТО БР ИББС-1.2-2010 «Обеспечение информационной безопасности организаций банков-

ской системы Российской Федерации. Методика оценки соответствия информационной безопасности организаций БС РФ требованиям СТО БР ИББС-1.0» устанавливает способы определения степени выполнения и итогового уровня соответствия ИБ указанным требованиям при проведении внутренней и/или внешней оценки и самооценки ИБ [74].

Целью данной методики является стандартизация подходов и способов оценки, используемых для определения уровня соответствия ИБ организации БС РФ требованиям СТО БР ИББС-1.0 по трем направлениям оценки:

- текущий уровень ИБ организации;
- менеджмент ИБ организации;
- уровень осознания ИБ организации.

Для этого определяются состав показателей ИБ и способы их оценивания.

Используются групповые и частные показатели ИБ. Групповые показатели ИБ образуют структуру направлений оценки, детализируя оценки по ним. Оценки групповых показателей используются для получения оценки по направлениям. Частные показатели ИБ входят в состав групповых показателей и представлены в виде вопросов, ответы на которые дают возможность определить оценки, которые затем формируют оценки групповых показателей.

Частные показатели разделены на две категории, выполнение которых обязательно и рекомендовано в организации. Также установлены критерии выставления оценок частных показателей ИБ, в которых оценивается степень документированности и/или выполнения требований по ОИБ.

В методике представлены формы, предназначенные для заполнения при проведении оценки. Каждая из форм содержит групповой показатель ИБ, входящие в него частные показатели, обязательность их выполнения, метрику (шкалу) для оценивания и коэффициенты значимости, используемые при вычислении частного показателя ИБ.

Оценка частного показателя ИБ должна основываться на свидетельствах аудита, в качестве основных источников которых рекомендуется использовать:

- внутренние нормативные документы проверяемой организации и при необходимости документы третьих лиц, относящиеся к ОИБ организации БС РФ;
- устные высказывания сотрудников проверяемой организации в процессе проводимых опросов;

- результаты наблюдений членов аудиторской группы за деятельностью сотрудников проверяемой организации в области ИБ.

Оценка группового показателя (за исключением группового показателя М9 «Общие требования по обработке персональных данных в организации БС РФ») вычисляется из оценок входящих в него частных показателей с учетом некоторых коэффициентов значимости, определяющих важность частного показателя для оценивания группового показателя.

В СТО БР ИББС-1.2 также представлен вид наглядного отображения получившихся результатов оценивания (оценок) в виде круговой диаграммы с уровнями соответствия требованиям СТО БО ИББС-1.0 с нулевого по пятый по трем направлениям оценки.

Вопросы для самоконтроля

1. Какой стандарт (серия стандартов) стал основоположником стандартизации систем управления ИБ?

2. Для организаций какой сферы применимы стандарты серии ISO/IEC 27000?

3. Каковы отличительные черты стандартов серии ISO/IEC 27000?

4. Какой из стандартов серии ISO/IEC 27000 содержит требования к созданию, внедрению, эксплуатации, мониторингу, анализу, сопровождению и совершенствованию СУИБ?

5. В чем состоят основные различия и сходства стандартов ISO/IEC 27001 и ITUT X. 1051?

6. Какой из стандартов серии ISO/IEC 27000 признан каталогом лучших практик по ИБ?

7. В каком стандарте серии ISO/IEC 27000 содержится руководство по внедрению СУИБ?

8. На основании чего может проводиться оценка эффективности СУИБ?

9. Можно ли проводить аудит (или сертификацию) на соответствие стандарту ISO/IEC 27002 (бывший ISO/IEC 17799)?

10. Каковы основные идеи руководства по аудиту СУИБ и средств управления ИБ, реализованных в СУИБ?

11. Почему подход к проведению аудита систем менеджмента качества и окружающей среды, изложенный в стандарте ISO/IEC 19011, может быть применен для проведения внутренних аудитов СУИБ?

12. В каком стандарте серии ISO/IEC 27000 описана инфраструктура руководства ИБ?

13. Какой стандарт серии ISO/IEC 27000 рассматривает вопросы управления безопасностью сетей?

14. В чем состоят преимущества использования (учета) требований российских и международных стандартов по управлению ИБ при построении СУИБ или отдельных процессов управления ИБ?

15. Каковы преимущества одновременного учета требований стандартов, предъявляемых как к СУИБ в целом, так и к отдельным процессам, разрабатываемым в рамках СУИБ?

16. В чем состоят основные сходства и различия между стандартами на СУИБ и на отдельные процессы управления ИБ?

17. Какие методы и средства ОИБ для ИТ рассматриваются в стандартах ISO/IEC 13335 и ГОСТ Р ИСО/МЭК 13335?

18. Как оценивается ИБ ИТ согласно стандартам ISO/IEC 15408 и 18045 и ГОСТ Р ИСО/МЭК?

19. Какие из рассмотренных стандартов затрагивают аспекты анализа рисков ИБ?

20. Каковы основные цели построения системы УИБ, соответствующей требованиям стандартов BS 25999 и 25777?

21. В чем может заключаться различие между требованиями к системам управления непрерывностью бизнеса и к процессу управления непрерывностью бизнеса?

22. Каковы основные цели следования модели PDCA при построении процесса управления инцидентами ИБ в соответствии с требованиями ГОСТ Р ИСО/МЭК ТО 18044?

23. Какие тенденции характерны для развития стандартизации управления ИБ в Российской Федерации?

24. В чем состоят преимущества использования отраслевых стандартов на СУИБ по сравнению, например, со стандартом ISO/IEC 27001, требования которого применимы к любой организации независимо от отрасли или сферы деятельности?

25. Каково значение стандартов серии СТО БР ИББС в рамках развития стандартизации управления ИБ в России?

26. Какие аспекты регламентируют стандарты серии СТО БР ИББС, если говорить об управлении ИБ?

27. Каковы цели и задачи стандартизации по ОИБ организаций БС РФ?

28. Каковы основные цели проведения аудита ИБ организаций БС РФ?

29. На основе какой методики рекомендуется проводить оценку соответствия уровня ИБ организации БС РФ требованиям стандарта СТО БР ИББС-1.0?

3. ПОЛИТИКА ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

3.1. Понятия политики обеспечения ИБ и политики ИБ организации

Термин «политика» (от греч. *politika* – государственные или общественные дела, *polls* – государство) давно используется в человеческом обществе. Существует много трактовок этого понятия, из которых чаще всего применяются следующие:

- сфера деятельности, связанная с отношениями между социальными группами, сутью которой является определение форм, задач, содержания деятельности государства;
- направление деятельности государства или каких-либо социальных групп в той или иной области в определенный период;
- образ действий, направленных на достижение чего-либо, поведение, определяющее отношения с людьми;
- общее намерение и направление, официально выраженное руководством [22].

В англоязычной литературе при рассмотрении вопросов ОИБ, кроме политики, используются и другие термины: стандарты, базис, руководства и процедуры [80].

Политики обычно рассчитаны на долгий срок и содержат руководство по разработке более конкретных правил для ситуаций и систем. Политики могут относиться к совершенно различным вопросам, таким как управленческие решения по настройке электронной почты организации, обеспечению режима секретности или защите факсов.

Политики интерпретируются и поддерживаются стандартами, основными направлениями, процедурами и руководствами. В них должно содержаться общее руководство для организации. По своей природе политики обязательны для исполнения. Они должны быть одобрены и поддержаны их основными исполнителями. Невозможность соблюдать политику должна быть санкционирована в виде исключения. Примеры областей, для которых необходимы политики: физическая защита, ИБ, персональные данные, безопасность персонала, безопасность оборудования, защита ПО, безопасность сетей, безопасность беспроводного доступа, УНБ, управление рисками ИБ, управление инцидентами ИБ.

Стандарт представляет собой правило, указывающее конкретное направление действий или ответную реакцию на данную ситуацию. Стандарты являются обязательными директивными указаниями (директивами), которые должны выполняться в соответствии с политиками и которые используются для определения соответствия этим политикам, служат спецификациями для осуществления политик. Стандарты разработаны в целях содействия осуществлению высокоуровневой политики организации, а не для создания новых политик.

Базис (линии отсчета, базовые линии) устанавливает, как для конкретных технологий должны быть реализованы средства управления. Это – зависящее от конкретной платформы правило защиты, которое принято во всей отрасли как обеспечивающее наиболее эффективный подход к данной реализации защиты. Базис создан для обеспечения того, чтобы функции защиты наиболее часто используемых систем были настроены и управлялись единым образом, поддерживающим постоянный уровень безопасности в пределах всей организации.

Процедуры определяют конкретно, как политики, стандарты, базисы и руководства будут реализованы в данной ситуации. Это технологии или процессы, зависящие и имеющие отношение к конкретным платформам, приложениям или процессам. Они используются для выработки шагов, которые должны быть предприняты на организационном уровне для обеспечения безопасности отдельных систем и процессов. Процедуры, как правило, разработаны, реализованы и обеспечены организацией, владеющей процессом или системой. С целью обеспечения конкретных технических или процедурных требований внутри организации, где они применяются, процедуры как можно точнее должны поддерживать организационные политики, стандарты, базисы и руководства. Примеры процедур: сертификация и аккредитация, оценка рисков ИБ, обнаружение вторжений, тесты на проникновение, реагирование на чрезвычайные ситуации, восстановление после аварий, резервирование, реагирование на инциденты ИБ.

Руководства (руководящие принципы, директивы) содержат рекомендации по тому, как должны выполняться другие требования. Руководство является общим заявлением, используемым в качестве рекомендации или предлагающим подход к осуществлению политики, стандартов и базисов. По существу это рекомендации, которые необходимо учитывать при осуществлении защиты. По своей природе не являясь обязательными, они должны соблюдаться, если нет документированных и одобренных причин не делать этого.

Взаимосвязь введенных терминов проиллюстрирована на рис. 3.1.

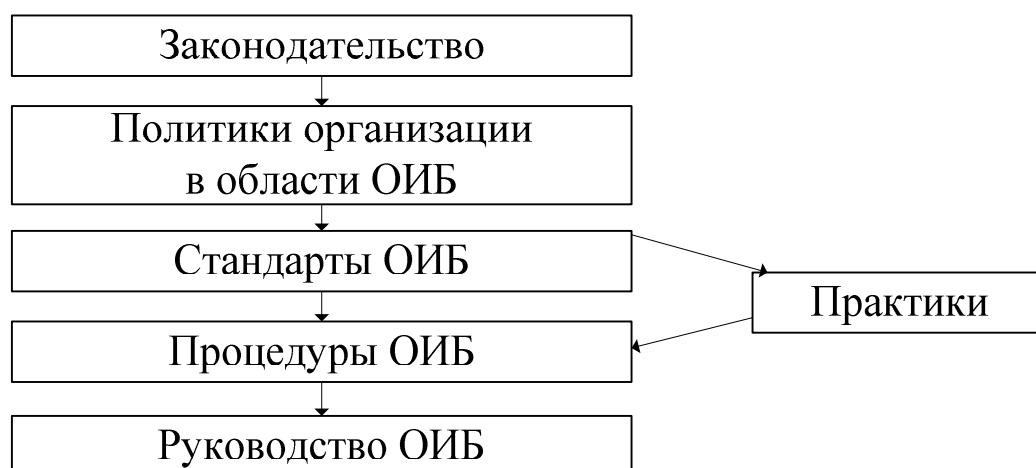


Рис. 3.1. Взаимосвязь понятий «политика», «стандарт», «процедура» и «руководство» в области ОИБ

Описательный пример – ПолИБ организации в отношении использования электронной почты. Эта неотъемлемая часть деятельности сотрудников организации подкрепляется различными стандартами, включая и требование регулярно удалять сообщения электронной почты через 90 дней после их появления. В этом примере базис связан с тем, как будут конфигурироваться средства управления для сервиса электронной почты, работающей на различных системах (например, OpenVMS, UNIX и т. п.). Процедуры – это конкретные требования применения в данной организации ПолИБ для электронной почты и обеспечивающих ее стандартов. И, наконец, руководства, разработанные в соответствии с лучшими практиками защиты информации, отправляемой или получаемой посредством электронной почты, предназначены для пользователей и администраторов.

Для организации общий подход и намерения в области ОИБ, официально выраженные руководством, отражаются в разработанном, утвержденном им и строго выполняемом на практике всеми ее сотрудниками и бизнес-партнерами документе – политике ОИБ организации, для краткости далее называемой политикой ИБ (ПолИБ).

ПолИБ содержит позицию организации по отношению к деятельности в области ОИБ, её стремление соответствовать государственным, международным требованиям и стандартам в этой области. ПолИБ определяет стратегию и тактику построения в организации системы защиты информации. (В российской терминологии документ, определяющий стратегию, часто называют концепцией, а доку-

мент, определяющий тактику, – политикой. За рубежом принято создавать единый документ, включающий в себя стратегию и тактику защиты одновременно.) ПолИБ организации является основой для разработки целого ряда документов в области ОИБ: стандартов, руководств, процедур, практик, регламентов, должностных инструкций и пр.

Согласно самому первому определению, приведенному в стандарте «Оранжевая книга» (Trusted Compute System Evaluation Criteria), ПолИБ – это набор норм, правил и практических приемов, которые регулируют управление, защиту и распределение ценной информации [81]. Гостехкомиссия России определила такую ПолИБ как совокупность правил, регламентирующих права субъектов к объектам доступа [76]. После этого данный термин определялся как в международных, так и российских стандартах и руководящих документах в основном как ПолИБ организации:

- совокупность требований и правил по ОИБ для объекта ИБ, выработанных в соответствии с требованиями руководящих и нормативных документов в целях противодействия заданному множеству угроз ИБ, с учетом ценности защищаемой информационной сферы и стоимости СОИБ [82];

- документированные решения в области ОИБ [83];

- совокупность (одно или несколько) документированных правил, процедур, практических приемов в области безопасности, которыми руководствуется организация в своей деятельности [10, 61].

СТО БР ИББС-1.0 вводит понятие ПолИБ организации БС РФ. Это документация, определяющая высокоуровневые цели, содержание и основные направления деятельности по ОИБ, предназначенная для организации БС РФ в целом [11].

Различают ПолИБ организации в целом (тогда она называется корпоративной ПолИБ) или ее подразделения. Такие политики называют также ПолИБ верхнего, или программного, уровня [83].

В ГОСТ Р ИСО/МЭК 133351-2006 была отдельно выделена ПолИБ ИТТ: правила, директивы, сложившаяся практика, которые определяют, как в пределах организации и ее ИТТ управлять, защищать и распределять активы, в том числе критичную информацию [54].

ПолИБ сети определяется как документ, в рамках единой информационной инфраструктуры и СОИБ организации формально устанавливающий правила доступа к ее компьютерной сети, на основе

которых пользователи этой сети (сотрудники и бизнес-партнеры организации) накапливают, применяют и распоряжаются ее активами.

В современной практике ОИБ термин «ПолИБ» может употребляться как в широком, так и в узком смысле [83]. В широком смысле ПолИБ определяется как система документированных управленческих решений по ОИБ организации. В узком смысле ПолИБ – отдельный нормативный документ, определяющий требования безопасности, систему мер и/или порядок действий, а также ответственность сотрудников организации и средства управления для определенной области ОИБ.

Также известно понятие «частная ПолИБ» [11], или ПолИБ по конкретным вопросам или проблемам, или ПолИБ по конкретным системам [84], ориентированная на отдельную область ОИБ или технологию, используемую в организации или ее подразделении. Например, это ОИБ в части, касающейся ИБ, ОИБ телекоммуникационных систем и сервисов, антивирусная защита, доступ в Интернет, использование средств криптографической защиты и т. д. В них формулируются требования на создание и эксплуатацию СЗИ, организацию информационных и бизнес-процессов организации по конкретному направлению ОИБ.

Таким образом, частные ПолИБ являются составляющими корпоративной ПолИБ организации, поскольку конкретизируют ее. Частная ПолИБ – это документация, детализирующая положения ПолИБ применительно к одной или нескольким областям ИБ, видам и технологиям деятельности организации [11]. Итак, частная ПолИБ – это ПолИБ в узком смысле.

Поскольку основу ПолИБ составляет, как правило, конкретный способ управления каким-либо видом доступа, определяющим порядок обращения субъектов системы к ее объектам, название этого способа и определяет название частной ПолИБ. Как показывает опыт, наиболее часто разрабатываемыми в организациях частными ПолИБ являются политики для следующих областей и технологий, имеющие аналогичные названия:

- физической защиты (включая вопросы организации пропускного режима, регистрации сотрудников и посетителей, использования средств сигнализации и видеонаблюдения и т. п.);
- организации режима секретности;

- ОИБ при процессе транспортировки носителей информации;
- обращения с информацией, составляющей государственную тайну;
- опубликования материалов в открытых источниках;
- доступа сторонних пользователей (организаций) в ПС организации;
- оценки рисков ИБ;
- управления паролями;
- контроля доступа и защиты от несанкционированного доступа;
- назначения и распределения ролей и обеспечения доверия к персоналу;
- использования Интернета;
- разработки и лицензирования ПО;
- установки и обновления версий ПО;
- приобретения ИС и их элементов (программных и аппаратных средств);
- использования отдельных универсальных ИТ в масштабе организации:
 - электронной почты;
 - сетевых сервисов;
 - программно-технических средств защиты;
 - межсетевых экранов (МЭ);
 - технологии ВЧС;
 - средств антивирусной защиты;
 - средств криптографической защиты информации;
 - электронной цифровой подписи (ЭЦП);
 - инфраструктуры открытых ключей;
 - модемов и других коммуникационных средств;
 - мобильных аппаратных средств и т. д.;
 - проведения внешних и внутренних аудитов ИБ;
 - резервирования информации и т. п.

В РС БР ИББС-2.0 по документации в области ОИБ отмечается, что деятельность организации БС РФ по ОИБ осуществляется на основе действующих законодательных актов и нормативных документов РФ по ОИБ, нормативных актов Банка России и внутренних документов самой организации по ОИБ [75]. В состав внутренних до-

кументов рекомендуется включать следующие виды документов (документированной информации), организованных в виде иерархической структуры (рис. 3.2):

- документы 1-го уровня, содержащие положения корпоративной ПолИБ организации и определяющие высокоуровневые цели, содержание и основные направления деятельности по ОИБ, предназначенные для организации в целом;



Рис. 3.2. Иерархия документов в области ОИБ для организации БС РФ

- документы 2-го уровня, содержащие положения частных ПолИБ и детализирующие положения корпоративной ПолИБ применительно к одной или нескольким областям ИБ, видам и технологиям деятельности организации;

- документы 3-го уровня, содержащие положения ИБ, применяемые к процедурам (порядку выполнения действий или операций) ОИБ, правила и параметры, устанавливающие способ осуществления и выполнения конкретных действий, связанных с ИБ в рамках технологических процессов, используемых в организации, либо ограничения по выполнению отдельных действий, связанных с реализацией защитных мер в используемых технологических процессах (технические задания, регламенты работ, порядки, инструкции по эксплуатации, руководства по администрированию и т. п.);

- документы 4-го уровня, содержащие свидетельства выполненной деятельности по ОИБ и отражающие достигнутые результаты (промежуточные и окончательные), относящиеся к ОИБ организации.

Согласно ГОСТ Р ИСО/МЭК 17799-2005, на верхнем уровне ПолИБ должны быть оформлены следующие документы: «Концепция обеспечения ИБ» (или просто «Концепция ИБ»), «Правила допустимого использования ресурсов информационной системы», «План обеспечения непрерывности бизнеса» [13]. На практике можно встретить и документы с такими названиями: «Регламент управления ИБ», «Технический стандарт ИБ» и т. п. Данные документы могут выпускаться в двух редакциях: для внешнего и внутреннего использования.

По аналогии с определением концепции ИБ РФ Межведомственной комиссии по ИБ Совета Безопасности РФ (1995 г.) концепция ИБ организации – это официально принятая руководством организации система взглядов на проблему ОИБ, методы и средства защиты жизненно важных интересов организации в информационной сфере. Эта система взглядов взаимоувязывает правовые, организационные и программно-аппаратные меры защиты и основана на анализе защищенности ИС в разрезе видов угроз и динамики их развития. Концепция ИБ отражает стратегию и тактику ОИБ организации и отвечает на три основных вопроса: что защищать, от чего защищать и как защищать. Таким образом, концепция ИБ организации во многом схожа с корпоративной ПолИБ, хотя второй документ содержит более конкретное наполнение стратегии и тактики правилами, процедурами, практическими приемами и руководящими принципами в области ОИБ, которыми руководствуется организация в своей деятельности.

Еще один подход разделяет ПолИБ на две категории: административные, выполняемые людьми, и технические, реализуемые с помощью оборудования и программ.

Организационная, или административная, ПолИБ и есть ПолИБ в определенном высшем понимании. Она обычно излагается в документах трех уровней. Документы верхнего уровня носят общий характер и определяют ПолИБ для организации в целом. Вторым уровнем выделяют в случае структурной сложности организации или при необходимости обозначить специфичные области деятельности, подразделения, технологии, подсистемы и т. п. Третий уровень относится к конкретным службам или подразделениям организации и детализирует верхние уровни ПолИБ. На данном уровне определяются конкретные цели, частные критерии и показатели ИБ, задаются права групп пользователей, формулируются условия доступа к информации, выводятся правила ОИБ и т. п.

Техническая ПолИБ – это совокупность законов, правил и практических методов, регулирующих обработку чувствительной информации и использование ресурсов ПО и аппаратное обеспечение (АО) ИС (www.finam.ru/dictionary). Техническая ПолИБ базируется на правилах двух видов. Первая группа связана с заданием правил разграничения доступа ко всем информационным ресурсам организации, вторая – основана на правилах анализа сетевого трафика как внутри интранета, так и при его выходе или входе из интранета. В основе этих правил лежит принцип доверия пользователям, приложениям, процессам, базам данных (БД), файлам и т. п. Поэтому определяя техническую ПолИБ, нужно установить, насколько можно доверять людям и информационным ресурсам, так как возможны атаки с подменой («маскарадом») ресурсов.

Кроме этого ПолИБ могут создаваться для отдельных пользователей или для группы пользователей, для отдельного департамента, роли/должности внутри организации или за ее пределами (для партнеров, клиентов, аудиторов и т. п.).

3.2. Причины выработки политики ИБ

Предположим, что администратор ИБ интранета крупной организации наблюдает за системой поздно вечером и видит, что развивается атака [85]. Что ему делать? Позволить атаке и дальше продолжаться и собирать регистрируемые соответствующими системами данные для дальнейшего расследования или отключить интранет от экстранета (от сетей бизнес-партнеров данной организации и каналов Интернета, соединяющих интранет и эти сети)? Если так, отключить ли основное средство фильтрации трафика МЭ между интранетом и экстранетом? Или отключить соединение с Интернетом, например, препятствуя доступу пользователей на веб-сервер организации? Имеет ли он полномочия это сделать? Руководству организации до наступления такого события необходимо четко расставить приоритеты и определить все необходимые действия.

Рассмотрим сценарий, когда администратор ИБ думает, что интранет действительно атакуют, поэтому и отключает соединение с экстранетом. Пользователи выражают свое недовольство из-за невозможности выполнять свои привычные операции в интранете. А потом оказывается, что администратор ИБ ошибся и, например,

принял работу только что поступившего в организацию нового сотрудника за злоумышленника. Кража данных является понятием теоретически возможным, а недовольные пользователи вполне реальны. Таким образом, необходима политика, которая определяет важность всех защитных мер и четко устанавливает процедуры, требуемые для выполнения, когда кажется, что имеет место атака. Как только точно определены приоритеты, нужно понять технологию реализации установленной политики.

Наиболее правильный и эффективный способ добиться минимизации рисков нарушения ИБ организации еще до того, как появится первая проблема с безопасностью, – разработать ПолИБ и в соответствии с ней реализовать, эксплуатировать и совершенствовать СОИБ организации [11].

Можно выделить несколько основных аргументов в пользу того, что ПолИБ обязательно должна быть выработана для организации любого масштаба и вида деятельности. Во-первых, ПолИБ составляет общую основу для защиты всех влияющих на ОИБ активов организации, в рамках которой определяются правила разграничения доступа к этим активам. Она определяет, какое поведение по отношению к активам разрешено, т. е. является санкционированным, а какое запрещено, является несанкционированным и свидетельствует о их незаконном использовании. Во-вторых, ПолИБ определяет «правила игры» для всех сотрудников организации и третьих лиц, что позволяет достичь согласия по вопросам ОИБ как внутри самой организации (включая ее руководство), так и вовне. В-третьих, ПолИБ часто помогает сделать правильный выбор самой платформы для работы с активами, учитывая, какие инструментальные средства и процедуры будут использованы.

Первостепенной целью разработки ПолИБ организации является обеспечение решения вопросов ОИБ в пределах организации и вовлечение ее высшего руководства в данный процесс. Для этого в первую очередь она определяет правильный (с точки зрения организации) способ использования ее активов, а также процедуры, предотвращающие или реагирующие на нарушения ИБ.

В основе любой политики лежат модели доверия, или трастовые модели. Для ИС наиболее точно смысл понятия «доверие» передает следующая формулировка: можно сказать, что один субъект «доверяет» другому, когда предполагает, что второй субъект будет вести себя точно так, как ожидает от него первый, на основе их взаимо-

действия [86, 87]. Таким образом, доверие имеет дело с предположениями, ожиданиями и поведением. Оно не может быть измерено количественно. Существует риск, связанный с доверием.

Следовательно, при разработке ПолИБ необходимо определить, кто, к чему и каким образом может получать доступ. Здесь можно провести следующую аналогию – при первой установке программно-аппаратных систем чаще всего производителем предусмотрена защита по принципу наименьшего доступа для всех. Далее для каждой группы пользователей и входящих в нее отдельных представителей определяются виды доверия (для файла – чтение, копирование, модификация, удаление, создание). Это дело достаточно сложное и даже деликатное. Если доверие ко всем слишком велико, то им могут злоупотреблять. Если доверия заслуживает лишь очень небольшая группа пользователей, то и в этом случае возникнут ситуации, когда выполнение обычных обязанностей сотрудниками организации будет затруднено, например, постоянными процедурами аутентификации, что вызовет с их стороны только раздражение, полное неприятие ПолИБ и нежелание ее поддерживать и осуществлять ее основные положения на практике. Компромиссное решение в данном случае и будет самым подходящим: всего должно быть в меру, в том числе доверия и недоверия.

Существуют три основные трастовые модели:

- *либеральная* – доверять всем и всегда. Модель – самая простая, но непрактичная, поскольку любые пользователь и процесс в системе имеют доступ к любым ресурсам независимо от их конфиденциальности. Один проникший в систему злоумышленник, внешний или внутренний, может получить несанкционированный доступ к информации, которая определяет успешность всего бизнеса организации;

- *запретительная* – не доверять никому и никогда. Модель также малоприменима на практике, поскольку существенно ограничивает или даже затрудняет выполнение основных функций практически всех служащих организации, и тогда просто невозможно найти тех, которые согласятся работать в таких условиях;

- *компромиссная* – доверять иногда некоторым людям и степень доверия периодически пересматривать. Модель определяет доступ ко всем ресурсам по мере необходимости, например по запросам от пользователей или руководства организации. Далее использование предоставленного доступа контролируется с помощью специальных систем, позволяющих регистрировать доступ пользователей и про-

цессов ко всем ресурсам и обнаруживать факты злоупотребления. Эти системы позволяют гарантировать, что доверие не нарушалось. Данная модель, как и все предыдущие, предполагает, что при начале работы в системе все пользователи уведомляются об их правах доступа, а примеры нарушения этих прав становятся общеизвестны всем сотрудникам организации. Из представленных это самая разумная модель.

Выбор конкретной модели доверия, с учетом которой разрабатывается ПолИБ, определяется руководством организации.

Среди других причин, побуждающих организацию разрабатывать ПолИБ, выделяют следующие [83]:

1. Требование руководства, обнаружившего недостаток внимания к проблемам ИБ, которые привели к снижению эффективности бизнеса. Несколько серьезных инцидентов, повлекших за собой остановку или замедление работы компании в результате различных локальных и удаленных атак, разглашение конфиденциальной информации или кража компьютеров существенно стимулируют появление таких требований.

2. Требования законодательства и отраслевых стандартов. ПолИБ позволяет определить правила, в соответствии с которыми часть информации организации будет отнесена к категории коммерческой или служебной тайны, что позволит защитить ее юридически (ст. 139 Гражданского кодекса РФ [88]). В зависимости от сферы деятельности организация должна выполнять требования существующего законодательства ее отрасли. Например, в соответствии со ст. 857 ГК РФ банки должны гарантировать тайну банковского счета и банковского вклада, операций по счету и сведений о клиенте. Страховщики должны защищать тайну страхования (ст. 946 ГК РФ) и т. п. Также в соответствии с Указом Президента РФ № 188 от 06.03.97 (с изменениями от 23.09.2005 г.) «Об утверждении перечня сведений конфиденциального характера» организации должны обеспечивать защиту персональных данных сотрудников.

3. Требования клиентов и партнеров о подтверждении необходимого уровня ОИБ для гарантии того, что их конфиденциальная информация защищена надлежащим образом. Они могут потребовать юридического подтверждения данного факта в контрактах. Именно в ПолИБ есть четкое доказательство намерений организации относительно ИБ.

4. Необходимость сертификации по стандартам (например, ISO/IEC 9001 [89, 90], 27002, 15408 и т. п.), подтверждающей необходимый уровень ОИБ для защиты информации и бизнес-процессов.

5. Устранение замечаний аудиторов и выполнение их рекомендаций. Любая внешняя аудиторская проверка обращает внимание на необходимость формализации всех бизнес-процессов, в том числе особое внимание уделяется наличию ПолИБ, на соответствие которой может проводиться аудит.

6. Обеспечение конкурентоспособности за счет оптимизации бизнес-процессов и увеличения результативности. Правильно разработанная и реализованная ПолИБ позволяет уменьшить время недоступности сервисов, вызванной инцидентами ИБ, таким образом увеличивая показатель живучести организации.

7. Демонстрация заинтересованности руководства в ОИБ, что значительно увеличивает приоритет безопасности в глазах сотрудников организации. Без этого они могут не воспринимать ПолИБ всерьез.

8. Создание корпоративной культуры ИБ и широкое вовлечение сотрудников в процесс ОИБ. Необходимо убедить сотрудников в том, что ОИБ – их прямая обязанность. Это достигается путем введения процедуры обязательного ознакомления с требованиями ПолИБ и подписания соответствующего документа о том, что сотрудник ознакомлен, ему понятны все требования политики и он обязуется их выполнять. ПолИБ позволяет ввести требования по поддержанию необходимого уровня ИБ в перечень обязанностей каждого сотрудника. Также важным условием успеха в области ОИБ становится создание в организации атмосферы, благоприятной для пропаганды и поддержания высокого приоритета ИБ.

9. Уменьшение стоимости страхования. Страхование – важная составляющая управления информационными рисками. Это метод защиты информации в рамках финансово-экономического обеспечения системы защиты информации, основанный на выдаче страховыми обществами гарантий субъектам информационных отношений по восполнению материального ущерба в случае реализации угроз ИБ. Наличие ПолИБ является необходимым и обязательным условием страхования. В России есть фирмы, предлагающие страховать информационные риски (например, РОСНО, Ингосстрах, РОСТРА и др.). Стоимость страхования определяется путем проведения аудита ИБ независимой организацией, специализирующейся в этой области.

10. Экономическая целесообразность. ПолИБ является самым дешевым и одновременно самым эффективным средством ОИБ за счет ее последовательного воплощения и дальнейшего соблюдения в каждодневной жизни организации.

11. Хорошая практика. Сегодня наличие ПолИБ – правило хорошего тона. Еще в 2002 г. в опросе, проведенном компанией PriceWater HouseCoopers в Великобритании, 67 % компаний выделили именно эту причину создания ПолИБ.

После принятия и утверждения ПолИБ касается каждого сотрудника организации. Большинство людей вполне оправданно могут сопротивляться любым мерам, которые, по их мнению, будут сказываться на результативности их работы. Например, многочисленные процедуры идентификации перед доступом к данным, находящимся в конфиденциальных БД, увеличат время эффективной работы за компьютером. Некоторые люди в силу своего характера могут сопротивляться любым нововведениям и переменам в работе. Часть пользователей может не признавать никаких запретов, ограничивающих свободу их действий, и рассматривать ПолИБ лишь как меру контроля за их поведением (такой контроль в зарубежных научных публикациях имеет свой термин – «синдром старшего брата»). Кроме того, люди боятся, что ПолИБ будет трудно придерживаться и осуществлять.

Каждый человек имеет свои представления относительно потребности в контроле за безопасностью. Они не всегда совпадают с теми, которые приняты в организации, куда он пришел работать. Если изначально потенциальный сотрудник не разделяет ПолИБ организации, стоит принципиально решать вопрос о его приеме на работу.

Доступ к активам организации предоставляется ее сотрудникам, а также клиентам, подрядчикам, бизнес-партнерам и другим заинтересованным посторонним лицам. Следовательно, пользователями ПолИБ являются все те, кто имеет доступ к активам организации и от чьей деятельности зависит обеспечение ее ИБ.

Так кто же должен быть заинтересован в ПолИБ? В первую очередь это сами пользователи, которых ПолИБ касается в наибольшей степени, поскольку регламентирует их каждодневную работу. Это вспомогательный персонал систем (системный администратор, администратор ИБ, технический персонал и т. д.), который должен реализовывать на практике и следить за выполнением ПолИБ. И наконец, это руководство организации. Именно оно в первую очередь ответ-

ственно перед своими сотрудниками, клиентами и заказчиками, обеспечено относительно репутации организации, заинтересовано в ее процветании в условиях рыночной конкуренции и в защите определяющих это процветание активов. Кроме этого ПолИБ устанавливает средства управления ИБ в соответствии с ее основными положениями и требованиями, что необходимо для использования в работе различных регулирующих органов, аудиторов ИБ и т. п.

3.3. Основные требования и принципы, учитываемые при разработке и внедрении политики ИБ

ПолИБ как высокоуровневый, основополагающий документ определяет систему приоритетов, принципов и методов достижения целей защищенности различных активов организации в условиях наличия для них угроз ИБ. Она содержит главные методологические подходы, позволяющие специалистам в области ИБ и информатизации, а также другим специалистам организации определить наиболее важные объекты защиты, подготовить необходимые меры защиты, принципы и направления работ. Поэтому формулировать ПолИБ путем выработки четкой позиции в решении вопросов ИБ должно высшее руководство: президент, председатель, директор, совет директоров или иной уполномоченный. Цель ОИБ не может быть достигнута, пока на самом высоком уровне не определено, чего следует добиваться, и не выделены ресурсы, позволяющие должным образом защитить информационную инфраструктуру организации и обеспечить управление ею.

ПолИБ организации разрабатывается на основе накопленного в организации опыта в области ОИБ, результатов идентификации активов, подлежащих защите, оценки рисков ИБ, с учетом особенностей бизнеса и технологий, требований законодательства Российской Федерации, отраслевых нормативных актов, а также интересов и бизнес-целей конкретной организации [11].

К ПолИБ предъявляются следующие требования [13, 14, 21, 22]:

- ПолИБ должна быть утверждена высшим руководством организации и издана.
- ПолИБ должна быть реализуема (содержать только те положения, которые могут быть выполнены на практике), а ее реализация контролируема.

- ПолИБ должна быть краткой (лучшие практики указывают на объем не более 10 с.), простой для понимания и не допускать двойного толкования ее положений.

- ПолИБ должна обеспечивать защиту и при этом не влиять на эффективность работы сотрудников организации, т. е. не снижать результативность их работы.

- ПолИБ должна устанавливать ответственность руководства и излагать подход организации к управлению ИБ.

- ПолИБ должна регулярно (через запланированные промежутки времени, по графику) анализироваться. Анализ должен включать в себя оценивание возможностей для улучшения ПолИБ и подход к управлению ИБ в ответ на изменения в организационном окружении, деловых обстоятельствах, юридических условиях или в технической среде. Анализ ПолИБ должен учитывать результаты ее анализа со стороны руководства.

- В случае возникновения значительных изменений в текущем развитии организации с целью обеспечить соответствие, адекватность и результативность ПолИБ, она должна пересматриваться и модифицироваться согласно разработанной заранее процедуре. Периодические пересмотры должны включать проверку соответствия ПолИБ актуальной законодательной базе, оценку ее эффективности, исходя из характера, числа и последствий зарегистрированных инцидентов ИБ, определение стоимости мероприятий по управлению ИБ и их влияние на бизнес, анализ влияния изменений в технологиях на деятельность организации. Такая процедура должна обеспечивать осуществление пересмотра ПолИБ в соответствии с изменениями, затрагивающими первоначальную оценку рисков ИБ, например, путем выявления существенных инцидентов ИБ, появления новых уязвимостей или изменения организационной или технологической инфраструктуры организации.

Должно быть назначено ответственное за ПолИБ должностное лицо, которое отвечает за ее реализацию и пересмотр в соответствии с установленной процедурой.

- ПолИБ должна быть надлежащим образом доведена до сведения всех сотрудников организации в доступной и понятной форме, с которой они должны ознакомиться чаще всего под расписку. Программа обучения в области ИБ и контрольные проверки действий в тех или иных ситуациях могут достаточно эффективно демонстрировать всем пользователям действенность соблюдения ПолИБ.

- Чтобы быть эффективной, ПолИБ должна быть наглядной. Это способствует реализации политики, помогая гарантировать ее знание и понимание всеми сотрудниками организации. Видеофильмы, семинары, статьи во внутренних изданиях организации или на ее внутреннем веб-узле увеличивают такую наглядность.

- ПолИБ должна быть обязательно согласована с общепризнанными основами теории ИБ, со всеми существующими нормативно-правовыми документами, соблюдение которых требуется от организации в стране ее функционирования, а также директивами, законами, приказами и общими задачами самой организации. Она должна быть интегрирована в общую политику организации и согласована с другими политиками (например, политикой приема/найма на работу).

- При распространении ПолИБ за пределы организации следует позаботиться о том, чтобы не раскрыть важную (конфиденциальную, критичную) информацию, потеря, раскрытие или уничтожение которой по тем или иным причинам нежелательны для бизнеса или её владельца.

- Пересмотренная ПолИБ также должна быть утверждена руководством.

- Выполняя перечисленные требования, можно разработать действительно эффективную ПолИБ, которая обладает конкретными свойствами:

- определяет необходимый и достаточный набор требований по ОИБ, позволяющих уменьшить риски ИБ до приемлемой величины;

- основывается на первоначально проведенном анализе рисков ИБ, оптимальном уровне риска для организации на основе заданного критерия;

- оказывает минимальное влияние на производительность труда;

- учитывает особенности бизнес-процессов организации;

- поддерживается руководством;

- позитивно воспринимается и исполняется сотрудниками.

Разрабатываемая ПолИБ обязательно отражает следующие принципы, которыми целесообразно руководствоваться при ее использовании и поддержании ИБ в организации на требуемом уровне [80, 85, 91]:

1. Законность, т. е. осуществление защитных мер в соответствии с действующим законодательством в области ИБ, другими норматив-

ными актами по ОИБ, утвержденными органами государственной власти, с применением всех дозволенных методов обнаружения и пресечения правонарушений.

2. Определенность целей, сформулированных в ПолИБ.

3. Системность, позволяющая учесть все взаимосвязанные и изменяющиеся во времени элементы, условия и факторы, значимые для поддержания ИБ в организации, включая все объекты защиты и направления нарушений ИБ, уязвимости используемых систем, высокую квалификацию злоумышленника и т. п.

4. Комплексный (мультидисциплинарный) подход к разработке ПолИБ, позволяющий учитывать правовые, технические, административные, организационные, учебные, коммерческие и функциональные вопросы.

5. Научная обоснованность и техническая реализуемость защитных мер, что позволяет реализовать их на современном уровне развития науки и техники для достижения заданного уровня ИБ, соответствующего установленным нормам и требованиям по ОИБ.

6. Эшелонированность (многоуровневость) обороны и разнообразие защитных средств (нельзя полагаться на один защитный рубеж, каким бы надежным он ни казался: в интранете за средствами физической защиты должны следовать программно-технические средства, за идентификацией и аутентификацией – управление доступом, и как последний рубеж – протоколирование и аудит); тогда злоумышленник для взлома системы должен владеть разнообразными знаниями и навыками.

7. Способность защитных мер к интеграции для наиболее эффективного выполнения требования ПолИБ и согласованность (скоординированное функционирование) применения различных защитных мер при построении целостной системы защиты организации, отсутствие слабых мест при стыковке различных защитных мер, покрытие ими всех объектов защиты в случае наступления инцидента ИБ.

8. Эффективность и непрерывность защиты, предполагающая целенаправленный непрерывный процесс принятия соответствующих мер на всех этапах жизненного цикла организации.

9. Разумная достаточность, позволяющая выбрать золотую середину между стойкостью защиты и ее стоимостью, потреблением вычислительных ресурсов, удобством работы пользователей и другими характеристиками защитных мер.

10. Своевременность, адекватность и пропорциональность защитных мер, определенных в ПолИБ, реальным угрозам и рискам ИБ.

11. Гибкость управления и применения защитных мер, позволяющая варьировать уровень защищенности в зависимости от текущей ситуации и потребности организации в ИБ в данный период времени. Гибкость также важна, когда установку средств защиты необходимо осуществлять на уже работающую систему, не нарушая процесса ее нормального функционирования.

12. Невозможность миновать защитные средства (применительно к интранету это означает, что все информационные потоки в защищаемый интранет и из него должны проходить через средство фильтрации МЭ; не должно быть «тайных» модемных входов или тестовых линий, идущих в обход него).

13. Усиление самого слабого звена, выявляемого при регулярном обследовании защищаемых активов организации (злоумышленник предпочитает легкую победу; часто самым слабым звеном оказывается не компьютер или ПО, а человек; тогда проблема ОИБ приобретает нетехнический характер).

14. Простота и управляемость защитных средств (защитные средства должны быть интуитивно понятны и просты в использовании; только для простого защитного средства можно доказать его корректность; только в простой и управляемой системе можно проверить согласованность конфигурации различных компонентов и осуществить централизованное администрирование).

15. Невозможность перехода защитных средств в небезопасное состояние, т. е. при любых обстоятельствах, в том числе нештатных, они либо полностью выполняют свои функции, либо полностью блокируют доступ к особо важным активам организации.

16. Наблюдаемость и контролируемость защитных мер (любые предлагаемые защитные меры должны быть устроены так, чтобы результат их применения был явно наблюдаем (прозрачен) и мог быть оценен подразделением организации, имеющим соответствующие полномочия).

17. Обязательность контроля (мониторинг и аудит) защитных мер и соблюдения ПолИБ, позволяющая своевременно выявлять и пресекать попытки ее нарушения на основе используемых защитных мер при совершенствовании критериев и методов оценки их эффективности с учетом влияния защитных мер на бизнес-цели организации.

18. Совершенствование защиты за счет периодической переоценки защитных мер и потребности в них.

19. Разделение полномочий (обязанностей), распределение ролей и ответственности, при котором ни один человек не имеет полномочий, позволяющих ему единолично осуществлять выполнение критичных операций, и не может нарушить критически важный для организации процесс или создать уязвимость в защите по заказу злоумышленников (важно, например, для предотвращения злонамеренных или неквалифицированных действий системного администратора, сговора между сотрудниками).

20. Минимизация полномочий и привилегий, предписывающая предоставлять пользователям и администраторам систем и ИБ только те права доступа, которые необходимы им для выполнения служебных обязанностей (цель – уменьшить ущерб от случайных или умышленных некорректных действий).

21. Рассмотрение как персональной (для каждого сотрудника в пределах его полномочий), так и групповой ответственности в случаях инцидентов ИБ, когда распределение прав и обязанностей сотрудников строится таким образом, чтобы в случае любого нарушения круг виновников был четко известен или сведен к минимуму.

22. Обеспечение всеобщей поддержки защитных мер, предусматривающее комплекс средств, направленных на обеспечение лояльности персонала и его постоянное теоретическое и практическое обучение (если сотрудники организации считают ИБ чем-то излишним или даже враждебным, то режим безопасности сформировать не удастся).

23. Информированность, т. е. каждый должен иметь возможность ознакомиться с положениями ПолИБ, знать о тех мерах, практиках и процедурах, на которые она ссылается.

24. Соблюдение этики и учет различных прав и законных интересов сотрудников организации, включая право на частную жизнь.

Этот список достаточно полон, но при необходимости он может быть расширен с учетом особенностей организации и сферы ее деятельности.

3.4. Содержание политики ИБ

ПолИБ только определяет, что должно быть защищено и какова ответственность в случае несоблюдения ее положений. Защитные меры устанавливают, как конкретно защитить активы организации. Они

являются механизмами реализации ПолИБ на практике и представляют собой полный перечень всех рекомендаций и действий, которые должны предприниматься в определенных обстоятельствах и при конкретных условиях. Защитные меры выбираются таким образом, чтобы устранить так называемую проблему одной точки провала (например, служащий внезапно уволился, и его функции по реализации ПолИБ никому не передали, или вышло из строя и не подлежит восстановлению какое-то средство защиты).

ПолИБ содержит общие требования по ОИБ организации в целом. При этом обязательно учитываются особенности организации и ее деятельности, а также выделяются основные направления, связанные с ОИБ организации, и формулируются общие (основные) требования по каждому из этих направлений.

Еще один важный момент – каков будет вид представления и состав документации, определяющей ПолИБ. ПолИБ может быть описана в одном большом или ряде небольших документов. Несколько не очень объемных документов чаще предпочтительнее, так как их проще при необходимости обновлять. Для организаций небольшого размера, конечно же, легче изложить всю ПолИБ в одном документе.

В тексте ПолИБ обязательно в явном виде присутствуют ответы на следующие вопросы: что (цель политики), кто (на кого она распространяется), где (ее область действия), как (факторы соблюдения и оценка соблюдения политики), когда (когда политика вступает в действие), почему (необходимость внедрения политики) (рис. 3.3) [17].

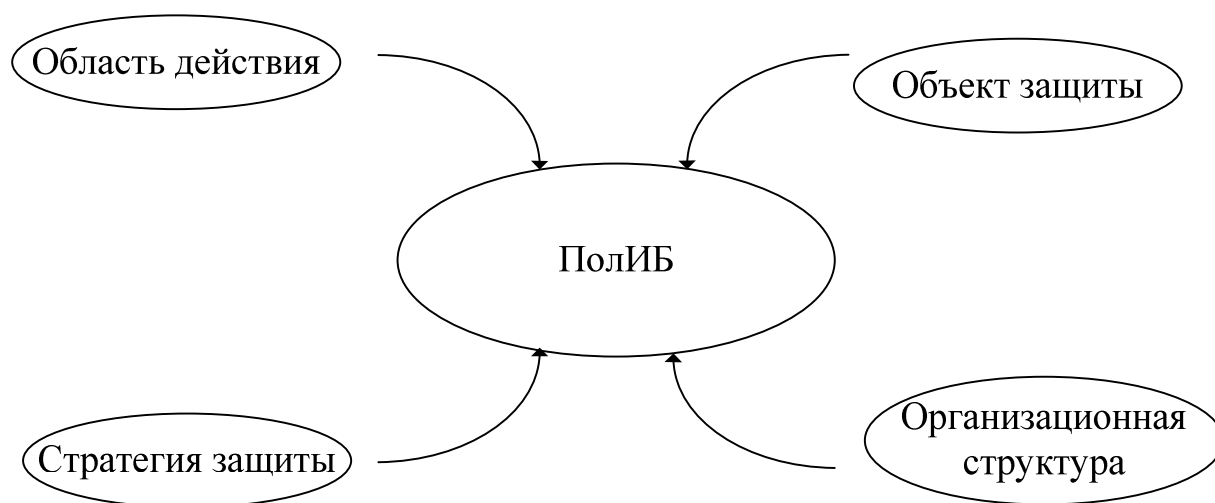


Рис. 3.3. Содержание ПолИБ организации

Выработка набора конкретных ПолИБ зависит от размера и целей организации, их принимающей. Они должны по возможности носить не рекомендательный, а обязательный характер. Ответственность за их нарушение должна быть четко определена.

Для автоматизации процесса создания ПолИБ и их проверки на соответствие некоторым наиболее популярным международным стандартам предназначены, например, британская система Cobra компании C&A Systems Security Ltd (www.riskworld.net) и российская система КОНДОР 2006 компании Digital Security (www.dsec.ru).

3.5. Содержание корпоративной политики ИБ

По своему назначению корпоративная ПолИБ является каркасом, объединяющим все остальные документы, регламентирующие обеспечение и управление ИБ в организации. В нее рекомендуется включать следующие положения [75]:

- определение ИБ в терминах деятельности данной организации, области действия политики, целей, задач и принципов ОИБ организации;
- изложение намерения ОИБ, направленного на достижение указанных целей и на реализацию принципов ОИБ;
- общие сведения об активах, подлежащих защите, их классификацию;
- модели угроз и нарушителей (внутреннего и внешнего) ИБ, на противодействие которым ориентирована корпоративная ПолИБ;
- высокоуровневое изложение правил и требований по ОИБ; представляющих особую важность для организации (например, обеспечение соответствия законодательным актам, нормативным документам РФ в области ОИБ и нормативным актам организации; требования к управлению ИБ; требования по предотвращению и обнаружению компьютерных вирусов и другого вредоносного ПО; требования по УНБ);
- санкции и последствия нарушений корпоративной ПолИБ;
- определение общих ролей и обязанностей, связанных с ОИБ, включая информирование об инцидентах ИБ;

- перечень частных ПолИБ, развивающих и детализирующих положения корпоративной ПолИБ, а также указание подразделений организации, ответственных за их соблюдение и/или реализацию;
- положения по контролю реализации корпоративной ПолИБ организации;
- ответственность за реализацию и поддержку документа;
- условия пересмотра (выпуска новой редакции) документа.

К разработке и согласованию корпоративной ПолИБ рекомендуется привлекать представителей служб организации, связанных с ее информационной сферой: руководство организации; профильных подразделений; службы информатизации; службы безопасности (ИБ).

Корпоративная ПолИБ обязательно утверждается руководителем организации (председатель, генеральный директор, президент), и в ее названии указывается наименование организации, которой она принадлежит. Может быть представлена как комплектом документов, так и единым обобщающим документом.

Цель (назначение). Корпоративная ПолИБ обычно содержит утверждение, поясняющее, зачем она была разработана. Всегда полезно явно указать цель или причины ее написания. Например, если организация предоставляет услуги по поддержке больших БД, тогда ее основными целями могут быть снижение числа ошибок, потерь и искажения данных, а также быстрота восстановления после нештатных ситуаций. Для организации, обрабатывающей персональные данные, первостепенной задачей может быть усиленная защита от несанкционированного раскрытия информации о клиентах [78, 79]. Поэтому типовыми являются следующие цели:

- обеспечение устойчивого функционирования организации за счет предотвращения реализации угроз ИБ ее активам, защита законных интересов владельца информации от противоправных посягательств, обеспечение нормальной производственной деятельности всех подразделений организации;
- обеспечение уровня ИБ в конкретных функциональных областях, соответствующего нормативным документам организации и рассчитанного на основе риск-ориентированного подхода (с учетом результатов оценки рисков ИБ);
- выработка планов восстановления после критических ситуаций и ОНБ организации и др.;
- достижение экономической целесообразности в выборе защитных мер;

- реализация подотчетности анализа регистрационной информации и всех действий пользователей с информационными ресурсами и т. п.

Задачами ОНБ являются все действия, которые необходимо выполнить для достижения поставленных целей. В частности, необходимо решать такие задачи, как анализ и управление рисками ИБ, расследование инцидентов ИБ, разработка и внедрение планов ОНБ, повышение квалификации и осведомленности сотрудников в области ИБ и т. д.

Область действия. Перед изложением самой ПолИБ определяется область ее действия с помощью ограничений и условий в понятных всем терминах, которые вводятся в явном виде. Надо уточнить, где, как, когда, кем и к чему применяется данная ПолИБ. Если, например, говорить о ПолИБ при подключении организации к Интернету, то может понадобиться уточнение, какие соединения, через которые ведется работа с Интернетом (напрямую или опосредованно), охватывает эта политика. ПолИБ также может определять, учитываются ли другие аспекты работы в Интернете, такие как соединение с Интернетом с домашнего компьютера.

ПолИБ точно определяет, какие активы организации она затрагивает: персонал, информацию, ПО и АО, устройства, технологии и т. п. Например, защищаемые в рамках ПолИБ активы организации можно описать так: «Положения настоящей ПолИБ распространяются на все виды информации, хранящиеся или передающиеся в организации, в том числе на информацию, зафиксированную на материальных носителях или передающуюся в устной или визуальной форме». Но во многих случаях корпоративная ПолИБ имеет отношение ко всем системам и сотрудникам организации без исключения.

Основные положения ПолИБ. В явной форме описывается позиция организации (решение ее руководства) по данному вопросу. Позиция может быть как сформулирована в наиболее общем виде – как набор целей, которые преследует организация в данном аспекте, так и конкретизирована.

В ПолИБ требуется кратко описать все процессы и процедуры СУИБ. В частности, выделяются такие процедуры, как контроль доступа к активам организации, внесение изменений в ее ИС, взаимодействие с третьими лицами, повышение квалификации сотрудников в области ИБ, расследование инцидентов ИБ, аудит ИБ. В описании

каждой процедуры необходимо четко определить цели и задачи процедуры, основные правила ее выполнения, регулярность или сроки выполнения.

Перечисляются конкретные меры, реализующие ПолИБ в организации, дается обоснование выбора именно такого перечня мер и указывается, какие угрозы ИБ для активов наиболее эффективно предотвращаются данными защитными мерами.

С целью формализации процесса управления ИБ в соответствии с ПолИБ требуется создание организационной структуры, которую также следует описать.

Необходимо предусмотреть период пересмотра ПолИБ, что может быть изложено, например, следующим образом: «Положения Политики ИБ требуют регулярного пересмотра и корректировки – не реже одного раза в полгода. Внеплановый пересмотр политики ИБ проводится в случаях:

- существенных изменений в национальной законодательной базе в области ИБ;
- внесения существенных изменений в интранет организации;
- возникновения инцидентов ИБ.

При внесении изменений в положения политики ИБ организации учитываются:

- результаты анализа функционирования СУИБ со стороны руководства организации;
- результаты аудита ИБ (внешнего и внутреннего);
- рекомендации независимых экспертов по ИБ».

Ответственность (роли и обязанности). В этом разделе ПолИБ точно устанавливается, кто и за что отвечает. Фраза «За ОИБ несут ответственность все сотрудники организации» на практике мало что означает. Указывается, на кого конкретно возлагается ответственность за соблюдение ПолИБ (например, менеджеров, владельцев активов, пользователей, администраторов систем и т. д.). Если для использования ПО сотрудникам требуется разрешение руководства, должно быть известно, у кого и как его можно получить.

Для ПолИБ уместно описание (с краткой детализацией) нарушений, которые неприемлемы, и последствий такого поведения. Могут быть явно перечислены наказания, применяемые к нарушителям ПолИБ.

За нарушение ПолИБ должны быть предусмотрены конкретные дисциплинарные, административные взыскания и материальная от-

ветственность. Но при этом нельзя забывать, что нарушения ПолИБ бывают и непреднамеренными со стороны сотрудников, они могут быть связаны, например, с отсутствием соответствующих знаний.

Устанавливаются как организационные, так и технические меры реагирования на нарушение ПолИБ. Эти меры предусматривают оповещение об инциденте ИБ, соответствующую реакцию, процедуры восстановления, сбор доказательств, проведение расследования и привлечение нарушителя к ответственности. Система мер по реагированию на инциденты ИБ должна быть скоординирована между ИТ-департаментом, службой безопасности и службой персонала.

Также полезно поставить задачу конкретному подразделению организации следить за соблюдением ПолИБ. Кроме этого приводится информация о должностных лицах, ответственных за реализацию ПолИБ, и четко устанавливаются их обязанности в отношении разработки и внедрения различных аспектов ПолИБ, а также в случае нарушения политики. Обязанность за общее управление ИБ возлагается на руководство организации. Ответственность сторонних пользователей обязательно оговаривается в соответствующих договорах. Отдельно описывается ответственность за контроль соблюдения ПолИБ.

Соблюдение ПолИБ. Это выражается в соблюдении двух видов соответствий:

- общего соответствия, обеспечивающего выполнение требований по разработке ПолИБ и определению ответственности, возложенной на различные организационные структуры поддержания ИБ. Часто на отдел надзора возлагается ответственность за контроль за соблюдением такого соответствия, в том числе насколько хорошо организация реализует приоритеты руководства, установленные в ПолИБ;

- использования только установленных наказаний и дисциплинарных мер. Поскольку ПолИБ – это высокоуровневый документ, то конкретные меры наказания за различные нарушения, как правило, не детализированы в корпоративной ПолИБ. Поэтому политика может разрешить создание соответствующих структур, которые будут заниматься нарушениями и реализацией конкретных дисциплинарных мер.

Ответственные (консультанты) по вопросам ИБ и справочная информация. Для любой ПолИБ нужны консультанты, с кем можно связаться в случае необходимости и получить квалифицированную помощь, разъяснения и дополнительную информацию по вопросам

ОИБ. Можно назначить сотрудника, занимающего конкретную должность консультанта. Например, по некоторым вопросам консультантом может быть один из менеджеров, по другим – начальник отдела, сотрудник технического отдела, системный администратор или сотрудник службы ИБ. Они должны уметь разъяснять положения ПолИБ и правила работы с конкретной системой. В их обязанности входит ознакомление всех новых служащих организации с ПолИБ при поступлении на работу и сообщение об изменениях в политике по мере их внесения. Также должно вестись обучение всех сотрудников основным вопросам ОИБ, а администратор и сотрудники отдела ИБ организации должны регулярно проходить переподготовку с целью повышения квалификации в специализирующихся в этих вопросах учебных заведениях.

Более современными общепризнанными стандартами, описывающими общее содержание комплексной ПолИБ организации (в контексте данного учебного пособия – корпоративной ПолИБ) являются ISO/IEC 27002:2005 [22] и ГОСТ Р ИСО/МЭК 17799-2005 [13]. В этих документах отмечается, что ПолИБ как неотъемлемая часть общей политики организации включает, как минимум, следующее:

- определение ИБ, ее общих целей и области действия, а также раскрытие значимости безопасности как инструмента, обеспечивающего возможность совместного использования информации;

- изложение целей и принципов ИБ, сформулированных руководством и соответствующих бизнес-стратегии и целям организации, включая вопросы оценки и управления рисками ИБ;

- краткое изложение и разъяснение наиболее существенных для организации политик, принципов, правил и требований, например: соответствие законодательным требованиям и договорным обязательствам; требования в отношении обучения вопросам ИБ; предотвращение появления и обнаружение вирусов и другого вредоносного ПО; УНБ; последствия нарушений и ответственность за нарушения ПолИБ;

- определение общих и конкретных обязанностей сотрудников в рамках управления ИБ, включая информирование об инцидентах ИБ;

- ссылки на документы, дополняющие ПолИБ, например, более детальные политики и процедуры безопасности для конкретных ИС, а также правила безопасности, которым должны следовать пользователи.

3.6. Содержание частных политик ИБ

Содержание частных ПолИБ по перечню разделов не отличается от таковых для корпоративной ПолИБ [84]. Все их положения ни в коем случае не должны вступать в противоречия с корпоративной ПолИБ и формируются на основании принципов, требований и задач, определенных в корпоративной ПолИБ, с учетом:

- детализации, уточнения и дополнительной классификации активов и угроз ИБ;
- определения владельцев защищаемых активов;
- оценки рисков ИБ и возможных последствий реализаций угроз ИБ в границах области действия регламентируемой политикой: области, системы, технологии, подразделения и т. п.

Не рекомендуется повторение одинаковых правил в различных частных политиках. Включение в частную ПолИБ правила, содержащегося в другой существующей политике, целесообразно осуществлять посредством соответствующей ссылки.

Частные ПолИБ определяют следующее [75]:

- цели и задачи ОИБ, на обеспечение которых направлена частная ПолИБ;
- область действия, объекты защиты, уязвимости, угрозы ИБ и оценку рисков ИБ, связанных с объектами защиты;
- сведения о виде деятельности, на ОИБ которой направлено действие положений частной ПолИБ, совокупности банковских технологий, применяемых в рамках выполнения данного вида деятельности, и основных технологических процессов, реализующих указанные технологии;
- субъекты (роли), на которых распространяется действие политики (как структурных подразделений организации, так и отдельных исполнителей);
- содержательную часть (требования и правила);
- обязанности по ОИБ в рамках области действия частной ПолИБ, описание функций субъектов (ролей) над управляемыми объектами в рамках регламентируемых технологических процессов;
- состав ссылочных документов (документы, ознакомление с которыми обязательно для адекватного понимания текста политики);
- положения по контролю реализации политики;
- ответственность за реализацию и поддержку политики;
- условия пересмотра политики.

Описание вопроса. Чтобы сформулировать частную ПолиБ, сначала необходимо описать проблему с учетом принятой терминологии, её особенностей и условий успешного разрешения. Кроме того, часто бывает полезно указать цели или обоснование политики, которые могут быть полезны при ее реализации. Например, организации нужно разработать политику использования «неофициального» ПО, под которым понимается любое ПО, не одобренное официально, переданное, не администрируемое и не находящееся в собственности организации. Кроме того, должны быть оговорены некоторые условия, например, для ПО, находящегося в собственности сотрудников, но одобренного для использования в их работе, и для ПО бизнес-партнеров организации.

Описание позиции организации. Четко излагается позиция организации (решение руководства) по данному вопросу. Продолжая предыдущий пример, это будет означать заявление, когда использование неофициального ПО запрещено во всех или отдельных случаях, есть ли дополнительные руководящие указания по его возможному утверждению и применению, возможны ли некоторые исключения из правил, когда, как и на какой основе их получить.

Применимость. Здесь уточняется, где, как, когда, к кому и какая конкретно политика применяется. Например, это может означать, что упомянутая политика использования неофициального ПО предназначена для применения только в основном офисе организации его сотрудниками и не применима к сотрудникам офисов, расположенных в других регионах. Кроме того, необходимо уточнение применения политики к сотрудникам, работающим в нескольких офисах и/или на дому.

Роли и ответственность. Если политика позволяет после соответствующего согласования использовать в работе неофициальное ПО, находящееся в собственности работников, то должно быть указано, как и где официально получить такое разрешение. Также необходимо уточнить, кто будет нести ответственность за обеспечение того, чтобы только рекомендованное ПО использовалось на компьютерах организации, и, возможно, осуществлять мониторинг компьютеров с целью обнаружения неофициального ПО.

Вопросы соответствия. Для некоторых типов политики может быть целесообразно описать, с некоторыми деталями, неприемлемые нарушения и последствия такого поведения. Наказания могут быть сформулированы вполне конкретно и должны быть согласованы

с кадровой политикой организации, соответствующими должностными лицами и ведомствами и, возможно, общественными организациями (например, профсоюзами). Желательно, чтобы какое-либо подразделение организации осуществляло контроль за таким соответствием.

Контактные лица и дополнительная информация. Конкретные фамилии в данном разделе не указываются, а пишутся только должности лиц, к которым следует обращаться за дополнительной информацией и разъяснениями.

В поддержку рассмотренной политики обычно создаются руководства и описываются процедуры. Для рассмотренного примера может быть создано руководство по проверке дисков и других мобильных устройств, приносимых сотрудниками из дома или привозимых из командировки в другой офис.

ПолИБ для конкретной системы особенно важна для использования и обеспечения ИБ этой системы. В разных подразделениях организации могут применяться различные системы (например, информационные), поэтому данная политика чаще всего имеет более узкую направленность, чем корпоративная. Она обязательно должна учитывать позицию тех, кто с этими системами непосредственно работает.

Разработать последовательную ПолИБ для конкретной системы можно, только выводя правила из целей ОИБ в поддержку основного назначения самой системы. Поэтому для такой ПолИБ полезно рассмотреть двухуровневую модель: цели ОИБ и функциональные правила ОИБ, которые тесно взаимосвязаны и часто трудно различимы с технической точки зрения их осуществления.

Цели ОИБ системы. Процесс их определения начинается с анализа потребности в обеспечении конфиденциальности, целостности и доступности для достижения основных целей использования системы. Но только такой формулировки недостаточно, цели должны быть указаны более конкретно. Они должны быть достижимы на практике и согласованы с целями других политик организации. Цели формулируются в виде ряда утверждений в отношении защищаемых ресурсов, с которыми работает система. Они должны учитывать допустимые в организации затраты на их достижение, а также функциональные, технические и другие ограничения.

Роли по ОИБ системы. Детализируются и формализуются правила назначения ответственности за ОИБ, правила использования системы и последствия их несоблюдения. Выделяются правила функ-

ционирования системы. Например, определяется санкционированное и несанкционированное изменение ее настроек, кто (по должности, рабочему положению и т. п.) может вносить санкционированные изменения (например, модифицировать, уничтожать и т. д.), в какие типы данных и при каких условиях. Степень детализации этих положений может быть различна. Чем более точно установлены правила, тем проще выявить, когда и кем они были нарушены, и автоматизировать обнаружение таких событий. Это создает определенные вычислительные сложности, поэтому при установлении, например, прав доступа лучше всего пользоваться принципом разумной достаточности.

Любые обоснованные отклонения от соблюдения корпоративной ПолИБ или общей практики при работе с рассматриваемой системой должны быть оговорены.

Реализация политики. Описываются все аспекты ОИБ системы, включая организационные, технические и др. Ограничение физического доступа в помещения, контроль логического доступа, системы обнаружения вторжений (СОВ), защита компьютеров от загрузки с дискет, контроль за работой ПО, регулярный внутренний аудит – лишь некоторые из средств, которые могут участвовать в реализации политики на практике.

Для большей наглядности вышеизложенного в прил. А приведены примеры некоторых частных ПолИБ, разработанные на основе англоязычного материала сайта организации SANS (www.sans.org/security/resources/policies/).

3.7. Жизненный цикл политики ИБ

Опыт разработки ПолИБ показывает, что жизненный цикл любой из них начинается с определения состава группы разработки и функций каждого сотрудника, входящего в нее. Сразу же решается, кто в дальнейшем будет знакомить с ней сотрудников организации и следить за ее реализацией, какие меры будут применяться к тем, кто ее нарушает, а также каковы периодичность и порядок пересмотра ПолИБ в зависимости от изменяющихся условий ведения бизнеса организации (это связано с тем, что соблюдение адекватной ПолИБ в течение длительного времени является практически невыполнимой задачей, так как меняется как окружающая среда, так и сама организация: модифицируются ее активы, информационная инфраструктура и т. п.).

Следующий шаг – это способ выработки ПолИБ, т. е. на основе какой информации будет определяться политика, кем эта информация представляется и какова степень доверия к ней. Как показывает практика, нельзя включать в рассмотрение те факторы, которые часто меняются. И нельзя сводить ПолИБ лишь к детальному плану реализации основных мер по защите всех активов организации (например, недопустима ориентация на конкретные средства защиты и указание конкретных версий продуктов конкретных производителей, иначе при появлении новых версий и выпуске средств новых производителей придется пересматривать всю ПолИБ).

На этом этапе создания ПолИБ необходимо получить ответы руководства, клиентов и пользователей отдельных сервисов организации и всех заинтересованных лиц на следующие вопросы: какие ожидания пользователи и клиенты возлагают на ОИБ организации? Потеряет ли организация клиентов, если ее ИБ будет обеспечена недостаточно серьезно или если она будет обеспечена настолько серьезно, что это затруднит выполнение ими своих обычных обязанностей? Сколько времени простоя или какие материальные потери уже принесли нарушения ИБ организации в прошлом? Обеспокоена ли организация угрозами ИБ, исходящими от внутренних пользователей? Может ли она доверять своим пользователям? Сколько конфиденциальной информации находится в интерактивном режиме доступа (онлайн) в сети организации? Каковы предполагаемые потери организации, если эта информация будет скомпрометирована или украдена? Нужны ли организации различные уровни ИБ для разных подразделений и категорий пользователей? Существуют ли в организации руководящие принципы, регламентирующие ОИБ, инструкции или законы, которые требуется выполнять? Если да, то следуют ли этим руководящим принципам и правилам в организации? Имеют ли требования основного бизнеса организации приоритет над требованиями по ОИБ при их несоответствии? Если да, то поощряется ли такой подход в организации? Насколько важны конфиденциальность, целостность и доступность информации для полноценной работы организации? Являются ли решения, которые принимаются в организации, соответствующими потребностям ее бизнеса и ее экономическому положению?

После ответа на все эти и, несомненно, другие важные вопросы определяется содержание самой ПолИБ и начинается ее написание.

Упрощенный взгляд на разработку и реализацию ПолИБ представлен на рис. 3.4.

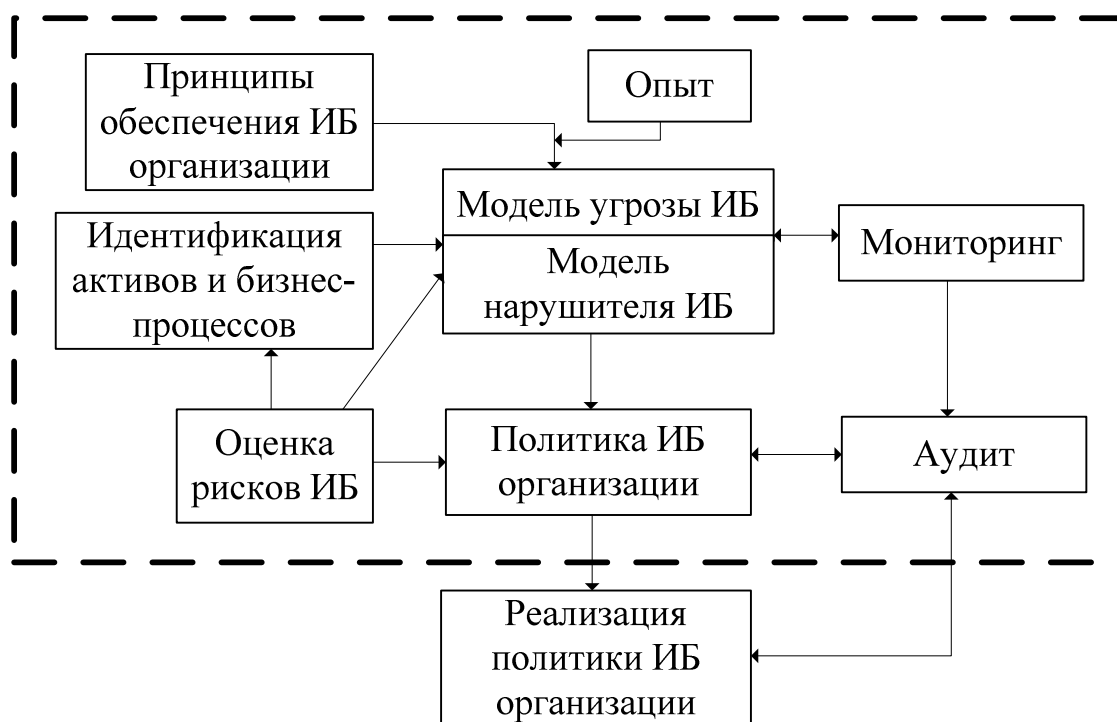


Рис. 3.4. Разработка и реализация ПолИБ

Руководствуясь признанными в организации принципами ОИБ, проведя идентификацию активов и бизнес-процессов, оценив риски ИБ, учитывая собственный опыт и лучшие мировые практики, извлекая уроки по результатам постоянного мониторинга ИБ, разрабатывают две модели ИБ: угроз ИБ и нарушителей ИБ. Все это вместе является основой ПолИБ. После соответствующих процедур согласования и утверждения ПолИБ вступает в силу, реализуется силами всех определенных заранее должностных лиц и соблюдается всеми, к кому она применима. ПолИБ является основным документом, выполнение которого на практике оценивается при проведении аудита ИБ (как внешнего, так и внутреннего) и каждодневного мониторинга событий, влияющих на ИБ.

При более детальном рассмотрении в жизненном цикле ПолИБ можно выделить четыре основные стадии: разработку, внедрение, применение, аннулирование, – и соответствующие им 11 шагов, которые нужно выполнить при работе с ПолИБ – начиная с написания и заканчивая изъятием из обращения (рис. 3.5) [80].

На стадии разработки ПолИБ пишется, в нее вносятся одобренные после обсуждения в коллективе и с руководством коррективы и в соответствии с установленной заранее процедурой ПолИБ утверждается. Затем на стадии внедрения ПолИБ доводится до сведения всех заинтересованных лиц (сотрудники, бизнес-партнеры, клиенты), обеспечивается ее соответствие всем необходимым стандартам, нормам и требованиям и непосредственное соблюдение, а также определяются исключительные случаи (исключения), когда она невыполнима.

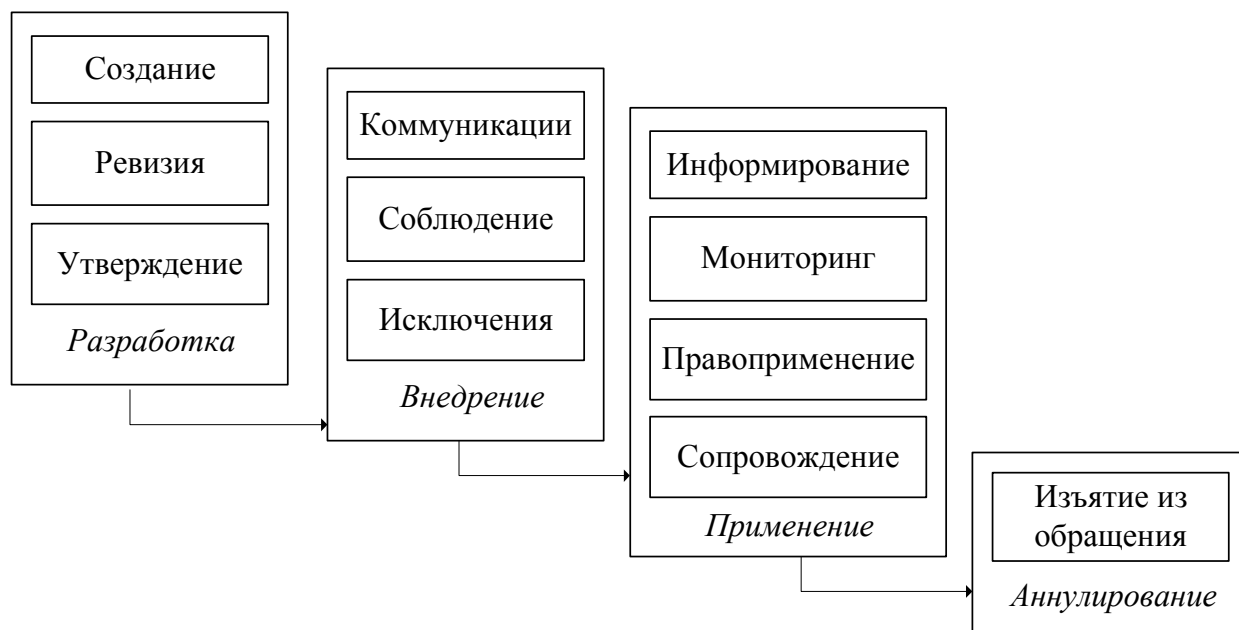


Рис. 3.5. Стадии жизненного цикла ПолИБ

На стадии применения ПолИБ поддерживается в актуальном состоянии (в нее вносятся соответствующие текущему уровню развития организации изменения), ее основные положения с изменениями доводятся до сведения всех заинтересованных лиц, а также постоянно проверяется ее соответствие всем установленным требованиям. Также должным образом контролируется исполнение ПолИБ всеми, на кого она распространяется.

Наконец, на стадии аннулирования, чаще всего после ее замены новой редакцией или совершенно новым по содержанию документом, ПолИБ изымается из обращения в связи с ненадобностью.

Все шаги жизненного цикла ПолИБ должны быть выполнены обязательно, а некоторые из них, такие как сопровождение, информирование, мониторинг соблюдения и правоприменение, выполняются итерационно во время всего жизненного цикла.

Разработка политики ИБ. Это длительный и трудоемкий процесс, требующий высокого профессионализма, отличного знания нормативной базы в области ИБ и, помимо всего прочего, писательского таланта. Не всегда создание ПолИБ нужно начинать с нуля. Во многих случаях можно воспользоваться существующими наработками, ограничившись адаптацией типового комплекта ПолИБ к специфическим условиям конкретной организации. Этот путь часто позволяет сэкономить многие месяцы работы и повысить качество разрабатываемых документов. Кроме того, он является единственно приемлемым в случае отсутствия в организации собственных ресурсов для квалифицированной разработки ПолИБ.

Сначала разрабатывается корпоративная ПолИБ, затем – частные политики.

Как было отмечено выше, в стадию разработки ПолИБ входят ее создание и согласование (включая коррекцию), ревизия и утверждение.

Создание, или написание, ПолИБ. Этот самый четко формализованный шаг жизненного цикла ПолИБ включает в себя деятельность по планированию, проведению различных исследований, документированию необходимой информации и написанию самой ПолИБ. На данном этапе обязательно осуществляются следующие мероприятия:

- определяется, зачем ПолИБ нужна в организации (например, в соответствии с правовыми требованиями или требованиями регулирующих органов);
- устанавливаются границы и область действия;
- выделяются роли и ответственность, связанные с реализацией и внедрением ПолИБ;
- назначается группа конкретных людей, которые будут участвовать во всех процессах создания политики;
- оценивается осуществимость реализации ПолИБ.

Также выявляется применимость различных требований к разработке ПолИБ конкретной организации (требования утверждающих политику, требования по ее согласованию, формат и т. д.), и проводятся исследования в соответствии со стандартизованными для различных отраслей лучшими практиками.

По мере необходимости осуществляется координация деятельности между всеми участвующими в процессе создания ПолИБ сторо-

нами как внутри, так и вне организации. Буклет SAGE «A Guide to Developing Computing Policy Documents» рекомендует следующий состав рабочей группы по разработке ПолИБ [92]:

- член совета директоров;
- представитель руководства организации (президент, директор, финансовый директор, директор по развитию и т. п.);
- директор департамента информатизации (автоматизации);
- директор департамента ИБ;
- представитель юридического отдела;
- аналитик ИТ-службы;
- аналитик службы безопасности;
- представитель пользователей;
- технический писатель.

Результатом данного шага является написанная политика, соответствующая стандартам и процедурам, принятым в организации.

Ревизия, или независимая оценка, ПолИБ. Как показывает практика, желательно, чтобы до начала ее использования в организации ПолИБ подверглась критической оценке. На этом шаге осуществляется независимая оценка отдельными лицами (группами лиц) ПолИБ, предшествующая окончательному ее утверждению. В процессе оценки должны рассматриваться не только технические, но и юридические аспекты ОИБ, поскольку политика имеет непосредственное отношение к практической деятельности организации и напрямую затрагивает работу ее персонала.

Обычно назначается специальная комиссия по оценке ПолИБ, которая анализирует и оценивает ее жизнеспособность. Эта комиссия состоит из группы заинтересованных лиц, работающих в организации, которые несут ответственность за то, чтобы ПолИБ была хорошо написана и понятна, полностью согласована и выполняема с точки зрения людей, процессов и технологий, которых она затрагивает. Из-за большого объема ПолИБ комиссия не имеет возможности оценить в короткие сроки все описанные процедуры ОИБ, но к этому нужно стремиться. Особо важные процедуры должны быть оценены обязательно.

Достоинства такой оценки не подлежат сомнению: ПолИБ получается более жизнеспособной, поскольку ее проверяют те, кто может

иметь несколько отличные или более широкие взгляды, чем взгляды создателей политики; более широкая поддержка ПолИБ за счет увеличения числа заинтересованных лиц; доверие к ПолИБ возрастает из-за привлечения к ее оценке специалистов различных профилей.

На этом шаге разработки ПолИБ осуществляются следующие действия:

- ПолИБ формально или неформально представляется оценщикам;
- решаются все вопросы, которые могут возникнуть во время оценки;
- обосновывается, почему ПолИБ необходима организации, и объясняются цели, содержание и потенциальная польза от ПолИБ.

Разработчики политики дают свои комментарии оценщикам, вырабатывают рекомендации по ее изменению, учитывают важные замечания и вносят изменения в окончательную редакцию, которая после этого готова к утверждению.

Также проводится оценка ПолИБ со стороны самого руководства организации. Входными данными для этого являются следующие сведения [13, 22]:

- обратная реакция заинтересованных сторон;
- результаты независимых анализов;
- статус предупреждающих и корректирующих действий;
- результаты предыдущего анализа со стороны руководства;
- выполнение процессов и соблюдение ПолИБ;
- изменения, которые могут повлиять на подход организации к управлению ИБ, включая изменения в окружении организации, направленности ее бизнеса, доступности ресурсов, в договорных, нормативных и юридических условиях или технической среде;
- тенденции, связанные с угрозами ИБ и уязвимостями;
- инциденты ИБ;
- рекомендации, представленные соответствующими органами.

Отчет с результатами анализа ПолИБ со стороны руководства включает любые решения и действия, касающиеся улучшения подхода организации к управлению ИБ и ее процессами, целей и средств управления и распределения ресурсов и/или обязанностей.

Утверждение ПолИБ. Данный процесс представляет собой простое одобрение руководством окончательной редакции документа. На бумажном документе с ПолИБ ставится подпись соответствующего уполномоченного должностного лица организации, после чего ПолИБ готова к непосредственному использованию.

Утверждение требует от разработчиков ПолИБ выполнения ряда действий:

- дать обоснованные разъяснения официальному лицу, имеющему полномочия утвердить ПолИБ;
- координировать все действия по утверждению ПолИБ с этим официальным лицом;
- представить рекомендации, появившиеся после ревизии ПолИБ;
- предпринимать должные усилия по расширению поддержки ПолИБ со стороны руководства организации.

Если уполномоченное лицо колеблется демонстрировать полное одобрение ПолИБ и сразу подписывать ее, разработчики политики должны решить вопросы временного утверждения ПолИБ.

Внедрение политики ИБ. После официального утверждения ПолИБ начинает претворяться в жизнь. Опыт показывает, что с наибольшими трудностями организациям приходится сталкиваться именно на этом этапе, который, как правило, связан с необходимостью решения технических, организационных и иных проблем. Часть пользователей может сознательно либо бессознательно сопротивляться введению новых правил поведения, которым теперь необходимо следовать, а также программно-технических механизмов защиты информации, в той или иной степени неизбежно ограничивающих свободный доступ к информации. Администраторов интранета может раздражать необходимость выполнения требований ПолИБ, усложняющих задачи администрирования. Помимо этого могут возникать и чисто технические проблемы, связанные, например, с отсутствием в используемом ПО функциональности, необходимой для реализации отдельных положений ПолИБ.

Чтобы внедрение завершилось успешно, должна быть создана группа по внедрению ПолИБ, действующая по согласованному плану в соответствии с установленными сроками выполнения работ.

В стадию внедрения ПолИБ входят три основных шага: коммуникации по ее распространению, собственно соблюдение ПолИБ теми, на кого она распространяется, и обработка исключительных ситуаций.

Коммуникации. Основной целью данного шага является распространение ПолИБ внутри организации и среди тех, на кого она распространяется: партнеров, клиентов и т. д. При этом обязательно проводятся такие мероприятия, как:

- определяются степень и метод начального распространения политики;
- решаются вопросы ее доставки в другие географические регионы, а также языковые проблемы;
- предотвращается несанкционированное распространение;
- устанавливается система надзора за распространением.

Для повышения эффективности перечисленных мероприятий разрабатывается и реализуется план, в котором рассматриваются все эти вопросы, а также выделяются ресурсы для данного шага, устанавливаются их зависимости, документируется ознакомление сотрудников с ПолИБ и вырабатываются способы повышения ее наглядности.

Распространением ПолИБ обычно занимается отдел коммуникаций организации.

Соблюдение ПолИБ. Этот шаг заключается в непосредственном выполнении ПолИБ и всех ее требований на практике, для чего осуществляются следующие мероприятия:

- проводится работа с сотрудниками организации, разъясняющая, как им наилучшим образом исполнять ПолИБ в различных ситуациях и организационных моментах;
- обеспечивается понимание политики теми, от кого требуется ее реализация, контроль и поддержка соблюдения;
- осуществляется мониторинг, отслеживание и составление отчетности по темпам, масштабам и эффективности деятельности по осуществлению ПолИБ;
- измеряется непосредственное влияние политики на деятельность организации;
- проводится информирование руководства о ходе осуществления ПолИБ.

Систематизируя лучшие практики по эффективному внедрению ПолИБ, можно сделать вывод, что соблюдение ПолИБ в значительной степени является элементом корпоративной этики. Поэтому на

уровень ИБ организации серьезное влияние оказывают отношения как в коллективе, так и между коллективом и собственником или руководством, представляющим интересы собственника. Следовательно, этими отношениями необходимо грамотно и своевременно управлять. Понимая, что наиболее критичным элементом ОИБ организации является ее персонал, собственник должен всемерно поощрять заинтересованность и осведомленность персонала в решении проблем ИБ и строгом соблюдении ПолИБ [11].

Исключения из ПолИБ. Основная деятельность на этом шаге – разрешение ситуаций, когда исполнение ПолИБ невозможно либо частично, либо полностью. Из-за нехватки времени, персонала и других эксплуатационных требований не все политики могут быть выполнены так, как это первоначально предполагалось. Таким образом, исключения из политики, в полной мере не отвечающие ее требованиям, рассматриваются и согласуются с соответствующими лицами, возможно, даже с руководством организации.

Определяется процедура фиксации запросов в соответствующие службы на признание, отслеживание, оценку и одобрение/неодобрение исключений. После этого такие исключения документируются и контролируются на протяжении утвержденного срока признания исключения. Все наиболее часто повторяющиеся исключения из политики, а также временные отказы от выполнения требований из-за краткосрочных обстоятельств фиксируются. Данной деятельностью может заниматься упомянутая выше комиссия, проводящая оценку ПолИБ.

Применение политики ИБ. За внедрением ПолИБ логически следует этап ее применения. В него входят информирование, мониторинг, правоприменение и сопровождение.

Информирование о ПолИБ. Этот шаг включает в себя постоянную деятельность по ознакомлению сотрудников организации и всех заинтересованных лиц и лиц, на которых она распространяется, с содержанием ПолИБ с целью выполнения ими ее требований. Для этого производятся следующие действия:

- определяются потребности в информировании различных целевых групп (исполнители, руководители, пользователи и т. д.) в рамках организации;

- устанавливаются наиболее эффективные методы информирования для каждой из групп: брифинги, обучение, рассылки сообщений и т. п.;

- разрабатываются и распространяются различные информационные материалы: видеоролики, презентации, плакаты, почтовые рассылки и т. д. о необходимости соблюдения ПолИБ;

- измеряется уровень информированности сотрудников о ПолИБ (например, посредством тестирования), и по полученным результатам данная деятельность корректируется.

Информирование также включает в себя освещение вопросов соответствия ПолИБ текущему бизнесу организации и правоприменения политики (с разъяснением наказаний за ее нарушение), а также рассмотрение текущих угроз ИБ, что свидетельствует об актуальности и реальности проблем ОИБ в организации.

В различных стандартах и рекомендациях в области ИБ особо отмечается, что необходимо не просто довести содержание ПолИБ до сведения всех целевых групп, но также провести обучение и дать необходимые разъяснения сомневающимся, которые пытаются обойти новые правила и продолжать работать по-старому.

За осуществление информирования назначаются ответственные (в пределах всей организации, если рассматривать, например, корпоративную ПолИБ, или в пределах подразделений, если рассматривать частные ПолИБ, касающиеся только этих подразделений). Обычно они работают совместно с департаментом персонала или департаментом, отвечающим за обучение персонала, что обеспечивает общность их совместных действий и оптимизирует использование задействованных в процессе информирования ресурсов. Такими ответственными чаще всего становятся сотрудники департамента ИБ.

Мониторинг ПолИБ. Соблюдение положений и требований ПолИБ является обязательным для всех сотрудников организации и должно непрерывно контролироваться. Информация для отслеживания и написания отчетов по эффективности соблюдения ПолИБ собирается из разных источников: наблюдений сотрудников и руководителей, отчетов с результатами различных плановых проверок (внешний и внутренний аудит ИБ, различные оценки, анализы и т. п.) и постоянного мониторинга в ИС (в первую очередь на основе журналов регистрации событий, влияющих на ИБ этих систем), а также отчетов и действий при реагировании на инциденты ИБ.

В данном контексте мониторинг заключается в постоянной деятельности по контролю за соблюдением или несоблюдением ПолИБ с использованием формальных и неформальных методов и подготовке отчетов для соответствующих лиц с целью принятия определенных мер.

Проведение систематически повторяемого (по заранее составленному графику) планового внешнего или внутреннего аудита ИБ является одним из основных методов контроля жизнеспособности ПолИБ, позволяющего оценить эффективность ее использования. Результаты аудита ИБ могут служить основанием для пересмотра некоторых положений ПолИБ и внесения в нее необходимых корректировок.

Ответственность за осуществление деятельности в рамках мониторинга распределяется между всеми сотрудниками и руководителями организации, внутренними аудиторами, сотрудниками, отвечающими за ИБ, и т. д.

Каждый сотрудник, на которого распространяются определенные требования по ОИБ в соответствии с ПолИБ, должен помогать в проведении мониторинга ПолИБ, сообщая обо всех замеченных им отклонениях как в самой политике, так и защитных мерах, реализующих ее.

Правоприменение ПолИБ. Правоприменение включает в себя ответную реакцию со стороны руководства на действия или бездействие, результатом которых стали нарушения ПолИБ. Это означает, что как только нарушение выявлено, определяются соответствующие корректирующие действия, которые применяются к нарушителям (в виде дисциплинарных мер), а также к процессам (их переработка) и технологиям (их обновление), пострадавшим от нарушений, что в дальнейшем предотвращает или затрудняет повторение подобных нарушений в будущем. Как уже отмечалось выше, включение информации о таких корректирующих действиях в информирование целевых групп является достаточно эффективным средством.

Основная ответственность за осуществление данной деятельности возлагается на руководителей, сотрудников, на которых распространяется ПолИБ.

Сопровождение ПолИБ. Данный шаг состоит в обеспечении широкого применения и поддержания целостности ПолИБ. Он включает следующие действия:

- отслеживаются основные побудительные мотивы и события для внесения изменений в ПолИБ (например, изменения в технологиях, процессах, людях, самой организации, направленности бизнеса и т. д.), которые могут влиять на политику;

- вырабатываются рекомендации и согласуются коррективы, которые требуется внести в ПолИБ в соответствии с вышеперечисленными изменениями;

- осуществляется документирование изменений в ПолИБ и регистрируется деятельность по ее корректировке.

Все это обеспечивает как постоянную доступность ПолИБ для всех сторон, на которых она распространяется, так и поддержание целостности политики посредством эффективного контроля ее редакций. Если в ПолИБ требуется внести изменения, то должны быть обязательно повторно выполнены шаги по пересмотру, утверждению, информированию, коммуникациям и соблюдению.

Ответственность за выполнение данного шага применительно к различным политикам несут все, на кого они распространяются: от руководства организации до ответственных за ИБ в подразделениях и рядовых сотрудников.

Аннулирование политики ИБ. Это – заключительная стадия жизненного цикла ПолИБ, а изъятие из обращения – последний его шаг. Чтобы избежать путаницы, отслужившая свой срок «лишняя» политика удаляется из перечня действующих, архивируется для дальнейших ссылок на нее, а решение об отмене ПолИБ (включая обоснование, дату и т. д.) документируется.

Изъятие из обращения устаревшей редакции ПолИБ, которая уже послужила своей цели, производится по различным причинам.

Первая из причин состоит в том, что ПолИБ не в полной мере отвечает всем потребностям организации, не всегда охватываются все области, которые должны быть регламентированы сформулированными в политике требованиями, однако понимание этого приходит с опытом. На стадии разработки организации часто пытаются написать ПолИБ без проведения ее независимой оценки, в результате политики не очень хорошо продуманы и надлежащим образом одобрены. Недальновидные руководители часто не уделяют должного внимания рассмотрению исключений (стадия внедрения ПолИБ), ошибочно думая, что не может быть таких обстоятельств, при которых соблюдение политики невозможно. Многие организации не в состоянии постоянно оценивать потребность в установленной ПолИБ на стадии ее применения, принижают важность обеспечения целостности и доступности политики. Скорее всего, после наблюдения за про-

цессом применения ПолИБ и оценки эффективности ее использования потребуется выполнить ряд существенных доработок. Тогда появится потребность во второй редакции той же ПолИБ.

Вторая причина – это то, что организация больше не применяет технологию, для которой разрабатывалась ПолИБ, или используемые технологии и организация бизнес-процессов существенно изменились, что приводит к необходимости корректировать существующие подходы к ОИБ и отказаться от данной ПолИБ как таковой.

Ответственностью за аннулирование ПолИБ наделяется соответствующее официальное лицо в организации.

3.8. Ответственность за исполнение политики ИБ

Согласно основным стандартам в области ИБ [13, 14, 21, 22], для полноценной реализации всех стадий и шагов жизненного цикла ПолИБ и адекватного назначения ответственности за их осуществление в организации создается соответствующая инфраструктура, обеспечивающая правильное понимание и постоянное исполнение политики, устанавливающая иерархические связи взаимоподдерживающих друг друга уровней и эффективно подстраивающаяся под частые изменения технологического и организационного характера. Обязательно определяются специалисты, непосредственно осуществляющие деятельность по управлению ИБ и таким образом внедряющие основные положения ПолИБ, например: обучающие сотрудников, разрабатывающие критерии для оценки эффективности, планирующие мероприятия по управлению ИБ и т. д.

Обычно создается рабочая группа по управлению ИБ, в которую, как правило, включены руководители различных подразделений организации. В обязанности группы входит утверждение документов по ОИБ, разработка и утверждение стратегии управления рисками ИБ, контроль выполнения процедур СУИБ, оценка эффективности функционирования СУИБ и др.

Также определяются назначаемые сотрудникам роли, связанные со всеми стадиями жизненного цикла ПолИБ. Под ролью понимается заранее определенная совокупность правил, устанавливающая допустимое взаимодействие между субъектом и объектом [11]. К субъек-

там могут относиться сотрудники, клиенты, партнеры и иные лица и иницилируемые от их имени процессы по выполнению действий над объектами. Объектами, в свою очередь, могут быть программные и аппаратные средства, информационные ресурсы, сервисы, процесс, системы, над которыми выполняются действия. При этом необходимо учитывать следующее:

- бизнес-цели организации и цели ОИБ, а также необходимые и достаточные ресурсы для реализации этих целей;
- функциональные и процедурные требования;
- разделение бизнес-процесса на подпроцессы для присвоения ролей, руководствуясь принципом «один процесс – несколько ролей»;
- возможность группировки и взаимодействия ролей;
- наличие контроля своевременности и качества выполнения ролей, для чего определяются дополнительные роли по ОИБ и критерии оценки эффективности выполнения правил для каждой роли, иначе может возникнуть новая уязвимость;
- установление ответственности за выполнение каждой роли.

Практика использования ПолИБ в различных организациях показывает, что наиболее часто используемыми типовыми ролями участников процессов ОИБ, выделяемыми в ПолИБ, являются следующие:

- создатель ресурса – сотрудник, непосредственно создавший ресурс;
- владелец ресурса – сотрудник, несущий конечную ответственность за ИБ ресурса и определяющий правила использования ресурса. Он организует ОИБ своего ресурса в виде формализованных правил, технических политик, настроек конфигурации, организационных мероприятий и регламентов;
- пользователь ресурса – сотрудник, привлеченный работник, использующий ресурс для своих производственных задач и несущий ответственность согласно корпоративным стандартам в рамках правил, определенных владельцем;
- администратор ресурса – сотрудник, ответственный за применение правил использования ресурса, определенного владельцем. Администратор обязан осуществить и поддерживать настройку среды работы ресурса для применения технических средств, обеспечивающих поддержку правил использования ресурса. Он должен сообщать контролеру и/или владельцу о нарушениях, недостатках и ошибках, выявленных при работе с ресурсом;

- контролер ресурса – сотрудник, ответственный за соответствие ресурса правилам, которые установлены владельцем. Контролер обязан имеющимися средствами мониторинга и аудита обеспечить уверенность в соблюдении пользователями и администраторами правил использования ресурса либо выявлять факты нарушения таких правил. Он обязан принять меры для прекращения и предотвращения нарушений.

Подобное распределение ролей хорошо тем, что позволяет правильно планировать процессы и обязанности отдельных субъектов. Если при разработке ПолИБ обнаруживается, что роли пересекаются, это дает повод усомниться в правильности планирования данного процесса либо распределения обязанностей его субъектов.

Ответственность за исполнение ПолИБ имеет непосредственное отношение к управлению ИБ в организации. Все вопросы, которые так или иначе относятся к человеческому фактору, эффективнее всего решаются при участии департамента персонала в центральном офисе или соответствующего подразделения в филиале организации. Ответственность, связанная с непосредственным выполнением процедур ОИБ, существенно зависит от технического аспекта и, следовательно, определяется совместно с представителями департаментов, сопровождающих работу программных и аппаратных средств. Эти процедуры часто выполняются децентрализованно (в разное время, «на местах» – в географически удаленных друг от друга офисах одной организации), но они должны обязательно быть согласованы с общей корпоративной ПолИБ и проверены для установления возможности их выполнения при оценке политики.

Ответственность на различных стадиях жизненного цикла ПолИБ во многом похожа (особенно это касается написания, информирования, сопровождения и аннулирования), но имеется и ряд различий. Они прежде всего связаны с тем, в рамках какой ПолИБ – корпоративной или частной – описывается ответственность.

Рассмотрение ответственности, связанной с ПолИБ, возможно и с других точек зрения. Ответственность по ОИБ активов организации может быть долгосрочной, возлагаемой на весь период жизненного цикла политики, или краткосрочной, предполагающей выполнение обязанностей в повседневной деятельности. Ответственность может возлагаться на всех сотрудников организации, что относится к корпоративной или частной ПолИБ для одной технологии или одной системы, эксплуатируемой во всех подразделениях организации,

или на часть сотрудников, работающих в одном или нескольких подразделениях с только там используемой системой или технологией. Контроль выполнения обязанностей в отношении ПолИБ может осуществляться централизованно или децентрализованно (чаще в отношении соблюдения частных ПолИБ) силами самой организации и ее подразделений. При вовлечении в соблюдение ПолИБ сторонних лиц, не работающих в данной организации на постоянной основе, возлагаемая на них ответственность может контролироваться из самой организации лишь в ограниченном объеме.

Выделяют несколько основных принципов, которыми руководствуются, устанавливая ответственность и распределяя роли и обязанности, связанные с ПолИБ [80].

Принцип разделения полномочий (обязанностей) предполагает такое распределение ролей и ответственности, при котором один человек не может нарушить критически важный для организации процесс. Данный принцип должен применяться при определении ответственности за конкретную функцию ОИБ в соответствии с требованиями ПолИБ, что обеспечивает выполнение необходимых проверок и баланса между обязанностями. При этом нельзя допускать конфликта интересов. Так, например, не следует совмещать обязанности по разработке, сопровождению, исполнению, администрированию или контролю систем, обязанности исполнителя и администратора, администратора и аудитора, разработчика и аудитора [11].

Руководствуясь соображениями эффективности, может потребоваться возложить ответственность за определенные функции в отношении ПолИБ не только на главного ответственного за ПолИБ, но и на других сотрудников организации. Например, распространение политики и коммуникации по вопросам ПолИБ лучше всего могут осуществить подразделения, обычно исполняющие подобные функции (например, департамент коммуникаций и т. п.). С другой стороны, деятельность по информированию эффективнее всего реализуется подразделением, занимающимся вопросами обучения сотрудников организации. Например, учебный департамент может оказать неоценимую поддержку при начальном распространении политики и в оценке эффективности деятельности по информированию сотрудников. Такая деятельность должна осуществляться на постоянной основе, поскольку она хорошо контролирует соблюдение ПолИБ и правоприменение ее положений, и определять требования по обновле-

нию программ информирования, каждая из которых является важным элементом эффективного повышения осведомленности сотрудников организации в вопросах, относящихся к политике.

Границы и время средств управления в отношении ПолИБ влияют на установление ответственности за выполнение конкретных требований политики. Как правило, ответственный за ПолИБ играет лишь ограниченную роль в мониторинге ее соблюдения, поскольку он должен одновременно участвовать во всех процессах реализации политики. Руководители среднего звена из-за их близости к обычным сотрудникам, подпадающим под действие ПолИБ, могут наиболее эффективно контролировать и обеспечивать соблюдение политики и поэтому должны нести ответственность за эти функции. Именно они могут гарантировать, что ПолИБ в настоящее время соблюдается, а все ее нарушения своевременно и эффективно рассматриваются.

Ограничения на полномочия соответствующего органа или лица также могут повлиять на успешное исполнение требований ПолИБ. Эффективность политики часто оценивается ее наглядностью и важностью, придаваемой ей руководством организации, и во многих случаях зависит от уполномоченных органов и лиц, на которых возлагается ответственность за ее внедрение и контроль за соблюдением. Чтобы политика имела широкую поддержку, утверждающее ее должностное лицо должно иметь в пределах организации признанные всеми полномочия. Как правило, функции по ОИБ в соответствии ПолИБ распределяются между различными подразделениями и требуют поддержки при их исполнении со стороны руководства верхнего уровня. Следовательно, ответственность за внедрение и соблюдение ПолИБ лучше всего возлагать на исполнительную дирекцию организации.

Привлечение комиссии по оценке ПолИБ может обеспечить более широкое понимание деятельности, на которую распространяется политика. Ее компетентная оценка поможет правильно написать ПолИБ, что будет способствовать ее принятию и успешной реализации. Эта оценка может быть также использована для прогнозирования потенциальных проблем с реализацией ПолИБ и эффективной оценки ситуаций, когда оправданы исключения из политики.

Должна быть ответственность за осуществление ПолИБ на всех стадиях ее жизненного цикла и отдельных шагах. На какую часть организации распространяется ПолИБ? Применима она только к одному подразделению, пользователям отдельной технологии или ко всей ор-

ганизации в целом? От ответа на эти вопросы зависит ответственность соответствующих лиц на уровне всей организации или ее отдельных технологий и систем.

Рекомендуется, чтобы все сотрудники организации давали письменное обязательство о соблюдении конфиденциальности, приверженности правилам корпоративной этики, включая требования по недопущению конфликта интересов [11]. При этом условие о соблюдении конфиденциальности должно распространяться на всю защищаемую от разглашения информацию, доверенную сотруднику или ставшую ему известной в процессе выполнения им своих служебных обязанностей. Обязанности сотрудников по выполнению требований ИБ в соответствии с ПолИБ должны включаться в трудовые контракты (соглашения, договоры). При приеме на работу новые сотрудники также должны подписывать соглашения об обязательности выполнения требований ПолИБ. При изменении служебных обязанностей сотрудников документы должны быть пересмотрены и подписаны заново. Для внешних организаций требования по соблюдению ПолИБ должны регламентироваться положениями, включаемыми в договоры (соглашения).

ПолИБ не должна налагать обязанности, которые не выполнимы на практике. Это будет провоцировать сотрудников на нарушение политики. Например, до сих пор встречаются требования ежедневно полностью сканировать жесткий диск рабочей станции на наличие вирусов. Или требование официально оформлять каждый, даже самый мелкий инцидент ИБ. Понятно, что буквальное выполнение таких требований может просто парализовать бизнес-процесс.

Вопросы для самоконтроля

1. Какие определения ПолИБ даются в различных международных стандартах?
2. В чем различие политик, стандартов, правил и процедур ОИБ?
3. Что такое трастовые модели?
4. С каких точек зрения и как можно описать виды ПолИБ?
5. Что понимают под ПолИБ в широком и узком смысле?
6. Для чего разрабатываются организационные (административные) и технические ПолИБ?

7. Перечислите основные требования, предъявляемые в различных источниках к ПолИБ.

8. Каковы основные принципы, позволяющие разработать эффективную ПолИБ?

9. Каково содержание документа, описывающего корпоративную ПолИБ? Что излагается в каждом из разделов этой политики?

10. Перечислите типовые цели корпоративной ПолИБ.

11. Каковы отличительные особенности содержания частной ПолИБ для отдельной области, требующей ОИБ, и для отдельной системы, используемой в организации? Что общего между этими политиками? Что излагается в каждом из разделов этих политик?

12. Перечислите основные стадии жизненного цикла ПолИБ. Из каких шагов они состоят? Какие из этих шагов выполняются итерационно и почему?

13. Отдельно сформулируйте цель и основные мероприятия, осуществляемые на каждом шаге жизненного цикла ПолИБ.

14. Как происходит процесс информирования в отношении ПолИБ?

15. Для чего и кем осуществляются ревизия, мониторинг и аудит ПолИБ? В чем различия этих шагов жизненного цикла ПолИБ?

16. Что понимается под исключениями из ПолИБ?

17. Зачем необходим пересмотр ПолИБ?

18. В каких случаях ПолИБ может быть аннулирована?

19. Что такое роль? Какие роли связаны с использованием ПолИБ?

20. Какие виды ответственности связаны со всеми стадиями жизненного цикла ПолИБ?

21. Какими принципами необходимо руководствоваться при установлении ответственности в отношении соблюдения ПолИБ?

4. СИСТЕМА УПРАВЛЕНИЯ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТЬЮ

4.1. Необходимость управления обеспечением ИБ организации

Как подчеркивается в различных стандартах по ОИБ [11, 13, 14, 21, 22 и др.], для противодействия угрозам ИБ, снижения рисков ИБ и эффективной обработки инцидентов ИБ необходимо обеспечивать и на протяжении длительного времени сохранять достаточный для организации уровень ИБ. Поэтому в настоящее время ОИБ является одним из основополагающих аспектов успешного ведения бизнеса.

В современных условиях ОИБ присущи специфические черты [93, 94]:

1. Прогнозный характер проблем и задач в области ОИБ. Подобно общему управлению организацией, управление ИБ включает задачи прогнозирования, ориентированные на предвидение возможности возникновения нарушений ИБ. Этот прогноз включает выявление причинно-следственных связей возможных проблем, моделирование действий нарушителей ИБ и последствий от их действий, планирование необходимых защитных мер и оценку последующего положительного эффекта от их применения и т. п.

2. Деградация мер и средств, обеспечивающих ИБ.

Даже в отсутствие злоумышленной или иной, требующей вмешательства службы ИБ, деятельности защитные меры со временем неминуемо деградируют, в результате чего риски ИБ возрастают. Правильно выстроенные процессы и используемые защитные меры в силу объективных причин имеют тенденцию к постепенному ослаблению своей эффективности. Это связано с тем, что угрозы ИБ, их источники и риски ИБ через некоторые промежутки времени изменяются под воздействием среды ведения бизнеса организации.

Другая причина состоит в том, что защитные меры всегда тем или иным образом ограничивают сотрудников и сам бизнес. Или в организации приобретается и устанавливается самая современная сертифицированная система управления и разграничения доступа, а через короткое время выясняется, что она «прозрачна» для пользователей, из-за неправильного распределения ролей и ответственности и плохо отлаженного механизма выделения полномочий всем и все разрешено. В итоге организация несет потери, так как на систему были зря потрачены немалые средства.

3. Изменчивость (стохастичность) бизнеса.

Бизнес ведется в условиях изменчивой среды, т. е. при большой неопределенности. Это естественное свойство среды, которое должно учитываться организацией в ее деятельности. В условиях неопределенности на бизнес-уровне принимается решение о необходимости осуществить то или иное действие, отсрочить его, позаботиться о дополнительных гарантиях или ресурсах либо вообще отказаться от выполнения действий. При этом используются естественные для бизнеса механизмы самоконтроля, позволяющие проверить степень достижения заданной цели.

Ясно, что изменчивость потребует постоянной подстройки ОИБ под изменение внутренней и внешней среды ведения бизнеса организации. Однако ИБ, в отличие от бизнеса, не имеет механизмов самоконтроля. Эффективность ОИБ реально выявляется только в момент нарушения ИБ. Новый бизнес всегда сопровождается новыми рисками ИБ. Организация должна адекватно оценивать степень влияния выявленных проблем в области ОИБ на ее бизнес-цели.

4. Рост масштабов и сложности самих задач ОИБ организации.

Всё это требует их эффективного решения, что не может быть достигнуто без целенаправленного управления процессами ОИБ, основанного на системном методологическом подходе.

5. Своевременность обнаружения проблем в области ОИБ.

Организация должна своевременно обнаруживать проблемы, прямо или косвенно относящиеся к ИБ и потенциально способные повлиять на успешное достижение ее бизнес-целей.

Эффективность деятельности по ОИБ реально проявляется только в момент атак; до наступления атаки непосредственно убедиться в эффективной реализации этой деятельности и, следовательно, успешном отражении атаки проблематично.

4.2. Деятельность по обеспечению ИБ организации как процесс

Обеспечение защищенности интересов (целей) организации непосредственно связано с ее основным бизнесом, а деятельность по ОИБ является вспомогательной по отношению к нему. При этом главное предназначение деятельности по ОИБ организации – содействие основным, управленческим и иным вспомогательным процессам веде-

ния бизнеса. Модель, представленная на рис. 4.1, иллюстрирует связи деятельности организации в области ИБ и ее основной деятельности и деятельность по ОИБ как процесс [4].

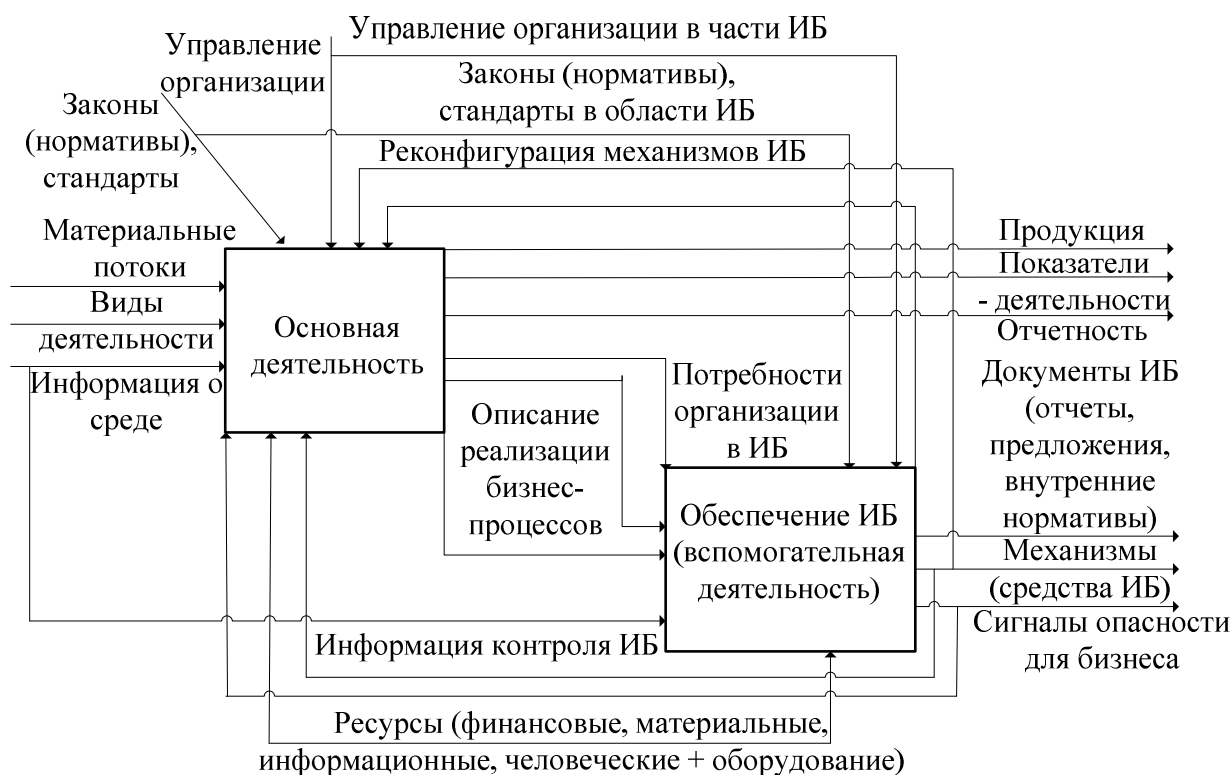


Рис. 4.1. Связи основной деятельности и деятельности по ОИБ

Планируя осуществление деятельности по ОИБ, организация должна ответить на множество важных вопросов: что может случиться, каковы последствия реализации угроз ИБ для ее отдельных активов и бизнеса в целом, как часто это может происходить и т. п. Поэтому входными данными для процесса ОИБ являются:

- информация о среде ведения бизнеса организации;
- потребности организации в ИБ;
- описание бизнес-процессов и их реализации;
- информация, используемая для контроля успешности деятельности по ОИБ.

Кроме этого учитываются законы (нормативы) и стандарты в области ИБ и управление организации в части ИБ, а также все ресурсы (финансовые, материальные, информационные, человеческие и оборудование).

Важнейшими исходными данными для эффективного ОИБ служат информационные модели основной деятельности организации,

описания бизнес-процессов, реализуемых технологий и т. д. Они определяют акцент и контекст всей деятельности по ОИБ, так как позволяют понять, где в структуре ведения бизнеса организации в части ИТ имеются уязвимости, где и при каких условиях могут проявиться те или иные угрозы ИБ и действия нарушителей ИБ, где находятся требующие защиты активы, какие защитные меры (организационные, административные, программно-аппаратные, технические) могут потребоваться и какие из них могут быть наиболее эффективными в каждом конкретном случае.

Как вспомогательная, деятельность по ОИБ влияет на бизнес организации посредством таких воздействующих элементов, как:

- регламентирующие ИБ документы для всех структурных подразделений организации;
- обучение персонала и работа с ним по вопросам ИБ;
- заказы на приобретение, поставку и регламентацию использования сервисов и систем ОИБ на объекты и системы в организации, которые далее могут эксплуатироваться другими вспомогательными и основными подразделениями;
- контроль за ОИБ, в том числе на основе информации об инцидентах ИБ, данных мониторинга и аудита ИБ;
- сигналы опасности для интересов (целей) деятельности организации в информационной среде, направляемые всем подразделениям организации.

Выходом (результатом) деятельности по ОИБ в организации являются:

- документы по ИБ (отчеты, предложения, в том числе по обучению персонала, внутренние нормативные документы);
- заказы на приобретение, поставку и регламентацию использования механизмов ИБ на объекты и системы в организации, которые далее могут эксплуатироваться другими вспомогательными или основными подразделениями, и порядок их использования;
- сигнал опасности для основной деятельности (бизнеса) организации.

Механизмы (средства, защитные меры) ОИБ, являющиеся результатом деятельности по ОИБ и поступающие в качестве ресурсного обеспечения для основной деятельности организации, эксплуатируются службами информатизации, а в отдельных случаях и основными функциональными подразделениями. Информация контроля результатов применения механизмов ОИБ анализируется службой ИБ.

Рассмотренная связь задает контекст высокого уровня, позволяющий в первую очередь позиционировать управленческие, информационные, материальные и ресурсные потоки в рамках взаимоотношения деятельности по ОИБ (как вспомогательной) с основной и другими бизнес-процессами в рамках организации.

Как показывает опыт осуществления деятельности по ОИБ в организации, ее успешность зависит от ряда факторов [13, 21]:

- утвержденная и соблюдаемая ПолИБ, учитывающая цели бизнеса организации;
- определенные методы, структура реализации, поддерживающие в рабочем состоянии деятельность организации, которая соответствует ее общей культуре;
- видимая поддержка и обязательства всех уровней руководства;
- правильное понимание требований ПолИБ, оценки и управления рисками ИБ;
- результативное информирование всех сотрудников и заинтересованных сторон о деятельности по ОИБ, руководящих принципах ПолИБ и стандартах в области ИБ;
- финансирование деятельности по ОИБ;
- обеспечение надлежащей осведомленности, подготовки и образования в области ИБ сотрудников организации;
- создание результативных процессов управления инцидентами ИБ;
- внедрение системы измерения, которая позволяет оценить деятельность по ОИБ и выработать предложения по ее улучшению.

К деятельности по ОИБ применим подход компании Cisco Systems (www.cisco.com), называемый «Колесо безопасности», который наглядно отражает постоянную динамику этой деятельности на основе применения ПолИБ (рис. 4.2).

Защита подразумевает применение описанных в ПолИБ и таким образом одобренных для организации защитных мер. Мониторинг выявляет нарушения ПолИБ в режиме реального времени (если рассматривать интранет организации, то это осуществляется с помощью СОВ) и то, насколько корректно на предыдущем этапе были выбраны и настроены защитные меры. Тестирование (внутренний и внешний аудит ИБ) используется для определения эффективности используемых защитных мер (в интранете для этого применяются сканеры анализа защищенности (САЗ), которые определяют, насколько текущее состояние дел соответствует правилам и процедурам, реализованным

в соответствии с ПолИБ). Улучшение (подстройка) защитных мер и самой ПолИБ осуществляется на основе собранной и проанализированной информации этапов мониторинга и тестирования.

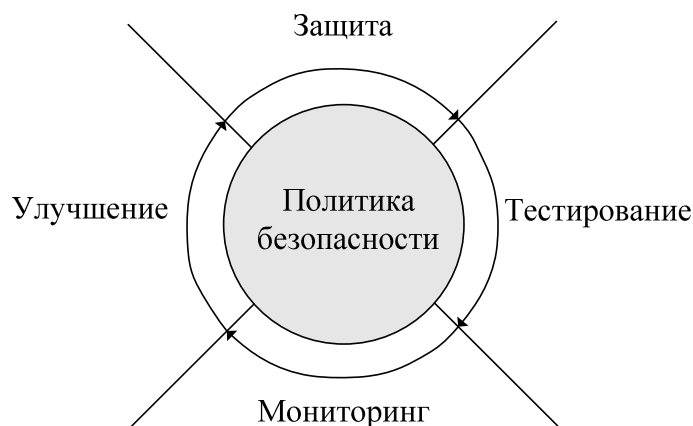


Рис. 4.2. «Колесо безопасности»
компании Cisco Systems

Круглая форма «Колеса безопасности» отражает его сущность – постоянное, циклическое совершенствование и уточнение ПолИБ и эксплуатируемых в соответствии с ней защитных мер. При этом результаты, получаемые на всех этапах, всегда сравниваются с ПолИБ, разработанной на первом шаге, чтобы убедиться, что выполняются все «высокоуровневые» задачи по ОИБ.

Другим примером возможной организации ОИБ является модель Lifecycle Security компании Axent (<http://www.symantec.com>) (рис. 4.3).

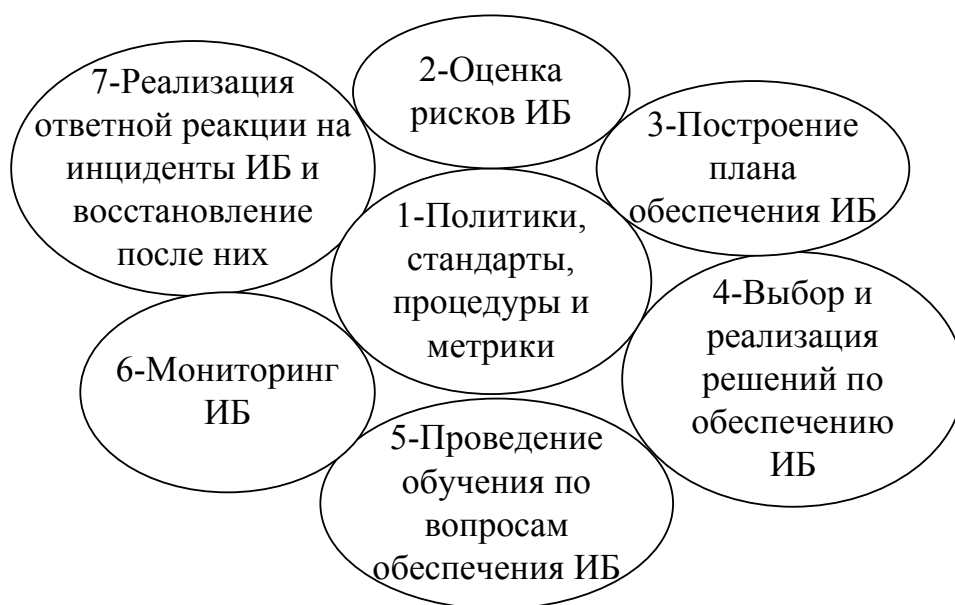


Рис. 4.3. Модель Lifecycle Security

Эта модель отображает семь взаимосвязанных этапов ОИБ в организации, представленных в виде набора процедур, позволяющих системно, комплексно и эффективно решать поставленные задачи по достижению требуемого уровня ИБ. На первом этапе определяются границы, в которых осуществляется деятельность по ОИБ, и задаются критерии оценивания полученных результатов, разрабатываются различные политики, стандарты, процедуры и метрики. Этап оценки рисков ИБ позволяет подробно описать состав и приоритеты защищаемых активов, базируясь на степени их важности для функционирования организации, выявить угрозы ИБ, идентифицировать уязвимости активов и определить ущерб от реализации угроз.

Результаты оценки рисков ИБ используются как основа для разработки плана ОИБ, помогающего распределить по приоритетам ресурсы и определить стратегию и тактику ОИБ за счет внедрения соответствующих защитных мер. После этого осуществляется выбор конкретных решений по ОИБ и их непосредственное внедрение и использование. Далее производится обучение сотрудников организации по вопросам ИБ и СУИБ, поскольку такие знания необходимы для корректной работы и обслуживания активов организации.

Этап мониторинга ИБ помогает выявить инциденты ИБ и позволяет оперативно контролировать эффективность СОИБ. Реализация ответной реакции на инциденты ИБ и восстановление после них гарантирует, что в случае обнаружения несанкционированной деятельности будут противопоставлены эффективные защитные меры и непрерывность бизнеса организации удастся сохранить.

Специальный стандарт организации NIST SP80033 «Underlying Technical Models for Information Technology Security» [95] описывает модель, лежащую в основе защиты ИТ и предназначенную для использования на стадиях проектирования и развития технических аспектов защиты ИТ. Предложенные рекомендации позволяют создать систему защиты ИТ с учетом рисков ИБ и обеспечить конфиденциальность, целостность, доступность и учетность (имеется в виду фиксация всех событий ИБ), а также гарантированность соблюдения этих свойств для систем и данных ИТ. В стандарте описана модель сервисов защиты для всех перечисленных свойств, предполагающая распределение и взаимосвязь этих сервисов по различным уровням защищаемых ИТ. В тексте стандарта упоминается управление системами, которое является важнейшим аспектом обеспечения безопасности этих систем.

4.3. Определение управления ИБ организации

Понимание управления как процесса распространяется и на область ИБ, что уже было выше продемонстрировано на процессе ОИБ. Управление ИБ – это тоже процесс, представляющий собой логически взаимосвязанную между собой и непрерывную во времени последовательность работ, направленную на достижение поставленной специфичной цели ОИБ [14, 21].

Следует сделать два важных замечания, касающихся терминологии. Во-первых, более правильным представляется использование словосочетания «управление ОИБ», а не просто «управление ИБ», поскольку управлять состоянием защищенности (из непосредственного определения ИБ) можно, лишь осуществляя деятельность по ОИБ, которая реализуется посредством соответствующих процессов по обеспечению такого состояния. Но для краткости далее будет использоваться общепринятый термин «управление ИБ», т. е. управление ОИБ.

Во-вторых, поскольку в международных стандартах по ИТ и ИБ при их гармонизации в российских документах при переводе английского слова «management» встречаются оба термина – «управление» и «менеджмент», отдается предпочтение первому, т. е. управлению ИБ, как наиболее привычному для российских специалистов, особенно относящихся к управленческому персоналу.

В настоящее время, к сожалению, не существует общепринятого определения управления ИБ. Этот термин чрезвычайно моден и используется многими: производителями и продавцами средств защиты, системными интеграторами, специалистами, представителями средств массовой информации (СМИ) и т. д. Например, первые две категории понимают под этим термином техническую составляющую процесса управления с единой консоли распределенной системой агентов, решающих в сетевой среде различные задачи по ОИБ: обнаружение вторжений и вирусов, управление настройками систем защиты и т. д. Журналисты называют системами управления ИБ любое ПО, что как-то и чем-то управляет. Многие пользователи понимают под управлением ИБ только управление программными или аппаратными СЗИ. Все эти взгляды слишком узконаправленны и ограничены.

Более правильно рассматривать управление ИБ как совокупность целенаправленных действий, осуществляемых для обеспечения нормального функционирования основных процессов и в конечном счете достижения бизнес-целей организации посредством обеспечения защищенности ее информационной сферы. Информационная сфера представляет собой совокупность информации, информационной инфраструктуры (состоит из банков данных и знаний, систем связи и т. п.), субъектов, осуществляющих сбор, формирование, распространение, хранение и использование информации, а также системы регулирования возникающих при этом отношений [11]. Совокупность целенаправленных действий включает оценку ситуации и состояния объекта управления (например, оценку и управление рисками ИБ), выбор управляющих воздействий и их реализацию (планирование, внедрение и обслуживание защитных мер и средств) и многое другое.

Обобщая приведенные выше формулировки, можно определить управление ИБ организации как циклический процесс, состоящий из совокупности целенаправленных действий, осуществляемых для достижения заявленных бизнес-целей организации посредством обеспечения защищенности ее информационной сферы, и включающий осознание необходимости ОИБ, постановку задачи по ОИБ, оценку текущей ситуации и состояния объекта управления, планирование мер по обработке рисков ИБ, реализацию, внедрение и оценку эффективности соответствующих защитных мероприятий и средств управления, распределение ролей и ответственности в области ОИБ, обучение и мотивацию сотрудников, выбор управляющих и корректирующих воздействий и их реализацию.

Управление ИБ организации – это не разовое мероприятие. Его следует рассматривать как непрерывную деятельность по постоянному поддержанию требуемого организацией уровня ИБ, так как правильно управляемая ИБ – инструмент успешного ведения бизнеса.

Основным предметом управления ИБ в организации являются следующие области деятельности:

- планирование работ по ОИБ, включая разработку и продвижение соответствующей документации;
- поддержка и участие в эксплуатации защитных мер;
- осуществление контроля за ОИБ и уровнем ИБ;
- совершенствование работ по ОИБ на основе собственного опыта и лучших практик.

В целом процесс управления ИБ организации, носящий циклический характер, заключается в следующем:

- описании объектов управления и защищаемых активов организации и сборе данных об их состоянии;
- выявлении и формализации возможных угроз ИБ и анализе рисков ИБ;
- оценке защищенности объектов управления (с выявлением уязвимостей) и ее сравнении с требованиями по ОИБ организации, сформулированными в ПолИБ;
- формировании управляющих воздействий;
- оценке результирующей деятельности по управлению ИБ.

Таким образом, управление ИБ в организации включает в себя две важнейшие составляющие – собственно сам процесс управления ИБ и систему управления ИБ (СУИБ) организации, которая подробно рассмотрена в п. 4.5.

Высшее руководство организации должно быть всесторонне проинформировано по вопросам ОИБ, определять направления управления политикой и стратегией в этой области, обеспечивать ресурсы для деятельности по ОИБ, назначать ответственных за осуществление данной деятельности, устанавливать приоритеты, поддерживать необходимые корректировки, выделять защищаемые активы и подлежащие оценке риски ИБ, страховать остаточные риски, а также настаивать на оценке затрат на ОИБ и их учете при расчете эффективности деятельности по ОИБ.

Руководство организации должно участвовать в создании ее ПолИБ, учитывать влияние политики на основной бизнес. После утверждения ПолИБ организация должна гарантировать: определенность и понятность ролей ответственных за ОИБ; наличие разработанных моделей угроз и нарушителей ИБ; реализацию инфраструктуры ОИБ и средств управления ею, включая стандарты, критерии оценки, практические приемы и процедуры, своевременный учет определенных приоритетов; мониторинг новых возникающих уязвимостей и регулярную подготовку соответствующей отчетности по результатам анализа защищенности; обучение сотрудников по вопросам ИБ.

На самом деле можно сделать еще большее обобщение и определить управление ИБ как часть общего управления организации, а не только управление ее ИТ.

Цель управления ИБ в организации заключается в гарантировании того, что соответствующие мероприятия по ОИБ осуществляются так, что в текущий момент надлежащим образом:

- снижены риски ИБ;
- осуществляются инвестиции в ОИБ;
- руководство ознакомлено со всеми проводимыми мероприятиями;
- верно сформулированы критерии оценки эффективности ОИБ.

Развивая идеи, изложенные в [96], можно сформулировать основные задачи управления применительно к ИБ:

1. Целеполагание (определение требуемого состояния или поведения) ОИБ и соответствующего уровня ИБ организации на основе риск-ориентированного подхода (подразумевает отсутствие недопустимого риска ИБ) и выполнения требований законодательных и нормативных документов по ОИБ.

2. Стабилизация (удержание в существующем состоянии в условиях возмущающих воздействий) – выбор и реализация таких управляющих воздействий по ОИБ (планирование, внедрение и обслуживание защитных мер), которые позволят сохранить требуемый организации уровень ИБ в течение длительного времени.

3. Выполнение программы (перевод в требуемое состояние в условиях, когда значения управляемых величин изменяются по известным законам) – соблюдение планов обработки инцидентов ИБ и рисков ИБ, проведения аудитов ИБ, корректирующих действий в отношении деятельности по ОИБ в соответствии с результатами аудитов ИБ и анализа данной деятельности со стороны руководства организации, ОИБ и многого другого, что запланировано и входит в разнообразную деятельность по ОИБ.

4. Слежение (удержание требуемого состояния или поведения в условиях, когда законы изменения управляемых величин неизвестны или изменяются) – оценка по установленным критериям уровня ИБ в условиях изменения угроз ИБ, появления новых атак и обнаружения новых уязвимостей (управление рисками нарушения ИБ; контроль за соблюдением ПолИБ, самооценка и внутренний

аудит ИБ, анализ работы СОВ и САЗ и т. п.) и поддержание требуемого уровня ИБ за счет реализации постоянных корректирующих воздействий (например, оперативного изменения настроек СЗИ).

5. Оптимизация (удержание или перевод в состояние с экстремальными значениями характеристик при заданных условиях и ограничениях) – достижение экономической целесообразности в выборе защитных мер и поддержания всех процессов ОИБ.

Уровни управления ИБ представлены на рис. 4.4 [93]. Самый верхний уровень – административный, на котором принимаются стратегические решения. Ниже располагаются уровни тактического и оперативного управления ИБ.

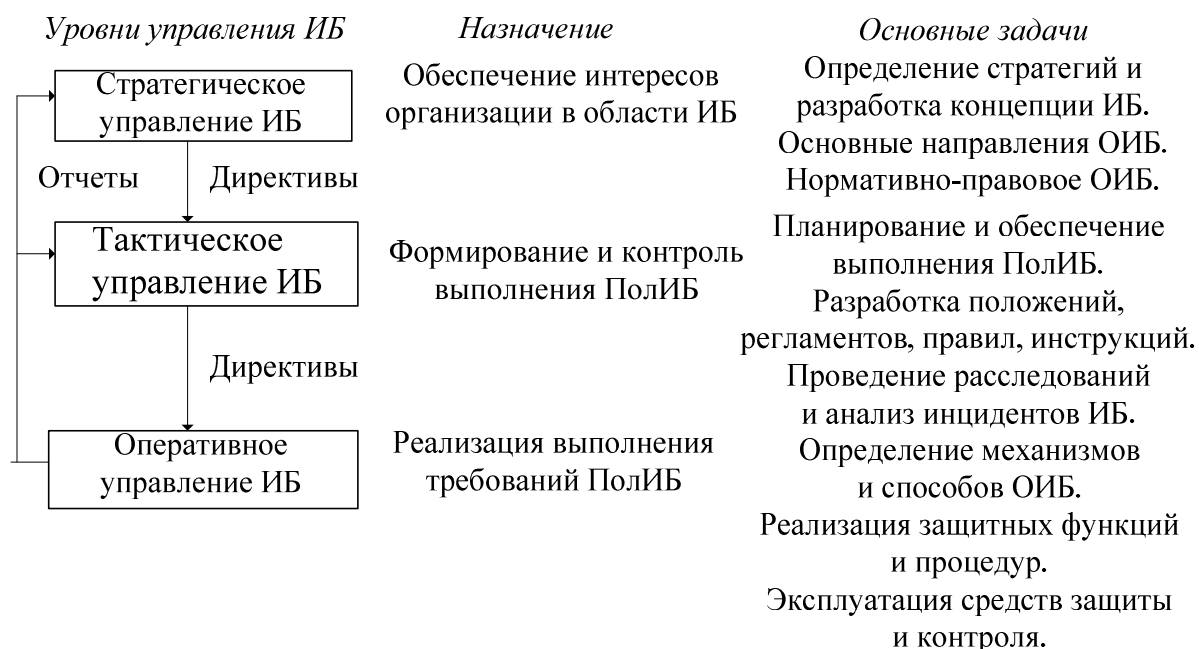


Рис. 4.4. Уровни управления ИБ организации

При построении системы оперативного управления ИБ на уровне тактического управления создается Центр управления ИБ. Основными задачами данного уровня являются формирование и контроль ПолИБ. Нижний уровень реализует выполнение ПолИБ (рис. 4.5, АС – автоматизированная система) [93]. Анализ состояния ИБ проводится на основе сопоставления определенной ПолИБ и данных мониторинга и аудита ИБ уровня оперативного управления.

Создание Центра управления ИБ позволяет облегчить проведение анализа и выработку корректирующих и предупреждающих действий.

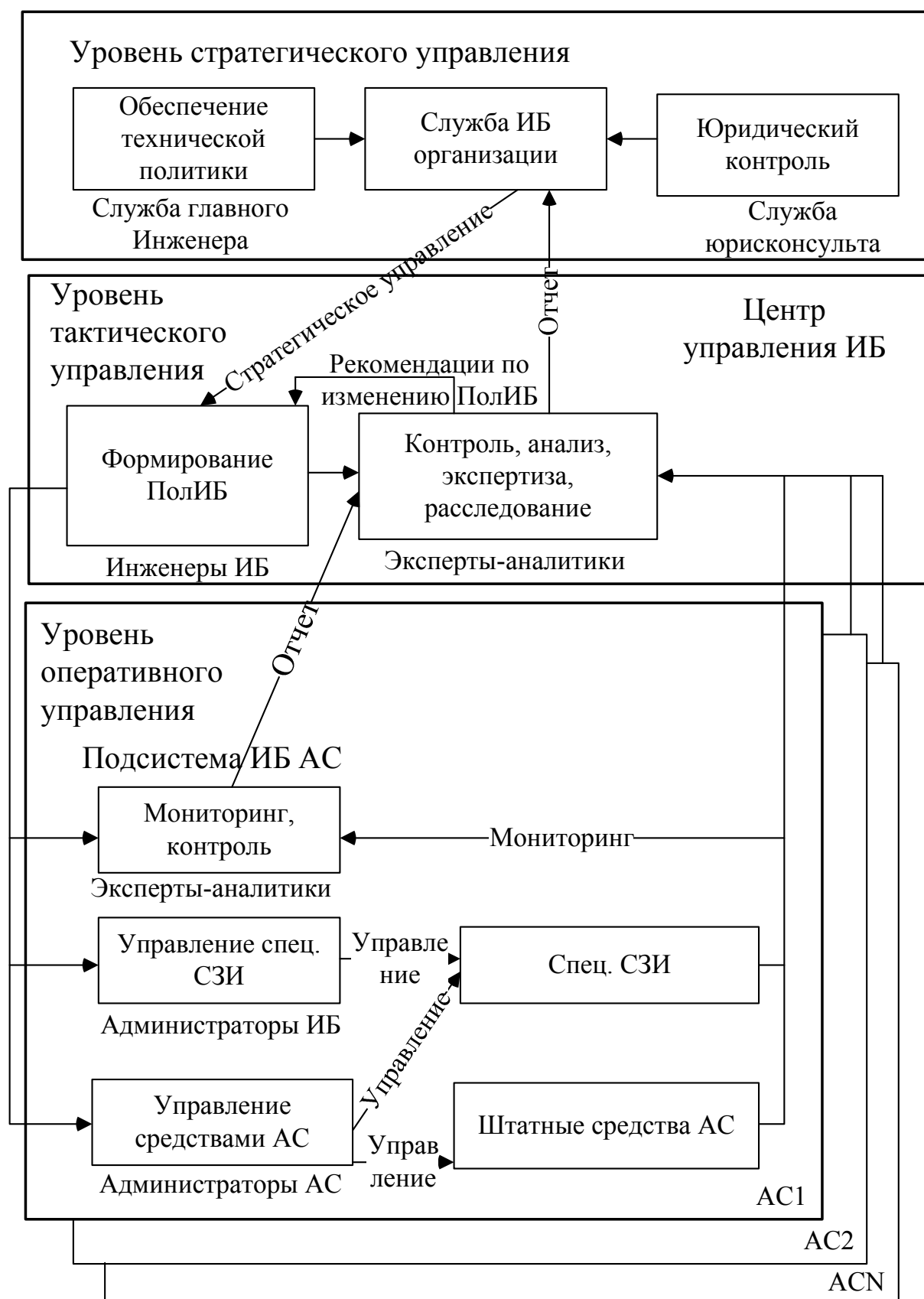


Рис. 4.5. Функциональная структура управления ИБ организации

4.4. Управление ИБ информационно-телекоммуникационных технологий организации

Процесс управления ИБ ИТТ интегрируется в общий процесс управления ИТТ. Он основывается на изложенных в ГОСТ Р ИСО/МЭК 133351 принципах [52, 54] и может быть реализован в масштабе как всей организации, так и ее конкретной части. Исходя из этого, ГОСТ Р ИСО/МЭК ТО 133353 определяет этапы управления ИБ ИТТ [27, 55]:

- анализ требований по ОИБ ИТТ;
- разработка плана выполнения этих требований;
- реализация положений выработанного плана;
- административный контроль над процессом управления ИБ ИТТ.

На рис. 4.6 приведены основные этапы процесса управления ИБ ИТТ, а также показана обратная связь между результатами процесса и его отдельными частями, которая должна устанавливаться по мере необходимости как в пределах выполнения одного из этапов, так и после завершения одного или нескольких этапов.

Процесс управления ИБ ИТТ начинается с определения целей и стратегии, которые в целях ОИБ и разработки ПолИБ ИТТ устанавливает организация. ПолИБ ИТТ – это правила, директивы, сложившаяся практика, которые определяют, как в пределах организации и ее ИТТ управлять, защищать и распределять активы, в том числе критичную информацию. ПолИБ ИТТ имеет подчиненное по отношению к ПолИБ организации положение. При ее создании также учитывается общая политика организации в сфере использования ИТТ в ее бизнесе. Таким образом, ПолИБ ИТТ организации должна отражать существенные принципы ИБ ИТТ и директивы, применимые к политике общей безопасности и ПолИБ в частности, и порядок использования ИТТ в организации.

ИТТ включает в себя следующую информацию:

- сведения о целях и области ее действия;
- цели СОИБ ИТТ и их соотношение с правовыми и нормативными обязательствами и бизнес-целями организации;
- принципы ОИБ ИТТ;
- требования, предъявляемые к СОИБ ИТТ с точки зрения обеспечения конфиденциальности, целостности, доступности, аутентичности, подотчетности, неотказуемости и надежности информации;
- сведения об организации и инфраструктуре ОИБ ИТТ;

- сведения об управлении ИБ, включающие в себя данные об ответственности и полномочиях как организации, так и отдельных лиц;
- категорирование подлежащих защите активов ИТТ; общий обзор для них уязвимостей и угроз ИБ;

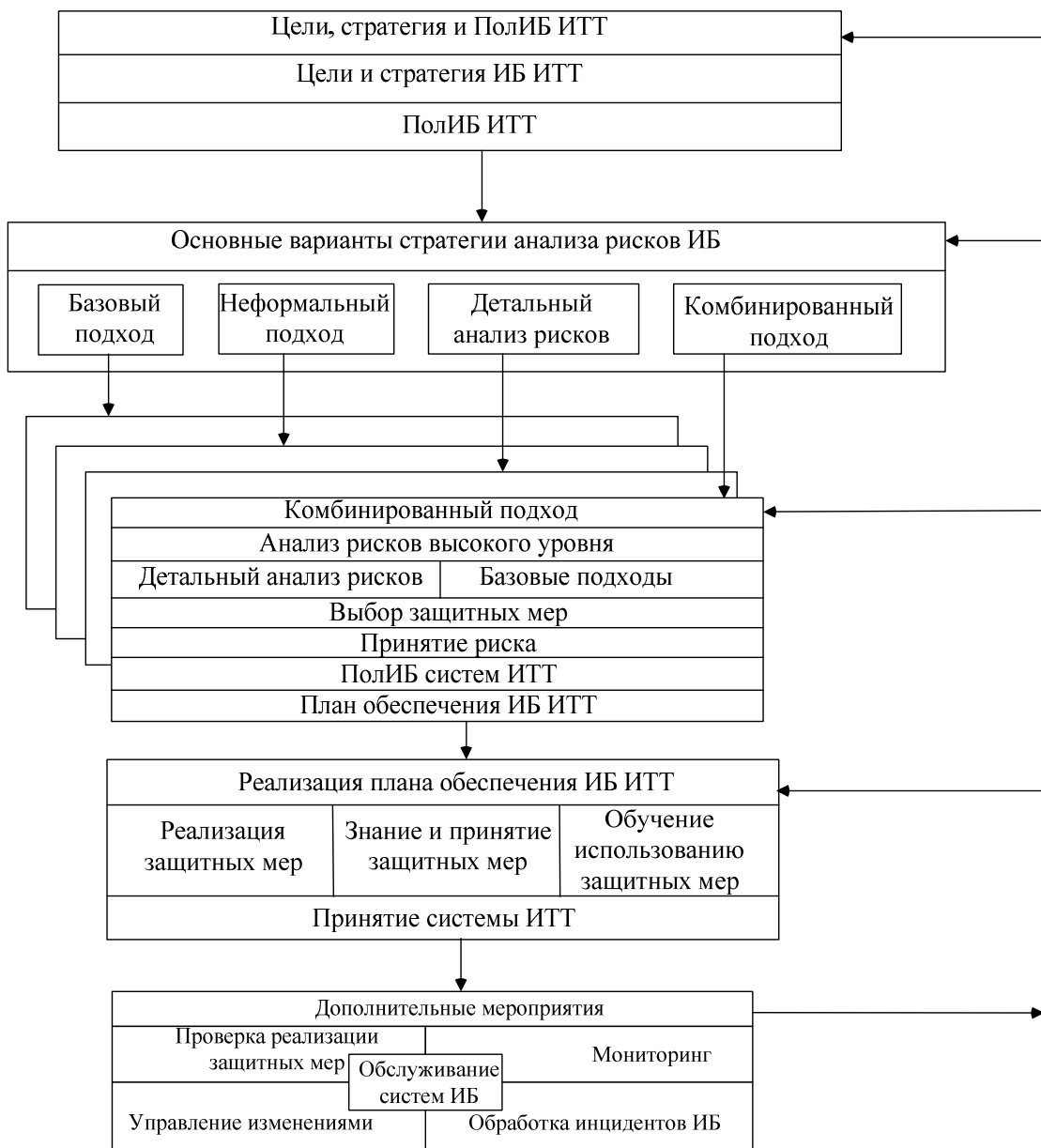


Рис. 4.6. Этапы управления ИБ ИТТ

- вариант подхода к управлению рисками ИБ, принятый организацией;
- пути и способы определения приоритетов при реализации защитных мер;
- сведения об общем уровне ИБ и остаточном риске ИБ, необходимые для осуществления управления;

- сведения о наличии общих правил контроля доступа (логический контроль доступа при одновременном контроле физического доступа лиц в здания, рабочие помещения, а также к системам и информации);

- ОНБ, включая планирование действий при чрезвычайных ситуациях и восстановлении после аварий, стратегии и план (планы);

- сведения о доведении до персонала защитных мер и обучении лиц, осуществляемом организацией;

- сведения об общих процедурах контроля и поддержания ИБ;

- общие проблемы ОИБ, касающиеся обслуживающего персонала;

- средства и способы доведения сути ПолиБ ИТТ до всех заинтересованных лиц;

- обстоятельства, при которых может быть проведен пересмотр ПолиБ ИТТ;

- методы контроля изменений, вносимых в ПолиБ ИТТ организации.

Важным этапом процесса является оценка рисков ИБ и методов их снижения до приемлемого уровня. При этом необходимо руководствоваться направленностью бизнеса организации, ее организационной структурой, условиями эксплуатации систем, использующих ИТТ (далее – систем ИТТ), а также специфическими вопросами и видами рисков ИБ, присущими каждой системе ИТТ, требующей ОИБ.

После оценки требований по ОИБ, предъявляемых к системам ИТТ и отдельным видам ИТ-сервисов, выбирается стратегия анализа рисков ИБ. Для определения систем с высоким уровнем рисков ИБ необходимо провести анализ уровня рисков и выбрать для них варианты стратегии ОИБ ИТТ. Выделенные системы рассматриваются с использованием метода детального анализа рисков ИБ, а для остальных систем может применяться базовый подход с принятием базового уровня рисков. Для систем с высоким уровнем рисков ИБ подробно изучаются активы, возможные угрозы ИБ и уязвимости и проводится детальный анализ рисков ИБ, что позволяет выбрать эффективные защитные меры, соответствующие оценкам уровня рисков ИБ. Использование такого базового подхода позволяет сосредоточить процесс управления рисками ИБ на областях, отличающихся наивысшим уровнем рисков или требующих наибольшего внимания, и разработать программу, характеризующуюся наименьшими затратами времени и средств.

После оценки рисков ИБ для каждой системы ИТТ определяют соответствующие защитные меры, снижающие уровень рисков до приемлемого. Под защитными мерами понимаются действия, процедуры и механизмы, способные обеспечить ИБ при осуществлении угрозы ИБ, уменьшить уязвимость, ограничить воздействие инцидента ИБ, обнаружить инциденты и облегчить восстановление защищаемых систем ИТТ. Эти меры реализуются в соответствии с планом ОИБ ИТТ. Данный этап сопровождается выполнением программ информирования и обучения использованию защитных мер, что является важным показателем эффективности принятых защитных мер.

Кроме того, управление ИБ ИТТ требует решения текущих задач, связанных с проведением различных последующих действий, что может привести к корректировке полученных ранее результатов и принятых решений. Последующие действия включают в себя обслуживание и проверку соответствия уровня ИБ, управление изменениями, мониторинг и обработку инцидентов ИБ.

В рамках управления ИБ ИТТ на уровне организации для каждой отдельной системы ИТТ на всем ее жизненном цикле необходимо решать вопросы, связанные с управлением ее ИБ, начиная с определения требований по ОИБ при проектировании системы и заканчивая снятием ее с эксплуатации и ликвидацией «следов функционирования» этой системы с жестких дисков и т. д. На рис. 4.7 показано влияние процессов управления ИБ только на стадии эксплуатации отдельной системы ИТТ [84].

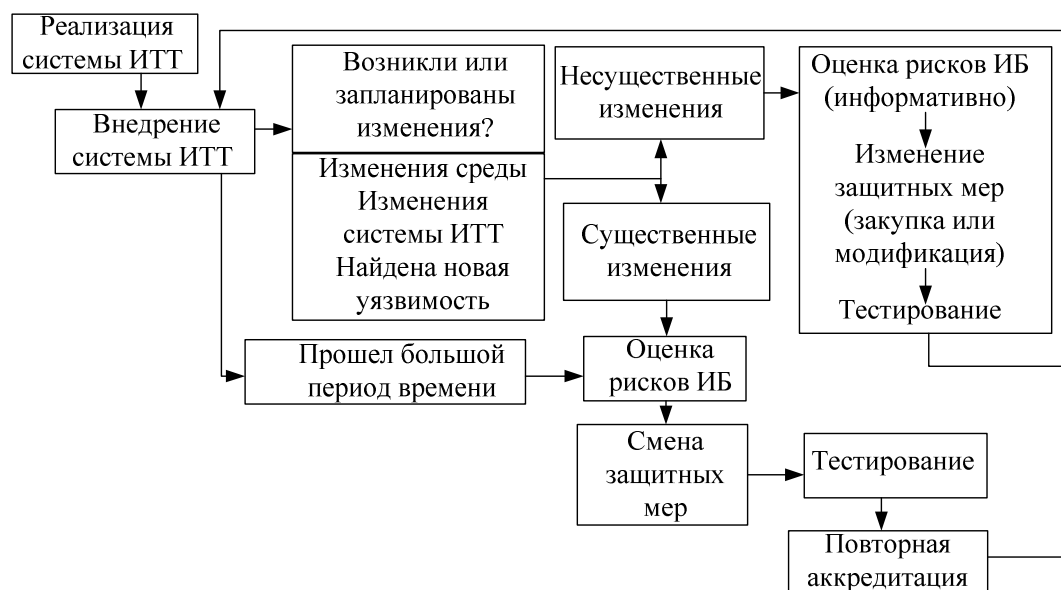


Рис. 4.7. Управление ИБ отдельной системы ИТТ на стадии ее эксплуатации

4.5. Система управления ИБ организации

Процесс управления ИБ организации реализуется СУИБ, включающей в себя помимо самого управляемого (защищаемого) объекта средства управления его состоянием, механизм сравнения текущего состояния с требуемым и средства формирования управляющих воздействий для локализации и предотвращения ущерба вследствие реализации угроз ИБ. Критерием управления в данном случае целесообразно считать минимум ущерба для активов организации при минимальных затратах на обеспечение их информационной безопасности, а целью управления – обеспечение требуемого состояния активов (управляемого объекта) в смысле защищенности.

СУИБ определяется как часть общей системы управления организации, основанная на подходе оценки и анализа бизнес-рисков, предназначенная для разработки, внедрения, эксплуатации, постоянного контроля, анализа, поддержания и улучшения ИБ и включающая организационную структуру, политику, планирование действий, обязанности, установившийся порядок, процедуры, процессы и ресурсы в области ИБ [14, 21].

СУИБ в организации выполняет следующие важнейшие функции:

- реализует целенаправленный, систематический и комплексный подход к управлению ИБ защищаемых активов, что приводит к повышению текущего уровня их защищенности;
- объединяет все применяемые в организации защитные и организационные меры в единый, адекватный реальным угрозам ИБ и управляемый комплекс, позволяющий достигать целей ОИБ на уровне всей организации;
- позволяет четко установить, как взаимосвязаны процессы и подсистемы ОИБ, кто за них отвечает, какие финансовые и трудовые ресурсы необходимы для их эффективного функционирования и т. д.;
- проводит процесс выполнения ПолИБ и позволяет находить и устранять слабые места в ОИБ;
- охватывает людей, процессы и ИТ-структуру организации.

Систематизируя представленные в различных источниках отрывочные сведения об отдельных элементах СУИБ, следует подчерк-

нать, что для выполнения перечисленных выше функций СУИБ конкретной организации должна включать в себя следующие важнейшие компоненты:

- соответствующую организационную структуру с поддерживающими ее подсистемами автоматизации функционирования СУИБ (документооборот, обработка, хранение и передача данных и т. п.), организации управления и собственной защиты;

- модель функционирования СУИБ (например, процессно-ролевая);

- методики и методы управления ИБ (методика управления ИБ общий свод правил, алгоритмов, приемов управления ИБ; метод управления ИБ, путь практического осуществления деятельности по управлению ИБ, способ достижения определенной цели в рамках ОИБ);

- документальное обеспечение функционирования СУИБ (политика СУИБ, планы СУИБ, процедуры, регламенты и т. д.);

- деятельность по планированию, реализации, проверке и совершенствованию СУИБ с соответствующими средствами выполнения конкретной деятельности;

- ответственность всех участвующих в процессе управления ИБ, и тех, кто попадает в область действия СУИБ;

- процессы управления ИБ, выполняемые на основе СУИБ;

- средства управления ИБ;

- необходимые ресурсы.

Средства управления ИБ организации, используемые в рамках СУИБ, выбираются на основе результата оценки рисков ИБ как части более общего процесса управления рисками ИБ и снижают риск до приемлемого уровня, при этом принимая во внимание и другие бизнес-риски организации. Обязательно должны быть определены, документированы, реализованы и поддерживаемы в рабочем состоянии технические средства управления ИБ. Но со временем действие различных внутренних и внешних обстоятельств (например, изменение ИС, реконфигурирование функций защиты, изменения окружающей среды, появление новых атак) может негативно сказаться на эффективности используемых в организации средств управления ИБ и в конечном счете потребовать пересмотра стандартов ИБ организации. Поэтому так важно адекватно изменять средства управления ИБ, что делается на основе постоянного анализа и технической проверки (вручную или с использованием инструментальных средств) правильности их реализации и функционирования.

Более упрощенно наглядное представление основных компонентов СУИБ показано на рис. 4.8 [16]. Процессы ОИБ поддерживаются ПолИБ и концепцией ОИБ, в которых сформулированы цели и стратегия ОИБ, а также организация самих процессов. Следовательно, СУИБ является неотъемлемой частью СОИБ.



Рис. 4.8. Основные компоненты СУИБ

Область действия СУИБ, ее администрирование и ресурсы зависят от размеров организации и ее защищаемых активов.

Чтобы быть действительно полезной для организации, СУИБ должна быть эффективной. Правильно разработанная, должным образом реализованная и применяемая СУИБ позволит не только вернуть затраченные на нее средства, но и внесет положительный вклад в успех бизнеса организации.

Как показывает накопленный в данной области мировой и отечественный опыт, эксплуатация СУИБ даст организации ряд бесспорных выгод от ее использования:

- обеспечение соответствия уровня ИБ законодательным, отраслевым, контрактным, внутрикорпоративным требованиям и целям бизнеса;
- доказательство стремления высшего руководства к ОИБ в необходимом объеме для всей организации в соответствии с установленными требованиями;
- повышение доверия партнеров, клиентов, заказчиков за счет демонстрации высокого уровня ОИБ всем заинтересованным сторонам;

- управляемое ОИБ и контролируемое управление ИБ (особенно в критичных ситуациях);
- систематизация процессов ОИБ;
- расстановка приоритетов в области ИБ;
- достижение «прозрачности» в ОИБ;
- обеспечение понятности защищаемых активов для руководства;
- выявление угроз ИБ для бизнес-процессов;
- достижение адекватности ОИБ существующим рискам;
- предупреждение возникновения инцидентов ИБ и снижение ущерба в случае их возникновения;
- повышение культуры ИБ в организации;
- интеграция защитных мер в бизнес-процессы;
- оптимизация (за счет формализации всех процессов ОИБ) и обоснование расходов на ИБ;
- снижение финансовых рисков и рисков прямых потерь;
- снижение операционных рисков за счет повышения экономической эффективности ОИБ;
- снижение рисков для инвесторов за счет повышения прозрачности процессов внутри организации;
- экономия времени, ресурсов и затрат на начальной стадии сбора информации при проведении любых аудитов ИБ;
- создание информации, порождаемой в процессе использования СУИБ, полезной для всех заинтересованных сторон, и т. д.

Поскольку внедрение СУИБ требует значительных ресурсов, все организации должны четко осознавать преимущества ее использования. Различные организации имеют разные бизнес-стимулы для этого, включая нормативную и правовую базу, статус (крупный или малый бизнес, общественная или правительственная организация), географическое расположение, сферу деятельности (вид бизнеса) и предоставляемые ею услуги (или производимую продукцию) и т. п.

Внедрение СУИБ должно стать стратегическим решением руководства организации. На ее проектирование и использование оказывают влияние потребности и цели, требования по ОИБ, применяемые процессы, а также размер и структура организации. Все эти элементы и поддерживающие их системы изменяются во времени. Поэтому и СУИБ будет также меняться соответственно потребностям организации.

Деловая аргументация для внедрения СУИБ должна быть четко документирована и подробно излагать ожидаемые затраты в сравнении с выгодами, которые могут быть получены от увеличения возможностей управления ИБ. СУИБ не должна создаваться в изоляции. Она должна учитывать все бизнес-риски и общие бизнес-стратегии организации [30].

Область действия СУИБ. Стандарты по управлению ИБ, в частности ГОСТ Р ИСО/МЭК 27001, оперируют понятием области действия СУИБ. Это область и границы применения СУИБ в терминах характеристик бизнеса, организации, ее расположения, ресурсов и технологий [14, 21]. Область действия СУИБ должна соответствовать как возможностям организации, так и ее ответственности за ОИБ в соответствии с требованиями, определенными в применимых к данной организации законодательных, нормативных и иных документах и соотносенными с проведенной для нее оценкой рисков ИБ.

Установление области действия СУИБ полностью зависит от организации. Необходимо, чтобы она была правильно определена, была полной и реально применимой, учитывала все зависимости, например, требования по ОИБ, которые должны быть выполнены при функционировании данной СУИБ, и интерфейсы с другими частями организации, находящимися вне области действия, а также другими системами, организациями, сторонними поставщиками. В этом случае другие части организации, которые необходимы СУИБ для повседневного функционирования (например, кадровые ресурсы, финансы, продажи и маркетинг или коммунальные службы), являются интерфейсами и зависимостями в дополнение к любым другим существующим интерфейсам и зависимостям.

Как видно из определения, в область действия СУИБ организации включаются:

- бизнес-процессы;
- технологии;
- активы (кадры, финансовые (денежные) средства, средства вычислительной техники, телекоммуникационные средства, различные виды информации, процессы, продукты и услуги, предоставляемые всем заинтересованным сторонам, клиентам, партнерам и т. д.);
- обоснование выбора ограниченной части организации (перечисление конкретных офисов, входящих в область действия) или всей организации в целом.

При выборе области действия СУИБ, в которой силами специально созданной рабочей группы будут внедряться процессы СУИБ, учитываются следующие факторы:

- деятельность и услуги (продукция), предоставляемые организацией своим партнерам и клиентам;
- целевая информация, ИБ которой должна быть обеспечена;
- бизнес-процессы, обеспечивающие обработку целевой информации;
- подразделения и сотрудники организации, задействованные в данных бизнес-процессах;
- программно-аппаратные и технические средства, обеспечивающие функционирование данных бизнес-процессов;
- территориальные площадки организации, в рамках которых происходят сбор, обработка и передача целевой информации.

В стандарте ISO/IEC 27003:2010 приведены примеры возможных целей управления ИБ, которые могут быть использованы в качестве входных данных для определения первоначальной области действия СУИБ [23]:

- содействие ОНБ и восстановлению после сбоев;
- повышение устойчивости к инцидентам ИБ;
- соответствие правовым требованиям и договорным обязательствам;
- создание условий для сертификации по стандартам ISO/IEC;
- создание благоприятных условий для эволюции организации и укрепления ее позиции;
- сокращение расходов на средства управления ИБ;
- защита активов, имеющих стратегическое значение;
- создание жизнеспособной и эффективной системы внутреннего контроля;
- обеспечение гарантий для заинтересованных сторон того, что информационные ресурсы защищены надлежащим образом.

Хорошей практикой при определении области действия будущей СУИБ является выбор одного из ключевых бизнес-процессов организации. Это объясняется тем, что в рамках наиболее критичных бизнес-процессов можно наиболее полно ощутить преимущества построения СУИБ, так как основной из целей ее создания является обеспечение адекватных и соразмерных средств управления ИБ, которые защищают активы и обеспечивают конфиденциальность для всех заинтересованных сторон, включая владельцев бизнеса. Также

появляется возможность постоянного мониторинга ОИБ в рамках выбранной области действия СУИБ, что позволяет своевременно принимать оперативные решения, затрагивающие все аспекты ОИБ, и повысить доверие к организации в целом.

Основной результат деятельности по определению области действия СУИБ – это документ, включающий следующее:

- сводку поручений по управлению ИБ, установленных руководством организации, и обязательств, налагаемых на внешние организации;
- описание того, как части области действия взаимодействуют с другими системами управления;
- список бизнес-целей управления ИБ;
- список критических бизнес-процессов, систем, информационных активов, организационных структур и географических районов, где будет применяться СУИБ;
- взаимоотношения существующих систем управления, регулирующих и надзорных органов, целей организации;
- характеристики бизнеса, самой организации, ее местонахождения, активов и используемых технологий.

Выбор области действия будущей СУИБ не такая простая задача, как кажется с первого взгляда. В рамках большой организации, предоставляющей внешние услуги своим заказчикам, для выбора области действия может потребоваться ведение отдельного проекта. В основе этого проекта будет лежать глубокий анализ существующих бизнес-процессов организации, их взаимосвязей, выходных результатов каждого из процессов и анализ заинтересованных сторон в рамках каждого из процессов. Даже в небольшой организации, где, казалось бы, есть всего несколько ключевых бизнес-процессов, подобный анализ очень полезен, так как в результате может быть получена непредвиденная заранее картина, в которой проявятся неочевидные взаимосвязи между процессами, и фокус критичности бизнес-процессов может быть смещен в другую сторону.

Довольно часто в качестве области действия СУИБ выбирается процесс поддержки работоспособности какой-либо АС. Обобщая имеющиеся лучшие практики разработки эффективных СУИБ, важно понимать, что для области действия СУИБ ключевыми (базовыми) понятиями являются процессы, а не АС (это одно из важнейших отличий существующих стандартов по СУИБ от требований по ОИБ АС, например, руководящих документов Федеральной служ-

бы по техническому и экспортному контролю). Поэтому выделяется некий процесс, например поддержки работоспособности рассматриваемой АС (если стоит такая задача). Тогда в данном случае для построения СУИБ необходимо идентифицировать процессы, которые войдут в область деятельности СУИБ и в которых участвует АС.

В случае если существует необходимость охватить СУИБ более чем одно подразделение организации, ее администрирование, управление и аудит все равно осуществляется централизованным образом, СУИБ подвергается анализу со стороны высшего руководства организации. Для всех подразделений, для которых функционирует СУИБ, аудит ИБ проводится в соответствии с внутренними процедурами организации. Особое внимание следует уделить тому, чтобы соответствующим образом определить интерфейсы и зависимости, учесть их при оценке рисков ИБ, а результаты этой оценки надлежащим образом отразить в системе реализуемых процессов управления ИБ. Но можно поступить иначе и для каждого подразделения построить разные СУИБ, которые будут управляться локально. Впоследствии при росте уровня зрелости всех локальных СУИБ и при постановке соответствующей задачи со стороны высшего руководства возможно их объединение в единую СУИБ, область деятельности которой будет распространяться сразу на несколько территориально распределенных подразделений организации.

Результаты определения применимой области действия СУИБ оказывают существенное влияние на объемы работ, которые необходимо будет выполнить при планировании СУИБ.

Документальное обеспечение СУИБ. Любые процессы управления базируются на поддерживающем их документальном обеспечении (далее – документации). Управленческие процессы СУИБ не являются исключением. Все вышеперечисленные национальные и международные стандарты для СУИБ требуют, чтобы в процессе внедрения СУИБ был разработан объемный пакет документации. Неправильно организованный процесс ее разработки может привести к серьезному перерасходу ресурсов и, более того, снизить эффект от внедрения СУИБ.

В рамках СУИБ используется достаточно большое количество различных документов, которые имеют свой жизненный цикл, – они создаются, согласуются, пересматриваются, исполняются, хранятся и т. д. По отдельным процессам управления ИБ создаются докумен-

ты, содержащие записи, свидетельствующие о работе этих процессов (например, протокол аудита ИБ и заполненные формы разрешения доступа). Регистрация таких записей предусматривает идентификацию, сбор, заполнение, хранение и ведение зарегистрированных данных. Все документы, относящиеся к СУИБ, должны находиться под ее управлением, а именно: учитываться, легко идентифицироваться, контролироваться с точки зрения версий и актуальности [5, 14, 21].

Существующие стандарты по управлению ИБ определяют совокупность обязательных требований по управлению документами и записями, которые должны обеспечить их адекватную защищенность и управляемость и использовать соответствующие процедуры и процессы [14, 21]. Эти требования согласованы с требованиями, содержащимися в других стандартах по системам управления, например в ГОСТ Р ИСО 9000-2001 [5]. Соблюдение данных требований дает организации ряд преимуществ (включая возможность проведения совместных/комплексных аудитов), позволяет сэкономить средства, необходимые для управления и сопровождения документации СУИБ, помогает лучше контролировать бизнес-активы и в результате обеспечить комплексное управление ИБ. Кроме этого управление документами и записями составляет важную часть процесса управления рисками ИБ, которая должна реализовываться параллельно с другими процессами управления ИБ.

Цели и выгоды наличия документации СУИБ для организации очевидны: детальное описание СУИБ и представление информации о ней всем заинтересованным и попадающим в область действия СУИБ лицам для лучшего понимания деятельности по управлению ИБ и своего места в этой деятельности.

Объем документации СУИБ может различаться у организаций вследствие их разного размера и вида деятельности, сложности процессов управления ИБ и их взаимодействия, а также компетенции создававшего их персонала.

В документацию СУИБ обычно включаются следующие документы:

- политика СУИБ;
- руководства по процессам управления ИБ;
- документированные процедуры;
- рабочие инструкции;
- формы и шаблоны;
- планы работ;
- спецификации;

- внешние документы (международные и национальные стандарты);
- отчетные документы и т. п.

Чтобы определить иерархию документации СУИБ, следует воспользоваться примером, описанным в рекомендациях РС БР ИББС-2.0-2007 «Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Методические рекомендации по документации в области обеспечения информационной безопасности в соответствии с требованиями СТО БР ИББС-1.0» [75], где определяется состав внутренних документов (документированной информации) по ОИБ. Возможное наполнение каждого уровня иерархии документов по ОИБ БС РФ (см. рис. 3.2) представлено на рис. 4.9.



Рис. 4.9. Иерархия документов по ОИБ БС РФ

Тогда по аналогии иерархия документов СУИБ может быть составлена следующим образом (рис. 4.10).

Документы СУИБ *первого уровня* включают политику СУИБ и, возможно, детализирующие ее подполитики (например, обработки рисков ИБ, инцидентов ИБ и т. п.).

Второй уровень представлен документами СУИБ:

1. Планы работ по управлению ИБ. В их состав входят: планы мероприятий по обеспечению деятельности в рамках управления ИБ, реализации и внедрению процедур, требований и мер по ОИБ, управ-

лению документами, связанными с СУИБ; планы обработки рисков ИБ; планы мероприятий на случай возможных инцидентов ИБ; планы работ по обслуживанию аппаратных средств и программных систем, используемых для ОИБ, обучению и повышению осведомленности работников организации и т. д. В них описываются перечень, порядок (последовательность), объем (в той или иной форме), сроки выполнения работ, а также руководители, исполнители и ответственность за выполнение работ.



Рис. 4.10. Пример иерархии документов СУИБ

2. Описания (стандарты) технологий ОИБ. Эти документы устанавливают требования и характеристики, предназначенные для всеобщего и многократного использования, касающиеся деятельности по ОИБ, осуществляемой в рамках и на основе СУИБ. Они могут разрабатываться в отношении как специализированных технологий ОИБ, так и технологий, реализуемых ИС, применяемыми в организации для ведения бизнеса.

Третий уровень – наиболее объемная часть документации, описывающая конкретные действия каждого участника процесса управления ИБ. Этот уровень составляют документы СУИБ, содержащие требования к процедурам управления ИБ, выполняемым как структурными подразделениями организации, так и ее сотрудниками в рамках технологических процессов, реализующих технологии, требования по ОИБ к которым определены в различных ПолИБ организации и политике СУИБ.

В этих документах даются детализированные описания, приводятся конкретные приемы и порядки выполняемых действий и/или вводимых ограничений, что должно позволить четко определить правила выполнения задач управления ИБ на каждом рабочем месте, для каждой роли ИБ, а также установить конкретную ответственность за выполнение предписанных требований. В разработке документов принимают участие специалисты по ИБ, отдела кадров, управления ИТ, службы физической защиты, юридического отдела и т. п.

Основными пользователями данной группы документов являются руководители подразделений, системные администраторы, ответственные за ОИБ конкретных активов.

Документы СУИБ третьего уровня могут быть утверждены лицами, ответственными за реализацию соответствующих видов деятельности по управлению ИБ. К этой группе документов СУИБ относятся, например:

- инструкции, в том числе и должностные;
- руководства, например по классификации защищаемых активов;
- методические указания;
- документы, содержащие требования к конфигурациям программно-аппаратных СЗИ с указанием конкретных значений параметров систем и их компонентов, а также способы их настройки, позволяющие обеспечить требуемый уровень ИБ.

Инструкции, руководства, методические указания по управлению ИБ, к которым предъявляются повышенные требования четкости и ясности изложения текста, содержат свод правил, устанавливающих порядок и способ выполнения отдельных операций по управлению ИБ. Эти документы обычно определяют следующее:

- субъект (субъектов), деятельность которого регламентируется документом, и/или наименование этой деятельности;
- ресурсы, необходимые для выполнения деятельности;
- детальное описание выполняемых операций, включая накладываемые ограничения, и результат выполнения операций;
- обязанности субъекта (субъектов) в рамках выполнения регламентируемой деятельности;
- права и ответственность субъекта (субъектов).

Более подробно документирование по отдельным процессам управления ИБ рассмотрено в п. 4.7.

Четвертый уровень составляют документы СУИБ, содержащие свидетельства записи о результатах реализации деятельности по

управлению ИБ, регламентированной документами верхних уровней иерархии. Все эти документы СУИБ вместе могут служить документированным доказательством реализации деятельности по управлению ИБ при проведении внутреннего контроля и аудитов ИБ организации.

К данной группе документов относятся: реестры и описи (например, опись активов), регистрационные журналы (включая журналы регистрации инцидентов ИБ), протоколы (например, протокол проведения испытаний), листы ознакомления, обязательства (например, обязательства о неразглашении), акты, договоры, отчеты. Наличие документов СУИБ этого уровня определяется требованиями, зафиксированными в документах СУИБ верхних уровней иерархии. Должно обеспечиваться их архивное хранение, время которого может определяться требованиями как законодательных актов РФ, так и самой организации.

В состав документов по управлению ИБ организации рекомендуется включить документ (классификатор), содержащий перечень и назначение всех документов СУИБ для каждого из вышеопределенных уровней иерархической структуры [75].

При наличии у организации сети филиалов в каждом из них рекомендуется иметь единый для организации, утвержденный комплект документов по управлению ИБ. В случае возникновения необходимости учета специфики конкретных филиалов в них должны быть разработаны собственные документы, учитывающие эту специфику, но при этом базирующиеся на положениях документов СУИБ, принятых головной организацией, и не противоречащие им.

Все документы СУИБ обязательно защищаются, и ими нужно управлять. СУИБ как документированная система управления должна удовлетворять следующим требованиям [14, 21]:

- документы должны проверяться на адекватность до их утверждения и выпуска;
- должны осуществляться анализ и обновление документов по мере необходимости и при пересмотре документов, а также их последующее повторное утверждение;
- должна быть обеспечена идентификация изменений и статуса текущей редакции документов;
- должна быть обеспечена доступность актуальных версий соответствующих документов в местах их использования;
- должна быть сохранена удобочитаемость и легкость идентификации документов;

- должна быть обеспечена доступность документов тем, кому они требуются, а также перемещение, хранение и, наконец, уничтожение документов согласно процедурам, применяемым в соответствии с их классификацией;

- должна быть обеспечена идентификация документов внешнего происхождения;

- должны быть обеспечены контроль и управление над распространением документов;

- должны быть предприняты меры по предотвращению случайного (неумышленного) использования устаревших документов;

- должна быть применена подходящая идентификация документов, если они сохраняются для каких-либо целей.

Также должны создаваться и поддерживаться в рабочем состоянии записи, содержащие свидетельства соответствия требованиям и эффективного функционирования СУИБ [14, 21]. В записях отражаются показатели процессов управления ИБ и все эпизоды значительных инцидентов ИБ, связанные с СУИБ. Эти записи должны быть защищены и управляемы, разборчивы, легко идентифицируемы и извлекаемы. Средства управления, необходимые для идентификации, хранения, защиты, поиска, а также сроки хранения и ликвидации записей должны быть документированы и реализованы.

Как было отмечено ранее, записи играют особенно важную роль в управлении ИБ. Например, при обработке инцидента ИБ важно, чтобы он был рассмотрен с той степенью своевременности и тем уровнем приоритета, которые соответствуют его серьезности. Чтобы обработать инцидент ИБ наиболее подходящим образом, требуются некоторые данные: где и когда он произошел, при каких обстоятельствах, что произошло, какие были последствия и т. д. Такие данные могут быть получены из правильно ведущихся, точных записей. И, конечно, существуют правовые требования по сбору и представлению доказательств в случае инцидента ИБ с уголовно-правовыми последствиями. Поэтому важно не только вести записи, но и обеспечивать их защиту, включая целостность, доступность и конфиденциальность.

Управление документацией СУИБ направлено на обеспечение разработки, учета, использования, хранения, проверки, обновления (поддержания актуального состояния) и изменения документов и записей. Все документальное обеспечение СУИБ проходит несколько стадий жизненного цикла: начальную оценку необходимости разра-

ботки документа исходя из намеченных целей, собственно его разработку специально определенной группой лиц с соответствующими полномочиями и предоставленными для этого ресурсами, утверждение уполномоченным лицом и установление дат его введения и пересмотра, публикацию внутри организации (доведение до сведения всех заинтересованных лиц и лиц, на которых его действие распространяется), использование документа и непосредственное исполнение его положений, сопровождение с последующим внесением изменений или изъятием из обращения после процедуры пересмотра (рис. 4.11). Если принято решение о внесении изменений и выпуске следующей редакции, то новый цикл традиционно начитается со стадии разработки.

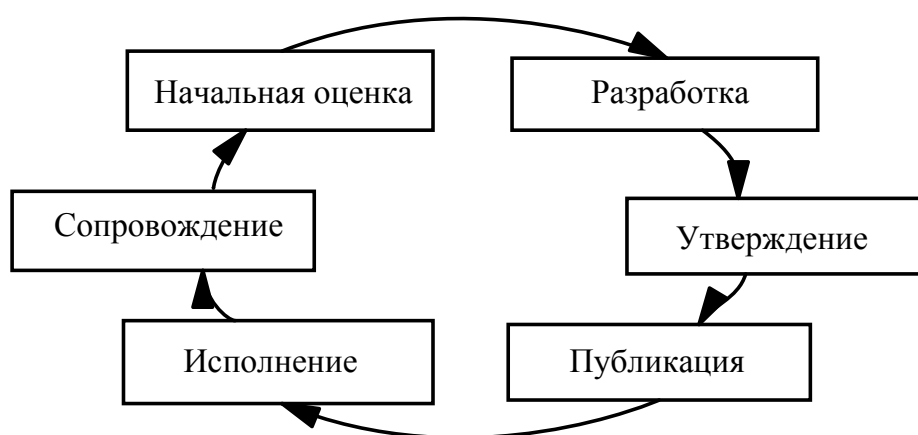


Рис. 4.11. Жизненный цикл документального обеспечения СУИБ

Организация может комбинировать документацию СУИБ с документацией других систем управления (таких как система менеджмента качества, охраны труда, экологического менеджмента), если СУИБ может быть четко идентифицирована вместе с соответствующими средствами других систем [32, 33].

Политика СУИБ. Залогом эффективного функционирования СУИБ является хорошо продуманная политика СУИБ. Это тот документ, на основе которого формулируются директивы, стандарты, процедуры, руководства и другая сопутствующая документация в области ОИБ. Поэтому, определив область действия, организация должна установить понятную и краткую политику СУИБ. Имея и применяя такую политику, организация берет под контроль направления своего развития и его результаты.

Чтобы не было дальнейшей путаницы в понятиях, следует отметить, что политика СУИБ рассматривается как надмножество (расширенное множество) ПолиБ организации [21], хотя эти две политики могут быть описаны в одном документе. Небольшим организациям может быть достаточно одной политики; организациям большего размера могут понадобиться различные политики. Если необходимо создание дополнительных политик (подполитик), то они должны быть определены на стадии, когда начинается разработка основной политики СУИБ.

Политика СУИБ – документ верхнего уровня, заявляющий о целях организации, намерениях, задачах и средствах достижения целей в определённой области действия СУИБ. Ее цель – обеспечение управления и поддержки ИБ со стороны руководства организации, поскольку для эффективного управления рисками ИБ требуется привлечение значительных ресурсов. Политика СУИБ предназначена для создания программы ОИБ (она предусматривает разработку и поддержку детальных процессов и процедур ОИБ в масштабе организации, совместимых с политикой), установления целей и задач функционирования СУИБ и распределения ответственности в рамках области действия СУИБ.

Таким образом, политика СУИБ должна [23]:

- соответствовать идентифицированной области действия СУИБ;
- включать в себя основные положения для определения целей;
- устанавливать цели функционирования СУИБ, основанные на требованиях и приоритетах в отношении ИБ организации;
- определять общие направления и принципы деятельности по отношению к ИБ, которые должны быть достигнуты при использовании СУИБ;
- учитывать бизнес-требования, а также требования нормативно-правовой базы и договорных обязательств;
- учитывать риск-ориентированный подход, принятый в организации, вводить критерии оценки рисков ИБ и определять структуру оценки рисков ИБ (например, в соответствии с ГОСТ Р ИСО/МЭК 27005-2010 [31] и ISO/IEC 27005:2008 [26]);
- устанавливать ответственность высшего руководства организации, связанную с СУИБ;
- управлять взаимосвязями со всеми партнерами, поставщиками и заказчиками, которые рассматриваются как имеющие влияние на ИБ защищаемых активов;

- устанавливать контекст управления стратегическими рисками организации, в котором будут осуществляться разработка и сопровождение СУИБ;

- быть утвержденной высшим руководством организации.

Также должно быть гарантировано, что все сотрудники организации и заинтересованные стороны, входящие в заявленную область действия СУИБ, ознакомлены с данной политикой, понимают, какое влияние она оказывает на их работу, и исполняют ее. Политика СУИБ ориентирована на непосредственных ее потребителей и гарантирует им наличие работоспособной СУИБ, действительно эффективно функционирующей в организации.

Рекомендуется иметь политику СУИБ краткую и концентрирующуюся на глобальных аспектах. В ней не должно быть конкретного и детального описания проблем и шагов, необходимых для внедрения и исполнения этой политики.

Чтобы удовлетворить всем требованиям, хорошая политика СУИБ, как и ПолиБ, должна соответствовать целям организации, быть применимой, осуществимой для внедрения, превентивной, легкой в понимании, избегать абсолютных понятий.

Формат политики СУИБ определяется внутри организации. Важно, чтобы она воспринималась как программный документ, который хочется прочесть, а не бегло просмотреть и проигнорировать.

Политика СУИБ должна охватывать следующие ключевые процессы СУИБ:

- управление рисками ИБ;
- управление инцидентами ИБ;
- управление аудитами ИБ;
- управление эффективностью СУИБ;
- управление персоналом;
- управление документацией и записями СУИБ;
- анализ функционирования СУИБ руководством организации;
- пересмотр и совершенствование СУИБ;
- управление корректирующими и предупреждающими действиями в области ОИБ;
- УНБ.

Как и ПолиБ, политику СУИБ необходимо периодически пересматривать на предмет актуализации ее целей и основных положений.

Поддержка СУИБ со стороны руководства организации. Руководство организации играет весьма важную роль на всех этапах жизненного цикла СУИБ, начиная от разработки и заканчивая ее постоянным совершенствованием. В связи с этим стандарты ISO/IEC 27001 и ГОСТ Р ИСО/МЭК 27001 вводят ряд требований [14, 21]. Руководство должно продемонстрировать свою поддержку разработки, ее внедрения, обеспечения функционирования, мониторинга, анализа и улучшения СУИБ посредством:

- разработки и утверждения политики СУИБ;
- обеспечения разработки целей и планов СУИБ;
- определения функций и ответственности в области ИБ;
- информирования сотрудников организации о важности достижения целей ОИБ и ее соответствия требованиям политики организации, об их ответственности перед законом и необходимости непрерывного совершенствования в реализации защитных мер;
- предоставления необходимых и достаточных ресурсов для внедрения, обеспечения функционирования, мониторинга, анализа, поддержки и улучшения СУИБ;
- установления критериев принятия рисков ИБ и уровней их приемлемости;
- обеспечения проведения внутренних аудитов СУИБ;
- проведения анализа СУИБ.

Прямо выраженная явная и реальная поддержка со стороны руководства организации требуется при определении и предоставлении ресурсов, которые необходимы для следующего:

- разработки, внедрения, обеспечения функционирования, мониторинга, анализа и улучшения СУИБ;
- поддержки требований бизнеса процедурами ОИБ и рассмотрения вопросов ОИБ для всех процессов и проектов, где используется информация и ИТ;
- выявления и обеспечения выполнения требований соответствующих законов, нормативных актов, а также договорных обязательств в области ОИБ;
- поддержания адекватной ИБ путем правильного применения всех реализованных мер управления ИБ;
- проведения при необходимости анализа и принятия соответствующих мер по его результатам;
- повышения при необходимости результативности СУИБ.

Также при поддержке руководства организация должна обеспечить необходимую квалификацию персонала, на который возложены обязанности выполнения задач в рамках СУИБ за счет реализации ряда мер:

- определения требуемого уровня знаний и навыков для персонала, выполняющего работу, влияющую на СУИБ;
- организации обучения персонала или принятия других мер (например, наем компетентного персонала) для удовлетворения указанных потребностей;
- оценки результативности предпринятых действий;
- ведения записей об образовании, навыках, опыте и квалификации сотрудников.

Организация также должна обеспечить понимание всеми сотрудниками значимости и важности деятельности в области ОИБ и их роли в достижении целей СУИБ.

Если отойти от формальных требований стандартов и задуматься, кто, кроме высшего руководства организации, обладает достаточными полномочиями для принятия решений и выполнения перечисленных действий, то можно прийти к выводу, что только высшее руководство в состоянии осуществлять эту деятельность, столь необходимую для полноценной жизни СУИБ. В этом случае появляется уверенность в том, что для СУИБ будут предоставлены все необходимые ресурсы, все управленческие решения будут также приняты в срок и с учетом стратегических целей бизнеса организации.

Бывает, что проекты по построению СУИБ инициируются руководителями подразделений ИБ. Тогда им необходимо потратить достаточно много времени, чтобы донести до высшего руководства организации все преимущества построения СУИБ, а также очертить круг задач, которые нужно решить в ходе ее построения и эксплуатации.

Помимо этого в рамках всех стадий жизненного цикла СУИБ требуется постоянная работа высшего руководства и принятие дополнительных управленческих решений. Введение СУИБ в действие должно быть утверждено руководством организации, например, соответствующим приказом по организации. Для регулярного анализа результатов работы СУИБ руководство должно принимать необходимые решения по улучшению или модификации процессов управления ИБ. На рассмотрение руководства организации выносятся результаты и вопросы функционирования СУИБ, статистика по процес-

сам управления ИБ, запросы заинтересованных сторон на внесение изменений в СУИБ и т. д. По результатам данного процесса на регулярной основе руководство организации выносит решения по всем аспектам работы СУИБ, требующим доработки.

Ценность этих результатов заключается в том, что все решения, принимаемые руководством, согласованы с общей бизнес-стратегией организации. Это очень важно, в самом определении СУИБ подчеркивается, что она является частью общей системы управления организации, и все решения, принимаемые в рамках СУИБ, должны учитывать цели и задачи бизнеса организации.

4.6. Процессный подход в рамках управления ИБ

Чтобы функционировать эффективно, организация должна идентифицировать различные виды осуществляемой деятельности и управлять ими. Как было отмечено ранее, любое действие, использующее ресурсы и управляемое с целью преобразования входных данных в выходные, может рассматриваться как процесс. Применение системы процессов в организации, идентификация и взаимодействие этих процессов, а также управление этими процессами может быть названо процессным подходом. Все это справедливо и в отношении обеспечения и управления ИБ, так как любые действия в рамках данных видов деятельности могут рассматриваться как процессы.

К управлению ИБ применим процессный подход, который распространяется на разработку, реализацию, эксплуатацию, мониторинг, анализ, сопровождение и совершенствование СУИБ организации. Поддержание на должном уровне СУИБ требует применения такого же подхода, как и любая другая система управления. Используемая в ISO/IEC 27001 и ГОСТ Р ИСО/МЭК 27001 для описания процессов СУИБ циклическая модель Р ИСА предусматривает непрерывный цикл мероприятий: «планирование – реализация – проверка – совершенствование» [11, 21]. При таком подходе к управлению ИБ особое значение придается следующему:

- пониманию требований по ОИБ организации и необходимости определить политику и цели ОИБ;
- внедрению и использованию обоснованных защитных мер для управления рисками ИБ организации в контексте общих бизнес-рисков организации;

- мониторингу и анализу результативности и эффективности СУИБ;
- постоянному совершенствованию, основанному на объективных показателях.

На текущий момент интерес к циклической модели связан, прежде всего, с проблемами внедрения и совершенствования современных систем управления, в частности СУИБ. Одна из основных целей внедрения СУИБ – создание таких условий в организации, когда происходит постоянный мониторинг и улучшение каждого из процессов ОИБ и смежных процессов. Взаимно усиливая друг друга, эти улучшения позволяют создать все более совершенную систему.

Частным критерием улучшения каждого из процессов может служить снижение числа несоответствий, выявляемых в ходе различных проверок, таких как внутренние аудиты ИБ, мониторинг эффективности процессов и т. д. Появление несоответствий можно рассматривать как возникновение некоторой проблемы, решение которой ведет к улучшению процесса (после этого она не возникает снова), а следовательно, и к достижению запланированных результатов, удовлетворению всех заинтересованных сторон и реализации принципа постоянного улучшения.

Каждый факт появления несоответствия должен приводить к выполнению определенной последовательности действий, а именно:

- коррекция (устранение несоответствия);
- анализ несоответствия;
- установление коренной причины его появления;
- определение корректирующих действий, направленных на устранение причины несоответствия;
- выполнение этих действий;
- анализ их результативности и эффективности.

Если же в ходе проверок удастся выявить факты, которые могут в будущем привести к возникновению несоответствий, то следует осуществить все вышеперечисленные действия, но только теперь их целью должно быть устранение причин потенциальных несоответствий.

Процессный подход к СУИБ показан на рис. 4.12 [11, 14, 21]. СУИБ принимает в качестве входных данных требования по ОИБ и ожидания заинтересованных сторон, и в результате ряда необходимых действий и процессов на выходе получается управляемая ИБ, которая удовлетворяет этим требованиям и ожиданиям.

На стадии планирования обеспечивается правильное задание контекста и масштаба СУИБ, оцениваются риски ИБ, предлагается соответствующий план обработки этих рисков.

На стадии реализации внедряются решения, принятые во время планирования.

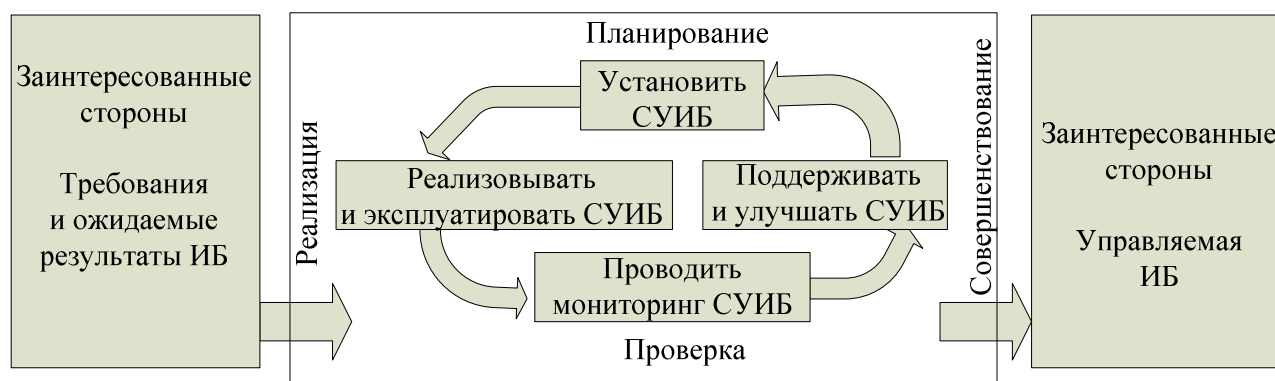


Рис. 4.12. Цикл PDCA в применении к процессам СУИБ

Чтобы гарантировать, что СУИБ в целом достигает своих целей, необходимы периодические проверки. На стадиях проверки и совершенствования усиливают, исправляют и совершенствуют решения по СУИБ, которые были определены и уже реализованы. В зависимости от конкретной ситуации проверки СУИБ могут проводиться в любое время и с любой периодичностью. В некоторых системах с целью обеспечения немедленного выполнения и реагирования они должны быть встроены в автоматизированные процессы. Для других процессов реагирование требуется только в случае инцидентов ИБ, когда в защищаемые активы внесены изменения или дополнения или произошли изменения угроз ИБ и уязвимостей.

Процесс непрерывного совершенствования обычно требует первоначального инвестирования в документирование деятельности, формализацию подхода к управлению рисками ИБ, определению методов анализа и выделению ресурсов и т. п. Эти меры используются для приведения цикла в действие. Они не обязательно должны быть завершены, прежде чем будут активизированы стадии пересмотра СУИБ.

Детально содержание деятельности в рамках названных стадий показано на рис. 4.13.

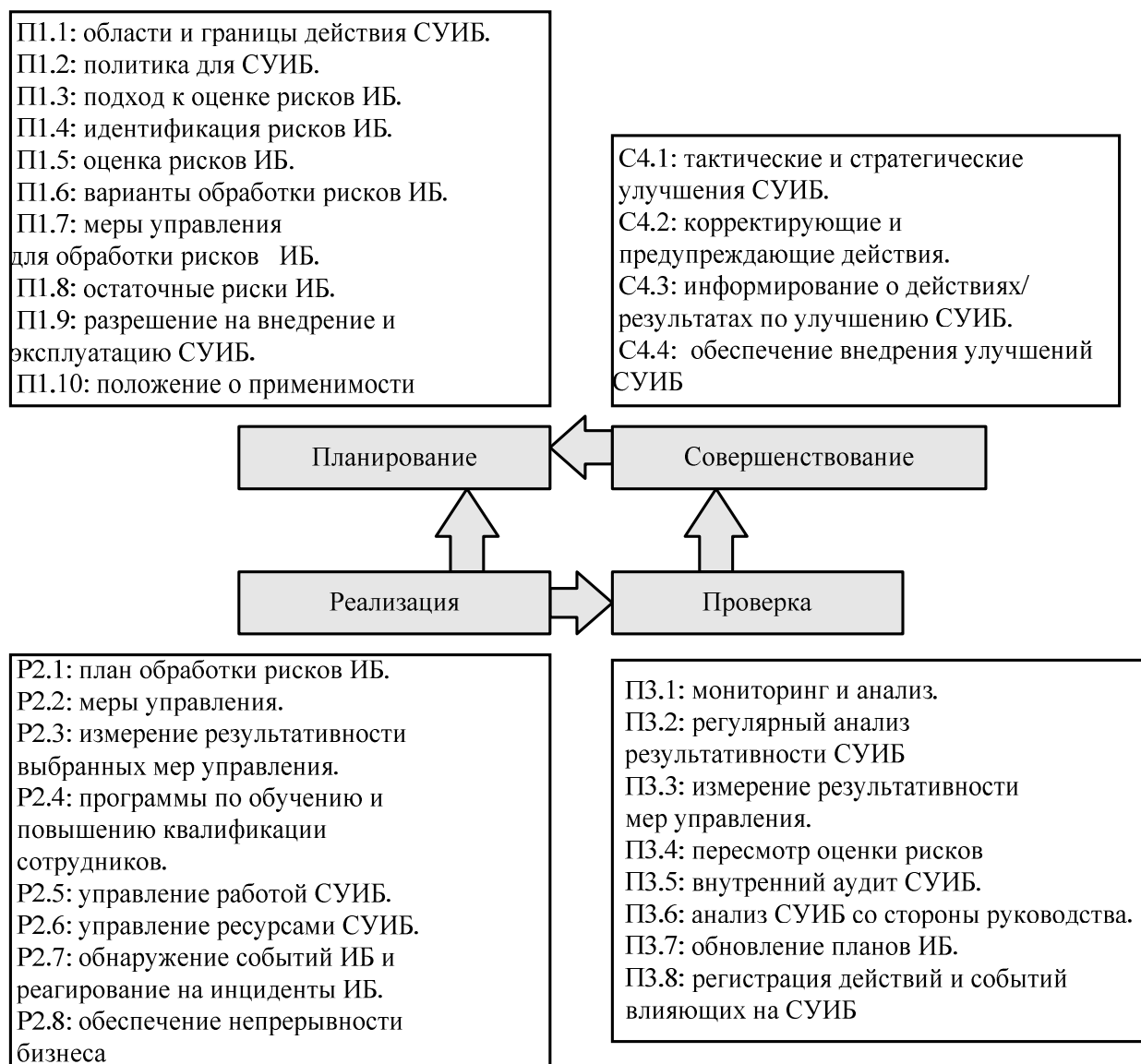


Рис. 4.13. Процессы цикла PDCA в применении к процессам СУИБ

Планирование СУИБ. Применительно к СУИБ на этапе планирования осуществляется ее непосредственная разработка: устанавливается область действия и политика для СУИБ, определяются цели, задачи, процессы и процедуры, адекватные потребностям бизнеса в управлении рисками ИБ и позволяющие повысить уровень ИБ, а также получить результаты, соответствующие общим политикам и целям организации.

Целью выполнения деятельности в рамках группы процессов «планирование» является запуск цикла СУИБ путем определения

первоначальных планов ее построения, ввода в действие и контроля, а также определения планов по совершенствованию на основании решений, принятых на этапе «Совершенствование» (если это уже не первый цикл).

Сочетая при создании СУИБ различные принципы управления в каждом отдельном контуре защиты объекта, можно добиться оптимального соотношения эффективности и стоимости ОИБ. Разработка СУИБ, как и любой другой системы управления, основывается на трех базовых принципах управления [97]:

1. Разомкнутое управление. Заранее сформированные требования реализуются исполнителями ОИБ, воздействуя на объект защиты. Достоинство – простота; недостаток – низкая эффективность защиты, так как трудно заранее предугадать момент воздействия и вид угрозы ИБ.

2. Компенсация. В контур управления ИБ оперативно вводится информация об обнаруженной угрозе ИБ, в результате чего исполнители ОИБ концентрируют свои усилия на ее локализации и противодействии ей. Достоинство – более высокая эффективность; недостатки – трудность правильного обнаружения угрозы ИБ и невозможность устранения последствий внутренних угроз.

3. Обратная связь. Обнаруживается не сама угроза ИБ, а реакция системы на нее и степень нанесенного ущерба. Достоинства – конкретность и точность отработки последствий внешних и внутренних угроз ИБ (экономическая целесообразность); недостаток – запаздывание (инерционность) принимаемых защитных мер.

Выполнение деятельности на данной стадии заключается в обследовании организации с целью определения степени соответствия требованиям по ОИБ и к СУИБ, определении/корректировке области действия СУИБ, разработке плана мероприятий по построению СУИБ с учетом выбранной области и степени соответствия требованиям к СУИБ в границах области деятельности, формализации подхода к оценке рисков ИБ и распределении ресурсов, проведении оценки рисков ИБ и определении/коррекции планов их обработки, разработке механизмов и процессов управления ИБ [14, 21].

При проведении обследования организации основными источниками информации являются документы организации (политики, про-

цедуры, инструкции и т. д.) и результаты интервьюирования сотрудников организации. После обследования организация должна выполнить следующие шаги (рис. 4.14) [14, 21, 93]:

1. Наметить/уточнить область и границы действия СУИБ с учетом характеристик бизнеса, организации, ее размещения, активов и технологий, также включая детали и обоснования любых исключений из области действия; при этом важно учесть все риски для организации (операционные, репутационные и т. п.).

2. Определить/уточнить политику СУИБ (она имеет приоритет по сравнению с ПолИБ организации, хотя они и могут быть представлены одним общим документом) на основе характеристик бизнеса организации, ее размещения, активов и технологий, которая:

- включает в себя концепцию для установки целей, основных направлений и принципов действия в отношении ИБ;
- учитывает бизнес-требования и нормативно-правовые требования (включая международные и национальные стандарты в области ОИБ), а также договорные обязательства по ОИБ;
- согласуется со стратегическим управлением рисками организации, в рамках которого будет происходить разработка и поддержка СУИБ;
- устанавливает критерии оценки рисков;
- утверждается руководством.

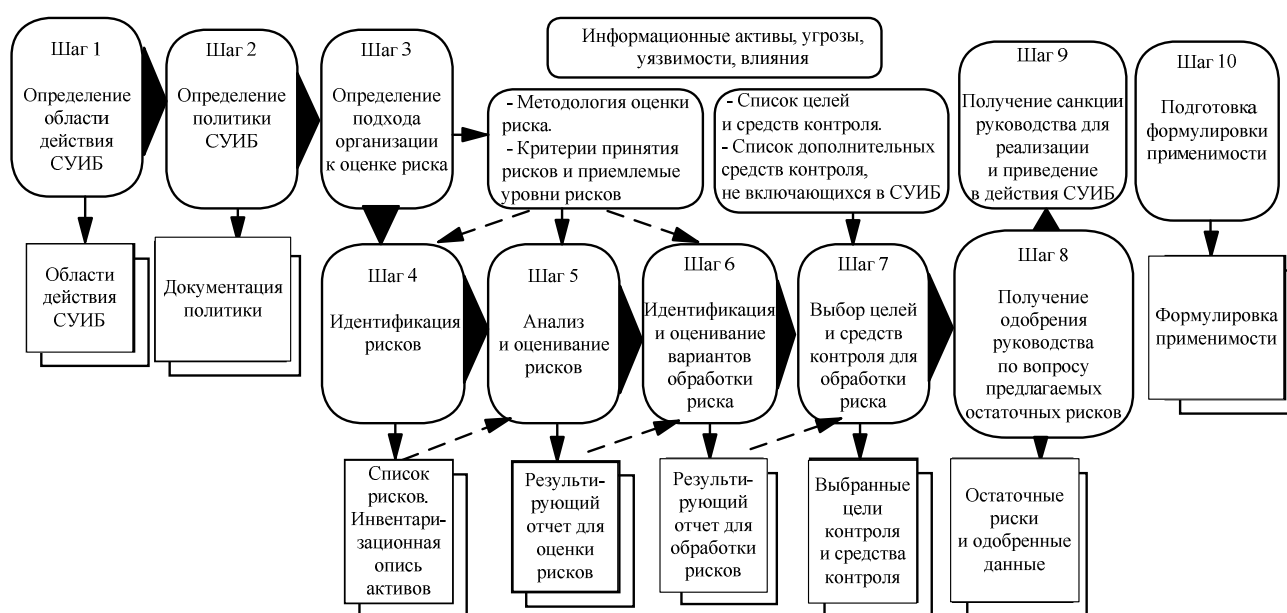


Рис. 4.14. Шаги планирования СУИБ

3. Установить/уточнить подход к оценке рисков ИБ для наиболее критичных активов и бизнес-процессов организации, включая:

- методологию оценки рисков ИБ, которая применима для СУИБ и соответствует установленным бизнес-требованиям по ОИБ и нормативно-правовым требованиям; она должна давать сравнимые и воспроизводимые результаты;

- критерии принятия рисков и приемлемые уровни риска.

4. Выявить и идентифицировать риски ИБ, определив:

- защищаемые активы в рамках области действия СУИБ, а также владельцев этих активов;

- угрозы ИБ для этих активов;

- уязвимости активов, которые могут быть использованы угрозами ИБ;

- негативные последствия, которые ведут к потере конфиденциальности, целостности и доступности активов.

5. Проанализировать и оценить риски ИБ, для чего необходимо оценить:

- ущерб для деятельности организации, который может быть нанесен в результате сбоя в ОИБ, с учетом возможных последствий нарушения конфиденциальности, целостности или доступности активов;

- реальную вероятность сбоя в ОИБ с учетом превалирующих угроз, уязвимостей и их последствий, связанных с этими активами, а также применяемых на текущий момент мер управления ИБ;

- уровни рисков;

- являются ли риски приемлемыми или требуют обработки с использованием критериев приемлемых рисков.

6. Определить и оценить различные варианты обработки рисков ИБ, среди которых:

- применение подходящих мер управления;

- сознательное и объективное принятие рисков при условии, что они полностью соответствуют требованиям политики и критериям организации в отношении принятия рисков;

- избежание риска;

- передача соответствующих бизнес-рисков сторонним организациям, например страховщикам или поставщикам.

7. Выбрать цели и меры управления (защитные меры) для обработки рисков ИБ, которые должны удовлетворять требованиям, определенным в процессе оценки и обработки рисков, с учетом критериев принятия рисков и нормативно-правовых требований и договорных обязательств.

8. Получить утверждение руководством предлагаемых остаточных рисков ИБ.

9. Получить разрешение руководства на внедрение и эксплуатацию СУИБ.

10. Подготовить Положение о применимости, которое включает:

- цели и меры управления и обоснование этого выбора;
- цели и меры управления, реализованные в настоящее время;
- перечень исключений целей и мер управления и процедуру обоснования их исключения.

Фактически представленные шаги этапа планирования СУИБ преследуют цель принятия решения организацией по трем основным вопросам:

- установление области действия и политики СУИБ (шаги 1 и 2);
- выбор защитных мер на основе управления рисками ИБ (шаги 3 – 7);
- получение одобрения руководства для мер обработки рисков ИБ и подготовка формулировки применимости требований, так как это влечет организационные и, возможно, финансовые издержки организации (шаги 8 – 10).

Все перечисленные действия являются весьма объемными и трудоемкими. Для их выполнения необходимо создание рабочей группы специалистов из разных подразделений организации, обладающих достаточными знаниями и полномочиями для принятия управленческих решений на всех этапах построения и последующего внедрения СУИБ.

Помимо этого руководство организации должно быть также заинтересовано в построении СУИБ. Важно, чтобы все решения на этапе «Планирование» были поддержаны и приняты руководством. Приверженность последнего может существенно облегчить разработку и внедрение системы.

Выходом данного этапа являются разработанные процессы управления ИБ, процедуры, поддерживающие и обеспечивающие работу этих процессов, а также инструкции для пользователей процессов и исполнителей ролей в рамках процессов.

Реализация СУИБ. На данном этапе происходит внедрение системы и разработанных процессов управления ИБ, их последующая эксплуатация, а именно внедрение и применение политики в отноше-

нии СУИБ, защитных мер, процессов и процедур СУИБ. Это весьма трудоемкий процесс, так как он требует назначения исполнителей ролей участников разработанных процессов и проведения обучения исполнителей работ, возможно оперативной корректировки процессов и т. д. [14, 21].

Этап «Реализация» осуществляется по результатам выполнения этапов «Планирование» и/или «Совершенствование» и заключается в выполнении всех планов, связанных с построением, вводом в действие и совершенствованием СУИБ, определенных на этапе планирования, и/или реализации решений, определенных на этапе совершенствования и не требующих выполнения деятельности по планированию соответствующих улучшений. Среди прочего важным является выполнение таких видов деятельности, как организация обучения и повышение осведомленности в области ИБ, реализация обнаружения и реагирования на инциденты ИБ, ОНБ.

Организация должна выбирать защитные меры, адекватные моделям угроз и нарушителей ИБ, с учетом затрат на реализацию таких мер и объема возможных потерь от реализации угроз ИБ. Должны применяться только те защитные меры, правильность работы которых может быть проверена. При этом организация должна регулярно оценивать адекватность защитных мер и эффективность их реализации с учетом влияния защитных мер на бизнес-цели.

Для реализации СУИБ организация должна предпринять следующее [14, 21]:

- а) разработать план обработки рисков ИБ, определяющий соответствующие действия руководства, ресурсы, обязанности и приоритеты в отношении управления рисками ИБ;

- б) реализовать план обработки рисков ИБ для достижения намеченных целей управления, включающий в себя вопросы финансирования, а также распределения функций и обязанностей;

- в) внедрить меры управления для достижения целей управления;

- г) определить способ измерения результативности выбранных мер управления или их групп и использования этих измерений для оценки результативности управления с целью получения сравнимых и воспроизводимых данных;

- д) реализовать программы по обучению и повышению квалификации сотрудников;

- е) управлять работой СУИБ;

- ж) управлять ресурсами СУИБ;

з) внедрить процедуры и другие меры управления, обеспечивающие быстрое обнаружение событий ИБ и реагирование на инциденты ИБ;

и) обеспечить непрерывность бизнеса организации.

Подробно поэтапные действия по внедрению СУИБ, составленные в соответствии с требованиями ГОСТ Р ИСО/МЭК 27001, ISO/IEC 27001 и немецкой методикой IT-Grundschutz, выглядят следующим образом [14, 16, 17, 21, 23]:

Этап 1 – управленческий:

- осознать цели и выгоды внедрения СУИБ;
- получить поддержку руководства на внедрение и ввод в эксплуатацию СУИБ;
- распределить ответственность по СУИБ.

Этап 2 – организационный:

- создать и обучить группу по внедрению и поддержке СУИБ;
- определить область действия СУИБ.

Этап 3 – первоначальный анализ существующей СУИБ:

- провести анализ СУИБ;
- определить перечень работ по доработке СУИБ.

Этап 4 – определение политики и целей СУИБ по каждому процессу.

Этап 5 – сравнение текущей ситуации со стандартом 27001:

- провести обучение требованиям стандарта ответственных за СУИБ;
- сравнить требования стандарта с существующим положением дел.

Этап 6 – планирование внедрения СУИБ:

- определить перечень мероприятий для достижения требований стандарта;
- разработать руководство по ИБ.

Этап 7 – внедрение системы управления рисками ИБ:

- разработать процедуру идентификации рисков ИБ;
- идентифицировать и ранжировать активы (каталог «Модули» методики IT-Grundschutz);
- определить ответственных за активы;
- оценить активы;
- идентифицировать угрозы ИБ и уязвимости активов (каталог «Угрозы» методики);
- рассчитать и ранжировать риски ИБ;
- разработать план по снижению рисков ИБ (каталог «Защитные меры» методики);

- определить неприменимые средства управления ИБ (прил. А стандарта 27001);

- разработать положение о средствах управления ИБ.

Этап 8 – разработка документации СУИБ:

- определить перечень документов (процедуры, записи, инструкции) для разработки;

- разработать следующие процедуры и документы:

- управленческие процедуры (стандарт на разработку документов, управление документами и записями; корректирующие и предупреждающие мероприятия; внутренний аудит ИБ; управление персоналом и т. д.);

- технические процедуры (приобретение, развитие и поддержка ИС; управление доступом; регистрация и анализ инцидентов ИБ; резервное копирование; управление съемными носителями и т. д.);

- управленческие записи (отчеты о внутренних аудитах ИБ; анализ СУИБ со стороны высшего руководства организации; отчет об анализе рисков ИБ; отчет о работе комитета по ИБ; отчет о состоянии корректирующих и предупреждающих действий; договоры; личные дела сотрудников и т. д.);

- технические записи (реестр активов, план предприятия, план физического размещения активов, план компьютерной сети, журнал регистрации резервного копирования, журнал регистрации факта технического контроля после изменений в ОС, журнал событий ИС, журнал регистрации действий системного администратора; журнал регистрации инцидентов ИБ, журнал регистрации тестов по непрерывности бизнеса и т. д.);

- инструкции, положения (правила работы с компьютерами и ИС, правила обращения с паролями, инструкция по восстановлению данных из резервных копий, политика удаленного доступа, правила работы с переносным оборудованием и т. д.).

Этап 9 – обучение персонала ИБ (руководители, сотрудники) требованиям ИБ.

Этап 10 – разработка и принятие мер по обеспечению работы СУИБ: внедрение средств защиты (административные, программно-аппаратные, технические).

Этап 11 – внутренний аудит СУИБ: подбор команды, планирование и проведение.

Этап 12 – анализ СУИБ со стороны высшего руководства.

Этап 13 – официальный запуск СУИБ: приказ о введении в действие СУИБ.

Этап 14 – оповещение заинтересованных сторон: информирование клиентов, партнеров, СМИ о запуске СУИБ.

Важным фактором успешного внедрения СУИБ является создание рабочей группы, ответственной за внедрение СУИБ. В ее состав должны войти:

- представители высшего руководства организации;
- представители подразделений, охватываемых СУИБ;
- специалисты подразделений, обеспечивающих ИБ в организации, имеющие соответствующее образование или подготовку, знающие основные принципы и лучшие практики в области ИБ.

Перечисленные выше сотрудники должны понимать меры защиты и процессы СУИБ, знать требования нормативной и правовой базы, поддерживаемой в организации, и пройти обучение по вопросам создания и эксплуатации СУИБ. В состав рабочей группы могут также входить привлеченные консультанты, специализирующиеся в вопросах СУИБ. Хорошей практикой является создание в организации комитета по ИБ, который, кроме вопросов, связанных с внедрением СУИБ, должен на постоянной основе обеспечить решение задач, определяемых эксплуатацией данной СУИБ и ее непрерывным совершенствованием.

Процедуры для реализации и управления СУИБ могут быть организованы как система (дерево) процессов (в терминах процессного подхода). Отдельные шаги реализации СУИБ могут быть представлены как целевые (профильные) процессы деятельности, инициируемые и завершаемые по принятым для них критериям (по времени или событию) и имеющие собственные самодостаточные регламентирующие нормы, включая организационную и ресурсную поддержку [93]. Это может быть также следствием решений организации в результате реализации требований нескольких стандартизированных систем управления (не только стандартной СУИБ, но и иных стандартизированных направлений управления). Поскольку практически все международные стандарты на системы управления методологически совместимы, это позволяет выделять и поддерживать унифицированные задачи, например, в части работы с персоналом организации.

Проверка СУИБ. Вопросы реализации СУИБ на практике неотделимы от соответствующих процедур контроля, сформулированных в отдельном блоке требований СУИБ. На этапе проверки производятся мониторинг и анализ СУИБ, включающие оценку и, если возмож-

но, количественное измерение результативности и эффективности процессов для проверки соответствия требованиям политики, целям ОИБ и практическому опыту функционирования СУИБ, а также информирование высшего руководства организации о результатах для последующего анализа.

Целью выполнения деятельности в рамках группы процессов «проверка» является обеспечение достаточной уверенности в том, что СУИБ, включая защитные меры, функционирует надлежащим образом и адекватна существующим угрозам ИБ, а также внутренним и/или внешним условиям функционирования организации, влияющим на ИБ. Кроме того, необходимо рассмотреть любые изменения в допущениях или области оценки рисков ИБ. Организация должна своевременно обнаруживать проблемы, прямо или косвенно относящиеся к ИБ, потенциально способные повлиять на ее бизнес-цели. Рекомендуются выявлять причинно-следственную связь возможных проблем и строить на этой основе прогноз их развития. Указанная деятельность может проводиться в любое время и с любой частотой, в зависимости от того, что является подходящим для конкретной ситуации.

На этапе «Проверка» необходимо осуществлять мониторинг и контроль используемых защитных мер, проводить аудит ИБ (внутренний и внешний), анализировать функционирование СУИБ в целом, в том числе со стороны руководства [11, 14, 21]. Желательно интегрировать процессы мониторинга и анализа СУИБ в систему внутреннего контроля организации.

Результат выполнения деятельности на этапе проверки является основой для выполнения деятельности по совершенствованию СУИБ. Более детально для проверки СУИБ организация должна предпринять следующее [14, 21]:

- выполнять процедуры мониторинга и анализа, а также использовать другие средства управления, чтобы:

- способствовать своевременному выявлению событий ИБ (ошибки в обработке информации, удавшиеся и неудавшиеся попытки нарушения ИБ) и, таким образом, предотвращать инциденты ИБ путем применения средств индикации;

- представлять руководству информацию для принятия решений о ходе выполнения деятельности по ОИБ, осуществляемой как ответственными лицами, так и ИТ;

- определять, являются ли эффективными действия, предпринимаемые СУИБ для устранения нарушений ИБ;

- проводить регулярный анализ результативности СУИБ (включая проверку ее соответствия политике и целям СУИБ и анализ мер управления ИБ) с учетом результатов аудиторских проверок и инцидентов ИБ, результатов измерений эффективности СУИБ, а также предложений и другой информации от всех заинтересованных сторон;

- измерять результативность средств управления для проверки соответствия требованиям по ОИБ;

- пересматривать оценки рисков ИБ через оговоренные периоды времени, анализировать остаточные риски и установленные приемлемые уровни рисков, учитывая изменения в организации, технологиях, целях деятельности и процессах, выявленных угрозах ИБ, результативности реализованных мер управления и внешних условиях, например, изменения нормативно-правовых требований, договорных обязательств, а также изменения в социальной структуре общества;

- проводить внутренние аудиты СУИБ через установленные периоды времени;

- регулярно проводить руководством организации анализ СУИБ в целях подтверждения адекватности ее функционирования в рамках установленной области действия и определения направлений совершенствования;

- обновлять планы ОИБ с учетом результатов анализа и мониторинга;

- регистрировать действия и события, способные повлиять на результативность или функционирование СУИБ.

Совершенствование СУИБ. Группа процессов «совершенствование» включает в себя деятельность по принятию решений о реализации тактических и/или стратегических улучшений СУИБ. Переход к этому этапу осуществляется только тогда, когда выполнение процессов этапа «Проверка» дало результат, требующий совершенствования СУИБ. При этом сама деятельность по совершенствованию СУИБ должна реализовываться в рамках групп процессов «реализация» (например, введение в действие существующего плана ОИБ, поскольку на стадии проверки определена необходимость в этом) и при необходимости – «планирование» (идентификация новой угрозы ИБ и последующие обновления оценки рисков на стадии планирования). При этом важно, чтобы все заинтересованные стороны немедленно

извещались о проводимых улучшениях СУИБ и при необходимости проводилось соответствующее обучение [11, 14, 21].

Реализация и внедрение данного процесса позволяет достичь намеченных целей:

- в организации действует механизм непрерывного улучшения СУИБ в целом и отдельных ее процессов;
- все выявленные или прогнозируемые отклонения показателей функционирования СУИБ от нормальных значений учитываются, и предпринимаются действия для исправления ситуации.

Основной задачей данного процесса является предупреждение и устранение причин несоответствий ситуаций, когда процессы или меры по ОИБ не соответствуют требованиям, заданным законодательством, международными стандартами, нормативно-распорядительными или иными документами, регламентирующими вопросы ОИБ в рамках области действия СУИБ организации.

Более детально для совершенствования СУИБ организация должна выполнять следующее [14, 21]:

- а) выявлять возможности тактического и стратегического улучшений СУИБ;
- б) предпринимать корректирующие и предупреждающие действия, использовать на практике опыт по ОИБ, полученный как в самой организации, так и в других организациях;
- в) передавать подробную информацию о действиях/результатах по улучшению СУИБ всем заинтересованным сторонам, при этом степень детализации должна соответствовать обстоятельствам, и при необходимости согласовывать дальнейшие действия;
- г) обеспечивать внедрение улучшений СУИБ для достижения запланированных целей.

На этапе совершенствования СУИБ с целью обеспечения ее непрерывности производится разработка и внедрение корректирующих и превентивных (предупреждающих) действий по результатам внутреннего аудита и анализа СУИБ, выполненного руководством организации, а также на основе другой значимой информации. Корректирующее действие – это действие, предпринятое для устранения причины обнаруженного несоответствия. Предупреждающее действие – действие, предпринятое для устранения причины потенциального несоответствия или другой потенциально нежелательной ситуации. Корректирующее действие предпринимается для предотвращения повторного возникновения несоответствия, тогда как предупреждающее действие – для предотвращения возникновения несоответст-

вия. Действие по предупреждению несоответствий часто является экономически более выгодным, чем корректирующее действие.

При корректировке функционирования СУИБ в первую очередь устраняются несоответствия двух видов:

- отсутствие или невозможность реализации некоторых требований СУИБ;
- неспособность СУИБ обеспечить соблюдение ПолиБ или реализовывать бизнес-цели организации.

Документированная процедура для корректирующего и предупреждающего действия должна определять требования [13, 22]:

- для выявления несоответствий (имеющихся и возможных);
- определения причин несоответствий;
- оценивания потребности в действиях, чтобы гарантировать, что несоответствия не возникнут снова;
- определения и реализации требующихся действий;
- записывания результатов предпринятых действий;
- анализа предпринятого действия.

Организация должна определить и предпринять действия по устранению причины (включая определение изменившихся рисков) несоответствия требованиям СУИБ. Причины несоответствий могут быть разделены на следующие группы:

- организационные недостатки;
- ошибки персонала;
- технические сбои;
- злоумышленные действия;
- обстоятельства непреодолимой силы.

Выявление и прогноз несоответствий защитных мер и процессов по управлению ИБ осуществляют, как правило, владельцы бизнес-процессов и лица, ответственные за эксплуатацию средств защиты. Несоответствия могут быть выявлены также любыми сотрудниками организации. Лицо, выявившее или спрогнозировавшее несоответствие, сообщает об этом, как правило, ответственному лицу, которое оформляет данный факт в виде необходимой записи СУИБ.

Источниками информации по выявленным или прогнозируемым несоответствиям могут являться:

- отчеты о внутренних и внешних аудитах ИБ;
- жалобы и рекомендации пользователей организации;
- результаты анализа функционирования СУИБ руководством;

- результаты мониторинга эффективности СУИБ;
- данные по инцидентам ИБ;
- любая другая информация, указывающая на наличие действующих или потенциальных несоответствий.

Записи о несоответствиях или о потенциальных несоответствиях должны регистрироваться. При регистрации несоответствия лучше группировать по некоторым категориям, например, согласно тому, к какому процессу управления ИБ или к какой группе защитных мер относится несоответствие. Это может оказаться полезным для последующего анализа статистики корректирующих и предупреждающих действий.

В разработке (а потом и организации выполнения) корректирующего или предупреждающего действия принимают участие владелец процесса СУИБ или руководитель структурного подразделения, в процессе (подразделении) которого возможно возникновение или возникло несоответствие. Руководитель подразделения по своему усмотрению может назначить одного из сотрудников подразделения ответственным за внедрение предупреждающего действия.

При разработке корректирующих или предупреждающих действий обязательно проводится оценка необходимости и адекватность затрат на проведение этих действий.

При этом должны учитываться следующие факторы:

- документ или требование, к которому относится данное несоответствие;
- причины несоответствий в процессе;
- целесообразность разработки корректирующих или предупреждающих действий;
- сроки выполнения корректирующих или предупреждающих действий;
- сроки проверки эффективности корректирующего/предупреждающего действия;
- ответственность за выполнение действия и проверку его эффективности.

Решение о предупреждающем или корректирующем действии принимается только при условии, если это действие не влияет на целостность СУИБ. Действие признается нарушающим целостность СУИБ, если его выполнение влечет за собой:

- несоответствие требованиям внутренних и внешних нормативных документов;
- нарушение требований документации СУИБ;

- снижение эффективности организационной структуры из-за появления у подразделений задач, дублирующих существующие, или появление участков с неопределенной ответственностью;
- нарушение баланса между ответственностью и полномочиями.

По результатам выполнения корректирующего или предупреждающего действия в сроки, установленные при планировании этого действия, осуществляется контроль эффективности его выполнения.

4.7. Работа с процессами СУИБ организации

Как было показано выше, в рамках процессного подхода к управлению ИБ и циклической модели PDCA постоянно приходится оперировать понятием процесса. Поэтому целесообразно определить основные способы задания и анализа процессов управления ИБ организации, реализуемых в рамках всего жизненного цикла СУИБ (для краткости – процессы СУИБ). Эти процессы затрагивают все аспекты ОИБ организации, так как ИБ – это результат устойчивого функционирования многих процессов, связанных с ведением бизнеса организации.

Примерами основных процессов СУИБ являются целевые (профильные) виды деятельности, иногда называемые частными управлениями [93] (рис. 4.15):

- управление активами;
- управление рисками ИБ;
- управление инцидентами ИБ;

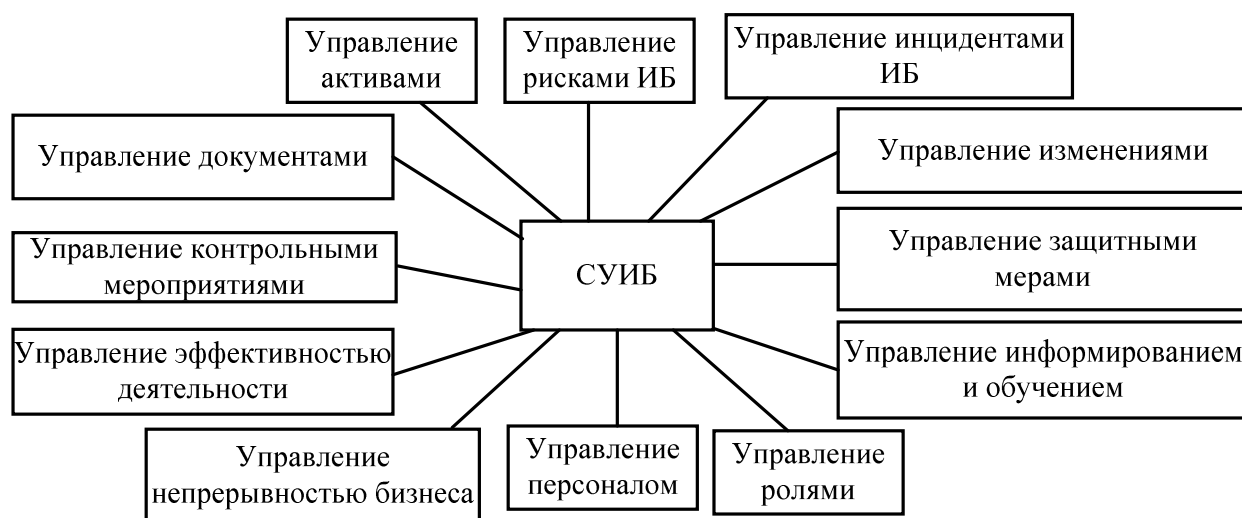


Рис. 4.15. Основные процессы СУИБ

- управление ролями, выполняемыми сотрудниками в рамках ОИБ;
- управление персоналом, включая службу ИБ;
- управление изменениями, улучшениями (тактическими, стратегическими), корректирующими и предупреждающими действиями;
- управление защитными мерами;
- управление информированием и обучением вопросам ОИБ;
- управление документами и записями, относящимися к деятельности в области ОИБ в рамках СУИБ;
- УНБ;
- управление контрольными мероприятиями в области проверки уровня ИБ (мониторинг, внутренние и внешние аудиты ИБ);
- управление эффективностью деятельности в области ОИБ.

Отдельный процесс СУИБ – логически взаимосвязанная между собой и непрерывная во времени последовательность работ, направленная на достижение поставленной специфичной цели ОИБ [14, 21]. В то же время информационные потоки в среде организации (операции и функции управления) могут содержать критерии, требующие реализации согласованных действий, формально относящихся к различным видам деятельности, частным управлениям в организации.

Задание процесса СУИБ. Прежде чем приступать к анализу процесса СУИБ, следует определить, какие параметры он может иметь и какие из этих параметров представляют наибольший интерес. Как отмечается во многих стандартах, при задании процесса СУИБ или его описании необходимо учитывать следующие его параметры [5, 23, 89, 90, 98]:

- название (определение) процесса;
- реализуемые в рамках процесса функции или их последовательность;
- внутренняя структура процесса, т. е. элементов, из которых состоит процесс, и взаимосвязей между ними;
- описание взаимосвязей процесса с другими процессами в организации;
- порядок деятельности в рамках реализации процесса;
- алгоритм (диаграмма) процесса;
- участники процесса;
- ответственное лицо – руководитель (владелец) процесса;
- входные и выходные данные (потоки), а также их поставщики (или потребители);

- требуемые ресурсы (производственные, технические, материальные, информационные и т. п.);
- определяющая цель (цели) процесса;
- оценка результативности и эффективности процесса, метрики процесса, точки и процедуры мониторинга процесса;
- возможные риски и влияние процесса на субъектов процесса;
- глоссарий процесса или ссылки на документы, где можно ознакомиться с используемыми в описании терминами;
- место документа «Описание процесса СУИБ» в системе документации организации более высокого уровня;
- состояние документа «Описание процесса СУИБ»: статус (рабочая версия, утвержден и т. д.), дата создания, автор, дата утверждения, лицо, утвердившее документ, дата изменения и дата сдачи в архив и т. д.

В различных ситуациях могут использоваться разные параметры процессов, реализуемых в рамках СУИБ. Так, например, знание целей процессов может существенно помочь на этапе выбора области действия будущей СУИБ, так как на их основе определяется важность и потребность в защите тех или иных бизнес-процессов организации. При анализе рисков ИБ сбор информации об активах потребует обращения к владельцам бизнес-процессов, как к людям, обладающим наиболее полным знанием о тех процессах СУИБ, владельцами которых они являются, а также об активах, используемых в этих процессах. Для анализа рисков ИБ может быть интересна информация о входах/выходах процесса и о его участниках. Заранее определенные метрики процесса позволят упростить мониторинг работы процесса, в частности, сравнение результатов разных видов мониторинга позволит сделать выводы о тенденциях в работе процесса и о возможных несоответствиях и разработать корректирующие и предупреждающие действия, устраняющие коренные причины несоответствий.

Из приведенных примеров видно, что все вышеперечисленные параметры процессов СУИБ важны. Даже если не существует явно закрепленных требований, обязывающих иметь описания процессов в рамках организации, разрабатывать такие описания крайне желательно, так как их наличие может существенно облегчить процессы разработки СУИБ, ее последующего внедрения и эксплуатации.

Одним из определяющих параметров в описании процесса СУИБ является его цель. Каждый процесс должен иметь цель или систему

целей, на достижение которых он направлен. Цели устанавливаются исходя из требований потребителей результатов (выходных потоков) процесса. Стандарты, рассматривающие СУИБ, рекомендуют сформулировать одну, наиболее важную цель процесса, поскольку на ее основе формируется метрика данного процесса. Использование нескольких целей потребует определения их интегральной оценки путем введения весовых коэффициентов, установление которых для каждой цели в большинстве случаев весьма затруднительно. Единая интегральная оценка необходима для определения единой метрики процесса СУИБ.

Цели могут меняться с течением времени. Например, на начальном этапе жизненного цикла у процесса СУИБ одни цели. Через некоторое время, когда процесс выстроен и оптимизирован настолько, что достижение ранее поставленных целей гарантируется, цель процесса может измениться.

Идентификация процессов СУИБ организации. Под идентификацией процессов СУИБ понимают определение состава процессов СУИБ, имеющих ключевое значение в рамках выбранной области действия – ОИБ, и составление их перечня, а также разработку модели каждого процесса, включающей краткую характеристику (например, в форме идентификационной карты), последовательность действий и процедуры процесса (например, в виде блок-схемы), показатели для оценки процесса [5, 89, 90, 98].

Идентификацию процессов СУИБ упрощает составленный еще до начала работ по созданию СУИБ перечень бизнес-процессов организации (в идеале в организации должна существовать подробная карта ее бизнес-процессов), нуждающихся в обеспечении их ИБ, и их описания. Наличие такого перечня может существенно снизить трудозатраты на выбор области и границ действия СУИБ и сделать это наиболее корректным образом, исходя из бизнес-целей организации. Однако если такого перечня в организации не существует и задача выбора области действия СУИБ решена, то необходимо разработать описание бизнес-процессов, входящих в нее.

Исходными данными для идентификации процессов СУИБ служит точная информация о характеристиках производимой продукции, активах, инцидентах, рисках ИБ и т. д. В качестве одного из вариантов можно выбрать цену и качество, которое формируется из качества продукции и сервиса. Например, для технической продукции качест-

во изделия складывается из технико-эксплуатационных, нормативно-правовых показателей, показателей экономичности и исполнения, а для процесса управления инцидентами ИБ – это их количество, ущерб, вероятность реализации и т. д.

Схему взаимодействия процессов СУИБ следует представить уже на этом этапе, чтобы проверить корректность входов и выходов, а также названий процессов. Входы и выходы помогут более четко определить границы процессов СУИБ, на каком этапе и чем заканчивается тот или иной процесс, что «запускает» данный процесс. С помощью схемы взаимодействия можно выявить пересечения и несоответствия процессов.

При выборе названий процессов СУИБ предпочтительны короткие словосочетания, отражающие суть выполняемой деятельности и ее результат, например, «управление инцидентами ИБ», или просто «инциденты ИБ», и «управление активами», или просто «активы».

Лучшие практики в отношении СУИБ обычно рекомендуют придерживаться правила: «один процесс СУИБ – одно подразделение – один бюджет – один руководитель процесса». Процессная модель управления не противопоставляет и не отвергает широко распространенную функциональную модель с вертикальной иерархической структурой и не противоречит проектному управлению. Процессная модель – еще одно представление функций и взаимосвязей в организации, базовым элементом управления которой являются виды деятельности и их результаты, причем акцент делается именно на управлении результатами с заданными параметрами, а не только на исполнении порученной функции.

В большинстве организаций руководители подразделений в рамках своих полномочий распоряжаются ресурсами, несут ответственность и являются руководителями своих процессов. Поэтому при идентификации процессов СУИБ требуется уточнить обязанности, этапы и взаимосвязи процессов. Исключением из правила будут процессы, охватывающие деятельность нескольких подразделений: управление документацией, внутренние аудиты, анализ СУИБ со стороны высшего руководства и т. д.

После составления начального варианта процессов СУИБ и их схемы взаимодействия каждый процесс обеспечивается ресурсами. Следовательно, для функционирования СУИБ необходимы обеспечивающие процессы поставщики ресурсов: сотрудников, оборудования, технологий, методик, средств измерений и т. д. Классифицировав виды ресурсов, для каждого процесса СУИБ следует определить процессы-поставщики.

Далее производится идентификация процессов оценки для продукции, самих процессов СУИБ, их потребителей и поставщиков. При этом оценка может быть частью какого-либо процесса СУИБ. Выделять ее в отдельный процесс целесообразно при необходимости отслеживать результаты (выходы). Здесь должны учитываться мониторинг и измерение параметров процессов СУИБ, внутренние аудиты ИБ, анализ СУИБ со стороны руководства и т. д.

Допускается объединение процессов поставщиков ресурсов и процессов измерения параметров в группу «обеспечивающие процессы», при этом понимая обеспечение более широко, как обеспечение функционирования СУИБ.

Есть процессы, выходом которых должны стать цели и политика предприятия в области ОИБ. Входом для них является информация о внутренней и внешней среде организации и ее бизнесе. Эту группу можно назвать «процессы управления», «процессы ответственности высшего руководства», «процессы стратегического управления». Процесс анализа СУИБ руководством организации, корректирующие, предупреждающие действия и улучшение СУИБ логичнее отнести именно к этой группе.

Помимо непосредственной идентификации необходимо определить или назначить руководителей (владельцев), связанных с бизнес-процессами выявленных процессов СУИБ. Руководитель процесса СУИБ – должностное лицо или коллегиальный орган, который имеет в своем распоряжении ресурсы процесса, информацию о нем, управляет ходом процесса и несет ответственность за его результат перед вышестоящим руководителем. Руководитель не касается функций, выполняемых в рамках процесса отдельными исполнителями; ему важна успешная реализация всего процесса. Руководитель процесса СУИБ обеспечивает взаимодействие с поставщиками входных потоков процесса и с потребителями его результатов. Он обладает наиболее полными знаниями о процессах СУИБ, владельцем которых он является, поэтому в случае необходимости описания процессов или получения каких-либо других сведений о процессе необходимо обращаться именно к нему.

Критерии выбора руководителя процесса СУИБ таковы:

- 1) детальное знание бизнес-процесса, компетентность и профессиональные знания;
- 2) возможность влиять на людей и способствовать изменениям (достаточный уровень полномочий);

3) коммуникативные способности, поскольку любые изменения в процессе СУИБ будут внедряться извне функционально-линейной иерархии и существует большая вероятность возникновения различных конфликтов;

4) понимание важности возложенных обязанностей, заинтересованность и надлежащая мотивация.

В обязанности руководителей процессов СУИБ, как правило, входят:

- разработка и организация процесса для достижения заданных результатов (выходов) процесса;
- расчет и обоснование ресурсов процесса;
- обеспечение соответствия результата (выхода) процесса установленным требованиям;
- обеспечение удовлетворенности потребителей процесса.

Помимо этого руководители процессов СУИБ должны обладать достаточными полномочиями для выполнения следующих действий:

- распоряжения ресурсами процесса (планирование работ, контроль, оценка результатов, поощрение сотрудников и т. д.);
- измерения параметров и анализа процесса;
- решения проблем и улучшения процесса.

После определения состава процессов оформляется перечень процессов СУИБ с присвоенным каждому процессу названием, обозначением и руководителем. Для каждой организации перечень процессов будет индивидуальным, отражающим присущие виды деятельности и производимую продукцию. Проверить этот перечень на соответствие требованиям ГОСТ Р ИСО/МЭК 9001 [89, 90] можно сопоставлением пунктов стандарта и процессов СУИБ.

Поскольку любую операцию можно считать процессом, надо ограничить степень детализации при определении состава процессов СУИБ. Необходимо, прежде всего, учитывать результат (выход) процесса, который важно отслеживать в СУИБ как значимый фактор влияния или условие достижения целей организации.

Следующей задачей после составления предварительного перечня процессов СУИБ является создание моделей процессов, обладающих такими свойствами, как:

- наглядность и полнота описываемого процесса без дублирования информации;
- возможность анализа процесса руководителями, аудиторами и проектными группами;

- рациональное использование ранее разработанной и подтвердившей на практике свою ценность документации предприятия.

Документирование и описание процесса СУИБ. Как отмечается в стандартах для СУИБ, цель документирования процессов СУИБ – описание их текущего состояния, что является первым шагом к их совершенствованию. При этом необходимо стремиться к описанию практически выполняемого, реального, а не идеального состояния, которого добиться сразу невозможно. Завышение требований при описании процессов ведет к тому, что сотрудники организации не смогут выполнять все предъявляемые к ним требования. Это приведет к ситуации, когда невозможно будет оценить действительную эффективность работы процессов СУИБ.

Описание процесса СУИБ определяет его сущность и структуру, позволяет эффективно планировать, обеспечивать, управлять и улучшать его. Можно выделить следующие цели описания процессов СУИБ [5, 89, 90, 98]:

- отображение реально существующих процессов;
- разработка системы управления процессами;
- управление работающими процессами;
- внедрение стандартных методов представления и описания процессов;
- формулировка измеримой цели для каждого процесса;
- создание упорядоченной структуры взаимосвязанных процессов, однозначно понимаемой всеми сотрудниками организации;
- получение возможности повторного использования отдельных процессов в других процессах (использование модульного принципа);
- разработка показателей результативности и эффективности, позволяющих оценить степень достижения цели процесса;
- снижение стоимости и повышение качества выполнения процессов;
- уточнение количества и вида ресурсов для осуществления процессов;
- распределение полномочий и ответственности участников процесса;
- создание сети рабочих групп, призванных заниматься организацией процессов в этих подразделениях.

Отдельный процесс СУИБ может состоять из подпроцессов, которые, в свою очередь, также могут состоять из подпроцессов. Степень декомпозиции процессов определяется самой организацией.

Степень детализации описаний процессов СУИБ должна определяться исходя из необходимости и достаточности обеспечения эффективности руководства процессами, сложности процесса, размеров и потребностей в управлении организацией. В соответствии с ГОСТ Р ИСО/МЭК 9001 документированию в рамках процесса подлежат: планирование и обеспечение, управление ходом процесса, ресурсы, процессы контроля [89, 90].

Описания процессов СУИБ могут включать описания в текстовой форме, карты, блок-схемы процессов и т. д.

Описание процессов в текстовой форме осуществляется в форме документированных процедур, составляющих основную документацию СУИБ и используемую при общем планировании и управлении ИБ. Документированной процедурой называется разработанное, документально оформленное, внедренное и поддерживаемое в актуальном состоянии описание последовательности действий в рамках процесса в виде установленного способа их осуществления. Суть процедуры – алгоритм исполнения процесса в конкретных условиях, обеспечивающий заданное качество процесса. Для одного процесса может разрабатываться несколько процедур, различающихся, например, условиями их выполнения, последовательностью действий и т. п. [89, 90].

Документированная процедура включает следующие основные разделы:

- цель и/или назначение процедуры (с учетом направления деятельности, описанной в процедуре);
- область действия;
- нормативные ссылки;
- термины, определения, аббревиатуры и сокращения;
- ответственность и полномочия;
- описание деятельности в соответствии с назначением процедуры (входные данные, ресурсы для осуществления деятельности (персонал, документация, оборудование, материалы), алгоритм выполняемой деятельности, последовательность выполняемых действий в соответствии с установленной целью и назначением процедуры, способы и средства мониторинга, анализируемые данные о результатах деятельности, выходные данные);
- регистрируемые данные;
- сведения о согласовании, утверждении, пересмотре процедуры;
- приложения.

Описание процесса СУИБ, отражающее последовательность действий, состав и содержание отдельных процедур, также можно представить в виде блок-схем. Такая форма описания достаточно информативна и удобна в работе, поскольку дает наглядное представление о последовательности работ, требованиях к выполнению этапов, ответственных исполнителях.

Также должен быть составлен общий перечень всех процессов СУИБ, в котором отражается следующее:

- записи, позволяющие идентифицировать описания процессов;
- информация, определяющая место документа «Перечень процессов СУИБ» в документации более высокого уровня, например руководстве по качеству;
- информация, идентифицирующая состояние документа «Перечень процессов СУИБ»: статус (рабочая версия, утвержден и пр.), дата создания, автор, дата утверждения, лицо, утвердившее документ, дата изменения, дата сдачи в архив и т. д.

Мониторинг и измерение параметров процесса СУИБ. С целью определения состояния, возможностей совершенствования и соответствия установленным требованиям процессы СУИБ должны подвергаться контролю и проверке. Процесс оценивания включает следующие этапы (рис. 4.16) [4]:

- 1) определение входных данных: назначение, область действия, ограничения (по времени, доступности и т. п.), особенности, подход, критерии компетентности специалиста по оценке;
- 2) определение основных ролей и обязанностей;
- 3) представление руководств для планирования, сбора данных, проверки их достоверности, определения атрибутов процесса и сообщения результатов оценки;
- 4) фиксирование выходных данных оценки.

Процесс оценивания процессов СУИБ основан на модели их оценки, включающей область действия (относительно эталонной модели процессов объекта оценки), показатели (используемые в качестве основы при сборе объективных данных для определения степени достижения атрибутов процессов, назначения и результатов процессов в рамках области действия модели оценки процесса) и отображение этой модели.

В рамках функционирования СУИБ осуществляется периодический мониторинг, измерение параметров и анализ работы ее процессов.

Мониторинг процесса СУИБ означает постоянное наблюдение (слежение) за его показателями.

Измерение параметров процесса СУИБ – это совокупность операций для установления значения величины параметров процесса.



Рис. 4.16. Основные элементы процесса оценивания процессов СУИБ

Анализ процесса СУИБ – деятельность, предпринимаемая для установления пригодности, адекватности, результативности рассматриваемого процесса для достижения установленных целей [5].

Основными методами мониторинга и измерения параметров процесса являются инструментальный (с помощью измерительного оборудования), социологический (анкетирование, опрос) и экспертный (оценки специалистов-экспертов) методы.

Процесс мониторинга СУИБ как непрерывный процесс, начинающийся с установления и определения потребностей и действий по мониторингу и требующий постоянной координации, представлен на рис. 4.17 [23].

Должно быть определено, что подлежит мониторингу, когда и что конкретно свидетельствует об отклонениях от нормального функционирования (например, что относится к инцидентам ИБ). Результаты мониторинга обязательно фиксируются с требуемой степенью детализации.

Для достижения целей мониторинга, измерения параметров и анализа для каждого процесса СУИБ определяются количественные показатели, являющиеся результатом измерения или расчета, и/или качественные характеристики какого-либо свойства процессов СУИБ.



Рис. 4.17. Процесс мониторинга СУИБ

Под показателем процесса СУИБ понимают обобщенную характеристику свойств СУИБ, дающую качественную или количественную оценку степени достижения процессом управления ИБ своей цели (в отличие от метрики, которая представляет собой количественное значение показателя, полученное в результате применения метода измерения к объектам измеряемой СУИБ). Это показатель операционной деятельности в области управления ИБ и способа ее осуществления. Он рассчитывается по определенной методике и адекватно характеризует результат и/или динамические показатели (изменение) функционирования процесса.

Для каждого показателя должно быть определено целевое (нормативное) значение или критерий, величина или интервал величин, которым должен соответствовать показатель процесса СУИБ. Критерий устанавливается в зависимости от целей процесса и статистических данных о характеристиках процесса за предыдущие периоды. Он может изменяться по мере развития процесса и повышения уровня его зрелости. В случае если текущее значение показателя сильно отличается от целевого значения (возможные отклонения от целевого значения необходимо предусматривать еще при планировании показателя

процесса), то необходимо выявить коренные причины такого отклонения и разработать меры по улучшению процесса, устраняющие эти отклонения. Также для показателя определяются желательные тенденции его изменения.

Для оценки процессов СУИБ можно использовать следующие показатели, которые должны задаваться и быть адекватными назначению процесса, требованиям его внутренних и внешних потребителей, бизнес-целям организации [98]:

- *результативность* – степень реализации запланированной деятельности и достижения запланированных результатов;
- *корректность* – степень соответствия реализации реального процесса его описанию;
- *управляемость* – степень, в которой производится управление выполнением процесса и получение результатов, отвечающих определенным целевым показателям;
- *эффективность* – соотношение между достигнутым результатом и использованными ресурсами (время, финансы и т. д.);
- *повторяемость* – способность процесса создавать выходные потоки с одинаковыми характеристиками при повторных его реализациях;
- *гибкость* (адаптируемость) – способность процесса приспосабливаться к изменениям внешних условий, перестраиваться так, чтобы не снижались ни результативность, ни эффективность;
- *экономичность* (стоимость) – совокупная стоимость выполнения функций процесса и передачи результатов от одной функции к другой.

Наглядно взаимосвязь трех важных понятий «результативность», «эффективность» и «экономичность» применительно к СУИБ показана на рис. 4.18.

Эффективность СУИБ связана с затратами на проведение деятельности по ОИБ для реализации целей функционирования СУИБ, направленной на достижение планируемого результата. Экономичность оценивает затраты на достижение конкретного результата, который в общем случае может не совпадать с целью деятельности. Тогда результативность СУИБ есть своего рода разность между экономичностью и эффективностью СУИБ.

Показатели оценки процессов СУИБ должны быть измеримыми величинами, рассчитываемыми на основе данных, полученных из

достоверных источников информации. Для показателей определяются название, единицы измерения, нормативные значения, с которыми будут сравниваться измеренные значения, источники данных, расчетные формулы, периодичность оценки.

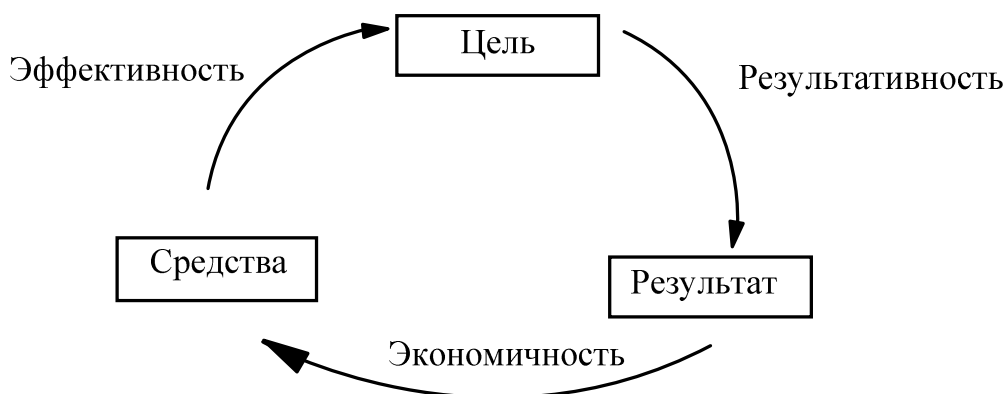


Рис. 4.18. Взаимосвязь понятий «результативность», «эффективность» и «экономичность»

Необходимо разработать или воспользоваться уже существующей методикой сбора данных и расчета какого-либо показателя. При самом упрощенном подходе если показатели оценки находятся в пределах нормативных значений, то процесс считается результативным. При отклонениях от нормы можно подсчитать, например, в процентах, насколько процесс результативен. Если трудно определить результат (выход) процесса и показатели его оценки, то проверяется корректность определения его границ и назначения в СУИБ. Возможно, при этом потребуются внесение изменений в перечень процессов СУИБ, так как отсутствие или «размытость» результата противоречит сути процессного подхода: каждая деятельность должна быть направлена на получение измеримого результата по достижении общих целей организации.

Информацию, задающую показатели оценки процессов СУИБ, можно оформить отдельными, периодически пересматриваемыми документами по каждому процессу с названием «План мониторинга процесса СУИБ». Решение о пересмотре показателей оценки процессов может приниматься при анализе СУИБ. Утверждать планы мониторинга может представитель руководства СУИБ.

Отчеты по результатам мониторинга процессов СУИБ должны соответствовать стандартам ISO/IEC 27004:2009 и ГОСТ Р ИСО/МЭК 27004-2011 [24, 25].

4.8. Стратегии построения и внедрения СУИБ

Когда перед организацией стоит задача внедрения СУИБ, можно выбрать один из двух подходов, каждый из которых имеет свои преимущества и недостатки:

- построение и внедрение СУИБ в целом;
- построение и внедрение процессов управления ИБ по отдельности с последующим объединением их в единую СУИБ.

При выборе первого подхода уже через непродолжительное время возможно обеспечить логическую связь между процессами управления ИБ и создать условия для работы СУИБ на всех этапах цикла PDCA. Например, по результатам внутренних аудитов ИБ можно исправлять коренные причины несоответствий критериям аудита посредством внедрения корректирующих действий. По всем этим процессам будут вестись записи, наличие которых позволит проводить полноценный мониторинг эффективности работы СУИБ и внедрять ее необходимые улучшения. При таком варианте от начала разработки СУИБ до ее внедрения в эксплуатацию проходит, как правило, около года.

При последовательном построении процессов управления ИБ также существуют свои преимущества. Основное из них – то, что процессы будут внедряться постепенно, тщательнее будут отлаживаться и корректироваться в соответствии с потребностями организации. Например, если начать процесс внедрения СУИБ с процесса управления инцидентами ИБ, уже через полгода эффективной работы процесса будет накоплена существенная статистика по угрозам ИБ, характерным для данной организации и ее активов. Наличие такой базы даст возможность приступить к разработке процесса анализа рисков ИБ и в качестве каталога угроз ИБ использовать данные, накопленные в результате работы процесса управления инцидентами ИБ.

Использование угроз ИБ, типичных для активов данной организации, позволяет более точно оценить риски ИБ для ее активов по сравнению с использованием каталогов типовых угроз ИБ, множество которых можно найти, например, в Интернете. В качестве другого примера можно взять процесс внутренних аудитов ИБ, который начинает приносить свои плоды уже с момента внедрения и проведения первых аудитов. И хотя данный вариант внедрения СУИБ сулит множество преимуществ, внедрение всей системы может занять не один год.

Для любой стратегии построения и внедрения СУИБ важнейшим вопросом является ее интеграция в общую деятельность организации, включая определение того, как и в какой мере затраты на СУИБ найдут отражение в результатах бизнеса. Поэтому построению и внедрению СУИБ должно предшествовать определение уязвимостей в информационной инфраструктуре организации и в связи с этим должны быть сформулированы цели и задачи ОИБ. Также перед внедрением СУИБ необходимо разработать большое количество процессов и документов, поддерживающих и обеспечивающих работу основных процессов управления ИБ, выявить исполнителей этих процессов и тех, кто будет управлять данными процессами и работой СУИБ в целом.

Важно определить и желательно сразу же закрепить за конкретными участниками базовые роли СУИБ – роли, в рамках которых будет осуществляться управление СУИБ. Так, например, необходима роль менеджера СУИБ. Он назначается из состава высшего руководства организации или из иного руководящего состава организации, наиболее подготовленного для данной роли. Менеджер по ИБ отвечает за общее руководство деятельностью по ОИБ в рамках СУИБ организации. В его обязанности входят, например, следующие функции:

- обеспечивать планирование мероприятий в рамках СУИБ;
- согласовывать внесение изменений в документацию и процессы СУИБ;
- обеспечивать руководство работой ответственных по вопросам ОИБ;
- консультировать по спорным вопросам СУИБ;
- составлять годовые планы обучения по СУИБ;
- составлять годовые планы внутренних аудитов, а также планы каждого из внутренних аудитов;
- участвовать в работе процессов управления ИБ;
- доводить до руководства информацию о критичных инцидентах ИБ, решения по внесению изменений и т. д.

Исполнители всех ролей в рамках СУИБ и отдельных процессов управления ИБ должны быть назначены руководством и обладать достаточными полномочиями для принятия всех необходимых реше-

ний и выполнения всех обязательных функций в рамках этих ролей. Например:

1) владелец актива (бизнес-процесса) – сотрудник, несущий ответственность за ОИБ актива и определяющий правила его использования. Он организует ОИБ своего актива в виде формализованных правил, технических политик, настроек конфигурации, организационных мероприятий и регламентов;

2) владелец процесса управления ИБ – должностное лицо (сотрудник) подразделения, входящего в область действия СУИБ, которое управляет процессом, имеет в своём распоряжении персонал, инфраструктуру и информацию о ходе (состоянии) процесса и отвечает за результативность и эффективность своего процесса;

3) пользователь СУИБ – любой сотрудник подразделения организации.

Подобное распределение ролей хорошо тем, что позволяет правильно планировать процессы и обязанности отдельных субъектов в рамках функционирования СУИБ.

Но помимо того, что необходимо распределить роли и закрепить их за конкретными исполнителями, требуется обучить исполнителей ролей. Организация должна гарантировать, что все сотрудники, на которых возложены обязанности, определенные в СУИБ, имеют надлежащую квалификацию для решения необходимых задач. Для этого организация должна выполнить следующее [14, 21]:

- определить необходимый уровень квалификации сотрудников, выполняющих работы, связанные с СУИБ;
- обеспечить обучение или принять другие меры (например, нанять квалифицированный персонал) для удовлетворения этих потребностей;
- оценить эффективность принятых мер;
- вести записи об образовании, обучении, навыках, опыте и квалификации.

Организация должна также гарантировать, что весь задействованный персонал осведомлен о значимости и важности его деятельности по ОИБ, а также о том, каким образом этот персонал участвует в достижении целей СУИБ.

Построение и внедрение СУИБ в целом. Это – трудоемкая задача, так как на этапе разработки требуется отследить все взаимосвя-

зи между процессами управления ИБ, а также сконструировать большое количество процессов таким образом, чтобы они заработали эффективно.

Объемы и сложность решаемых задач требуют слаженной работы целой команды специалистов. При построении СУИБ, внедряемой по данной схеме, необходимо организовать рабочую группу, которая будет включать в себя специалистов в разных областях: специалистов по ИБ, владельцев бизнес-процессов (как правило, это линейные руководители подразделений), специалистов по информационно-технологической поддержке, специалистов по кадрам, представителей финансового подразделения и т. д. Помимо этого необходимо не забывать про роль высшего руководства в этом процессе.

Как правило, при данной схеме внедрения СУИБ большой объем работ идет параллельно. При внедрении СУИБ в целом осуществляется разработка и практически одновременное внедрение перечисленных ранее процессов управления ИБ, реализуемых в рамках функционирования СУИБ: управление рисками ИБ, инцидентами ИБ и т. д. (см. п. 4.7). В такой ситуации важную роль играют грамотное планирование работ и их хорошая координация.

Для построения ряда процессов необходимо соблюдать определенную последовательность. Так, после утверждения области действия будущей СУИБ и разработки политики СУИБ следует приступить к анализу рисков ИБ. И только после получения результатов работы данного процесса, отчета по результатам анализа рисков ИБ и плана обработки рисков ИБ можно приступить к разработке необходимых процессов и процедур, учитывающих, если это необходимо, планируемые защитные меры.

Поскольку в рамках СУИБ составляется достаточно большое количество документов, а по процессам управления ИБ создаются записи, еще на ранних стадиях разработки СУИБ необходимо разработать и внедрить функционирующие под ее контролем процессы управления документами и записями. После этого можно приступать к разработке группы процессов анализа и улучшения СУИБ (внутренние аудиты ИБ; мониторинг эффективности процессов и защитных мер; управление корректирующими/предупреждающими действиями), а также процессов управления инцидентами ИБ и УНБ.

При выборе стратегии внедрения СУИБ в целом тоже существуют различные варианты ее построения, которые в основном затрагивают

аспекты выбора области действия. Существует две возможности – внедрение СУИБ для небольшой (ограниченной) области действия с последующим расширением или сразу для всей области действия.

СУИБ для небольшой области действия с последующим расширением. В качестве области действия СУИБ может быть выбран небольшой (в смысле несложный) процесс, в котором участвует ограниченное количество сотрудников. Основными преимуществами такого подхода являются:

- возможность более легкой модификации процессов управления ИБ на этапе их внедрения;
- более тесная работа с сотрудниками, входящими в область действия СУИБ, в части внедрения процессов управления ИБ в культуру организации;
- оперативная связь с сотрудниками в ходе внедрения процессов управления ИБ;
- использование данной области действия в качестве «испытательного полигона» для отработки всех процессов управления ИБ.

Проект по построению СУИБ для небольшой области действия занимает меньше времени и требует на первых этапах менее тщательной отработки всех процессов. Помимо этого данная область может быть использована в качестве полигона: процессы, разработанные в рамках данной области действия, могут быть использованы впоследствии в качестве шаблонов при расширении области действия СУИБ на другие процессы.

В рамках последующих проектов по расширению области действия СУИБ могут применяться отработанные методики анализа рисков ИБ, обработки инцидентов ИБ, обучения сотрудников и т. д. При этом совершенно необязательно расширять зону действия всех процессов управления ИБ одновременно. Возможно постепенное ее расширение начиная с тех процессов, которые уже хорошо отработаны на полигоне и могут принести существенную пользу при своем расширении.

При принятии решения о добавлении в область действия СУИБ новых активов (бизнес-процессов) организации нужно четко определить цели расширения СУИБ на них и цели самой СУИБ в рамках данных активов. Следует также отметить, что расширение единой СУИБ возможно и на смежные активы. Если рассматривать отдельные, невзаимосвязанные процессы, то, скорее всего, нужно внедрять разные локальные СУИБ.

СУИБ для большой области действия. Построение СУИБ сразу для большой области действия обладает рядом своих преимуществ и недостатков. Из преимуществ можно выделить то, что если такой проект реально запускается, то, скорее всего, имеется действительная заинтересованность руководства в нем, и для построения и внедрения СУИБ все управленческие решения будут приниматься своевременно, а необходимые ресурсы – предоставляться вовремя.

Но при таком подходе на этапах внедрения и дальнейшего функционирования СУИБ практически невозможно оперативно вносить изменения в процессы управления ИБ. Это обусловлено тем, что такие процессы чаще всего затрагивают большое количество сотрудников. Их оповещение и обучение новым правилам не такая простая задача. Помимо этого в связи с обширностью области действия управленческая ролевая структура, скорее всего, будет весьма разветвленной и негибкой, что повлечет за собой сложности в согласовании вносимых изменений. Механизмы получения обратной связи от пользователей СУИБ также не будут такими простыми и гибкими, как в случае внедрения СУИБ для небольшой области действия.

Однако подход, при котором СУИБ охватывает большую часть организации, может свидетельствовать о серьезном подходе руководства организации к ОИБ и управлению ею.

Построение и внедрение процессов СУИБ по отдельности. При построении и внедрении процессов управления ИБ, выполняемых в рамках функционирования СУИБ, можно выделить те же преимущества, что и для СУИБ для небольшой области действия. Однако ошибочно думать, что эти преимущества достигаются только лишь при внедрении отдельных процессов для небольшой области действия. Если внедрять процессы постепенно, то этих же преимуществ можно добиться и при внедрении сразу же для большой области действия.

При выборе стратегии внедрения процессов СУИБ по отдельности с последующим их объединением в единую СУИБ последовательность работ, разработки и внедрения процессов будет примерно такой же, как и при внедрении СУИБ в целом. За исключением того, что цели внедрения отдельных процессов должны определяться на этапе их разработки и потом их выполнение должно четко отслеживаться. Возможно, потребуется оформление политик для каждого из процессов, которые будут по структуре совпадать со структурой общей политики СУИБ.

При внедрении отдельных процессов необходимо делать это постепенно, отводя время на внедрение процесса в культуру, обучение пользователей, внесение изменений в процесс по результатам первых циклов его работы. Именно в таком случае будут достигнуты преимущества данной стратегии внедрения СУИБ.

Поскольку процессы будут разрабатываться отдельно, возможно, разными людьми, то при их постепенном внедрении и последующем объединении в единую систему могут возникнуть проблемы с взаимосвязями между процессами. Это может быть вызвано несоответствием выходных данных одного процесса и входных данных следующего за ним процесса управления ИБ, несоответствием ролей и исполнителей ролей в разных процессах и т. д. Чтобы избежать этого, необходимо иметь четкую стратегию развития процессов и СУИБ в целом, последовательно ее отслеживать и строить СУИБ в соответствии с ней.

Вопросы для самоконтроля

1. Дайте определения ОИБ, управления ИБ и СУИБ организации.
2. Опишите деятельность по ОИБ организации как процесс. Каковы его входные и выходные данные, ресурсы и управляющие воздействия?
3. Как процесс ОИБ в организации связан с процессами ее основной деятельности?
4. Каковы основные этапы процесса управления ИБ ИТТ?
5. Что является хорошей практикой при выборе области действия СУИБ? Какие стратегии выбора области действия СУИБ существуют?
6. Какие факторы необходимо учитывать при выборе области действия СУИБ?
7. Какие параметры процессов являются наиболее значимыми при выборе области действия проектируемой СУИБ?
8. Что входит в документальное обеспечение СУИБ? Каковы этапы его жизненного цикла?
9. Какие уровни документов включает в себя иерархия документов СУИБ? Какие виды конкретных документов создаются на каждом из уровней?

10. В чем состоит основное различие между понятиями «документ» и «запись»?
11. В чем заключается процесс управления документами и записями?
12. Какова взаимосвязь между понятиями «ПолИБ» и «Политика СУИБ»?
13. Что должна включать в себя политика СУИБ?
14. На каких этапах руководство организации должно продемонстрировать свою приверженность к разработке, реализации, эксплуатации, мониторингу, анализу, сопровождению и совершенствованию СУИБ?
15. В чем состоит основная необходимость участия высшего руководства в жизненном цикле СУИБ?
16. Каким образом при использовании циклической модели PDCA применительно к СУИБ требования и ожидания к результатам ОИБ преобразуются в управляемую ИБ?
17. Дайте определение процесса управления ИБ организации.
18. Какие действия и процессы выполняются на стадии планирования СУИБ? Каковы задачи данного этапа?
19. Специалистов каких подразделений необходимо включать в рабочую группу по построению СУИБ и почему?
20. Какие действия и процессы выполняются на стадии реализации и внедрения СУИБ, задачи данного этапа?
21. Какие действия и процессы выполняются на стадии проверки СУИБ, задачи данного этапа?
22. Какие действия и процессы выполняются на стадии совершенствования СУИБ, задачи данного этапа?
23. В чем разница и сходство между понятиями корректирующего и предупреждающего действий?
24. Почему в рамках процессного подхода к управлению ИБ следует особое внимание уделять мониторингу и анализу результативности и эффективности СУИБ?
25. В чем состоят различия между такими основными свойствами процессов, как эффективность и результативность?
26. Что входит в понятие «задание процесса управления ИБ»?
27. Какие этапы включает в себя идентификация процессов управления ИБ в организации и какие действия необходимо предпринять в рамках этих этапов?

28. Каковы основные преимущества документирования процессов управления ИБ организации и наличия подробных карт процессов организации?

29. Каковы основные элементы процесса мониторинга процессов управления ИБ организации?

30. На основе каких данных необходимо разрабатывать метрики мониторинга для процессов управления ИБ?

31. На что может указывать расхождение между целевым и текущим значениями метрик мониторинга для процессов управления ИБ?

32. Какая информация может потребоваться для того, чтобы определить целевое значение метрик процесса управления ИБ и кто может представить такую информацию?

33. Какой тип процессов управления ИБ представляет наибольший интерес для анализа и мониторинга при эксплуатации СУИБ?

34. Какого уровня сотрудники (по служебной иерархии) организации, вероятнее всего, будут выполнять роль владельца процесса управления ИБ?

35. Возможно ли построение СУИБ, охватывающей несколько территориальных подразделений организации? Какие особенности при этом необходимо учитывать?

36. В чем состоят основные преимущества и недостатки стратегии построения и внедрения СУИБ в целом?

37. В чем заключаются преимущества и недостатки стратегии построения и внедрения отдельных процессов управления ИБ с последующим их объединением в СУИБ?

38. Какова предпочтительная последовательность внедрения процессов управления ИБ?

39. В чем состоят преимущества и недостатки построения СУИБ для небольшой области действия с возможным расширением в будущем?

40. Каковы преимущества и недостатки построения СУИБ для большой области действия?

41. Какой вид управления требуется при построении единой СУИБ, распространяющейся на несколько территориальных подразделений организации?

42. Наличие каких ролей необходимо в рамках ролевой структуры СУИБ?

43. В чем состоит преимущество использования ролевого принципа в рамках СУИБ?

ЛИТЕРАТУРА

1. Леонов, Г.А. Теория управления / Г.А. Леонов. — СПб.: СПбГУ, 2006.
2. Репин, В. Процессный подход к управлению. Моделирование бизнес-процессов / В. Репин, В. Елиферов. — М.: Стандарты и качество, 2004.
3. Акофф, Р. Планирование будущего корпорации / Р. Акофф. — М.: Сирин, 2002.
4. Аудит информационной безопасности / под ред. А.П. Курило. — М.: БДЦПресс, 2006.
5. ГОСТ Р ИСО 9000-2001. Системы менеджмента качества. Основные положения и словарь. — М.: Госстандарт России, 2001. — 32 с.
6. Лигинчук, Г.Г. Основы менеджмента. Ч. 1. Учебн. курс / Г.Г. Лигинчук. — М.: Московский институт экономики, менеджмента и права, 2009.
7. Нив, Г. Пространство доктора Деминга / Г. Нив. — М.: Альпина Бизнес Букс, 2007.
8. Гостехкомиссия России. Защита от несанкционированного доступа к информации. Термины и определения. — М., 1992.
9. Рекомендации по стандартизации Р 50.1.053-2005. Информационные технологии. Основные термины и определения в области технической защиты информации: утв. Приказом Ростехрегулирования от 06.04.2005 № 77-ст. — М.: Стандартинформ, 2005.
10. ГОСТ Р 50922-2006. Защита информации. Основные термины и определения. — М.: Стандартинформ, 2008.
11. Стандарт Банка России СТО БР ИББС-1.0. Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Общие положения. — М.: Банк России, 2001.
12. Галатенко, В.А. Основы информационной безопасности / В.А. Галатенко. — М.: Бином, Лаборатория знаний Интуит, 2008.
13. ГОСТ Р ИСО/МЭК 17799-2005. Информационная технология. Методы и средства обеспечения безопасности. Практические правила управления информационной безопасностью. — М.: Стандартинформ, 2006.
14. ГОСТ Р ИСО/МЭК 27001-2006. Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования. — М.: Стандартинформ, 2008.

15. ГОСТ Р 53113.1-2008. Информационная технология. Защита информационных технологий и автоматизированных систем от угроз информационной безопасности, реализуемых с использованием скрытых каналов. Ч. 1. Общие положения. – М.: Стандартинформ, 2009.
16. Information Security Management Systems (ISMS), BSI Standard 1001, Version 1.5, Mai 2008 [Электронный ресурс]. – URL: <http://www.bsi.bund.de>.
17. ITGrundschutz Methodology, BSI Standard 1002, Version 2.0, Mai [Электронный ресурс]. – URL: <http://www.bsi.bund.de>.
18. Risk Analysis on the Basis of ITGrundschutz, BSI Standard 1003, Version 2.5, Mai 2008 [Электронный ресурс]. – URL: <http://www.bsi.bund.de>.
19. Business Continuity Management, BSI Standard 1001, Version 1.0, November 2008 [Электронный ресурс]. – URL: <http://www.bsi.bund.de>.
20. ISO/IEC 27000:2009. Information technology. Security techniques. Information security management systems. Overview and vocabulary [Электронный ресурс]. – URL: <http://www.iso.org>.
21. ISO/IEC 27001:2005. Information technology. Security techniques. Information security management systems. Requirements [Электронный ресурс]. – URL: <http://www.iso.org>.
22. ISO/IEC 27002:2005. Information technology. Security techniques. Code of practice for information security management [Электронный ресурс]. – URL: <http://www.iso.org>.
23. ISO/IEC 27003:2010. Information Technology. Security Techniques. Information Security Management Systems Implementation Guidance [Электронный ресурс]. – URL: <http://www.iso.org>.
24. ISO/IEC 27004:2009. Information technology. Security techniques. Information security management. Measurement [Электронный ресурс]. – URL: <http://www.iso.org>.
25. ГОСТ Р ИСО/МЭК 27004-2011. Информационная технология. Методы и средства обеспечения безопасности. Менеджмент информационной безопасности. Измерения. – М.: Стандартинформ, 2012.
26. ISO/IEC 27005:2011. Information technology. Security techniques. Information security risk management [Электронный ресурс]. – URL: <http://www.iso.org>.
27. ISO/IEC 133353:1998 Information technology. Guidelines for the management of IT Security. Part 3: Techniques for the management of IT Security. – Curso: Universidad de Cadiz, 2003.

28. ISO/IEC 133354:2000. Information technology. Guidelines for the management of IT Security. Part 4: Selection of safeguards. – Curso: Universidad de Cadiz, 2003.

29. ГОСТ Р ИСО/МЭК 51897-2002. Менеджмент риска. Термины и определения. – М.: Госстандарт России, 2003.

30. BS 77993:2006. Information security management systems. Guidelines for information security risk management. – Gaithersburg: National Institute of Standards and Technology, 2007.

31. ГОСТ Р ИСО/МЭК 27005-2010. Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности. – М.: Стандартинформ, 2011.

32. ISO/IEC 27006:2011. Information technology. Security techniques. Requirements for bodies providing audit and certification of information security management systems [Электронный ресурс]. – URL: <http://www.iso.org>.

33. ГОСТ Р ИСО/МЭК 27006:2008. Информационная технология. Методы и средства обеспечения безопасности. Требования к органам, обеспечивающим аудит и сертификацию систем менеджмента ИБ. – М.: Стандартинформ, 2010.

34. ISO/IEC 27007:2011. Information technology. Security techniques. Guidelines for Information Security Management Systems auditing [Электронный ресурс]. – URL: <http://www.iso.org>.

35. ISO/IEC 27008:2011. Information technology. Security techniques. Guidance for auditors on ISMS controls [Электронный ресурс]. – URL: <http://www.iso.org>.

36. ISO/IEC 27011:2008. Information technology. Security techniques. Information security management guidelines for telecommunications organizations based on ISO/IEC 27002 [Электронный ресурс]. – URL: <http://www.iso.org>.

37. ITUT Recommendation X.1051 Information security management system. Requirements for telecommunications (ISMST) [Электронный ресурс]. – URL: <http://www.itu.int>

38. ISO/IEC 27013. Information technology. Security techniques. Guideline on the integrated implementation of ISO/IEC 200001 and ISO/IEC 27001 [Электронный ресурс]. – URL: <http://www.iso.org>.

39. ISO/IEC 200001:2005. Information technology service management. Specification for Service Management [Электронный ресурс]. – URL: <http://www.iso.org>.

40. ISO/IEC 200002:2005. Information technology service management. Code of Practice for Service Management [Электронный ресурс]. – URL: <http://www.iso.org>.

41. ISO/IEC 27014. Information technology. Security techniques. Information security governance framework [Электронный ресурс]. – URL: <http://www.iso.org>.

42. ISO/IEC 27031:2011. Information technology. Security techniques. Guidelines for information and communications technology readiness for business continuity [Электронный ресурс]. – URL: <http://www.iso.org>.

43. BS 25777:2008. Information and communications technology continuity management. Code of practice. – Gaithersburg: National Institute of Standards and Technology, 2009.

44. PAS 77:2006. IT Service Continuity Management. Code of practice [Электронный ресурс]. – URL: <http://www.bsi.bund.de>.

45. ISO/IEC 270331:2009. Information technology. Security techniques. Network security. Part 1: Overview and concepts [Электронный ресурс]. – URL: <http://www.iso.org>.

46. ГОСТ Р ИСО/МЭК 270331-2011. Информационная технология. Методы и средства обеспечения безопасности. Безопасность сетей. Часть 1. Обзор и концепции. – М.: Стандартинформ, 2012.

47. ISO/IEC 270333:2010. Information technology. Security techniques. Network security. Part 3: Reference networking scenarios. Threats, design techniques and control issues [Электронный ресурс]. – URL: <http://www.iso.org>.

48. ISO/IEC 27035:2011. Information technology. Security techniques. Information security incident management [Электронный ресурс]. – URL: <http://www.iso.org>.

49. ISO/IEC TR 18044:2004. Information technology. Security techniques. Information security incident management [Электронный ресурс]. – URL: <http://www.iso.org>.

50. ГОСТ Р ИСО/МЭК ТО 18044-2007. Информационная технология. Методы и средства обеспечения безопасности. Менеджмент инцидентов информационной безопасности. – М.: Стандартинформ, 2009.

51. BS 10008:2008. Evidential weight and legal admissibility of electronic information. Specification. – Gaithersburg: National Institute of Standards and Technology, 2009.

52. ISO/IEC 133351:2004. Information technology. Security techniques. Management of information and communications technology security. Part 1: Concepts and models for information and communications technology security management [Электронный ресурс]. – URL: <http://www.iso.org>.

53. ISO/IEC 133355:2001. Information technology. Security techniques. Management of information and communications technology security. Part 5: Management guidance on network security [Электронный ресурс]. – URL: <http://www.iso.org>.

54. ГОСТ Р ИСО/МЭК 13335-1-2006. Информационная технология. Методы и средства обеспечения безопасности. Концепция и модели менеджмента безопасности информационных и телекоммуникационных технологий. – М.: Стандартинформ, 2007.

55. ГОСТ Р ИСО/МЭК ТО 13335-3-2007. Информационная технология. Методы и средства обеспечения безопасности. Методы менеджмента безопасности информационных технологий. – М.: Стандартинформ, 2007.

56. ГОСТ Р ИСО/МЭК ТО 13335-4-2007. Информационная технология. Методы и средства обеспечения безопасности. Выбор защитных мер. – М.: Стандартинформ, 2008.

57. ГОСТ Р ИСО/МЭК ТО 133355-2006. Информационная технология. Методы и средства обеспечения безопасности. Руководство по менеджменту безопасности сети. – М.: Стандартинформ, 2007.

58. ISO/IEC 154081:2009. The Common Criteria for Information Technology Security Evaluation. 1: Introduction and general model [Электронный ресурс]. – URL: <http://www.iso.org>.

59. ISO/IEC 15408-2:2008. The Common Criteria for Information Technology Security Evaluation. Security functional components [Электронный ресурс]. – URL: <http://www.iso.org>.

60. ISO/IEC 154083:2008. The Common Criteria for Information Technology Security Evaluation. Security assurance components [Электронный ресурс]. – URL: <http://www.iso.org>.

61. ГОСТ Р ИСО/МЭК 15408-1-2008. Информационная технология. Методы и средства обеспечения безопасности. Критерии оценки безопасности информационных технологий. Введение и общая модель. – М.: Стандартинформ, 2009.

62. ГОСТ Р ИСО/МЭК 154082-2008. Информационная технология. Методы и средства обеспечения безопасности. Критерии оценки безопасности информационных технологий. Функциональные требования безопасности. – М.: Стандартинформ, 2009.

63. ГОСТ Р ИСО/МЭК 154083-2008. Информационная технология. Методы и средства обеспечения безопасности. Критерии оценки безопасности информационных технологий. Требования доверия к безопасности». – М.: Стандартинформ, 2009.

64. ISO/IEC 18045:2008. Information technology. Security techniques. Methodology for IT security evaluation [Электронный ресурс]. – URL: <http://www.iso.org>.

65. ГОСТ Р ИСО/МЭК 18045-2008. Информационная технология. Методы и средства обеспечения безопасности. Методология оценки безопасности информационных технологий. – М.: Стандартинформ, 2009.

66. ISO 19011:2011. Guidelines for auditing management systems [Электронный ресурс]. – URL: <http://www.iso.org>.

67. ГОСТ Р ИСО 19011-2003. Руководящие указания по аудиту систем менеджмента качества и/или систем экологического менеджмента. – М.: Стандартинформ 2004.

68. BS 259991:2006. Business continuity management. Code of practice. – Gaithersburg: National Institute of Standards and Technology, 2009.

69. BS 259992:2007. Business continuity management. Specification. – Gaithersburg: National Institute of Standards and Technology, 2009.

70. ГОСТ Р 53647.12009. Менеджмент непрерывности бизнеса. Часть 1. Практическое руководство. – М.: Стандартинформ, 2011.

71. ГОСТ Р 53647.22009. Менеджмент непрерывности бизнеса. Часть 2. Требования. – М.: Стандартинформ, 2011.

72. ГОСТ Р 53647.32010. Менеджмент непрерывности бизнеса. Часть 3. Руководство по внедрению. – М.: Стандартинформ, 2011.

73. Стандарт Банка России СТО БР ИББС-1.1. Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Аудит информационной безопасности. – М.: Банк России, 2007.

74. Стандарт Банка России СТО БР ИББС-1.2. Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Методика оценки соответствия информационной безопасности организаций БС РФ требованиям СТО БР ИББС-1.0. – М.: Банк России, 2007.

75. Рекомендации в области стандартизации Банка России РС БР ИББС-2.0. Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Методические рекомендации по документации в области обеспечения информационной безопасности в соответствии с требованиями СТО БР ИББС-1.0. – М.: Банк России, 2010.

76. Рекомендации в области стандартизации Банка России РС ИББС-2.1. Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Руководство по самооценке соответствия информационной безопасности организаций БС РФ требованиям СТО БР ИББС-1.0. – М.: Банк России, 2011.

77. Рекомендации в области стандартизации Банка России РС БР ИББС-2.2. Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Методика оценки рисков нарушения информационной безопасности. – М.: Банк России, 2012.

78. Рекомендации в области стандартизации Банка России РС БР ИББС-2.3. Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Требования по обеспечению безопасности персональных данных в информационных системах персональных данных организаций БС РФ. – М.: Банк России, 2012.

79. Рекомендации в области стандартизации Банка России РС БР ИББС-2.4. Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Отраслевая частная модель угроз безопасности персональных данных при их обработке в информационных системах персональных данных организаций БС РФ. – М.: Банк России, 2012.

80. Tipton, H.F., Krause M. Information Security Management Handbook. 6th edition. Taylor & Francis Group, USA, 2007.

81. Department of Defense Trusted Compute System Evaluation Criteria, DoD 5200.28STD, 1985.

82. Гостехкомиссия России. Информационная безопасность и защита информации. Сборник терминов и определений. – М.: Гостехкомиссия России, 2001.

83. Бармен, С. Разработка правил информационной безопасности / С. Бармен. – М.: Вильямс, 2002.

84. Guttman, B., Roback, E. An Introduction to Computer Security: The NIST Handbook. NIST Special Publication 80012. 1995.

85. Запечников, С.В. Информационная безопасность открытых систем: учеб. для вузов. В 2 т. Т. 1: Угрозы, уязвимости, атаки и подходы к защите / С.В. Запечников, Н. Г. Милославская, А.И. Толстой, Д. В. Ушаков. – М.: Горячая линия Телеком, 2006. – 536 с.
86. ITUT Recommendation X.509 «Information Technology. Open Systems Interconnection. The Directory: Public Key and Attribute Certificate Frameworks». June 2000.
87. Mui L., Mohtashemi M., Halberstadt A. A computational model of trust and reputation // System Sciences. 2002. P. 24312439.
88. Гражданский кодекс Российской Федерации: принят Государственной Думой Российской Федерации в 2004 г. – М.: ИНФРА-М НОРМА, 2004.
89. ISO/IEC 9001:2008. Quality management systems. Requirements [Электронный ресурс]. – URL: <http://www.iso.org>.
90. ГОСТ Р ИСО/МЭК 9001-2001. Системы менеджмента качества. Требования. – М.: Стандартиформ, 2002.
91. Галатенко, В. Информационная безопасность в Интранет: концепции и решения / В. Галатенко, И. Трифаленков/ Jet Info Online. – 1996. – № 2324 (3031).
92. A Guide to Developing Computing Policy Documents (SAGE Short Topics in System Administration). Edited by Barbara L. Dijker. 1996.
93. Обеспечение информационной безопасности бизнеса / под ред. А. И. Курило. – М.: Альпина Паблишерз, 2011.
94. Проблемы управления информационной безопасностью: Сборник трудов ИСА РАН / под ред. Д.С. Черешкина. — М.: Едиториал УРСС, 1998.
95. Underlying Technical Models for Information Technology Security (NIST Special Publication 80033). U.S. Government Printing Office Washington, 2001.
96. Алесинская, Т. В. Основы логистики. Общие вопросы логистического управления: учеб. пособие / Т.В. Алесинская. – Таганрог: ТРТУ, 2005.
97. Теория автоматического управления: в 2 ч. / под ред. А.А. Воронова. – М.: Высшая школа, 1986.

ПРИЛОЖЕНИЕ А

Примеры частных политик информационной безопасности

1. ПОЛИТИКА ИСПОЛЬЗОВАНИЯ КОМПЬЮТЕРОВ ИНТРАНЕТА

Обзор. Данная политика не накладывает ограничений, противоречащих установившейся в организации культуре открытости, доверия и целостности. Она защищает сотрудников, партнеров и саму организацию от незаконных или разрушительных действий индивидуумов, случайных или намеренных.

Системы Интернета/интранета/экстранета, включая (но не ограничиваясь) компьютеры, ПО, ОС, носители данных, учетные записи для электронной почты, средства работы с WWW и FTP, являются собственностью организации. Эти системы при их обычном функционировании должны использоваться для целей бизнеса и служить интересам организации, а также для ее клиентов и партнеров (ознакомьтесь, пожалуйста, с кадровой политикой организации).

Действенная ИБ – это результат работы команды, предполагающий участие и поддержку каждого сотрудника и подразделения организации, работающих с информацией и/или ИС. Каждый пользователь компьютера должен знать эти руководящие принципы и вести себя в соответствии с ними.

Цель политики – определить допустимое использование компьютеров организации. Данные правила защищают сотрудников организации. Недопустимое использование компьютеров создает для организации угрозы заражения компьютерными вирусами и взлома интранета и его сетевых сервисов, а также проблемы юридического характера.

Область действия. Политика применяется ко всем сотрудникам, временным рабочим, консультантам, внештатным сотрудникам и другим работникам организации, включая всех третьих лиц. Политика распространяется на все компьютеры, которыми владеет или получила в лизинг организация.

Основные положения. Настоящий документ определяет:

- порядок предоставления сотрудникам доступа к компьютерам, входящим в интранет организации;
- порядок отмены доступа;
- порядок изменения прав доступа;
- требования, предъявляемые к сотрудникам организации в связи с предоставлением им доступа к компьютерам интранета;
- порядок осуществления контроля доступа;
- ответственность сотрудников организации.

Общее использование и владение. Поскольку администрация интранета организации стремится обеспечить разумный уровень секретности, пользователи должны знать, что данные, которые они создают на ее компьютерах, являются собственностью организации. Администрация интранета организации вправе знакомиться с личной конфиденциальной информацией сотрудников, хранимой на любом компьютере, принадлежащем организации.

Сотрудники должны исходить из здравого смысла при персональном использовании компьютеров интранета.

За разработку руководств по персональному использованию систем Интернета/интранета/экстранета ответственность несут отдельные департаменты. При отсутствии такой политики сотрудники должны руководствоваться ведомственной политикой персонального использования. Если сотрудники в чем-то не уверены, то они должны консультироваться со своим руководителем или администратором.

Любую информацию, которую пользователи считают конфиденциальной или уязвимой, рекомендуется шифровать. Руководство по классификации информации дано в политике работы с конфиденциальной информацией. Шифрование почтовых сообщений и документов регламентируется политикой шифрования.

С целью обеспечения функционирования интранета и его защиты уполномоченные лица внутри организации могут в любое время осуществлять мониторинг оборудования, систем и сетевого трафика (см. политику аудита ИБ).

С целью проверки на соответствие политике организация оставляет за собой право проводить аудит ИБ интранета и систем на регулярной основе.

Безопасность и составляющие информационной собственности организации. Пользовательские интерфейсы для доступа к информации, содержащейся в системах Интернета/интранета/экстранета, должны быть отнесены к классу либо конфиденциальному, либо открытому (как это определено в руководствах по конфиденциальности организации). Некоторыми примерами конфиденциальной информации являются: частная собственность организации, корпоративные стратегии, требующие защиты от конкурентов производственные секреты, спецификации, списки клиентов, исследовательские данные и т. п. Сотрудники должны делать все возможное, чтобы предотвратить НСД к этой информации.

Храните пароли должным образом и не используйте совместно одну учетную запись. Авторизированные пользователи несут ответственность за защиту своих паролей и учетных записей. Системные пароли должны меняться ежеквартально, пользовательские – каждые полгода.

Все ПК, ноутбуки и рабочие станции должны быть защищены заставками с паролями, активизируемыми через 10 мин пассивности пользователя, или средствами перезагрузки.

Шифруйте данные в соответствии с политикой шифрования. Поскольку информация на переносных компьютерах особо уязвима, нужно быть особо внимательными. Защищайте ноутбуки в соответствии с рекомендациями по их защите.

Посылка сообщений в группы новостей с электронных адресов организации должна содержать приписку, что выраженное мнение является личным мнением отправителя, а не всей организации, если такая отправка сообщений не входит в обязанности сотрудника.

Все используемые сотрудниками компьютеры, соединенные с Интернетом/интранетом/экстранетом организации и являющиеся собственностью сотрудника или организации, должны постоянно сканироваться антивирусным ПО с актуальной энциклопедией обнаруживаемых вирусов, если это не нарушает ведомственную или групповую политику.

Сотрудники должны проявлять особую бдительность при открытии прикреплений к почтовым сообщениям, полученным от незнакомых отправителей, поскольку там могут находиться вирусы, почтовые бомбы или троянские программы.

Недопустимое использование. В общем случае запрещены перечисленные ниже действия. Приведенный список не является исчерпывающим, но он может служить основой для определения действий, которые попадают в категорию недопустимого использования.

Сотрудники могут быть освобождены от этих ограничений при выполнении своих законных рабочих обязанностей (например, системным администраторам может потребоваться отключить доступ компьютера к сети, если он мешает работе сервисов).

Ни при каких обстоятельствах сотрудникам организации не разрешается участвовать в каких-либо действиях по использованию компьютеров организации, являющихся незаконными в соответствии с местным, федеральным, государственным или международным законодательством.

Работа с системами и сетями. Строго запрещаются следующие действия, все без исключения:

- нарушение прав любого человека или компании, защищенных авторским правом, торговым секретом, патентом или другой интеллектуальной собственностью, или другими законами, или актами, включая (но не ограничиваясь) установку или распространение «украденных» или других программных продуктов, на использование которых организация не имеет соответствующих лицензий;
- несанкционированное копирование авторского материала, включая (но не ограничиваясь) оцифровку и распространение фотографий из журналов, книг или других авторских источников, авторской музыки и установку любого авторского ПО, на которые организация или конечный пользователь не имеет действующей лицензии;
- экспорт ПО, технической информации, технологий и ПО для шифрования, предусмотренных международными или региональными экспортными законами (при сомнениях требуется консультация со специалистами);
- внедрение разрушающих программ в Интернет/интранет-/экстранет (например, вирусов, червей, троянских коней, почтовых бомб и т. п.); передача пароля своей учетной записи или разрешение использовать эту учетную запись другим лицам (например, членам семьи при работе в домашних условиях);
- использование компьютеров организации в личных целях; мошеннические предложения продукции, изделий или услуг, исходящие с любой учетной записи организации;

- заверения о гарантиях явно или неявно, если это не является частью обычных рабочих обязанностей;

- нарушение ИБ или разрушение связей интранета («нарушение ИБ» включает (но не ограничивается) доступ к данным, вход на сервер или учетную запись, к которым сотруднику доступ не предусмотрен, если это не входит в круг его обычных рабочих обязанностей; «разрушение» включает (но не ограничивается) перехват трафика, наводнение ring-запросами, подмену пакетов, «отказ в обслуживании» и подделку информации о маршрутизации с конкретными целями); сканирование портов или защиты;

- выполнение любых форм мониторинга интранета, позволяющее перехватить данные, не предназначенные для компьютеров сотрудников, если это не является частью их обычных рабочих обязанностей; обход аутентификации пользователя или защиты любого компьютера, сегмента интранета или учетной записи;

- вмешательство в работу или блокирование сервиса для любого пользователя, отличного от компьютера сотрудника (например, реализация «отказа в обслуживании»);

- использование любой программы/сценария/команды или посылка любых сообщений с целью вмешательства или отключения пользовательских терминальных сессий, применяя любые средства, локально или через Интернет/интранет/экстранет;

- передача информации о сотруднике(ах) организации лицами вне организации.

Работа с электронной почтой и средствами связи. Строго запрещаются все без исключения следующие действия:

- посылка незапрашиваемых электронных сообщений, включая материалы рекламного характера, пользователям, которые не просили об этом (спам);

- любые формы преследования по электронной почте или телефону, независимо от языка, частоты или размера сообщений;

- несанкционированное использование или подделка заголовков почтовых сообщений;

- запрос адреса с любого другого почтового адреса, отличного от указанного в качестве отправителя, с целью беспокоить пользователя или собирать ответы;

- создание или пересылка сообщений, использующих схему пирамиды;

- использование незапрашиваемых сообщений, приходящих в интранет организации из Интернета/интранета/экстранета других сервис-провайдеров, от имени или с целью рекламы любых сервисов, предоставляемых организацией или соединение с которыми происходит через интранет организации;
- посылка одинаковых или похожих, не относящихся к бизнесу сообщений в большое число групп новостей.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определения. Спам – несанкционированная и/или незапрашиваемая массовая рассылка почтовых сообщений.

История пересмотра политики (например, в виде таблицы с датами внесенных изменений и их содержанием).

2. ПОЛИТИКА ИСПОЛЬЗОВАНИЯ ПАРОЛЕЙ

Обзор. Пароль является важным аспектом ОИБ. Это первый рубеж защиты учетных записей пользователей. Плохо выбранный пароль может стать причиной взлома всего интранета организации. Поэтому все сотрудники организации (включая работающих по контракту и партнеров, имеющих доступ к системам организации) являются ответственными за соответствующие шаги, как отмечено ниже, по выбору и защите своих паролей.

Цель политики – установить стандарт по созданию стойких паролей, их защите и частоте смены. Настоящая политика устанавливает требования к порядку выбора, хранения, использования, периодичности смены и другим вопросам, связанным с применением механизмов парольной аутентификации в интранете организации.

Область действия – для всего персонала, имеющего свою учетную запись или ответственного за нее (или за любую форму доступа, которая поддерживается или требует пароля) в любой системе, находящейся в организации, имеющей доступ к интранету организации или хранящей любую информацию организации, предназначенную не для всеобщего доступа.

Основные положения. Все системные пароли (например, root, NT admin, учетные записи администраторов приложений и т. п.) должны изменяться по крайней мере раз в квартал.

Все системные пароли для продуктов должны храниться в единой базе данных паролей, администрируемой соответствующей организацией (например, InfoSec).

Все пароли пользователей (например, почтовые, Интернета, для настольного компьютера и т. п.) должны изменяться по крайней мере каждые шесть месяцев. Рекомендуемая частота смены пароля – каждые четыре месяца.

Учетные записи пользователей, имеющие системные привилегии, заданные с помощью членства в группе или программы типа «sudo», должны иметь уникальный пароль, отличный от других паролей этого пользователя.

Пароли нельзя передавать по электронной почте или другим видам электронных средств связи.

При использовании протокола управления сетью SNMP пароли для «community strings» должны быть отличны от установок по умолчанию «public», «private» и «system» и от паролей, используемых для входа в интерактивный режим. Везде, где это возможно, должен использоваться хеш с ключом (например, SNMPv2).

Все пользовательские и системные пароли должны выбираться в соответствии с нижеприведенным руководством.

Руководство. *Общее руководство по выбору паролей.* В организации пароли используются с разными целями. Чаще это: пользовательские учетные записи, доступ к Интернету, почтовые пароли, пароли для заставок, пароли для голосовой почты и пароли на локальных маршрутизаторах. Поскольку не везде используются одноразовые (динамические) пароли, нужно знать, как выбрать стойкий пароль.

Слабые пароли обладают следующими свойствами:

- пароль содержит менее восьми символов;
- пароль является словом из словаря какого-либо языка;
- пароль содержит:
 - фамилию и имя, кличку животного, имя друга, марку машины, фантастическое имя и т. п.;
 - компьютерный термин или имя, команду, узел, наименование организации, название АО или ПО;
 - производное от наименования организации;

- дату рождения или другую персональную информацию типа адреса или номера телефона;
- слово или сочетание символов типа aaabbb, qwerty, zyxwvuts, 123321 и т. п.;
- все перечисленное, только в обратном порядке написания;
- любое из перечисленного с цифрой на конце или в начале (например, secret1, lsecret).

Сильный пароль имеет следующие характеристики:

- содержит символы верхнего и нижнего регистра;
- наряду с буквами содержит цифры и знаки препинания ('(2)#\$%Л &*()_+!~=V {}[]:»;'<>?,./);
- состоит не менее чем из восьми символов;
- не является словом любого языка, сленга, диалекта, жаргона и т. п.;
- не содержит персональной информации, фамилии и т. п.;
- не записан рядом с компьютером или хранится на нем в специально с этой целью созданном файле.

Лучше выбрать пароль, который легко запомнить. Один из способов – взять за основу название песни, пословицы и т. п. Например, на основе фразы «This May Be One Way To Remember» можно создать пароль «TmBlw2R!» или «TmblW>r~».

Стандарты защиты паролей. Вес пароли являются конфиденциальной информацией организации.

Для учетных записей в организации и вне нее используйте разные пароли. Внутри организации для различного доступа (к приложениям, к разным ОС и т. п.) также используйте разные пароли.

Не используйте одну учетную запись в организации совместно с кем-либо, включая помощников или секретарей.

Также запрещается:

- говорить кому-либо пароль по телефону;
- писать пароль в почтовом сообщении;
- давать пароль начальнику;
- обсуждать пароль с коллегами;
- намекать на формат пароля (например, «моя фамилия»);
- не писать пароль при опросах;
- не использовать один пароль всеми членами семьи;
- не давать пароль коллегам на время своего отсутствия на работе.

Если кто-либо просит ваш пароль, ссылайтесь на этот документ или просите позвонить в департамент ИБ.

Не используйте опцию приложений «Запомнить пароль» (например, в Microsoft Outlook или Netscape Messenger).

Не храните записанным на бумаге пароль в офисе или на компьютере в незашифрованном файле.

Меняйте пароль не реже раза в полгода (системные пароли нужно менять ежеквартально). Рекомендуемый срок смены паролей – каждые четыре месяца.

Если есть подозрения, что пароль или учетная запись были взломаны, сообщите об инциденте соответствующему уполномоченному лицу и замените все пароли.

Периодически пробуйте взломать или подобрать пароль. Если это удастся с применением соответствующих средств, потребуйте от пользователя сменить пароль.

Стандарты для разработки приложений. Разработчики приложений должны создавать программы, имеющие следующие свойства:

- аутентификация отдельных пользователей, а не групп;
- хранение паролей не должно осуществляться в открытом виде или в любой легко читаемой форме;
- управление ролями, исключающее ситуацию, когда один пользователь может получить функции другого без знания его пароля;
- поддержка TACACS+ , RADIUS и/или X.509 с LDAP, где это возможно.

Использование паролей и парольных фраз для удаленного доступа пользователей. Доступ к интранету организации посредством удаленного доступа должен контролироваться на основе одноразовых паролей или ключевой системы со стойкими парольными фразами.

Парольные фразы обычно используются для аутентификации с открытым/личным ключом. Такая система определяет математическое отношение между известным всем открытым ключом и личным ключом, известным только пользователю. Без парольной фразы, открывающей личный ключ, пользователь не может получить доступ.

Парольные фразы – это не то же самое, что пароли. Парольная фраза – это более длинная и поэтому более защищенная версия пароля. Обычно она состоит из нескольких слов. Кроме того, такая фраза более защищена от атак по словарю.

Правильно составленная парольная фраза достаточно длинна и содержит комбинации символов, цифр и знаков препинания на верхнем и нижнем регистрах. Например, «The*?#>* @TrafficOn-The!01Was*&!# ThisMorning». Все правила выбора паролей применимы и к парольным фразам.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определение. Учетная запись администратора приложения – любая учетная запись, предназначенная для администрирования приложения (например, администратора базы данных Oracle и т. п.).

История пересмотра политики.

3. ПОЛИТИКА ИСПОЛЬЗОВАНИЯ АЛГОРИТМОВ ШИФРОВАНИЯ

Цель политики – определить условия и способы использования алгоритмов шифрования, известных в настоящее время в обществе и доказавших свою эффективную работу. Также данная политика создает условия для гарантированного соблюдения федеральных законов и определяет полномочные органы по распространению и использованию алгоритмов шифрования вне страны, в которой находится организация.

Область действия. Политика применяется ко всем сотрудникам и партнерам организации.

Основные положения. Стандартные алгоритмы шифрования типа DES, Blowfish, RSA, RC5 и IDEA (в России – ГОСТ 2814789) должны использоваться в качестве основы для шифрования. Эти алгоритмы представляют фактический шифр, используемый для одобренного применения. Например, Pretty Good Privacy (PGP) использует комбинацию IDEA и RSA или Диффи – Хеллмана, а Secure Socket Layer (SSL) использует RSA. Для симметричной криптосистемы длина ключа должна быть не менее 56 бит. Для асимметричных криптосистем ключи должны иметь длину, обеспечивающую эквивалентную

стойкость. Для организации требования к длине ключа будут пересматриваться ежегодно и обновляться, насколько это позволяют технологии.

Использование собственных алгоритмов шифрования не разрешается ни в каких целях, пока не будет получено заключение квалифицированных экспертов не из числа заинтересованных лиц и одобрено соответствующим полномочным органом страны, где находится организация. Это не должно противоречить экспортным ограничениям на алгоритмы шифрования страны.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определения. Собственный алгоритм шифрования – алгоритм, который не был обнародован и/или не представлялся на исследование общественности. Разработчиком алгоритма может быть организация, индивидум или правительство. Симметричная криптосистема – метод шифрования, в котором один ключ используется как для зашифрования, так и расшифрования данных. Асимметричная криптосистема – метод шифрования, в котором используются два различных ключа: один – для зашифрования, другой для расшифрования данных.

История пересмотра политики.

4. ПОЛИТИКА АНТИВИРУСНОЙ ЗАЩИТЫ

Цель – определить требования, обеспечивающие эффективное обнаружение и предотвращение вирусов, которые должны выполняться для всех компьютеров, соединенных с интранетом организации.

Область действия. Данная политика применяется для всех компьютеров организации, представляющих собой персональные компьютеры (ПК) или участвующих в совместном использовании файлов. Это включает (но не ограничивается) настольные компьютеры, ноутбуки, серверы file/ftp/tftp/proxy и любые устройства на основе ПК, генерирующие трафик.

Основные положения. Настоящий документ определяет систему защитных мер, предпринимаемых отделом ИТ, направленных на защиту компьютеров, входящих в состав интранета организации, от

компьютерных вирусов, троянских программ и прочих деструктивных программных кодов, а также устанавливает требования к конфигурации комплексной системы антивирусной защиты интранета и мероприятия, обеспечивающие поддержание этой системы в работоспособном состоянии. Антивирусная политика также определяет структуру и компоненты комплексной системы антивирусной защиты интранета, распределение административных ролей по управлению системой антивирусной защиты и соответствующие полномочия администраторов антивирусной защиты.

Все компьютеры организации на основе ПК должны иметь стандартное, поддерживаемое организацией, антивирусное ПО, установленное и проводящее проверку по расписанию с заданным интервалом.

Само ПО и энциклопедия обнаруживаемых вирусов должны поддерживаться в актуальном состоянии.

Зараженные вирусами компьютеры должны отключаться от интранета до уничтожения вирусов.

Системные администраторы являются ответственными за разработку процедур, согласно которым антивирусное ПО работает на постоянной основе и все компьютеры проверяются на отсутствие вирусов.

В соответствии с политикой принятого использования все действия по созданию и/или распространению деструктивных программ в интранете организации (например, вирусов, червей, «троянских коней», почтовых бомб и т. п.) запрещены.

Пользуйтесь следующими рекомендациями для предотвращения заражения вирусами:

Всегда применяйте только стандартное ПО, обновляемое через портал интранет организации. Используйте последнюю версию ПО. Обновляйте ПО по мере выпуска для него новых версий.

Никогда не открывайте файлы или макросы, присоединенные к почтовым сообщениям, пришедшим от неизвестных отправителей. Немедленно уничтожьте эти вложения и очистите корзину почтовых сообщений.

Уничтожайте спам и другую бесполезную почту без ее пересылки по другим адресам в интранете организации в соответствии с принятой политикой допустимого использования электронной почты.

Никогда не загружайте файлы с неизвестных и непроверенных источников.

Избегайте прямого совместного использования дисков с доступом на чтение/запись не особой надобности.

Всегда сканируйте дискеты/диски, не являющиеся вашими собственными, на отсутствие вирусов перед их использованием.

Регулярно делайте резервные копии важной информации и системных настроек и храните данные в защищенном месте.

Если используемое в работе бизнес-приложение конфликтует с антивирусным ПО, завершите его работу; убедитесь, что компьютер не заражен, запустив антивирус; временно заблокируйте работу антивируса и снова запустите бизнес-приложение. После окончания его работы разблокируйте антивирус. Пока антивирус не работает, не запускайте приложения, которые могут передавать вирусы, например, электронную почту или совместное использование файлов.

Новые вирусы обнаруживаются практически каждый день. Регулярно пересматривайте антивирусную политику и данные рекомендации.

Также определяются структура и состав средств антивирусной защиты, требования к конфигурации этих средств, контроль их функционирования.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определение. Важная информация – незаменимая и необходимая для деятельности организации информация, ошибочное изменение или подделка которой приносит большой ущерб, а восстановление после уничтожения невозможно либо очень трудоемко и связано с большими затратами.

История пересмотра политики.

5. ПОЛИТИКА ОЦЕНКИ РИСКОВ ИБ

Цель – уполномочить соответствующих лиц периодически выполнять оценку рисков ИБ с целью определения уязвимостей и их последующего устранения.

Область действия. Оценка рисков ИБ может проводиться любым уполномоченным лицом в пределах организации или любым внешним уполномоченным лицом, которое подписало соглашение с третьими лицами организации. Оценка рисков ИБ может проводиться для любой ИС и интранет в целом, включая приложения, серверы, подсети, а также любой процесс или процедуру, с помощью которых эта система управляется и/или поддерживается.

Основные положения. За разработку, развитие и реализацию программ устранения обнаруженных уязвимостей несут совместную ответственность уполномоченные лица и отдел – владелец оцениваемой системы. Ожидается, что сотрудники будут помогать оценке рисков ИБ, проводимой для систем, за которые они ответственны. Также ожидается, что сотрудники будут работать с уполномоченной группой оценки рисков ИБ по развитию плана устранения уязвимостей.

Процесс оценки рисков ИБ. Дается описание процесса или приводится ссылка на источник информации, содержащий такое описание.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определение. Уполномоченное лицо – любой сотрудник, отдел, группа лиц или третье лицо внутри или вне организации, ответственное за поддержание активов организации.

История пересмотра политики.

6. ПОЛИТИКА АУДИТА ИБ

Цель – создать основу для проведения аудита ИБ любой системы или интранета организации уполномоченными лицами.

Цели проведения аудита ИБ:

- обеспечить целостность, конфиденциальность и доступность информации и ресурсов систем и интранета;
- обнаружить возможные проблемы с ОИБ и несоответствия ПолИБ организации;
- провести при необходимости мониторинг активности пользователей или систем.

Область действия. Данная политика распространяется на все компьютеры и средства связи, которыми владеет или пользуется организация, а также на те, которые размещаются на ее территории, но не являются ее собственностью или не используются ею.

Основные положения. Настоящая политика определяет:

- нормативную базу для деятельности внутренних и внешних аудиторов ИБ;
- полномочия внешних и внутренних аудиторов ИБ;
- ответственность аудиторов за ОИБ и нормальный режим функционирования ИС и интранета организации;
- порядок и условия проведения аудита ИБ и анализа рисков ИБ.

При запросе или с целью проведения планового аудита ИБ всем уполномоченным лицам должен быть предоставлен в организации требуемый доступ. Он может включать:

- пользовательский и/или системный доступ к любому средству связи;
- доступ к информации (электронной, бумажной и т. п.), которая порождается, передается или хранится на оборудовании организации или на ее территории;
- доступ в рабочие помещения (лаборатории, офисы, хранилища и т. п.);
- доступ для интерактивного мониторинга и контроля трафика в интранете организации.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

История пересмотра политики.

7. ПОЛИТИКА ДЛЯ ПОГРАНИЧНЫХ МАРШРУТИЗАТОРОВ ИНТРАНЕТА

Цель – определить минимальные требования по защищенному конфигурированию всех пограничных маршрутизаторов и коммутаторов, соединенных с интранетом или используемых в производственных целях самой организацией или от ее имени.

Область действия. Политика распространяется на все пограничные маршрутизаторы и коммутаторы, соединенные с интранетом организации. На маршрутизаторы и коммутаторы внутри интранета политика не распространяется. Для маршрутизаторов и коммутаторов внутри демилитаризованной зоны (ДМЗ) применяется политика для оборудования ДМЗ.

Основные положения. Конфигурация каждого маршрутизатора должна соответствовать общепринятым стандартам.

На маршрутизаторе не должно быть сконфигурировано никаких локальных учетных записей. Для аутентификации всех пользователей должен использоваться протокол TACACS+ или RADIUS (в зависимости от требуемого функционала).

Пароль на вход в привилегированный режим маршрутизатора должен храниться в зашифрованном виде. В качестве пароля привилегированный режим маршрутизатора должен использовать текущий пароль, выданный организацией, осуществляющей поддержку маршрутизатора. Запретить следующее:

- направленный широковещательный IP-трафик (IP-directed broadcasts);
- входящие на маршрутизатор пакеты, направленные с ложных адресов, например, перечисленных в RFC1918; TCP и UDP small services;
- все типы маршрутизации от источника;
- все веб-сервисы, запущенные на маршрутизаторе.

Использовать стандартные для организации «SNMP community strings». Правила доступа должны добавляться по мере необходимости.

Маршрутизатор должен быть включен в корпоративную систему управления с заранее определенным контактным лицом.

На каждом маршрутизаторе должна присутствовать надпись: «Несанкционированный доступ к данному сетевому оборудованию запрещен. На доступ и конфигурирование устройства необходимо соответствующее разрешение. Все действия, выполняемые на этом устройстве, регистрируются. Нарушение данной политики повлечет за собой дисциплинарные взыскания или даже преследования в соответствии с законом. Никто не имеет права на сохранность информации, вводимой в сеансе удаленного доступа к данному устройству».

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

История пересмотра политики.

8. ПОЛИТИКА УДАЛЕННОГО ДОСТУПА К ИНТРАНЕТУ

Цель – определить стандарты подключения к интранету организации любого хоста. Они предназначены для минимизации потенциального ущерба организации от угроз ИБ, которые может создать несанкционированное использование ресурсов организации. Это включает угрозы потери конфиденциальности данных, интеллектуальной собственности, имиджу, важным внутренним системам организации и т. п.

Область действия. Политика применяется ко всем сотрудникам, контрактным рабочим, поставщикам и агентам, имеющим собственные или предоставленные организацией компьютеры или рабочие станции, подключенные к интранету организации. Политика применяется к удаленным соединениям, используемым для выполнения работы по заказу организации, включая чтение и отправку электронной почты и просмотр веб-ресурсов интранета.

Основные положения. Сотрудники, контрактные рабочие, поставщики и агенты организации, имеющие привилегии удаленного доступа (УД) к ее интранету, должны гарантировать, что их удаленное подключение является локальным соединением пользователя с организацией.

Доступ с персональных компьютеров к Интернету в личных целях всеми членами семьи через интранет организации запрещен для сотрудников, платящих за наем жилья. Они несут ответственность за то, чтобы члены их семьи не нарушали политики организации, не предпринимали никаких противоправных действий и не использовали доступ ни в каких других целях, кроме рабочих. Также они несут полную ответственность за всю последовательность действий, повлекшую злоупотребление доступом.

Применяются все политики, регламентирующие защиту информации при доступе к интранету посредством удаленных подключений

(например, политика шифрования, политика построения ВЧС, политика беспроводного доступа), а также политика допустимого использования компьютеров интранета организации.

Требования. Защищенный УД должен тщательно контролироваться. Контроль осуществляется посредством аутентификации на основе одноразовых паролей или открытых/личных ключей со стойкими парольными фразами (см. политику использования паролей).

Сотрудник организации не должен сообщать свой идентификатор и почтовый пароль никогда и никому, даже членам семьи.

Сотрудники и контрактные рабочие организации, имеющие привилегированный УД, должны гарантировать, что имеющиеся у них собственные или предоставленные им организацией компьютер/рабочая станция, удаленно подключенные к интранету организации, в то же время не соединены ни с какой другой сетью, за исключением персональных сетей, находящихся под полным контролем пользователя.

Для выполнения своей работы в интересах организации сотрудники и контрактные рабочие, имеющие привилегированный УД, не должны использовать почтовые ящики, не принадлежащие организации (например, Hotmail, Yahoo, AOL), или другие внешние ресурсы, тем самым гарантируя, что личный бизнес не смешивается с официальной работой.

Маршрутизаторы для выделенных каналов связи (например, ISDN), сконфигурированные для доступа к интранету организации, должны соответствовать минимальным требованиям аутентификации принятого протокола (например, CHAP).

Никогда не разрешается реконфигурация домашнего оборудования пользователя с целью его одновременного подключения к множественным каналам связи, включая виртуальные.

На конфигурирование нестандартного АО для УД требуется разрешение соответствующих служб организации, которые должны утвердить защищенные настройки для доступа к этому обеспечению.

Все хосты, включая ПК, соединенные с внешними по отношению к интранету организации сетями с применением технологий УД, должны использовать самое современное антивирусное ПО. Подключения третьих лиц должны соответствовать требованиям, зафиксированным в подписанном с ними соглашении.

Личное оборудование, используемое для подключения к интранету организации, должно соответствовать требованиям для оборудования УД, принадлежащего организации.

Организации или частные лица, которые хотят использовать нестандартные решения для УД к интранету организации, должны получить особое разрешение от соответствующих служб организации.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определения. Хост – устройство, имеющее уникальный адрес.

Под УД к интранету организации понимаются все виды доступа, осуществляемые по внешним каналам связи (через контролируемые сети или устройства) и с использованием устройств доступа, расположенных за пределами охраняемой зоны и не контролируемых организацией. Основными видами УД являются:

- доступ к интранету по коммутируемым каналам связи с использованием модемов и телефонной сети, который предоставляется сотрудникам организации, находящимся в отпуске, в командировке или в деловых поездках, а также представителям партнеров, проводящим работы в интранете/экстранете организации;

- доступ мобильных пользователей к интранету с использованием VPN-каналов связи типа «компьютер – сеть» через Интернет, предоставляемый сотрудникам организации, находящимся в отпуске, в командировке или в деловых поездках, а также представителям партнеров, проводящим работы в интранете/экстранете организации;

- подключения удаленных подразделений организации к интранету с использованием VPN-каналов типа «сеть – сеть» через Интернет. Реализации УД, рассматриваемые в данной политике, включают (но не ограничиваются): подключения на основе Frame Relay/ISDN/X.25, подключения через сервер УД (по протоколам SLIP, PPP); доступ по протоколу Telnet из Интернета; доступ по телефонной линии на основе обычного модема (например, на основе DSL); доступ посредством кабельного модема; прямое подключение (например, на основе SSH), подключение к ВЧС и т. п.

CHAP (Challenge Handshake Authentication Protocol) – основанный на однонаправленной хеш-функции протокол, используемый для аутентификации.

История пересмотра политики.

9. ПОЛИТИКА ПОСТРОЕНИЯ ВИРТУАЛЬНЫХ ЧАСТНЫХ СЕТЕЙ

Цель – определить руководящие принципы для VPN-соединений с интранетом организации с применением УД на основе протоколов IP Sec или L2TP.

Область действия. Политика применяется ко всем сотрудникам, временным рабочим, консультантам, внештатным сотрудникам и другим работникам организации, включая всех третьих лиц, использующих VPN-доступ к интранету организации. Данная политика распространяется на те реализации VPN, в которых используются концентраторы IP Sec.

Основные положения. Имеющие на это разрешение сотрудники и третьи лица организации (например, клиенты, поставщики и т. п.) могут пользоваться VPN-доступом, который считается сервисом, управляемым пользователем. Это означает, что сам пользователь отвечает за выбор сервис-провайдера Интернета (Internet Service Provider, ISP), руководит настройкой, устанавливает требуемое ПО и платит арендную плату (детали изложены в политике УД). Дополнительно к этому:

- сотрудник, имеющий разрешение на VPN-доступ, должен гарантировать, что неуполномоченные пользователи не получают доступа к интранету организации;
- использование VPN контролируется либо на основе аутентификации с одноразовыми паролями (типа токенов), либо системами с открытым/личным ключом со стойкими парольными фразами;
- при активном подключении к интранету VPN направляют весь трафик от и к ПК по VPN-туннелю; весь остальной трафик отбрасывается;
- одновременное соединение с несколькими VPN не разрешается;
- VPN-шлюзы устанавливаются и управляются соответствующей рабочей группой организации;
- на всех компьютерах, включая ПК, соединенных с интранетом организации посредством VPN или любой другой технологии, должно быть установлено стандартное для организации современное антивирусное ПО;

- пользователь VPN будет автоматически отключаться от интранета организации после 30 мин неактивности; после этого пользователь должен снова войти в систему для восстановления подключения; пингование (pings) или другие искусственные сетевые процессы не должны использоваться для поддержания соединения в открытом состоянии;

- время работы VPN-концентратора ограничивается 24 ч соединения; пользователи компьютеров, не являющихся оборудованием организации, должны сконфигурировать их таким образом, чтобы они соответствовали политикам организации для ВЧС и интранета;

- можно использовать только разрешенные организацией VPN-клиенты;

- при использовании VPN-технологии на персональном оборудовании пользователи должны осознавать, что их компьютеры являются фактически расширением интранета организации и поэтому они подчиняются тем же правилам и положениям, которые применяются к собственному оборудованию организации.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определения. Концентратор IPSec – устройство, в котором заканчиваются виртуальные каналы.

История пересмотра политики.

10. ПОЛИТИКА ДЛЯ ЭКСТРАНЕТА

Цель – определить политику соединения с интранетом организации третьих лиц для осуществления бизнеса в интересах организации.

Область действия. Политика регламентирует соединения между третьими лицами, которые требуют доступа к непредназначенным для широкого доступа ресурсам организации, независимо от того, какой вид соединений применяется – телекоммуникационный (типа Frame Relay или ISDN) или VPN-технология. Политика не распространяется на третьих лиц типа сервис-провайдеров Интернета (ISP),

обеспечивающих доступ организации к Интернету или к телефонным сетям общего пользования (Public Switched Telephone Network).

Основные положения.

Предварительные условия. Рассмотрение запросов для экстранет подключения. Все запросы на новые соединения с экстранетом должны быть тщательно рассмотрены департаментом ИБ, о чем выдается соответствующее заключение. Это гарантирует то, что они не противоречат требованиям бизнеса и при этом соблюдается принцип минимального доступа.

Соглашение о соединении с третьими лицами. Все запросы на подключение между третьими лицами и организацией требуют, чтобы представители третьих лиц и организации были уполномочены и готовы подписать соответствующее соглашение. Это соглашение должно быть подписано как минимум заместителем руководителя спонсорского подразделения и уполномоченным представителем третьих лиц. Подписанный документ должен храниться в группе поддержки экстранета и в том подразделении, к чьим ресурсам подключаются третьи лица.

Вступление в действие. Все подключения к экстранету для ведения бизнеса должны сопровождаться соответствующим обоснованием в письменном виде, утвержденным руководителем проекта в группе поддержки экстранета. Подключения к конкретным ресурсам организации должны быть одобрены владельцами этих ресурсов и их администраторами ИБ.

Контактные лица. Спонсорское подразделение должно выделить сотрудника, который будет являться контактным лицом по всем вопросам экстранет-подключения. Это лицо действует от имени спонсорского подразделения и несет ответственность за все пункты, имеющие отношение к политике и соглашению. В случае смены контактного лица требуется немедленно известить об этом группу поддержки экстранета.

Установление соединения. Спонсорское подразделение внутри организации, в интересах которого устанавливается подключение

к третьим лицам, обращается с запросом к соответствующей группе поддержки экстранета. Эта группа привлекает департамент ИБ для рассмотрения вопросов, связанных с ИБ в проекте. Если запрашиваемое подключение заканчивается в спонсорском подразделении, последнее должно привлечь своего администратора ИБ. Спонсорское подразделение должно представить департаменту ИБ и группе поддержки экстранета для рассмотрения полную и исчерпывающую информацию о виде запрашиваемого доступа.

В соответствии с утвержденными бизнес-требованиями и заключением об ИБ все устанавливаемые подключения должны удовлетворять принципу минимального доступа. Ни при каких обстоятельствах Организация не может положиться на третьих лиц в отношении защиты своих ресурсов и интранета.

Модификация или изменения соединения и доступа. Все изменения доступа должны сопровождаться соответствующим обоснованием и являться предметом рассмотрения для выдачи заключения об ИБ. Изменения осуществляются в соответствии с утвержденным организацией процессом управления изменениями. Спонсорское подразделение несет ответственность за уведомление группы управления экстранетом и/или департамента ИБ об изменении первоначально представленной информации, что позволит своевременно сохранить защищенность и само подключение.

Прекращение доступа. Когда доступ больше не требуется, спонсорское подразделение внутри организации должно уведомить группу поддержки экстранета, осуществляющую подключение. Она ликвидирует подключение. Это может означать либо модификацию существующих разрешений, либо полное прекращение доступа. Группа поддержки экстранета и спонсорское подразделение должны ежегодно проводить аудит ИБ своих экстранет-подключений, что гарантирует актуальность существующих соединений и соответствие им предоставляемого доступа. Обнаруженные ненужные или давно не используемые для бизнеса организации соединения должны быть немедленно отключены. О таких случаях и о случаях нарушения ИБ департамент ИБ или группа поддержки экстранета должны информировать контактное лицо или спонсорское подразделение с целью принятия ими соответствующих мер.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определения. Третьи лица – люди или организации, не являющиеся официальными или вспомогательными частями организации.

Спонсорское подразделение – подразделение внутри организации, представившее запрос на экстранет-подключение третьих лиц.

История пересмотра политики.

11. ПОЛИТИКА ДЛЯ ОБОРУДОВАНИЯ ПОГРАНИЧНОЙ ДЕМИЛИТАРИЗОВАННОЙ ЗОНЫ

Цель – определить стандарты, которым должно отвечать все собственное и/или используемое организацией оборудование, находящееся за пределами МЭ, отделяющего внутренний интранет организации от внешних по отношению к нему сетей. Эти стандарты предназначены для снижения потенциального ущерба организации от потери важной или конфиденциальной информации, интеллектуальной собственности или ее имиджа, что может явиться следствием несанкционированного использования ресурсов организации.

Объект политики – оборудование, установленное на границе с другими сетями за МЭ организации, как часть пограничной демилитаризованной зоны (ДМЗ). Это оборудование (сетевое и хосты) является потенциально уязвимым к атакам, исходящим из внешних сетей (типа Интернета).

Политика определяет следующие стандарты:

- ответственность владельцев;
- требования защищенного конфигурирования;
- требования к работе;
- требования к изменению управления.

Область действия. Все оборудование или устройства, расположенные в ДМЗ, являющиеся собственностью или используемые организацией (включая хосты, маршрутизаторы, коммутаторы и т. п.) и/или зарегистрированные в принадлежащем ей домене (Domain Name System, DNS), должны соответствовать данной политике. Эта

политика также распространяется на любой хост, которым управляет или владеет внешний сервис-провайдер или третье лицо, если это оборудование находится в домене организации или будет принадлежать ей. Все новое оборудование, которое подпадает под действие данной политики, должно быть сконфигурировано в соответствии с ее требованиями. Все существующее и позднее закупленное оборудование, размещаемое в недоверенных сетях организации, должно также соответствовать данной политике.

Основные положения.

Владение и ответственность. Оборудование и приложения, являющиеся объектами данной политики, должны администрироваться группой поддержки, утвержденной департаментом ИБ для управления ДМЗ, приложениями и/или сетями.

Оборудование должно быть зарегистрировано в корпоративной системе управления. Для этого как минимум требуется следующая информация:

- местонахождение хоста и контактное лицо;
- аппаратная платформа и ОС с версией;
- основные функции и приложения;
- парольные группы с привилегированными правами.

Сетевые интерфейсы должны иметь соответствующие записи на DNS-сервере (минимально А и PTR-записи).

Парольные группы должны поддерживаться в соответствии с корпоративными системой/процессами управления паролями.

Всем членам департамента ИБ по требованию (см. политику аудита ИБ) должен предоставляться немедленный доступ к оборудованию и системным журналам.

Об изменениях в текущем оборудовании и появлении нового оборудования требуется немедленно уведомить соответствующих лиц с целью изменения корпоративных процессов/процедур управления.

Для проверки соблюдения данной политики департамент ИБ будет периодически проводить аудит оборудования ДМЗ (см. политику аудита ИБ).

Общая политика конфигурирования. Все оборудование должно соответствовать следующей конфигурационной политике: АО, ОС,

сервисы и приложения (должны быть одобрены департаментом ИБ на этапе предварительного анализа).

Настройки ОС должны соответствовать стандартам инсталляции и конфигурирования для защищенных хостов и маршрутизаторов (ссылка на стандарт).

Вес обновления, рекомендуемые производителями или департаментом ИБ, должны быть установлены. Это относится ко всем установленным сервисам, даже если они временно или постоянно отключены. Административная группа должна проверять это.

Сервисы и приложения, не удовлетворяющие требованиям бизнеса, должны быть отключены.

Доверительные отношения между системами должны использоваться только по требованиям бизнеса, быть задокументированы и одобрены департаментом ИБ.

Сервисы и приложения не для общего доступа должны быть внесены в соответствующие контрольные списки.

Незащищенные сервисы или протоколы (по определению департамента ИБ) должны быть заменены на более защищенные аналоги, если таковые существуют.

Удаленное администрирование должно осуществляться по защищенным каналам (например, шифрованным сетевым соединениям, использующим протоколы SSH или IPSec) или через консольный доступ, независимый от ДМЗ. Если средства защиты каналов не применимы, для всех уровней доступа должны использоваться одноразовые пароли.

Все обновления контента (содержимого) хостов должны осуществляться по защищенным каналам.

Все имеющие отношение к ИБ события должны регистрироваться и сохраняться в утвержденных департаментом ИБ журналах для последующего аудита ИБ. Эти события включают (но не ограничиваются) следующее:

- попытку неудачного входа пользователя;
- отказ в получении привилегированного доступа;
- нарушения политики доступа.

Департамент ИБ рассматривает запросы на отказ в предоставлении доступа в порядке поступления и удовлетворяет их, если на то есть основания.

Установка нового оборудования и изменение процедур управления. Все новые установки и изменения конфигурации существующего оборудования и приложений должны соответствовать следующим политике/ процедурам:

- все новые установки должны осуществляться по разработанной процедуре размещения оборудования в ДМЗ;
- изменения конфигурации должны соответствовать процедурам корпоративного управления изменениями;
- для осуществления аудита ИБ систем/приложений, заменяемых новыми сервисами, должен приглашаться департамент ИБ;
- в одобрении размещения нового оборудования и изменения каких-либо конфигураций департамент ИБ должен участвовать непосредственно или через систему управления изменениями.

Оборудование, управляемое внешними сервис-провайдерами. Ответственность за защиту оборудования, устанавливаемого внешними сервис-провайдерами, должна быть оговорена в контракте с ними и контактными лицами, отвечающими за ИБ. Подписавшие контракт со стороны организации несут ответственность за следование политике третьих лиц.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы. Внешние сервис-провайдеры, уличенные в несоблюдении данной политики, будут обязаны выплатить штрафы, вплоть до прерывания действия контракта.

Определения. ДМЗ – любая недоверенная сеть, соединенная с интранетом организации, но отделенная от нее МЭ, используемая для внешнего (Интернет/экстранет и т. п.) доступа из организации или представляющая информацию внешним пользователям.

Недоверенная сеть – любая сеть, отделенная от интранета МЭ с целью избежать повреждения ресурсов от незаконного сетевого трафика, НСД (сети партеров, Интернет и т. п.) или чего-то еще, идентифицируемого как потенциальная угроза ИБ для таких ресурсов.

История пересмотра политики.

12. ПОЛИТИКА ПОДКЛЮЧЕНИЯ ПОДРАЗДЕЛЕНИЙ К ИНТРАНЕТУ

Цель – определить требования ИБ для подразделений организации, гарантирующие, что конфиденциальная информация и технологии не будут скомпрометированы и что сервисы и интересы организации будут защищены от работы подразделений.

Применение. Политика распространяется на все связанные внутри организации подразделения, служащих организации и третьих лиц, имеющих доступ к ее подразделениям. Все существующее оборудование и то, которое будет установлено в будущем, к которому применима данная политика, должно быть сконфигурировано в соответствии с ней. ДМЗ подчиняется отдельной политике.

Основные положения.

Владение и ответственность. Организация назначает администраторов подразделений, контактных лиц и представителей в администрации организации, с которыми работают эти лица. В случае смены этих лиц руководители подразделений обязаны представлять новую информацию в департамент ИБ и администрации организации. Администраторы подразделений должны быть постоянно на связи для информирования в случае необходимости, в противном случае решается вопрос об их обязанностях.

Администраторы подразделений несут ответственность:

- за защиту своих подразделений и их влияние на интранет или любые другие сети;
- следование данной политике и установленным в соответствии с ней процедурам. Если что-то не определено в политике и процедурах, они должны приложить все усилия для защиты организации от уязвимостей;
- соответствие работы подразделения ПолИБ организации. Особенно важно соблюдать политику использования паролей для сетевых устройств и хостов, политику беспроводного доступа, антивирусную политику и физическую защиту;
- контроль доступа в подразделении. Доступ к подразделению предоставляется его администратором или назначенным должностным лицом тем пользователям, которые имеют такую производственную необходимость, на короткое или длительное время. Это подра-

зумекает постоянный мониторинг списков доступа, что гарантирует своевременную отмену доступа для тех, кому он больше не нужен.

Группа поддержки сети обязана осуществлять управление МЭ между интранетом организации и сетями подразделений.

Эта группа и/или департамент ИБ оставляют за собой право отключить подключение подразделения в случае его негативного воздействия на интранет или создания угрозы для ее ИБ.

Эта группа должна иметь IP-адреса всех подразделений, входящих в интранет организации, в единой корпоративной базе данных адресов, наряду с текущей контактной информацией подразделения.

Любое подразделение, которому требуется внешнее подключение, должно представить департаменту ИБ схему и документацию с обоснованием причин, спецификацией оборудования и схемой IP-адресации. Департамент ИБ рассмотрит запрос и удовлетворит его, если не нарушаются требования ИБ организации.

Пароли всех пользователей должны соответствовать политике использования паролей организации. В случае если учетная запись на оборудование подразделения уже не требуется, она должна быть уничтожена в срок не позднее трех дней. Групповые пароли для компьютеров подразделения (Unix, Windows и т. п.) должны меняться каждые три месяца. Для любого устройства подразделения при изменении состава группы пароль должен быть изменен в срок не позднее трех дней.

Ни одно подразделение не должно предоставлять эксплуатационных сервисов. Они определяются как ведущие и совместно используемые, критичные для бизнеса сервисы, генерирующие потоки поступлений или обеспечивающие работу клиентов. Они должны находиться в ведении соответствующего департамента.

Департамент ИБ рассматривает запросы на отказ в предоставлении доступа в порядке поступления и удовлетворяет их, если на то есть основания.

Общие конфигурационные требования. Трафик между интранетом и сетями подразделений, а также между сетями отдельных подразделений без необходимости не разрешен, поскольку это может поставить под угрозу их конфиденциальную информацию.

Весь трафик между интранетом и подразделением должен проходить через МЭ, которым управляет группа поддержки интранета. Се-

тельные устройства подразделения (включая беспроводные) не должны иметь перекрестные ссылки между подразделением и интранетом.

Оригинальные настройки МЭ и любые изменения в них должны быть предварительно проанализированы и одобрены департаментом ИБ, который при необходимости может потребовать пересмотра требований ИБ.

Департамент ИБ оставляет за собой право в любое время проводить аудит ИБ всей информации и административных процедур подразделения, включая (но не ограничиваясь) входящие и исходящие пакеты, МЭ и сетевую периферию.

Подразделениям запрещается проводить сканирование портов, изучение сети, «наводнение» трафика и другие подобные действия, которые негативно влияют на интранет организации и другие сети. Такие действия должны быть запрещены.

Принадлежащие подразделению шлюзы должны соответствовать рекомендациям организации и должны удостоверяться корпоративными серверами аутентификации.

Пароль на вход в привилегированный режим для всех шлюзов подразделения должен отличаться от паролей для другого оборудования подразделения. Этот пароль должен соответствовать политике использования паролей организации. Он дается только тем, кто уполномочен администрировать сеть подразделения.

В подразделениях, где неперсонал организации имеет физический доступ (например, в учебных классах), запрещается прямое подключение к интранету организации. Кроме этого, в таких подразделениях ни на каких компьютерах не должна находиться конфиденциальная информация организации. Подключение уполномоченного персонала к интранету из таких подразделений обязательно должно использовать аутентификацию через корпоративный сервер аутентификации, временные списки доступа, SSH, VPN-клиенты или подобные технологии, одобренные департаментом ИБ.

Инфраструктурные устройства (типа IP-телефонов), которым требуется подключение к интранету, должны соответствовать политике для закрытых территорий.

Все запросы на внешние подключения подразделений должны быть рассмотрены и одобрены департаментом ИБ. Аналоговые и ISDN каналы связи должны быть сконфигурированы только на доступ к доверенным номерам. Для аутентификации должны использоваться стойкие пароли.

Все сети подразделений с внешними подключениями не должны соединяться с интранетом организации или любой другой внутренней сетью непосредственно, через беспроводной канал или на основе любого другого вида компьютерного оборудования.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определения. Внутреннее подразделение – подразделение внутри организации. Группа поддержки сети отвечает за те части интранета организации, которые не принадлежат ни одному подразделению.

Подразделение – непроизводственное отделение организации, занимающееся разработкой, демонстрацией, обучением и/или тестированием продуктов. Внешние подключения (известные как ДМЗ) включают (но не ограничиваются) сетевые подключения третьих лиц, аналоговые и ISDN каналы связи и любые другие телекоммуникационные (T1/E1, T3/E3, OC3, OC 12, DSL и т. п.) каналы передачи данных. Шлюзы подразделения составляют его собственность и соединяют сеть подразделения с остальным интранетом организации (весь трафик должен проходить через эти шлюзы).

МЭ – устройство, контролирующее доступ между сетями.

ДМЗ – сеть, расположенная за основными корпоративными МЭ, но также находящаяся под административным контролем организации.

История пересмотра политики.

13. ПОЛИТИКА ПОДКЛЮЧЕНИЯ К ИНТРАНЕТУ С ПРИМЕНЕНИЕМ МОДЕМА

Цель – защитить информацию организации в электронном виде от непреднамеренной компрометации персоналом, имеющим разрешение на использование модемных подключений.

Область действия. Политика регламентирует разрешенный модемный доступ и его использование авторизованными пользователями организации.

Основные положения. Сотрудники организации и уполномоченные третьи лица (клиенты, поставщики и т. п.) могут использовать модемные подключения для получения доступа к ее интранету. Модемные подключения должны жестко контролироваться с применением аутентификации на основе одноразовых паролей. Запрос на модемное подключение должен осуществляться в соответствии с разработанной для этого процедурой.

Сотрудник, имеющий разрешение на модемное подключение, должен гарантировать, что это подключение не используется людьми, не являющимися сотрудниками организации, с целью получения доступа к ресурсам ее ИС и интранета. Сотрудник должен постоянно помнить, что такое подключение является фактическим расширением интранета организации и поэтому открывает возможный путь к ее конфиденциальной информации. Он и/или третьи лица должны принять все возможные меры по защите ресурсов организации.

Учетные записи, соответствующие модемным подключениям, подлежат аудиту ИБ. Если в течение шести месяцев учетная запись не использовалась, то она удаляется.

Аналоговые мобильные телефоны и телефоны не GSM-стандарта не могут использоваться в этих целях, так как их сигнал может быть легко несанкционированно прослушан или перехвачен. Только телефоны GSM-стандарта рассматриваются как достаточно защищенные для подключения к интранету организации.

Беспроводной доступ к интранету организации регламентируется политикой беспроводного доступа.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

История пересмотра политики.

14. ПОЛИТИКА РАБОТЫ С КОНФИДЕНЦИАЛЬНОЙ ИНФОРМАЦИЕЙ

Цель – определить, какая информация может представляться несотрудникам организации, а какая не должна выходить за пределы организации без соответствующего на то разрешения. Информация, подпадающая под действие данной политики, включает (но не огра-

ничивается) информацию, хранимую или совместно используемую с применением различных средств. Это – информация в электронном виде, бумажная информация и информация, совместно используемая устно или визуально (например, через телефон или видеоконференцсвязь) на стадиях обработки, передачи и хранения, защищаемая от модификации или раскрытия.

Все сотрудники должны быть ознакомлены с перечнем информации, регламентируемым данной политикой. Отнесение специфической информации к определенному классу дается администратором ИБ подразделения или организации. Все вопросы, относящиеся к руководству, решает департамент ИБ организации. Сотрудники должны следовать здравому смыслу при защите конфиденциальной информации организации.

Влияние руководства на осуществление ежедневных обязанностей служащих должно быть минимальным.

Область действия. Вся информация организации подразделяется на открытую и конфиденциальную. Открытая информация – это информация, доступ к которой не связан ни с какими потерями.

Конфиденциальная информация – это информация, доступ посторонних к которой для части сотрудников или посторонних лиц нежелателен, так как может вызвать материальные и моральные потери.

Далее приводятся примеры: общая корпоративная информация, промышленные секреты, программы развития, персональные данные служащих, телефонные справочники, информация о третьих лицах и т. п. Категорирование информации по конфиденциальности выполняется субъективно руководством или персоналом в соответствии с выделенными ему полномочиями в зависимости от риска ее разглашения.

Основные положения. Руководство организации детально описывает, как защитить различную конфиденциальную информацию. Оно будет различным для разных организаций, так как отнесение одной и той же информации к тому или иному классу (например, минимальной, средней и максимальной конфиденциальности) зависит от многих обстоятельств от бизнеса организации, условий осуществления бизнеса, ее размера и многого другого.

1. Информацией минимальной конфиденциальности является общая корпоративная информация, некоторая техническая информация

и отдельные данные о персонале. Доступ имеют сотрудники организации, контрактные работники, те, кто должен знать эту информацию в соответствии с потребностями бизнеса. Метод распространения в организации – стандартная внутренняя внутриофисная переписка, одобренная электронная почта и методы передачи электронных файлов. Методы распространения за пределами организации – официальные почтовые службы страны или других стран, одобренная электронная почта и методы передачи электронных файлов. Распространение в электронном виде – ограничений нет при условии отправки разрешенным получателям. Хранение – беречь от неуполномоченных людей, защищать от потери, контролировать доступ. Уничтожение – по разработанной процедуре уничтожения бумажных и электронных носителей информации с невозможностью восстановления. Наказания – согласно административному, гражданскому или уголовному праву.

2. Информация средней конфиденциальности – это финансовая и техническая информация, информация о бизнесе и большая часть персональных данных. Доступ – сотрудники организации и не-сотрудники, подписавшие соглашение о неразглашении информации, которым она требуется для бизнеса. Метод распространения в организации – стандартная внутренняя внутриофисная переписка, одобренная электронная почта и методы передачи электронных файлов. Методы распространения за пределами организации – официальные курьерские и почтовые службы страны или других стран. Распространение в электронном виде – ограничений нет при условии отправки разрешенным получателям внутри организации, вне организации обязательно в зашифрованном виде. Хранение – с индивидуальным контролем доступа. Уничтожение – по разработанной процедуре уничтожения бумажных и электронных носителей информации с невозможностью восстановления. Наказания – согласно административному, гражданскому или уголовному праву.

3. Информация максимальной конфиденциальности – это промышленные секреты, маркетинговая, финансовая и техническая информация, информация о функционировании, исходные коды и часть персональных данных. Доступ – только сотрудники организации, имеющие разрешенный доступ и подписавшие соглашение о неразглашении информации. Метод распространения в организации – непосредственная доставка в руки, доставка в конверте со штампом конфиденциальности, одобренные методы передачи электронных

файлов. Методы распространения за пределами организации – разрешенная курьерская служба с подписью о вручении. Распространение в электронном виде – ограничений нет при условии посылки разрешенным получателям внутри организации, вне организации обязательно в зашифрованном виде. Хранение – с индивидуальным контролем доступа, с обеспечением физической защиты (включая хранение на компьютере). Уничтожение – по разработанной процедуре уничтожения бумажных и электронных носителей информации с невозможностью восстановления. Наказания – согласно административному, гражданскому или уголовному праву.

Данная политика также должна определять:

- кто может иметь доступ к конфиденциальной информации вообще и при особых обстоятельствах;
- в каких системах может храниться и обрабатываться конфиденциальная информация;
- информация какой степени секретности может быть распечатана на физически незащищенных принтерах;
- как конфиденциальная информация удаляется из систем и запоминающих устройств (например, размагничивание носителей данных, чистка жестких дисков, резка бумажных копий);
- любые установки по умолчанию для файлов и каталогов, определяемые в системных файлах конфигурации, и т. п.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определение. Определены методы передачи электронных файлов на основе FTP-клиентов и веб-браузеров.

История пересмотра политики.

15. ПОЛИТИКА ДЛЯ ВЕБ-СЕРВЕРА

Цель – определить стандарты базовой конфигурации оборудования внутреннего веб-сервера, находящегося во владении и/или используемого организацией. Эффективная реализация данной политики уменьшит НСД к составляющим собственность организации информации и технологиям.

Область действия. Политика распространяется на серверное оборудование, находящееся во владении и/или используемое организацией, и веб-серверы, зарегистрированные в любом внутреннем сетевом домене организации. Политика применяется только к оборудованию интранета организации. Защищенное конфигурирование внешнего оборудования из ДМЗ организации регламентируется политикой для оборудования ДМЗ.

Основные положения.

Владение и ответственность. Все размещенные в организации внутренние веб-серверы находятся в собственности рабочей группы, осуществляющей их системное администрирование. Должны существовать и использоваться каждой рабочей группой руководства по настройке веб-серверов, основанные на потребностях бизнеса и утвержденные соответствующими службами организации. Рабочие группы должны осуществлять мониторинг соответствия конфигурации и предпринимать предписанные действия при выявлении отклонений. Каждая рабочая группа должна определить процесс изменения руководств по настройке, который должен быть рассмотрен и утвержден в установленном порядке.

Веб-сервер должен быть зарегистрирован в корпоративной системе управления. Для определения обратной связи, как минимум, необходима следующая информация:

- местонахождение веб-сервера и контактное лицо для обратной связи;
- аппаратная платформа и ОС с версией;
- основные функции и приложения, если таковые используются.

Информация в корпоративной системе управления должна быть актуальной.

За изменениями конфигурации веб-серверов должны быть внесены соответствующие изменения в процедуры управления.

Общее руководство по конфигурированию:

Настойки ОС должны соответствовать утвержденным руководствам. Сервисы и приложения, которые не используются, нужно отключить. Доступ к сервисам должен регистрироваться и/или защищаться методами контроля доступа (типа TCPWrappers), если это возможно.

Самые последние обновления, устраняющие уязвимости системы, должны устанавливаться сразу же после их появления, за исключением тех случаев, когда это мешает выполнению неотложных работ.

Доверительные отношения между системами являются угрозой ИБ, поэтому лучше избегать их использования. Лучше применять другой, более надежный метод связи.

Всегда используйте стандартные принципы ОИБ, требующие наименьшего доступа для выполнения функций.

Когда для работы достаточно привилегий обычного пользователя, не используйте административную учетную запись root.

Если технически доступно и выполнимо защищенное канальное подключение, то привилегированный доступ должен осуществляться на его основе (например, зашифрованное сетевое соединение с использованием протоколов SSH или IPSec).

Веб-вервер должен физически располагаться в среде с контролируемым доступом.

Работа с веб-сервером из неконтролируемого закрытого помещения запрещается.

Мониторинг. Все относящиеся к ИБ события в важных или конфиденциальных системах должны регистрироваться, и в журналах регистрации должна сохраняться следующая информация:

- все записи событий должны сохраняться, как минимум, неделю;
- ежедневные резервные копии измененной информации должны храниться не меньше месяца;
- еженедельные полные резервные копии журналов событий должны храниться не меньше месяца;
- ежемесячные полные резервные копии должны храниться не меньше двух лет.

Обо всех относящихся к ИБ событиях следует уведомлять соответствующие службы, которым нужно представить для рассмотрения журналы событий и сообщения об инцидентах ИБ в установленной форме. При необходимости они помогут определить корректирующие меры.

Относящиеся к ИБ события включают (но не ограничиваются):

- сканирование портов;
- НСД к привилегированным учетным записям;
- аномальные признаки, не относящиеся к работе приложений хоста, являющегося веб-сервером.

Соглашения. Аудит ИБ веб-сервера должен выполняться регулярно уполномоченными лицами внутри организации.

В соответствии с политикой аудитом ИБ руководит внутренняя группа или уполномоченная внешняя организация. Они отбирают обнаруженные события и при необходимости посылают соответствующие отчеты в правоохранительные органы.

Должно быть сделано все возможное, чтобы аудит ИБ не вызвал сбоев в работе или потерю ресурсов.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определения. В рамках данной политики веб-сервер – внутренний веб-сервер организации.

Демилитаризованная зона (ДМЗ) – сетевой сегмент, внешний по отношению к интранету организации.

История пересмотра политики.

16. ПОЛИТИКА ОТПРАВКИ ЭЛЕКТРОННОЙ ПОЧТЫ ЗА ПРЕДЕЛЫ ИНТРАНЕТА

Цель – предотвратить несанкционированное или случайное раскрытие конфиденциальной информации организации.

Область действия. Политика распространяется на автоматическую отправку электронной почты за пределы интранета организации и связанную с этим случайную передачу конфиденциальной информации сотрудниками, поставщиками и агентами, работающими от имени организации.

Основные положения. Сотрудники должны проявлять особую бдительность при отправке электронной почты из интранета организации во внешнюю сеть. Электронная почта организации не будет автоматически посылаться внешнему получателю, за исключением той, которая одобрена администратором ИБ подразделения сотрудника. Конфиденциальная информация, как это определено в политике работы с конфиденциальной информацией, в открытом виде не отправ-

ляется никакими средствами, поскольку она носит критический для бизнеса характер и должна быть зашифрована в соответствии с политикой шифрования.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определения. Электронная почта – это электронная передача информации на основе почтового протокола (типа SMTP).

Пересылаемая почта – электронная почта, пересылаемая из интранета к внешнему получателю.

Информация считается конфиденциальной, если она может нанести ущерб финансового характера, репутации или позиции на рынке самой организации или ее клиентам.

Случайное раскрытие – намеренное или ненамеренное открытие запрещенной информации людям, которым не нужно знать эту информацию.

История пересмотра политики.

17. ПОЛИТИКА ХРАНЕНИЯ СООБЩЕНИЙ ЭЛЕКТРОННОЙ ПОЧТЫ

Цель – определить, какую отправленную и полученную электронную почту хранить и как долго. Распространяется на информацию, хранимую или совместно используемую посредством электронной почты или других применяемых в настоящее время технологий передачи сообщений. Отнесение информации к классам определяет руководитель подразделения. Вопросы по данному руководству направляются департаменту ИБ.

Применение. Политика распространяется на четыре основных класса почтовой корреспонденции (переписки): административную (срок хранения – четыре года), финансовую (четыре года), общую (один год) и однодневную (после прочтения уничтожить).

Основные положения. Административная корреспонденция включает, например, сообщения о политике компании, выходных, поведении, защите интеллектуальной собственности и многое другое,

сообщения с пометкой «Только для администрации». Для хранения такой корреспонденции ее копии нужно отправлять в почтовый ящик `admin@Домен_организации`, администрированием которого занимается департамент ИТ.

Финансовая корреспонденция – это вся информация, относящаяся к доходам и расходам организации. Для ее хранения копии сообщений нужно отправлять на адрес `fiscal@Домен_организации`, администрированием которого занимается департамент ИТ.

Общая корреспонденция – информация, относящаяся к взаимодействию с клиентами и выполнению бизнес-функций отдельными сотрудниками организации. Они несут ответственность за ее сохранение.

Однодневная корреспонденция – большая часть электронной почты, включающая персональные почтовые сообщения, запросы на получение рекомендаций, разработку продуктов и т. п.

Сообщения текущего почтового клиента могут сохраняться с использованием стандартных встроенных процедур или копироваться в файл и в таком виде храниться. Сообщения клиента административного или финансового характера должны копироваться в электронное сообщение и пересылаться в соответствующий адрес для хранения.

Защищенные средства связи организации должны применяться в случаях, предусмотренных в политике работы с конфиденциальной информацией. В остальных случаях информация должна храниться в незашифрованном виде.

Резервирование работы почтового сервера. Организация создает резервные копии данных с почтового сервера, и раз в квартал соответствующий носитель изымается из ротации и хранится отдельно. Никто не может уничтожать электронную почту с этого носителя.

Ответственность. Любой сотрудник, нарушивший политику, может быть привлечен к дисциплинарному наказанию, вплоть до увольнения с работы.

Определение. Текущий почтовый клиент – разрешенный к использованию в организации клиент для работы с электронной почтой.

История пересмотра политики.

18. ПОЛИТИКА ДЛЯ МЕЖСЕТЕВЫХ ЭКРАНОВ

Политика для МЭ описывает, как управляется АО и ПО такого специального средства защиты, как МЭ, и какие при этом изменения в интранете требуются и допустимы (например, в операционной системе того компьютера, получившего название «бастион», где будет установлен МЭ). Эта политика должна определять:

- кто может получить привилегированный доступ к МЭ;
- кому разрешено получать информацию о конфигурации и списках доступа к МЭ;
- процедуры написания запроса на изменение конфигурации МЭ и удовлетворения этого запроса;
- сроки пересмотра конфигурации МЭ и т. д.

19. ПОЛИТИКА ПОДКЛЮЧЕНИЯ НОВЫХ УСТРОЙСТВ К ИНТРАНЕТУ

Политика подключения новых сетевых устройств к интранету организации определяет требования и порядок добавления в интранет новых аппаратных средств. Эта политика особенно важна для оборудования, которое будет располагаться до средств защиты интранета, например на стыке интранета с любой другой открытой сетью до МЭ. Также она нужна для того АО, доступ к которому будет открыт сразу для нескольких групп пользователей. Такая политика должна определять, например:

- кто может устанавливать новые ресурсы в интранете;
- какие при этом обоснования и уведомления должны быть выполнены;
- как документируются в интранете любые изменения;
- каковы требования по защите при подключении новых сетевых устройств;
- как будут защищаться устройства, не имеющие встроенных средств защиты и т. д.

Учебное издание

Еременко Владимир Тарасович

Рытов Михаил Юрьевич

Рязанцев Павел Николаевич

Орешина Марина Николаевна

УПРАВЛЕНИЕ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТЬЮ

Учебное пособие

Редактор Т.Д. Васильева

Технический редактор Т.П. Прокудина

Федеральное государственное бюджетное образовательное
учреждение высшего профессионального образования
«Государственный университет - учебно-научно-
производственный комплекс»

Подписано к печати 01.06.2015 г. Формат 60×84 1/16.

Усл. печ. л. 16,5. Тираж 100 экз.

Заказ №_____

Отпечатано с готового оригинал-макета
на полиграфической базе ФГБОУ ВПО «Госуниверситет - УНПК»,
302030, г. Орел, ул. Московская, 65.